CS315 Handouts

Network Security

MIDTERM

Topic (1 to 72)

Made by Yasir Ejaz
(MCP , MCSE , MCSA , CCNA)
0321 5253058
[yasirejaz@gmail.com]

Introduction to Course

Network Security

Introduction to Course

Objectives of the Topic

- After completing this topic, a student will be able to
  - get motivated, describe learning outcomes and describe the text and references books.

Introduction to Course

Motivation

- Before the widespread use of data processing equipment, security of information was provided primarily by physical and administrative means.
- E.g. rugged filing cabinets with locks

Introduction to Course

- Requirements for information security have undergone two major changes:
- a) As the computers were introduced, a need for protecting information stored on the shared computers was felt – Computer Security.

Introduction to Course

- b) As networks and communications facilities for carrying data from one computer to another were introduced, a need for protecting data during their transmission was felt – Network or Internet security.

Introduction to Course

Stored data:

- Business data must not be leaked to competitors
- Personal information
- Copyrighted software

Introduction to Course

Security Violations: Some Examples

- User A transmits a file to user B. User C, who is not authorized to read the file, is able to capture a copy of the file during its transmission – eavesdropping

Introduction to Course

- User D transmits a message to a computer E. User F intercepts the message, alters its contents and then forwards the message to E, which accepts the message as coming from D – Man-in-the-middle Attacks.

Introduction to Course

- It is also possible that user F constructs its own message and transmits that message to E as if it had come from computer D.

Introduction to Course

Some Other Common attacks

- Cryptanalysis
- Password Pilfering
- Intrusion
- Denial of Service Attacks
- Malicious software

Introduction to Course

Security Breaches can result in

- Financial loss for corporations
- Theft of intellectual property
- Lawsuits
- Threat to public safety

Introduction to Course

- The field of network and Internet security consists of measures to deter, prevent, detect, and correct security violations that involve the transmission of information.

Introduction to Course

Required Books

- W. Stallings, *"Network Security Essentials: Applications and Standards"*, Pearson Education, 2014
- *"CCNA Security 1.1 Student Packet Tracer Manual "* Cisco Networking Academy, 2012

Introduction to Course

Reference Books

- W. Stallings, "*Cryptography and Network Security Principles and Practice*", Pearson Education, 2014

Introduction to Course

Course Composition: Two parts

- Part 1 will provide a practical survey of network security applications and standards.
- It has been sub-divided into 3 subparts.

Introduction to Course

Subpart1: Cryptography

- Symmetric Encryption principles
- Public-Key Cryptography and message authentication

Introduction to Course

Subpart2: Network Security Applications

- Key distribution and user authentication
- Network Access Control and cloud Security
- Transport-level Security
- Wireless Net. Security

Introduction to Course

Subpart2: Network Security Applications

- Electronic Mail Security
- IP Security

Introduction to Course

Subpart3: System Security

- Malicious Software
- Intrusions
- Firewalls

Introduction to Course

- In Part 2, we will perform lab experiments to configure networks employing Cisco components for various security aspects.
- Packet Tracer will be used.

Introduction to Course

Grading Policy

- Assignments + Quizzes = 15%
- Mid Term Exam = 35%
- Final Term Exam = 50%

End

Definition Of Computer Security

Network Security

Definition Of Computer Security

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe a definition of the computer security.

Definition Of Computer Security

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Definition Of Computer Security

- The National Institute of Standards and Technology (NIST) Computer Security Handbook defines the term computer security as follows:

Definition Of Computer Security

- The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability, and confidentiality of information system resources.

Definition Of Computer Security

- Resources include hardware, software, firmware, information/data, and telecommunications.

Definition Of Computer Security

Computer Security: Three Key Objectives

- Confidentiality
- Integrity
- Availability

Definition Of Computer Security

Confidentiality

- a) Data confidentiality: Assures that private or confidential information is not made available or disclosed to unauthorized individuals.

Definition Of Computer Security

Confidentiality

- b) Privacy: Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.

Definition Of Computer Security

Integrity

- a) Data integrity: Assures that information and programs are changed only in a specified and authorized manner.

Definition Of Computer Security

Integrity

- b) System integrity: Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.

Definition Of Computer Security

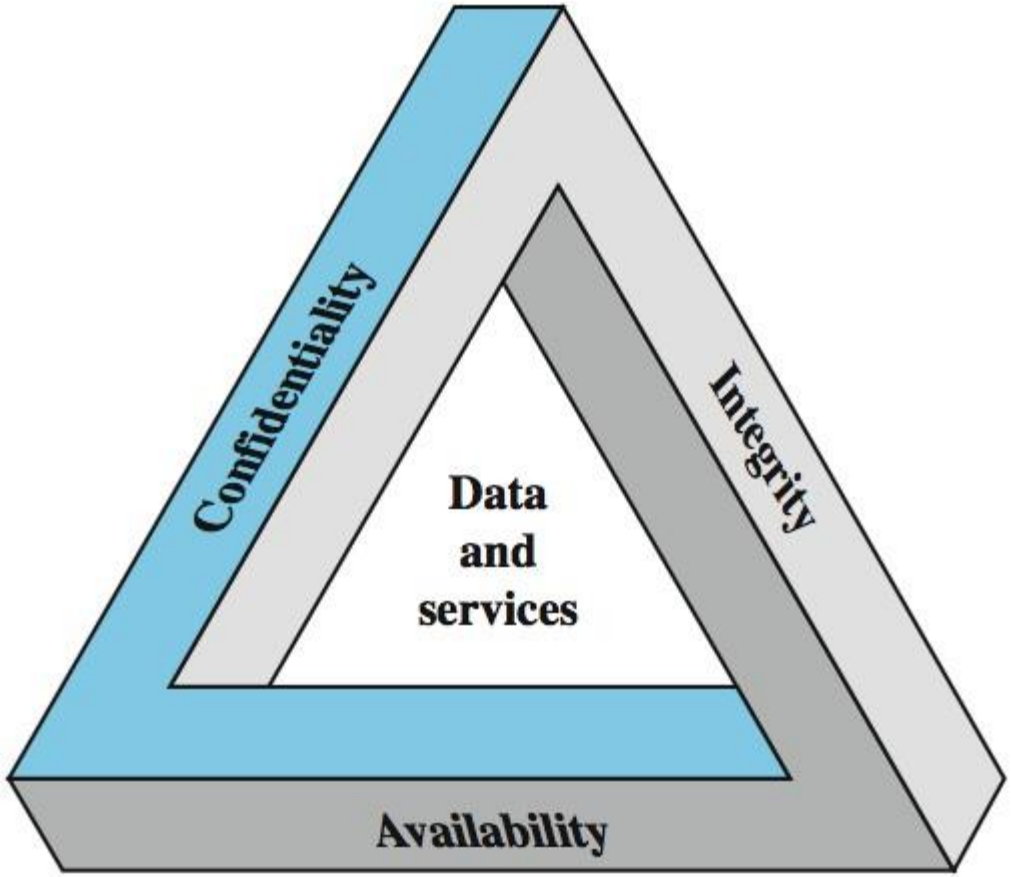
Availability

- Assures that systems work promptly and service is not denied to authorized users.

Definition Of Computer Security

The Security Requirements Triad:

CIA Triad



Definition Of Computer Security

Possible Additional Concepts:

- Authenticity
- Accountability

Definition Of Computer Security

Authenticity:

- The property of being genuine and being able to be verified and trusted.
- verifying that users are who they say they are and that each input arriving at the system came from a trusted source.

Definition Of Computer Security

Accountability:

- The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.
- This supports nonrepudiation, intrusion detection and prevention etc.

Definition Of Computer Security

Accountability:

- Systems must keep records of their activities to permit later forensic analysis to trace security breaches or to aid in transaction disputes.

End

Impact Of A Security Breach

Network Security

Impact Of A Security Breach

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe levels of impact of a security breach on the system.

Impact Of A Security Breach

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Impact Of A Security Breach

- In case, there be a breach of security (i.e., a loss of confidentiality, integrity, or availability), three levels of impact on organizations or individuals can be considered.

Impact Of A Security Breach

Low

- The loss could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.
- A limited adverse effect means that, a security breach might

Impact Of A Security Breach

- (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced

Impact Of A Security Breach

- (ii) result in minor damage to organizational assets
- (iii) result in minor financial loss
- or (iv) result in minor harm to individuals.

Impact Of A Security Breach

Moderate

- The loss could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.
- A serious adverse effect means that the loss might

Impact Of A Security Breach

- (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced.

Impact Of A Security Breach

- (ii) result in significant damage to organizational assets
- (iii) result in significant financial loss
- or (iv) result in significant harm to individuals that does not involve loss of life or serious, life-threatening injuries.

Impact Of A Security Breach

High

- The loss could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
- A catastrophic adverse effect means that,

Impact Of A Security Breach

- (i) cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions

Impact Of A Security Breach

- (ii) result in major damage to organizational assets
- (iii) result in major financial loss
- or (iv) result in severe or catastrophic harm to individuals involving loss of life or serious, life-threatening injuries

Impact Of A Security Breach

Examples of Security Requirements

- **a) Confidentiality:**
- Student grade information is an asset whose confidentiality is considered to be highly important by students.

Impact Of A Security Breach

- Grade information should only be available to students, their parents, and employees that require the information to do their job.
- Student enrollment information may have a moderate confidentiality rating.

Impact Of A Security Breach

- Student enrollment information is seen by more people on a daily basis, is less likely to be targeted than grade information and results in less damage if disclosed.

Impact Of A Security Breach

- Directory Information such as lists of students or faculty may be assigned a low or no confidentiality rating.

Impact Of A Security Breach

- **b) Integrity:**
- Assume a hospital patient's allergy information to be stored in a database.
- The doctor should be able to trust that the information is correct and current.

Impact Of A Security Breach

- Suppose a nurse who is authorized to update this info deliberately falsifies the data to cause harm to the hospital.
- Restore to a trusted basis quickly and to trace the error back to the person responsible.

Impact Of A Security Breach

- Patient allergy information requires high integrity.
- Inaccurate information could result in serious harm or death to a patient and expose the hospital to massive liability.

Impact Of A Security Breach

- A Web site that offers a forum to registered users to discuss some specific topic would be assigned a moderate level of integrity.
- An example of a low-integrity requirement is an anonymous online poll.

Impact Of A Security Breach

Availability

- The more critical a component or service, the higher the level of availability required.

Impact Of A Security Breach

- A system that provides authentication services.
- An interruption results in inability for customers to access computing resources and for staff to access resources to perform critical tasks.

Impact Of A Security Breach

- A moderate availability requirement is a public Web site for a university.
- An online telephone directory lookup application would be classified as a low-availability requirement.

End

Challenges Of Network Security

Network Security

Challenges Of Network Security

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain challenges of network security.

Challenges Of Network Security

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Challenges Of Network Security

Computer Security

- Is the generic name for the collection of tools designed to protect data stored on computers and to thwart hackers.

Challenges Of Network Security

- The use of networks and communications facilities allows for carrying data from one computer to another.
- **Network or internet security** measures are needed to protect data during their transmission.

Challenges Of Network Security

- Network or internet security consists of measures to deter, prevent, detect, and correct security violations that involve the transmission of information.

Challenges Of Network Security

Deterrence

- is usually the first line of defense against intruders who may try to gain access.
- It works by creating an atmosphere intended to frighten intruders.

Challenges Of Network Security

Prevention

- is the process of trying to stop intruders from gaining access to the resources of the system.
- Barriers include firewalls, demilitalized zones (DMZs).

Challenges Of Network Security

Detection

- occurs when the intruder has succeeded or is in the process of gaining access to the system.
- Signals from the detection process include alerts to the existence of an intruder.

Challenges Of Network Security

Response

- is an aftereffect mechanism that tries to respond to the failure of the first three mechanisms.
- It works by trying to stop and/or prevent future damage or access to a facility.

Challenges Of Network Security

- No clear boundaries between Computer and Network forms of security.
- E.g., a virus may be introduced into a system physically when it arrives on an optical disk, or arrives over an internet.

Challenges Of Network Security

Challenges:

- 1) Security is not as simple as it might first appear to the novice.
- Mechanisms used to provide confidentiality, authentication, nonrepudiation, integrity are quite complex.

Challenges Of Network Security

- 2) In developing a security mechanism or algorithm, one must always consider potential attacks on security features.
- Successful attacks are designed by exploiting an unexpected weakness in the mechanism.

Challenges Of Network Security

- 3) Procedures used to provide particular services are often counterintuitive.
- It is only when the various aspects of the threat are considered that elaborate security mechanisms make sense.

Challenges Of Network Security

- 4) At what points in a network, are certain security mechanisms needed and at what layer(s) of an architecture such as TCP/IP should mechanisms be placed.

Challenges Of Network Security

- 5) Participants of security mechanisms may be in possession of some secret information (e.g., an encryption key), which raises questions about the creation, distribution, and protection of that secret information.

Challenges Of Network Security

- 6) Security is essentially a battle of wits bet. a perpetrator and the designer.
- The attacker needs only find a single weakness, while designer must find and eliminate all weaknesses to achieve perfect security.

Challenges Of Network Security

- 7) Security requires constant monitoring, and this is difficult in today's overloaded environment.
- 8) Little benefit from security investment is perceived until a security failure occurs.

Challenges Of Network Security

- 9) Strong security is often viewed as an impediment to efficient and user-friendly operation.

End

The OSI Security Architecture

Network Security

The OSI Security Architecture

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe the OSI security architecture and its usefulness.

The OSI Security Architecture

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

The OSI Security Architecture

- In an organization, the manager responsible for security has to effectively assess the security needs of an organization.
- He has to evaluate and choose various security products and policies.

The OSI Security Architecture

- Thus, the manager needs some systematic way of defining the requirements for security and characterizing the approaches to satisfying those requirements.

The OSI Security Architecture

- This is difficult enough in a centralized data processing environment.
- With the use of local and wide area networks, the problems are compounded.

The OSI Security Architecture

- Such a systematic approach was defined by the International Telecommunication Union (ITU) Telecommunication Standardization Sector (ITU-T).

The OSI Security Architecture

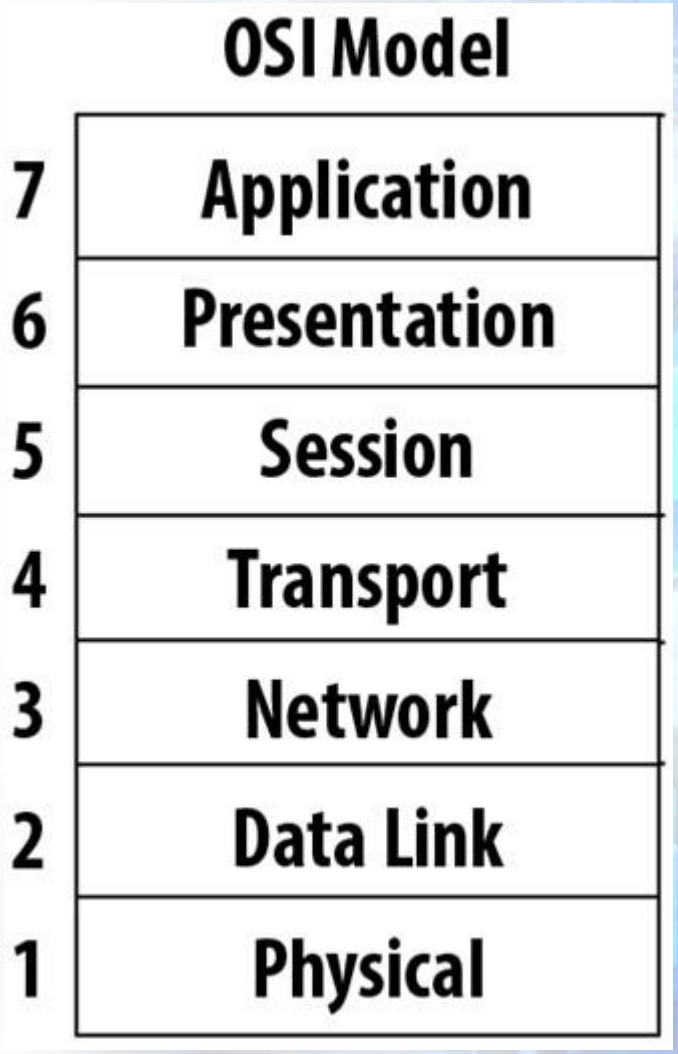
- (ITU-T) is a United Nations sponsored agency that develops standards, called Recommendations, relating to telecommunications and to open systems interconnection (OSI).

The OSI Security Architecture

- Recommendation X.800, Security Architecture for OSI.
- The open systems interconnection (OSI) security architecture was developed in the context of the OSI protocol architecture.

The OSI Security Architecture

OSI protocol architecture



The OSI Security Architecture

- The OSI security architecture is useful to managers as a way of organizing the task of providing security.
- It focuses on security attacks, mechanisms, and services.
- These are defined next:

The OSI Security Architecture

Security Attack:

- Any action that compromises the security of information owned by an organization.

The OSI Security Architecture

Security Mechanism:

- A process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack.

The OSI Security Architecture

Security Service:

- A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization.

The OSI Security Architecture

- The services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the service.

The OSI Security Architecture

RFC 4949, Internet Security Glossary.

Threat

A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Attack

An assault on system security that derives from an intelligent threat; that is, an intelligent act that is a deliberate attempt (especially in the sense of a method or technique) to evade security services and violate the security policy of a system.

The OSI Security Architecture

- The OSI architecture is an international standard, computer and communications vendors have developed security features for their products and services that relate to this structured definition of services and mechanisms.

End

Security Attacks

Network Security

Security Attacks

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe the security attacks.

Security Attacks

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Security Attacks

- According to the OSI Architecture X.800, security attacks can be classified in two categories:
- passive attacks, and
- active attacks

Security Attacks

- A **passive attack** attempts to learn or make use of information from the system but does not affect system resources.
- An **active attack** attempts to alter system resources or affect their operation.

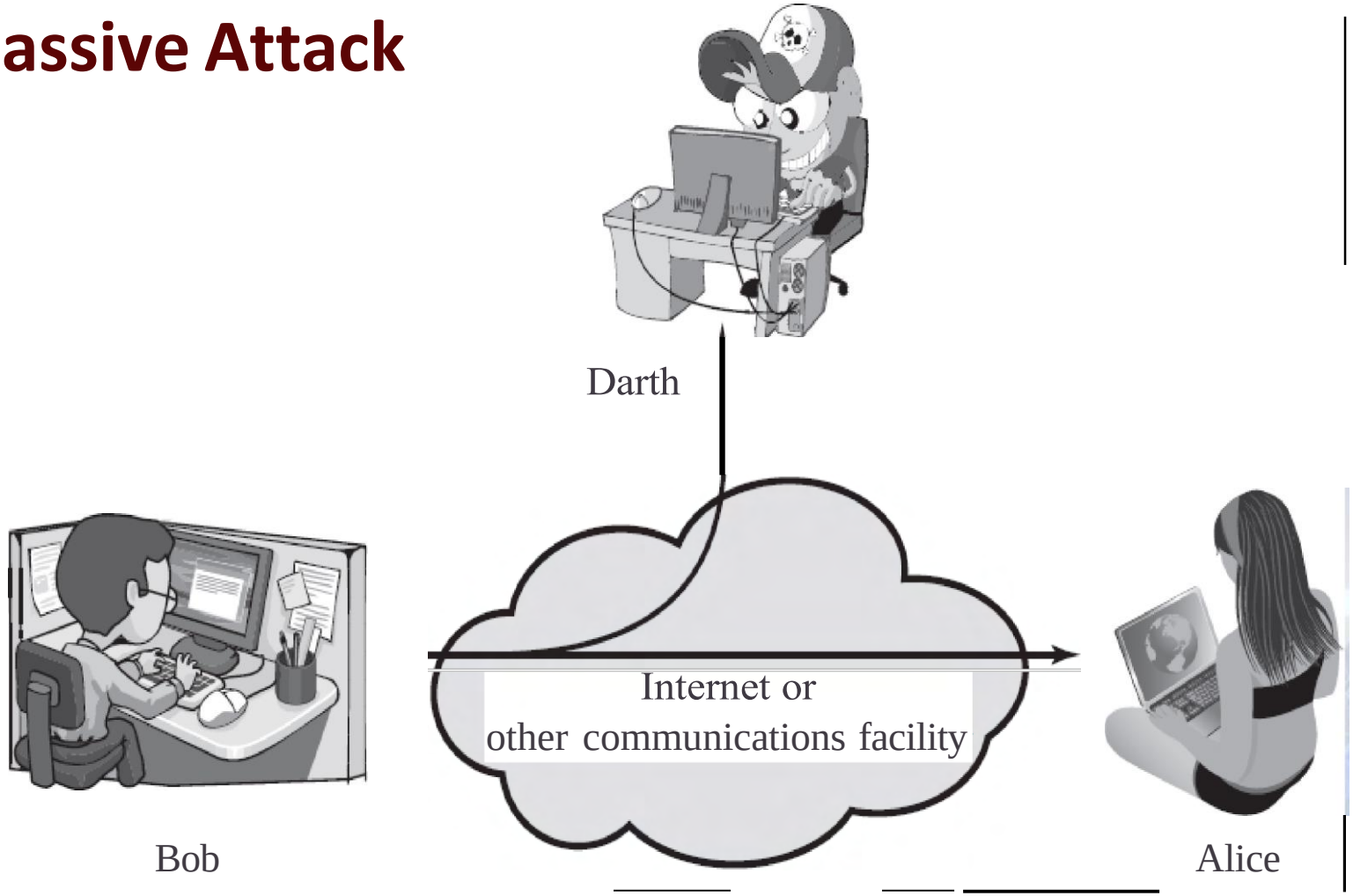
Security Attacks

Passive Attacks:

- Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions.
- The goal of the opponent is to obtain information that is being transmitted.

Security Attacks

Passive Attack



Security Attacks

- There are two types of passive attacks
- release of message contents, and
- traffic analysis.

Security Attacks

Release of message contents:

- A telephone conversation, an e-mail message, and a transferred file may contain confidential info. Prevent an opponent from learning contents of these transmissions.

Security Attacks

Traffic Analysis:

- Even if contents of messages are encrypted, an opponent might still be able to observe the pattern of these messages.

Security Attacks

- He could determine the location and identity of communicating hosts and could observe the frequency and length of messages being exchanged.
- He can guess the nature of the communication.

Security Attacks

- Passive attacks do not alter the data.
- Neither the sender nor receiver is aware that a third party has observed the traffic pattern.
- Emphasis is on prevention rather than detection.
- Use Encryption.

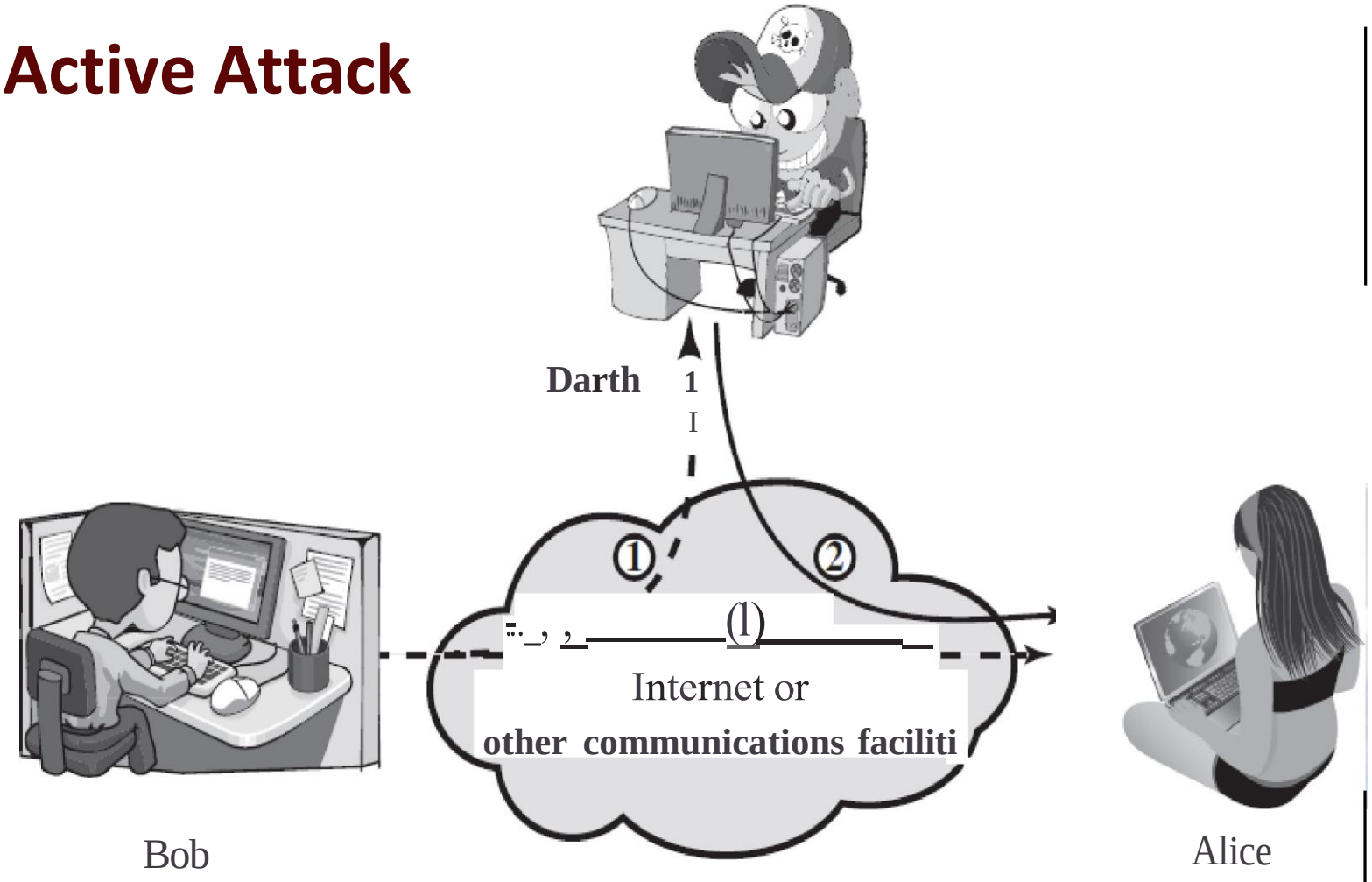
Security Attacks

Active Attacks:

- Active attacks involve some modification of the data stream or the creation of a false stream.

Security Attacks

Active Attack



Security Attacks

- Active attacks can be subdivided into four categories:
- masquerade,
- replay,
- modification of messages, and
- denial of service.

Security Attacks

Masquerade:

- It takes place when one entity pretends to be a different entity.
- It usually includes one of the other forms of active attack.

Security Attacks

Replay:

- It involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect.

Security Attacks

Modification of messages:

- It simply means that some portion of a legitimate message is altered, or that messages are delayed or reordered, to produce an unauthorized effect.

Security Attacks

Denial of Service:

- It prevents or inhibits the normal use or management of communications facilities.
- E.g. an entity may suppress all messages directed to a particular destination.

Security Attacks

- Active Attacks are difficult to prevent because of the wide variety of potential physical, software, and network vulnerabilities.
- Goal is to detect attacks and to recover from any disruption or delays caused by them.

End

Authentication, Access Control

Network Security

Authentication, Access Control

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain authentication and access control services.

Authentication, Access Control

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Authentication, Access Control

Security Services: Defined by X.800, OSI Security Architecture:

- a service provided by a protocol layer of communicating open systems and that ensures adequate security of the systems or of data transfers.

Authentication, Access Control

Defined by RFC 4949:

- a processing or communication service provided by a system to give a specific kind of protection to system resources

Authentication, Access Control

- Security services implement security policies and are implemented by security mechanisms.

Authentication, Access Control

X.800 Service Categories:

- Authentication
- Access control
- Data confidentiality
- Data integrity
- Nonrepudiation

Authentication, Access Control

Authentication :

- Concerned with assuring that a communication is authentic.
- In the case of a single message, assures the recipient that the message is from the source that it claims to be from.

Authentication, Access Control

- In the case of an ongoing interaction, two aspects are involved:
- First, at the time of connection initiation, the service assures that the two entities are authentic, that is, that each is the entity that it claims to be.

Authentication, Access Control

- Second, the service must assure that the connection is not interfered with in such a way that a third party can masquerade as one of the two legitimate parties for the purposes of unauthorized transmission or reception.

Authentication, Access Control

- Two specific authentication services are defined in X.800:
- Peer entity authentication
- Data origin authentication

Authentication, Access Control

Peer entity Authentication :

- Provides for the corroboration of the identity of a peer entity in an association.

Authentication, Access Control

- It’s provided for use at establishment of or during the data transfer phase of a connection.
- Provides confidence that an entity is neither performing a masquerade nor an unauthorized replay of a previous connection.

Authentication, Access Control

Data origin authentication:

- Provides for the corroboration of the source of a data unit.
- It does not provide protection against the duplication or modification of data units.

Authentication, Access Control

- This type of service supports applications like electronic mail, where there are no prior interactions between the communicating entities.

Authentication, Access Control

Access Control:

- It is the ability to limit and control the access to host systems and applications via communications links.

Authentication, Access Control

- To achieve this, each entity trying to gain access must first be identified, or authenticated, so that access rights can be tailored to the individual.

End

Confidentiality, Integrity, Nonrepudiation

Network Security

Confidentiality, Integrity, Nonrepudiation

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain data confidentiality, data integrity and nonrepudiation services.

Confidentiality, Integrity, Nonrepudiation

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Confidentiality, Integrity, Nonrepudiation

X.800 Service Categories:

- Authentication
- Access control
- Data confidentiality
- Data integrity
- Nonrepudiation

Confidentiality, Integrity, Nonrepudiation

Data Confidentiality:

- is the protection of transmitted data from passive attacks.
- Assurance that data received are exactly as sent by an authorized entity (i.e., contain no modification, insertion, deletion, or replay).

Confidentiality, Integrity, Nonrepudiation

- Broadest service protects all user data transmitted between two users over a period of time.
- E.g. when a TCP connection is set up bet. two systems, it prevents the release of any user data transmitted.

Confidentiality, Integrity, Nonrepudiation

- Narrower forms of service include the protection of a single message or even specific fields within a message.

Confidentiality, Integrity, Nonrepudiation

- The other aspect is the protection of traffic flow from analysis.
- This requires that an attacker not be able to observe the source and destination, length, or other characteristics of the traffic.

Confidentiality, Integrity, Nonrepudiation

Data Integrity:

- can apply to a stream of messages, a single message, or selected fields within a message.
- the most useful and straightforward approach is total stream protection.

Confidentiality, Integrity, Nonrepudiation

- Connection-oriented integrity service deals with a stream of messages and assures that messages are received as sent with no duplication, insertion, modification, reordering, or replays.

Confidentiality, Integrity, Nonrepudiation

- the connection-oriented integrity service addresses both message stream modification and denial of service.

Confidentiality, Integrity, Nonrepudiation

- A connectionless integrity service deals with individual messages without regard to any larger context, and generally provides protection against message modification only.

Confidentiality, Integrity, Nonrepudiation

- Because the integrity service relates to active attacks, we are concerned with detection rather than prevention.
- automated recovery mechanisms allow to recover from the loss of integrity of data.

Confidentiality, Integrity, Nonrepudiation

Nonrepudiation:

- prevents either sender or receiver from denying a transmitted message.

Confidentiality, Integrity, Nonrepudiation

- When a message is sent, the receiver can prove that the alleged sender in fact sent the message.
- When a message is received, the sender can prove that the alleged receiver in fact received the message.

Confidentiality, Integrity, Nonrepudiation

Availability Service:

- The property of a system or a system resource being accessible and usable upon demand by an authorized system entity, according to performance specifications for the system.

Confidentiality, Integrity, Nonrepudiation

- One that protects a system to ensure its availability.
- Addresses the security concerns raised by denial-of-service attacks.
- Depends on proper management and control of system resources.

End

Security Mechanisms

Network Security

Security Mechanisms

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe security mechanisms.

Security Mechanisms

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Security Mechanisms

- Security mechanisms defined by X.800, Security Architecture for OSI can be divided into two broad categories w.r.t their implementation.

Security Mechanisms

A) Specific Security Mechanisms

- May be incorporated into the appropriate protocol layer in order to provide some of the OSI security services

Security Mechanisms

Encipherment

- Use of mathematical algorithms to transform data into a form that is not readily intelligible.
- The transformation and subsequent recovery depend on the algorithm and encryption keys.

Security Mechanisms

Digital Signature

- Data appended to, or a cryptographic transformation of, a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery.

Security Mechanisms

Access Control

- A variety of mechanisms that enforce access rights to resources.

Data Integrity

- A variety of mechanisms used to assure the integrity of a data unit or stream of data units.

Security Mechanisms

Authentication Exchange

- A mechanism intended to ensure the identity of an entity by means of information exchange.

Security Mechanisms

Traffic Padding

- The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.

Security Mechanisms

Routing Control

- Enables selection of particular physically secure routes for certain data and allows routing changes, especially when a breach of security is suspected.

Security Mechanisms

Notarization

- The use of a trusted third party to assure certain properties of a data exchange.

Security Mechanisms

B) Pervasive Security Mechanisms

- Mechanisms that are not specific to any particular OSI security service or protocol layer.

Security Mechanisms

Trusted Functionality

- That which is perceived to be correct with respect to some criteria (e.g., as established by a security policy).

Security Mechanisms

Security Label

- The marking bound to a resource (which may be a data unit) that names or designates the security attributes of that resource.

Security Mechanisms

Event Detection

- Detection of security-relevant events.

Security Mechanisms

Security Audit Trail

- Data collected and potentially used to facilitate a security audit, which is an independent review and examination of system records and activities.

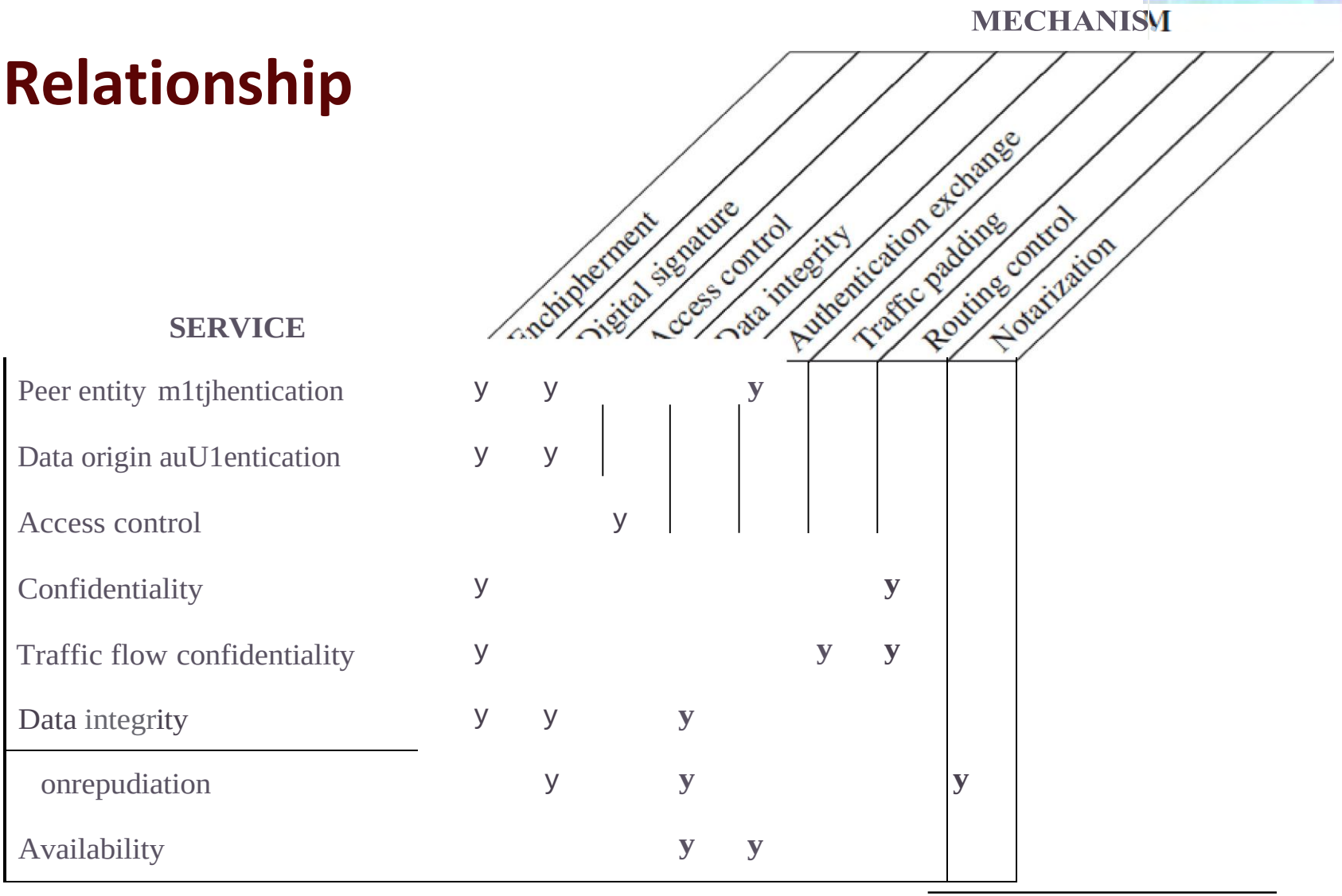
Security Mechanisms

Security Recovery

- Deals with requests from mechanisms, such as event handling and management functions, and takes recovery actions

Security Mechanisms

Relationship



SERVICE	Enchipherment	Digital signature	Access control	Data integrity	Authentication exchange	Traffic padding	Routing control	Notarization
Peer entity m1tjhentication	y	y		y				
Data origin auU1entication	y	y						
Access control			y					
Confidentiality	y					y		
Traffic flow confidentiality	y				y	y		
Data integrity	y	y		y				
onrepudiation		y		y			y	
Availability				y	y			

A Model For Network Security

Network Security

A Model For Network Security

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe a model for network security.

A Model For Network Security

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

A Model For Network Security

- Assume a message is to be transferred from one party to another across some sort of Internet service.
- The two parties, who are the principals in this transaction, must cooperate for the exchange to take place.

A Model For Network Security

- A logical information channel is established by defining a route through the Internet from source to destination and by the cooperative use of communication protocols (e.g., TCP/IP) by the two principals.

A Model For Network Security

- To protect the information from an opponent who may present a threat to confidentiality, authenticity, and so on, security comes into play.
- All of the security techniques have two components:

A Model For Network Security

- 1. A security-related transformation on the information to be sent.
- Example1: encryption of the message, which scrambles the message so that it is unreadable by the opponent.

A Model For Network Security

- Example2: the addition of a code based on the contents of the message, which can be used to verify the identity of the sender.

A Model For Network Security

- 2. Some secret information shared by the two principals and unknown to the opponent.
- E.g. encryption key used with the transformation to scramble the message before transmission and unscramble it on reception.

A Model For Network Security

- A trusted third party (TTP) may be needed to achieve secure transmission.
- E.g. a TTP may be responsible for distributing the secret information to the two principals while keeping it from any opponent.

A Model For Network Security

- This general model shows that there are four basic tasks in designing a particular security service:

A Model For Network Security

- 1. Design an algorithm for the security-related transformation. An opponent should not be able to defeat purpose of the algorithm.
- 2. Generate the secret information used by the algorithm.

A Model For Network Security

- 3. Develop methods for the distribution and sharing of the secret information.
- 4. Specify a protocol enabling the principals to use the security algorithm and the secret information for a particular security service.

A Model For Network Security

A Generic Model For Network Security

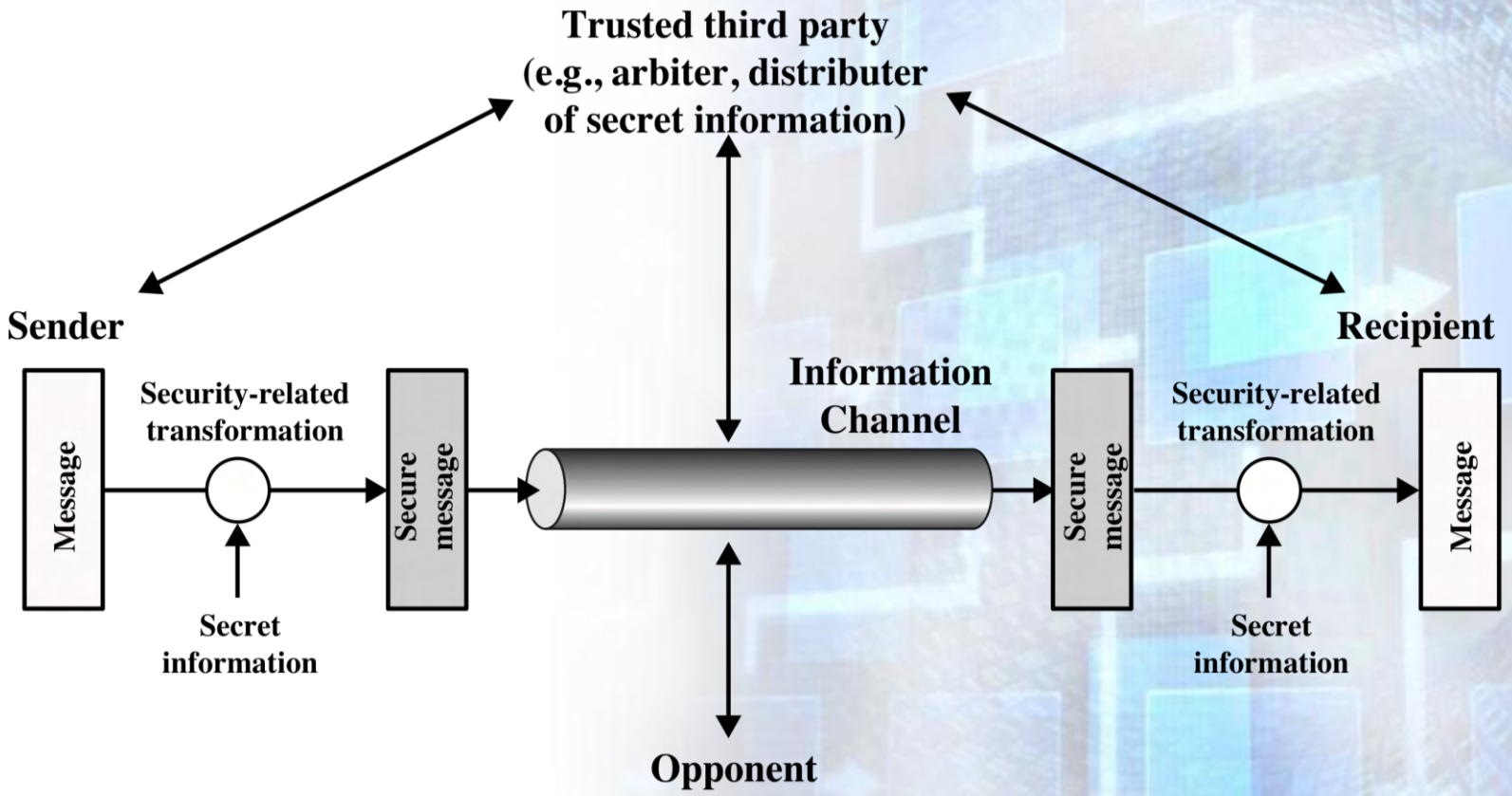


Figure 1.2 Model for Network Security

A Model For Network Security

- Next, we describe a general model which reflects a concern for protecting an information system from unwanted access.
- E.g. A hacker who attempts to penetrate system that can be accessed over a net.

A Model For Network Security

- An intruder can be a disgruntled employee who wishes to do damage or a criminal who seeks to exploit computer assets for financial gain (e.g., obtaining credit card numbers or performing illegal money transfers).

A Model For Network Security

- Using this model requires us to:
- Select appropriate gatekeeper functions to identify users
- Implement security controls to ensure only authorized users access designated information or resources.

A Model For Network Security

Network Access Security Model

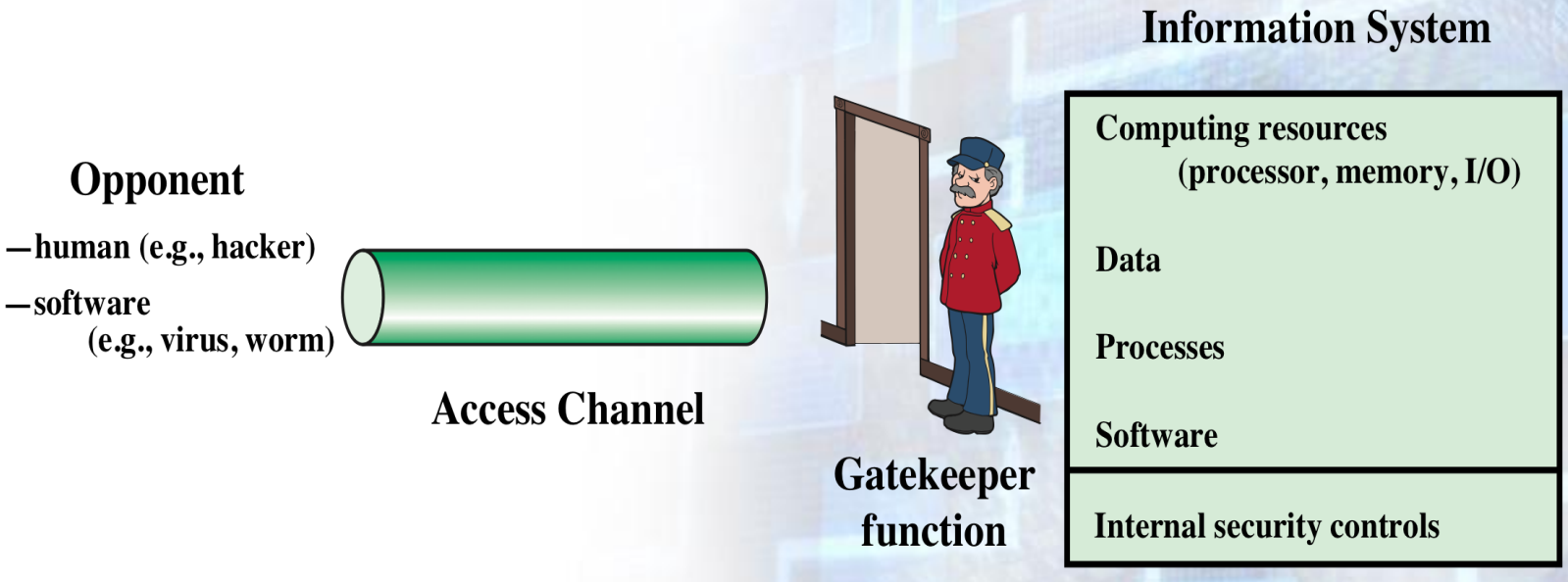


Figure 1.3 Network Access Security Model

A Model For Network Security

- Another type of unwanted access is the placement in a computer system of logic that exploits vulnerabilities in the system and that can affect application programs.

End

Basics Of Symmetric Encryption

Network Security

Basics Of Symmetric Encryption

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe basics of symmetric encryption.

Basics Of Symmetric Encryption

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Basics Of Symmetric Encryption

- Symmetric encryption, or single-key encryption, was the only type of encryption in use prior to the development of public key encryption in the 1970s.

Basics Of Symmetric Encryption

Some Basic Terminology

- Plaintext - original message
- Ciphertext - coded message
- Cipher - algorithm for transforming plaintext to ciphertext .

Basics Of Symmetric Encryption

- Key - info used in cipher known only to sender/receiver
- Encipher (encrypt) - converting plaintext to ciphertext
- Decipher (decrypt) - recovering ciphertext from plaintext

Basics Of Symmetric Encryption

- Cryptography - study of encryption principles/methods
- Cryptanalysis (code breaking) - study of principles/methods of deciphering ciphertext without knowing key
- Cryptology - field of both cryptography and cryptanalysis

Basics Of Symmetric Encryption

Symmetric Encryption Principles

- A symmetric encryption scheme has five ingredients

Basics Of Symmetric Encryption

Plaintext

- This is the original intelligible message or data that is fed into the algorithm as input.

Encryption Algorithm

- It performs various substitutions and transformations on the plaintext.

Basics Of Symmetric Encryption

Secret Key

- It is also input to the encryption algorithm. The key is a value independent of the plaintext and of the algorithm.

Basics Of Symmetric Encryption

Secret Key …

- The algorithm will produce a different output depending on the specific key being used at the time.
- The exact substitutions and transformations performed depend on the key.

Basics Of Symmetric Encryption

Ciphertext

- This is the scrambled message produced as output. It depends on the plaintext and the secret key. For a given message, two different keys will produce two different ciphertexts (is unintelligible).

Basics Of Symmetric Encryption

Decryption algorithm

- This is essentially the encryption algorithm run in reverse.
- It takes the ciphertext and the secret key and produces the original plaintext.

Basics Of Symmetric Encryption

Model of Symmetric Encryption

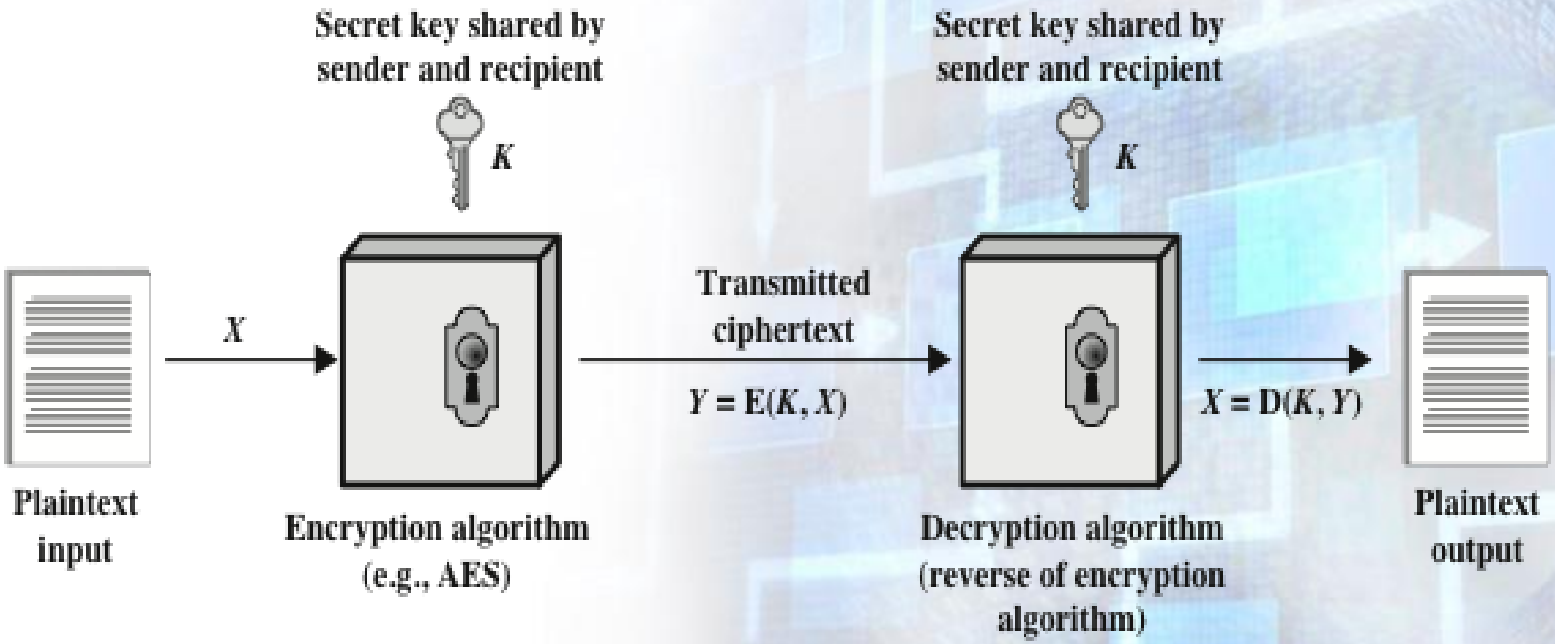


Figure 2.1 Simplified Model of Symmetric Encryption

Basics Of Symmetric Encryption

Requirements

- Two requirements for secure use of symmetric encryption

Basics Of Symmetric Encryption

- 1. We need a strong encryption algorithm.
- An opponent should be unable to decrypt ciphertext or discover the key even if he is in possession of a no. of ciphertexts together with the plaintext that produced each ciphertext.

Basics Of Symmetric Encryption

- 2. Sender and receiver must have obtained copies of the secret key in a secure fashion and must keep the key secure.
- If someone discovers the key and knows the algorithm, all communication using this key is readable.

Basics Of Symmetric Encryption

- The security of symmetric encryption depends on the secrecy of the key, not the secrecy of the algorithm

Basics Of Symmetric Encryption

- It is impractical to decrypt a message on the basis of the ciphertext plus knowledge of the encryption/decryption algorithm.
- This makes it feasible for widespread use.

Basics Of Symmetric Encryption

End

- Manufacturers can and have developed low-cost chip implementations of data encryption algorithms.
- These chips are widely available and incorporated into a number of products.

Cryptanalysis

Network Security

Cryptanalysis

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain Cryptanalysis.

Cryptanalysis

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Cryptanalysis

- Cryptography - study of encryption principles/methods.
- Cryptanalysis (code breaking) - study of principles/methods of deciphering ciphertext without knowing key.

Cryptanalysis

- Cryptographic systems are generically classified along three independent dimensions.

Cryptanalysis

1. The type of operations used for transforming plaintext to ciphertext.

- two general principles:
- Substitution
- Transposition

Cryptanalysis

Substitution:

- Each element (bit, letter, group of bits or letters) in the plaintext is mapped into another element.

Cryptanalysis

Transposition:

- Elements in the plaintext are rearranged.
- Fundamental requirement is that no information be lost.
- Product systems involve multiple stages of substitutions and transpositions.

Cryptanalysis

2. The number of keys used.

- Referred to as symmetric, single-key, secret-key, or conventional encryption if both sender and receiver use the same key.

Cryptanalysis

- Referred to as asymmetric, two-key, or public-key encryption if the sender and receiver each use a different key.

Cryptanalysis

3. The way in which the plaintext is processed.

- A block cipher processes the input one block of elements at a time, producing an output block for each input block.

Cryptanalysis

- A stream cipher processes the input elements continuously, producing output one element at a time, as it goes along.

Cryptanalysis

Cryptanalysis

- The strategy used by the cryptanalyst depends on the nature of the encryption scheme and the information available to the cryptanalyst.

Cryptanalysis

Ciphertext Only:

- The cryptanalyst knows ciphertext only.
- Uses brute-force approach - try all possible keys.
- Make the key space very large so it becomes impractical.
- Easiest to defend

Cryptanalysis

Known plaintext:

- The analyst may be able to capture one or more plaintext messages as well as their encryptions.
- Or he may know that certain plaintext patterns will appear in a message.
- May deduce the key.

Cryptanalysis

Probable-word:

- An opponent may know parts of the message, then he can obtain specific information.
- E.g. an accounting file is being transmitted, placement of certain key words in the header of the file.

Cryptanalysis

Chosen-plaintext:

- If the analyst is able to choose the messages to encrypt, the analyst may deliberately pick patterns that can be expected to reveal the structure of the key.

Cryptanalysis

Type of Attack	Known to Cryptanalyst
Ciphertext Only	• Encryption algorithm • Ciphertext
Known Plaintext	• Encryption algorithm • Ciphertext • One or more plaintext-ciphertext pairs formed with the secret key
Chosen Plaintext	• Encryption algorithm • Ciphertext • Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated with the secret key
Chosen Ciphertext	• Encryption algorithm • Ciphertext • Ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key
Chosen Text	• Encryption algorithm • Ciphertext • Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated *with* the secret key • Ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key

Cryptanalysis

- The last two (chosen ciphertext and chosen text) are less commonly employed as cryptanalytic techniques but are nevertheless possible avenues of attack.

Cryptanalysis

- Only a relatively weak algorithm will fail to withstand a ciphertext-only attack.
- Generally, an encryption algorithm is designed to withstand a known-plaintext attack.

Cryptanalysis

- An encryption scheme is **computationally secure** if ciphertext generated by the scheme meets one or both of the criteria:
- The cost of breaking the cipher exceeds the value of the encrypted information.

Cryptanalysis

- The time required to break the cipher exceeds the useful lifetime of the information.

Cryptanalysis

Brute Force attack:

- Involves trying every possible key until an intelligible translation of the ciphertext into plaintext is obtained
- On average, half of all possible keys must be tried to achieve success.

Cryptanalysis

End

- To supplement the brute-force approach
- Some degree of knowledge about the expected plaintext is needed.
- Some means of automatically distinguishing plaintext from garble is also needed.

Feistel Cipher Structure

Network Security

Feistel Cipher Structure

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain structure of Feistel Cipher.

Feistel Cipher Structure

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Feistel Cipher Structure

- Many symmetric block encryption algorithms have a structure, which was first described by Horst Feistel of IBM in 1973.

Feistel Cipher Structure

Feistel Encryption

- The inputs to the encryption algorithm are a plaintext block of length 2w bits and a key K.
- The plaintext block is divided into two halves, LE_0 and RE_0.

Feistel Cipher Structure

- The two halves of the data pass through n rounds of processing and then combine to produce the ciphertext block.

Feistel Cipher Structure

- Each round *i* has as inputs LE_{i-1} and RE_{i-1} derived from the previous round, as well as a subkey K_i derived from the overall *K*.

Feistel Cipher Structure

- In general, the subkeys K_i are different from K and from each other and are generated from the key by a subkey generation algorithm.

Feistel Cipher Structure

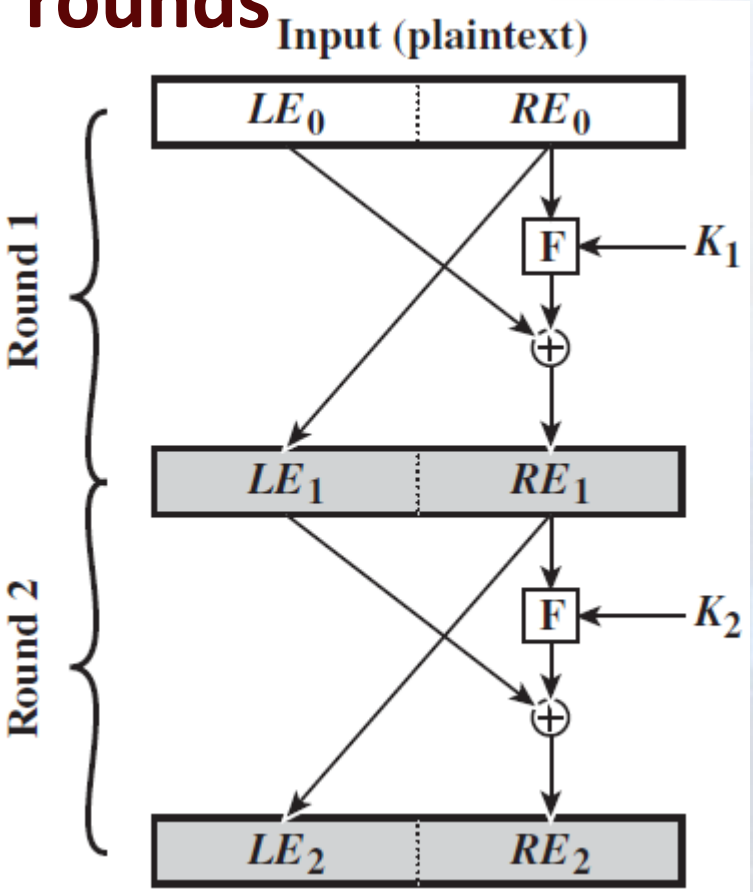
- In a given round, a substitution is performed on the left half of the data.
- Apply a round function F to the right half of the data and then take XOR of the output of that function and the left half of the data.

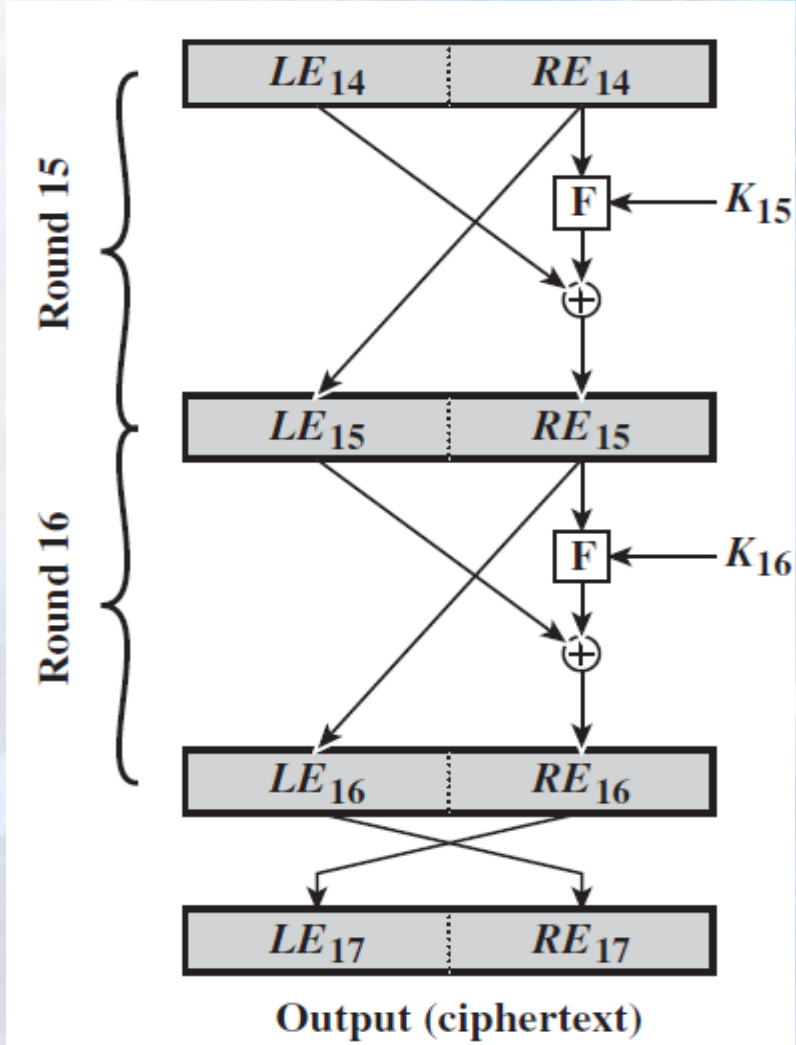
Feistel Cipher Structure

- The round function has the same general structure for each round but is parameterized by the round subkey K_i.
- A permutation is then performed to interchange the two halves of the data.

Feistel Cipher Structure

Feistel Encryption 16 rounds





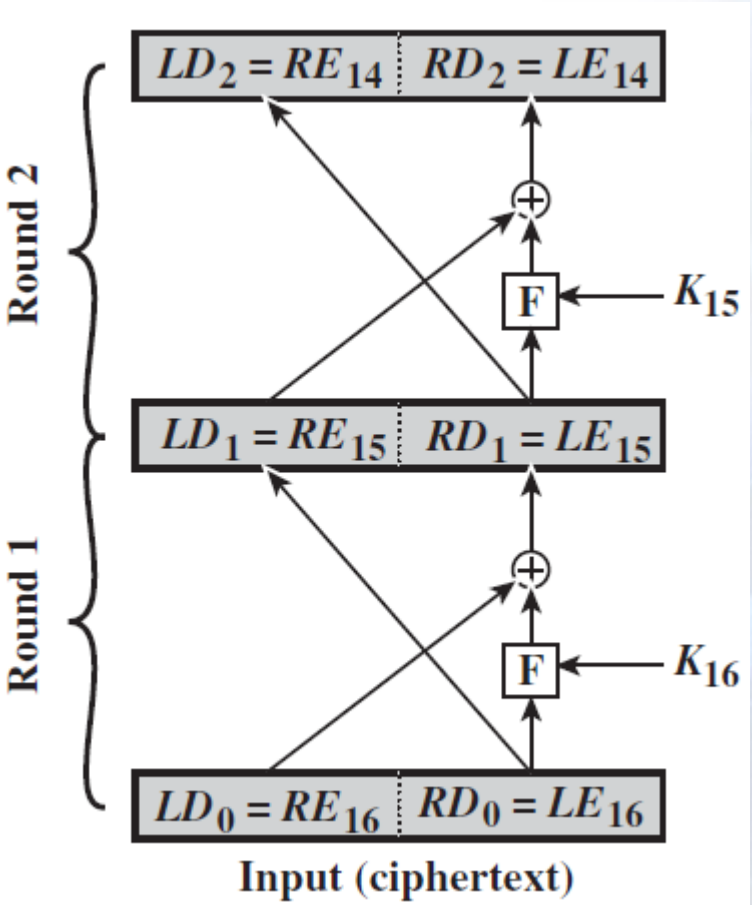
Feistel Cipher Structure

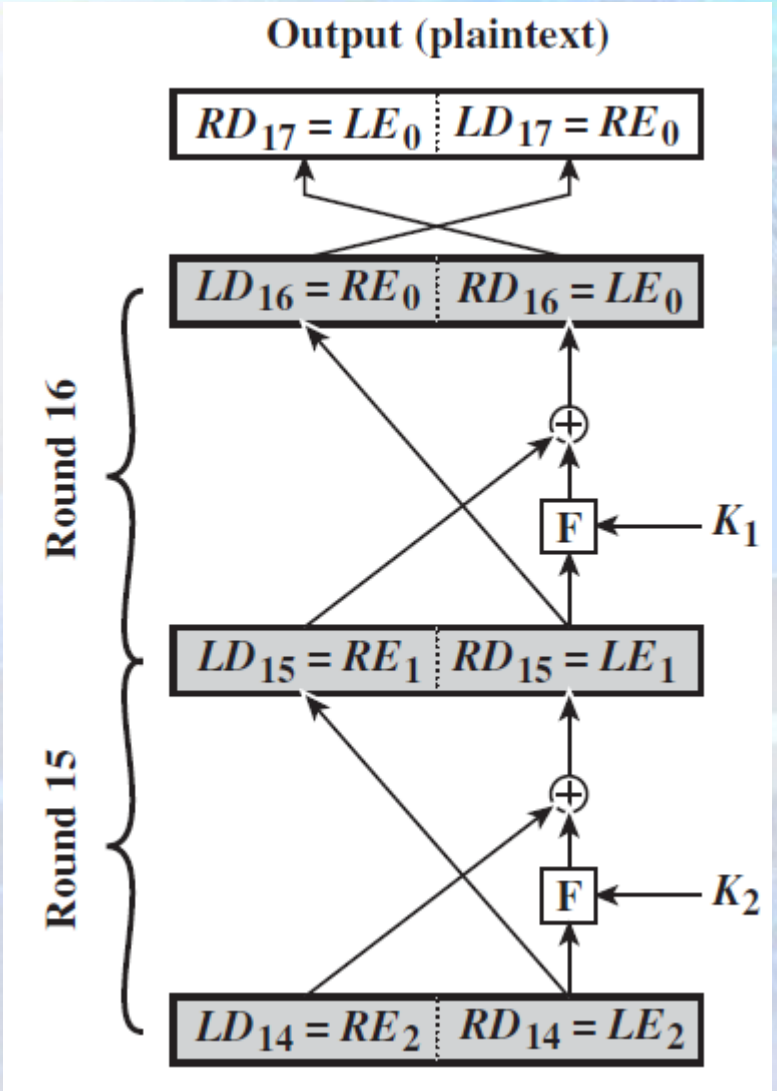
Feistel Decryption

- Use the ciphertext as input to the algorithm, but use the subkeys K_i in reverse order. That is, use K_n in the first round, K_{n-1} in the second round, and so on until K_1 is used in the last round.

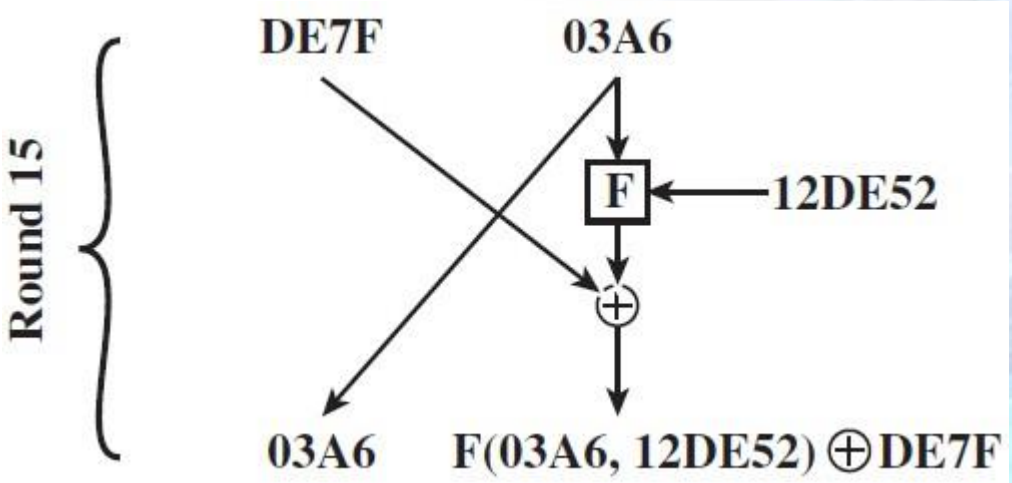
Feistel Cipher Structure

Feistel Decryption



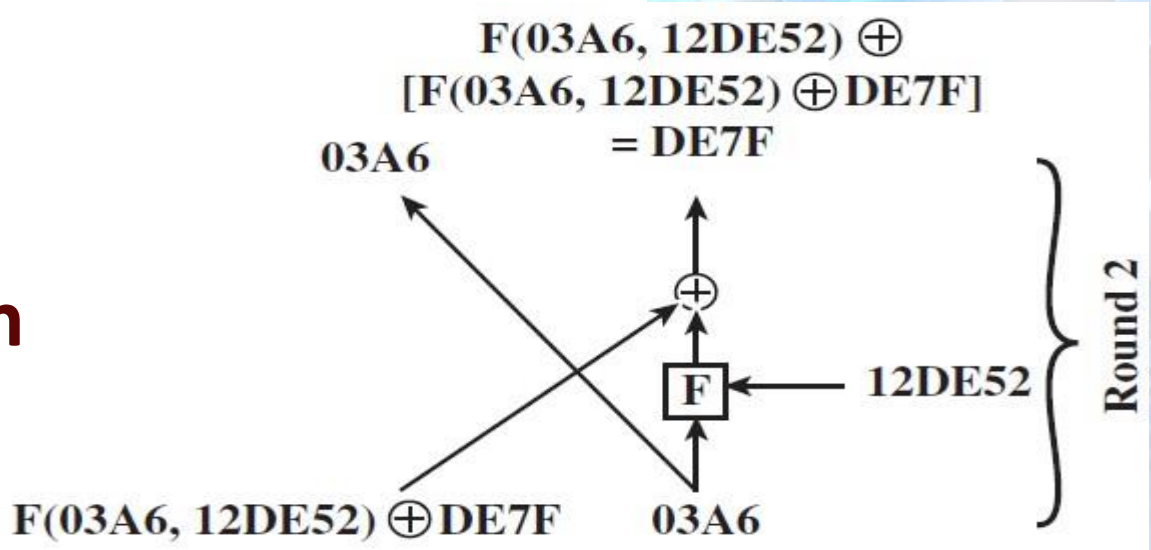


Feistel Cipher Structure



Encryption

Decryption



Feistel Cipher Structure

Feistel Cipher Design Features:

- **Block size:** Larger block sizes mean greater security (all other things being equal) but reduced encryption/decryption speed.

Feistel Cipher Structure

- **Key size:** Larger key size means greater security but may decrease encryption/decryption speed.

Feistel Cipher Structure

- **Number of rounds:** The essence of a symmetric block cipher is that a single round offers inadequate security but that multiple rounds offer increasing security.

Feistel Cipher Structure

- **Subkey generation algorithm:** Greater complexity in this algorithm should lead to greater difficulty of cryptanalysis.
- **Round function:** Greater complexity generally means greater resistance to cryptanalysis.

Feistel Cipher Structure

- **Fast software Algorithms:** Encryption is embedded in applications or utility functions in such a way as to preclude a hardware implementation. Thus, speed of execution of the algorithm becomes a concern.

Feistel Cipher Structure

End

- **Ease of analysis:** If the algorithm can be concisely and clearly explained, it is easier to analyze that algorithm for cryptanalytic vulnerabilities and develop a higher level of assurance as to its strength.

Data Encryption Standard (DES)

Network Security

Data Encryption Standard (DES)

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe data encryption standard.

Data Encryption Standard (DES)

Figures and material in this topic have been

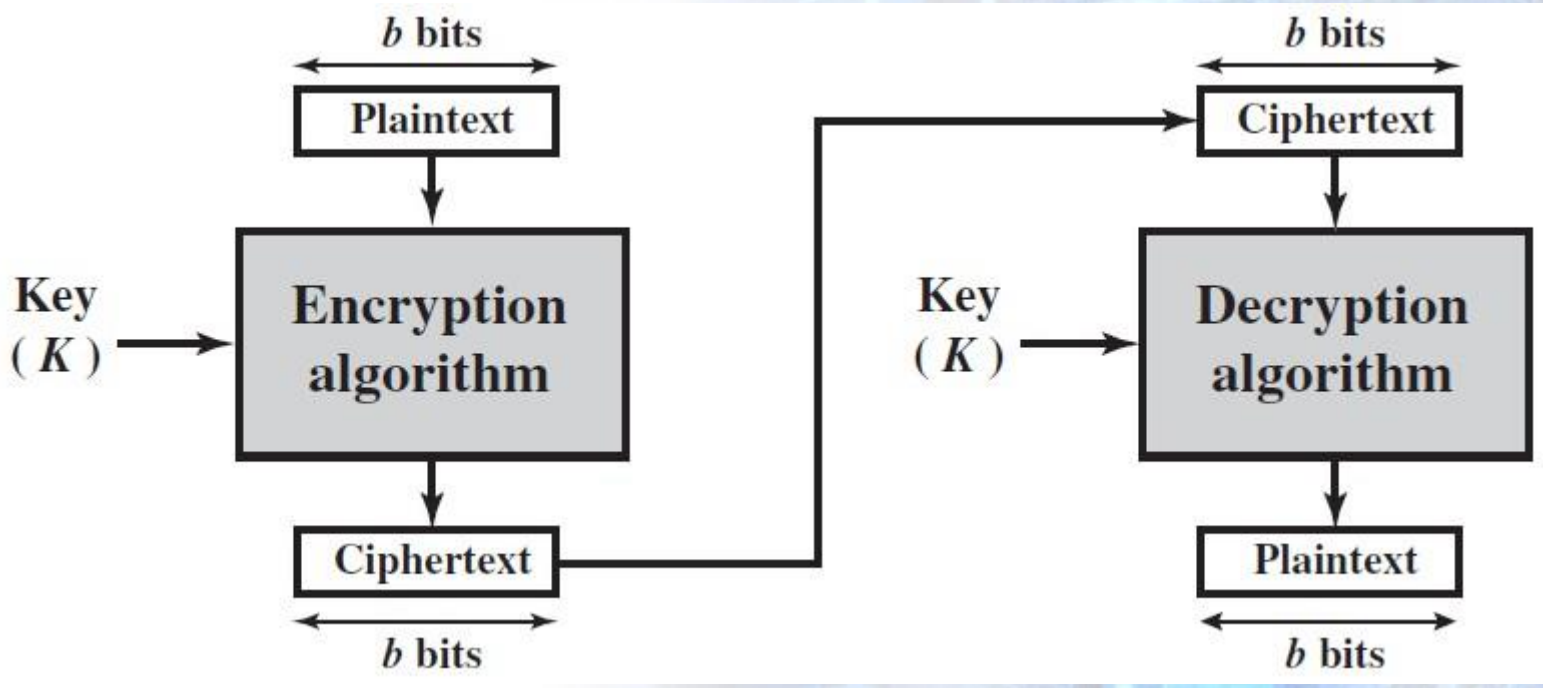
- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Data Encryption Standard (DES)

- A block cipher processes plaintext input in fixed-sized blocks and produces a block of ciphertext of equal size for each plaintext block.
- The two users share a common encryption key.
- DES is an example.

Data Encryption Standard (DES)

Block Ciphers



Data Encryption Standard (DES)

- Data Encryption Standard (DES) was issued in 1977 as Federal Information Processing Standard 46 (FIPS 46) by the National Institute of Standards and Technology (NIST).

Data Encryption Standard (DES)

DES Encryption

- Data are encrypted in 64-bit blocks using a 56-bit key.
- The algorithm transforms 64-bit input in a series of steps into a 64-bit output.

Data Encryption Standard (DES)

- There are two inputs to the encryption function: the plaintext to be encrypted and the key.
- The function expects a 64-bit key out of which only 56 are used; other 8 bits can be set arbitrarily.

Data Encryption Standard (DES)

- Plaintext proceeds in three phases.
- **First**, the 64-bit plaintext passes through an initial permutation (IP) that rearranges the bits to produce the permuted input.

Data Encryption Standard (DES)

- The **2nd phase** consists of 16 rounds of the same function, which involves both permutation and substitution functions.
- The output of the last round consists of 64 bits that are a function of the input plaintext and the key.

Data Encryption Standard (DES)

- The left and right halves of the output are swapped to produce preoutput.
- **Finally**, the preoutput is passed through a permutation that is the inverse of the initial permutation function, to produce the 64-bit ciphertext.

Data Encryption Standard (DES)

Subkey Generation

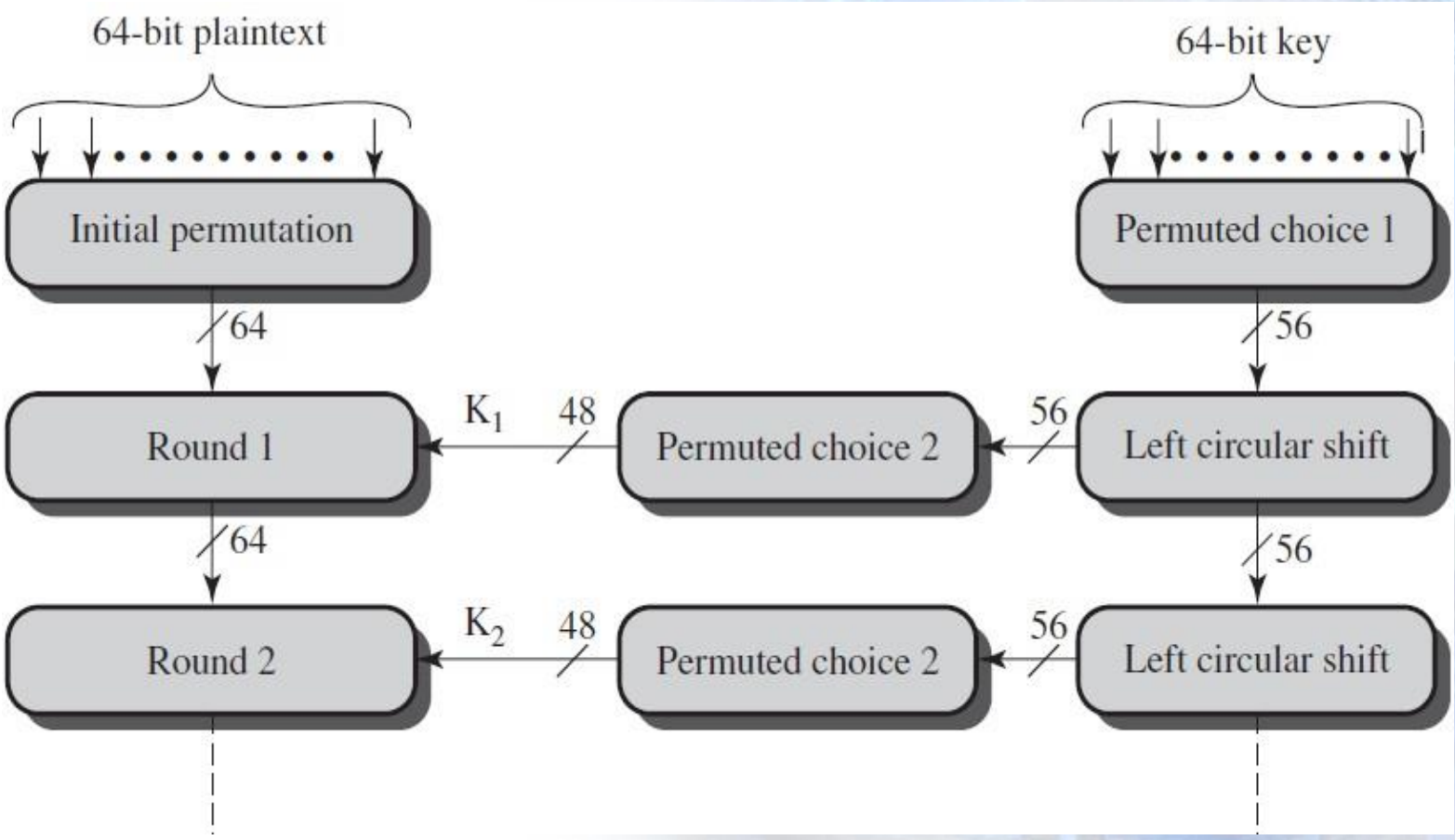
- Initially, the key is passed through a permutation function.
- Then, for each of the 16 rounds, a subkey (K_i) is produced by the combination of a left circular shift and a permutation.

Data Encryption Standard (DES)

- The permutation function is the same for each round, but a different subkey is produced because of the repeated shifts of the key bits.

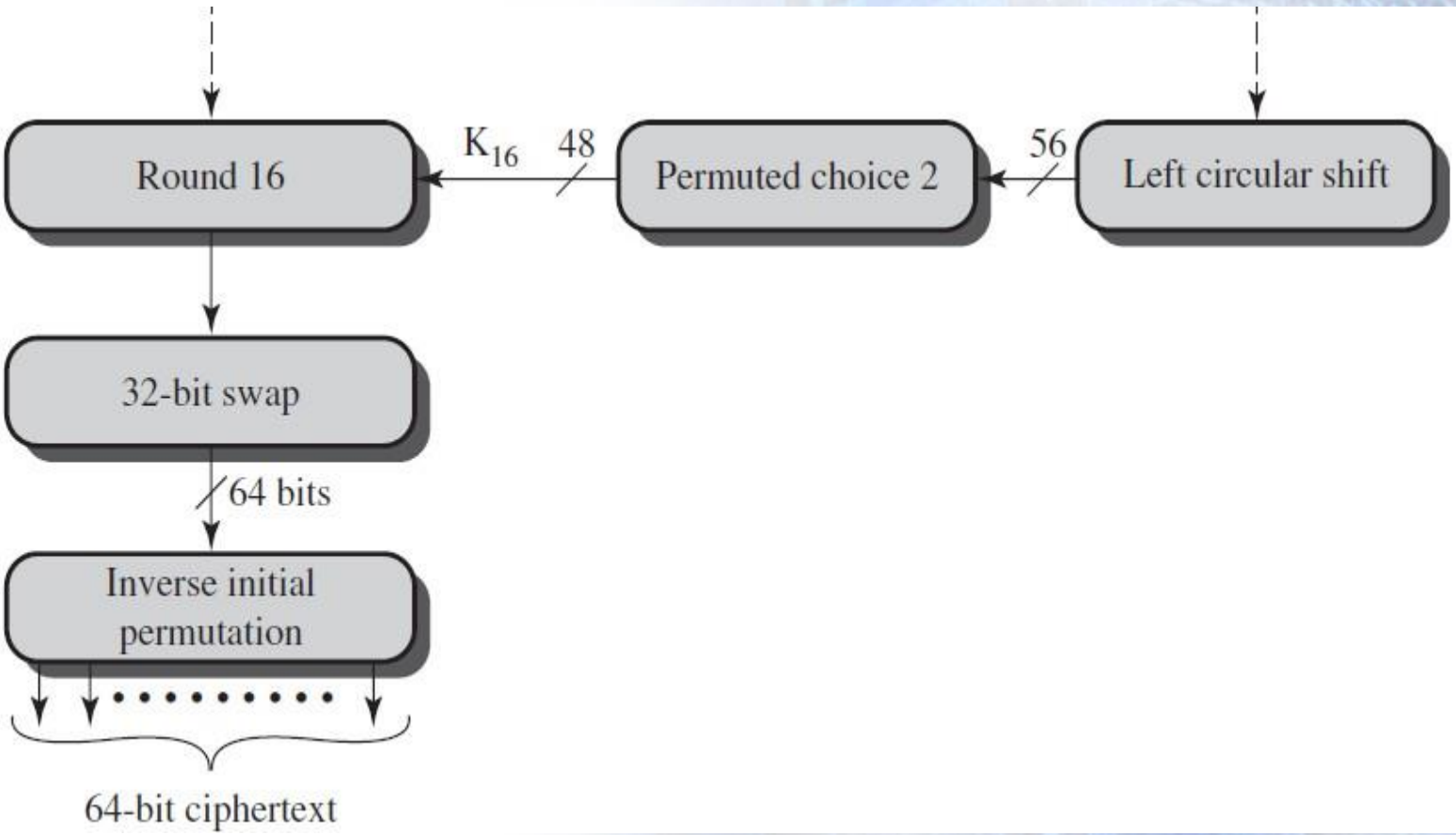
Data Encryption Standard (DES)

Working of DES



Data Encryption Standard (DES)

Working of DES



Data Encryption Standard (DES)

DES Decryption

- It uses the same algorithm as encryption, except that the application of the subkeys is reversed.
- Also, the initial and final permutations are reversed.

Data Encryption Standard (DES)

Concerns about DES

- 1.The algorithm itself
- Refers to the possibility that cryptanalysis is possible by exploiting the characteristics of the algorithm

Data Encryption Standard (DES)

- 2.The use of a 56-bit key
- $2^{56} = 7.2 \times 10^{16}$ keys
- Time required if PC works at 10^9 decryptions/s, then 2^{55} ns = 1.125 years.
- Time required if PC works at 10^{13} decryptions/s, then 1 hour.

Data Encryption Standard (DES)

- DES finally proved insecure in July 1998.
- Electronic Frontier Foundation (EFF) have broken it using a machine that took less than three days.

End

Triple DES

Network Security

Triple DES

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe Triple DES.

Triple DES

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Triple DES

- DES uses a 56-bit key
- $2^{56} = 7.2 \times 10^{16}$ keys
- Time required if PC works at 10^9 decryptions/s, then 2^{55} ns = 1.125 years.
- Time required if PC works at 10^{13} decryptions/s, then 1 hour.

Triple DES

- Given the potential vulnerability of DES to a brute-force attack, use of multiple encryption and multiple keys was suggested.
- Rationale was to preserve the existing investment in software, & hardware.

Triple DES

- 3DES uses three keys and three executions of the DES algorithm.
- The function follows an encrypt-decrypt-encrypt (EDE) sequence.

Triple DES

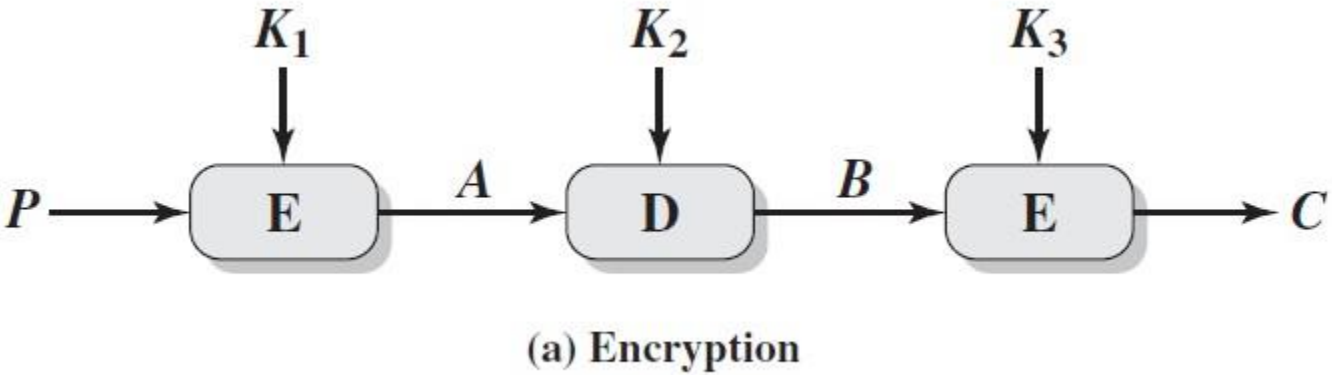
- Given a plaintext P, ciphertext C is generated as
- $C =$

  $E(K_3, D(K_2, E(K_1, P)))$

- where E[K, X] encryption of X using key K
- D[K, Y] decryption of Y using key K

Triple DES

3DES Encryption



(a) Encryption

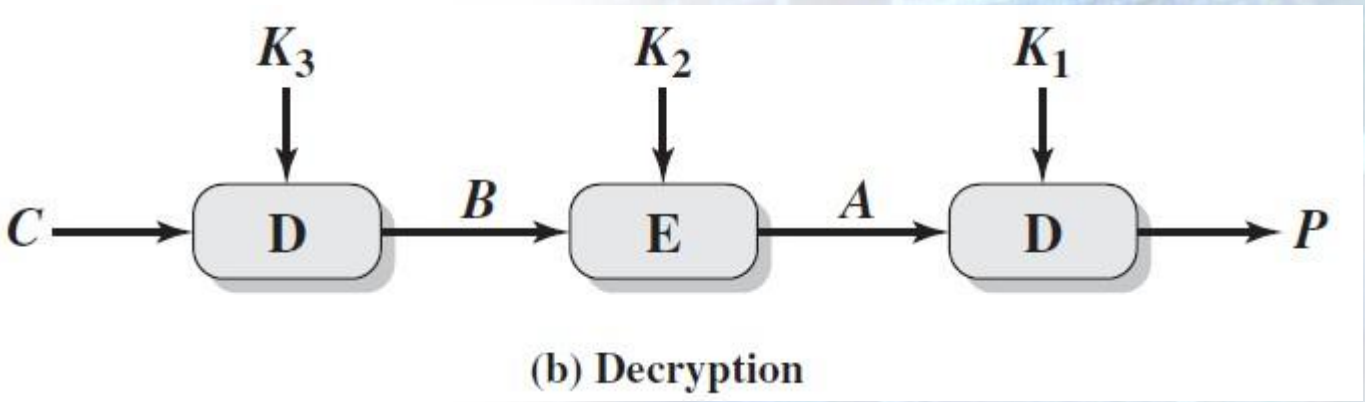
Triple DES

- Decryption is simply the same operation with the keys reversed:

- P = $D(K_1, E(K_2, D(K_3, C)))$

Triple DES

3DES Decryption



(b) Decryption

Triple DES

- There is no cryptographic significance to the use of decryption for the second stage of 3DES encryption.

Triple DES

- Its only advantage is that it allows users of 3DES to decrypt data encrypted by users of the older single DES:

- C =

  $E(K_1, D(K_1, E(K_1, P)))$

  $= E[K, P]$

Triple DES

- Federal Information Processing Standards (FIPS) 46-3 also allows for the use of two keys, with $K_1 = K_3$; this provides for a key length of 112 bits.

Triple DES

- The cost of a brute-force key search on 3DES is on the order of $2^{112} = (5 * 10^{33})$.

Triple DES

- 3DES with two keys is a relatively popular alternative to DES and has been adopted for use in the key management standards ANSI X9.17 and ISO 8732.

Triple DES

Triple DES with Three Keys:

- Many researchers now feel that three-key 3DES is the preferred alternative.
- With three distinct keys, 3DES has an effective key length of 168 bits.

Triple DES

- $2^{168} = 3.7 \times 10^{50}$ keys
- Time required if PC works at 10^9 decryptions/s, then 2^{167} ns = 5.8 x 10^{33} years.
- Time required if PC works at 10^{13} decryptions/s, then 5.8 x 10^{29} years.

Triple DES

- Backward compatibility with DES is provided by putting $K_3 = K_2$ or $K_1 = K_2$.

Triple DES

Usage of 3DES:

- A number of Internet-based applications have adopted three-key 3DES:
- Pretty Good Privacy (PGP) and Secure/Multipurpose Internet Mail Extension (S/MIME).

Triple DES

FIPS 46-3 Guidelines for 3DES:

- 3DES is the approved symmetric encryption algorithm of choice.
- The original DES is permitted under the standard for legacy systems only; new procurements should support 3DES.

Triple DES

- Government organizations with legacy DES systems are encouraged to transition to 3DES.

End

Advanced Encryption Standard

Network Security

Advanced Encryption Standard

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe Advanced Encryption Standard.

Advanced Encryption Standard

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Advanced Encryption Standard

- The principal drawbacks of 3DES:
- 1.It has three times as many rounds as DEA and is correspondingly slower.
- 2.Both DEA and 3DES use a 64-bit block size.
- Its not a reasonable candidate for long term use.

Advanced Encryption Standard

- In 1997 NIST issued a call for proposals for a new AES:
- 1.Should have a security strength equal to or better than 3DES and significantly improved efficiency.

Advanced Encryption Standard

- 2. Must be a symmetric block cipher with a block length of 128 bits and support for key lengths of 128, 192, and 256 bits.

Advanced Encryption Standard

- 3. Evaluation criteria included security, computational efficiency, memory requirements, hardware and software suitability, and flexibility

Advanced Encryption Standard

- NIST selected Rijndael as the proposed AES algorithm
- Developers were two cryptographers from Belgium: Dr. Joan Daemen and Dr. Vincent Rijmen
- published as a final standard (FIPS PUB 197) in 2001.

Advanced Encryption Standard

- AES uses a block length of 128 bits and a key length that can be 128, 192, or 256 bits.
- For our discussion, we assume 128 bits in this topic.

Advanced Encryption Standard

- The input to the encryption and decryption algorithms is a single 128-bit block.
- In FIPS PUB 197, this block is depicted as a square matrix of bytes.

Advanced Encryption Standard

- The block is copied into the **State** array, which is modified at each stage of encryption or decryption.
- After the final stage, **State** is copied to an output matrix.

Advanced Encryption Standard

- Similarly, the 128-bit key is depicted as a square matrix of bytes.
- This key is then expanded into an array of key schedule words: Each word is four bytes and total key schedule is 44 words for 128-bit key.

Advanced Encryption Standard

- Ordering of bytes in a matrix is by column.
- First four bytes of a 128-bit plaintext input to the encryption cipher occupy the first column of the **in** matrix, the second four bytes occupy the second column, and so on.

Advanced Encryption Standard

- Similarly, the first four bytes of the expanded key, which form a word, occupy the first column of the **w** matrix.

Advanced Encryption Standard

AES's Working:

- Four different stages are used, one of permutation and three of substitution

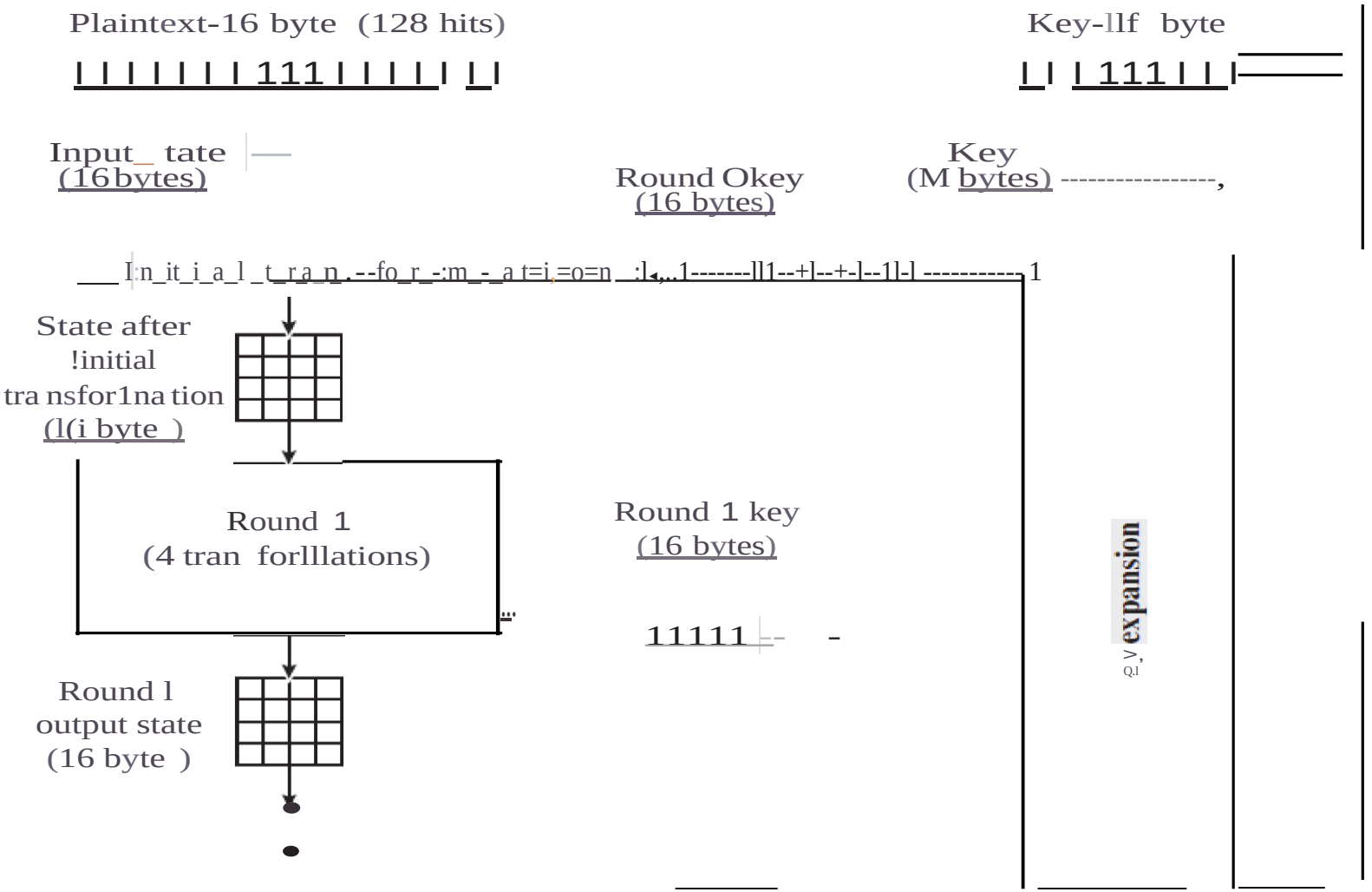
Advanced Encryption Standard

- **Substitute bytes:** Uses a table, referred to as an S-box, to perform a byte-by-byte substitution of the block.
- **Shift rows:** A simple permutation that is performed row by row.

Advanced Encryption Standard

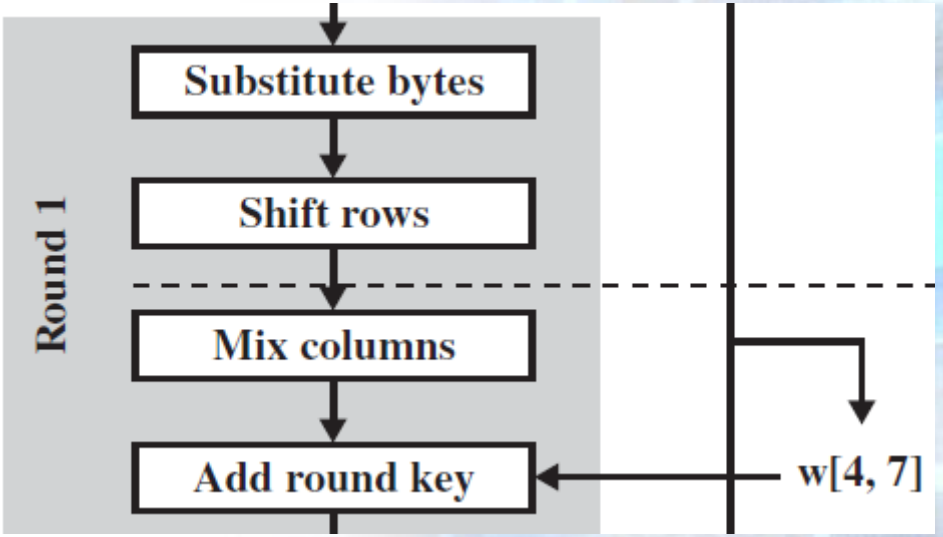
- **Mix columns:** A substitution that alters each byte in a column as a function of all of the bytes in the column.
- **Add round key:** A simple bitwise XOR of the current block with a portion of the expanded key.

Advanced Encryption Standard

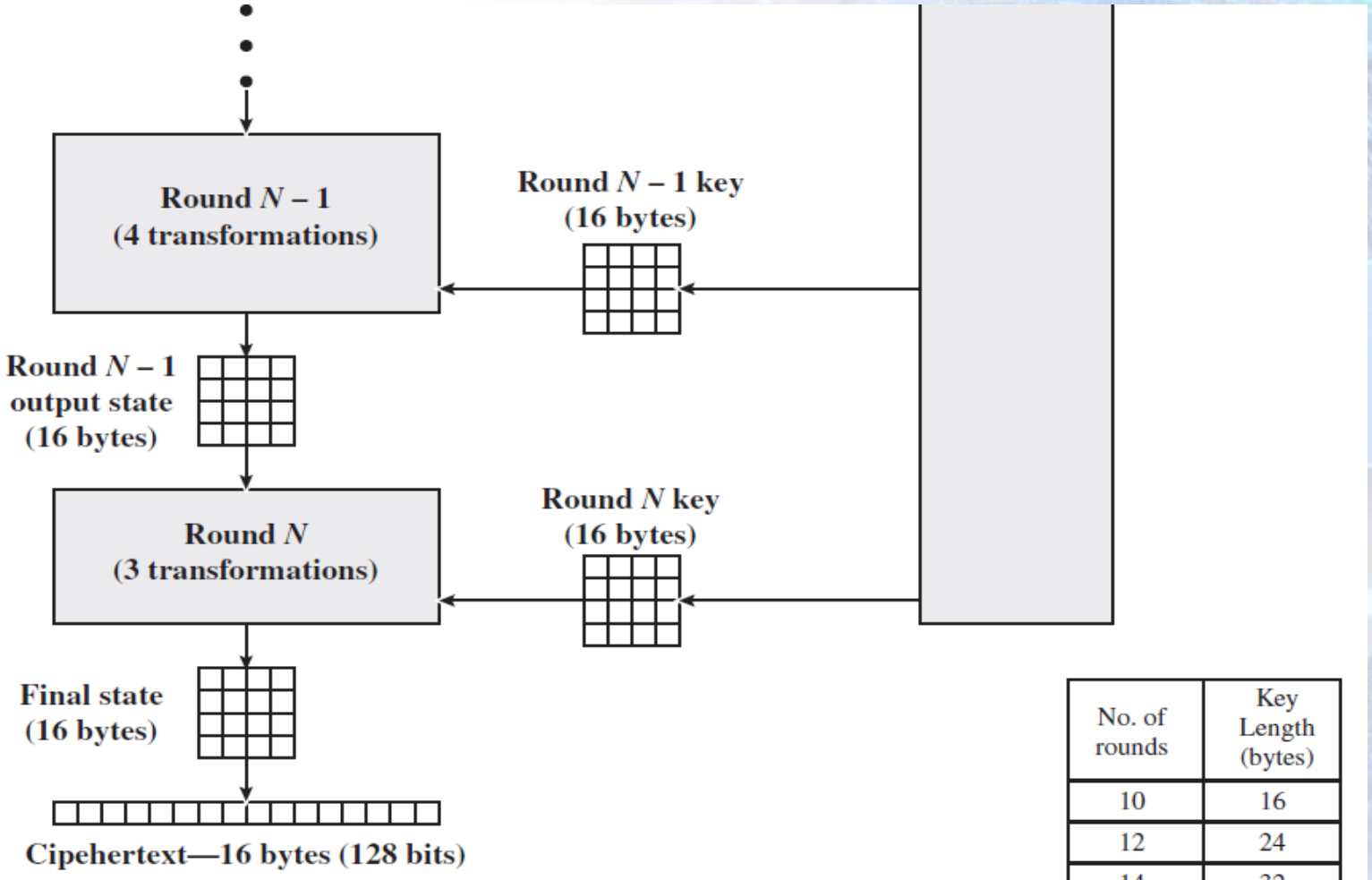


Advanced Encryption Standard

Internal Details of a round.



Advanced Encryption Standard



No. of rounds	Key Length (bytes)
10	16
12	24
14	32

Advanced Encryption Standard

Some comments:

- AES structure is not a Feistel structure.
- For both encryption and decryption, the cipher begins with an Add Round Key stage, followed by nine rounds that each includes all four stages

Advanced Encryption Standard

- Each stage is easily reversible.
- The final round of both encryption and decryption consists of only three stages.
- The decryption algorithm is not identical to the encryption algorithm.

Advanced Encryption Standard

- The decryption algorithm makes use of the expanded key in reverse order.

End

The Use of Random Numbers

Network Security

The Use of Random Numbers

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain use of random numbers.

The Use of Random Numbers

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

The Use of Random Numbers

- A number of network security algorithms based on cryptography make use of random numbers.

The Use of Random Numbers

Random Numbers



The Use of Random Numbers

- **Examples:**
- Generation of keys for the RSA public-key encryption algorithm and other public-key algorithms.

The Use of Random Numbers

- Generation of a symmetric key for use as a temporary session key; used in a number of networking applications such as Transport Layer Security, Wi-Fi, e-mail security, and IP security.

The Use of Random Numbers

- In a number of key distribution scenarios, such as Kerberos, random numbers are used for handshaking to prevent replay attacks.

The Use of Random Numbers

Requirements

- Two distinct and not necessarily compatible requirements for a sequence of random numbers are:
- Randomness
- Unpredictability

The Use of Random Numbers

Randomness

- The concern in the generation of a sequence of allegedly random numbers has been that the sequence of numbers be random in some well defined statistical sense.

The Use of Random Numbers

- The following criteria are used to validate that a sequence of numbers is random.

The Use of Random Numbers

- **Uniform distribution:** The distribution of bits in the sequence should be uniform; that is, the frequency of occurrence of ones and zeros should be approximately the same.

The Use of Random Numbers

- **Independence:**
- No one subsequence in the sequence can be inferred from the others.

The Use of Random Numbers

- There are well-defined tests for determining that a sequence of numbers matches a particular distribution, such as the uniform distribution.
- There is no such test to “prove” independence.

The Use of Random Numbers

- A number of tests can be applied to demonstrate if a sequence does not exhibit independence.
- The general strategy is to apply a number of such tests until the confidence that independence exists is sufficiently strong.

The Use of Random Numbers

Unpredictability

- In some applications, the requirement is not much that the sequence of numbers be statistically random but that the successive members of the sequence are unpredictable.

The Use of Random Numbers

- E.g. reciprocal authentication and session key generation.

The Use of Random Numbers

- With “true” random sequences, each number is statistically independent of other numbers in the sequence and therefore unpredictable.

The Use of Random Numbers

- Care must be taken that an opponent not be able to predict future elements of the sequence on the basis of earlier elements.

End

Pseudorandom Numbers

Network Security

Pseudorandom Numbers

Objectives of the Topic

- After completing this topic, a student will be able to
  - understand pseudorandom numbers.

Pseudorandom Numbers

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Pseudorandom Numbers

- For cryptographic applications, algorithmic techniques for random number generation are deterministic and therefore produce sequences of numbers that are not statistically random.

Pseudorandom Numbers

- If the algorithm is good, the resulting sequences will pass many reasonable tests of randomness.
- Such numbers are referred to as **pseudorandom numbers**.

Pseudorandom Numbers

- You may be somewhat uneasy about the concept of using numbers generated by a deterministic algorithm as if they were random numbers.
- it generally works.

Pseudorandom Numbers

- Under most circumstances, pseudorandom numbers will perform as well as if they were random for a given use.

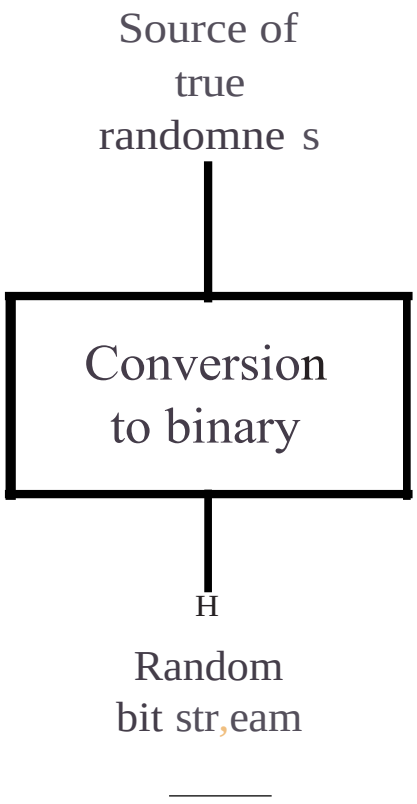
Pseudorandom Numbers

True Random Number Generator (TRNG)

- takes as input a source that is effectively random.
- the source is often referred to as an entropy source .

Pseudorandom Numbers

TRNG



Pseudorandom Numbers

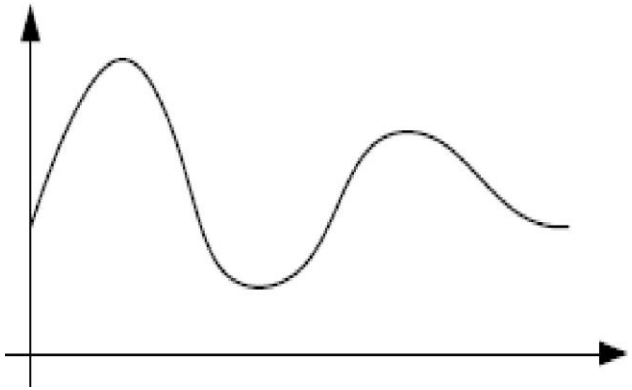
- The entropy source is drawn from physical environment of the computer and could include keystroke timing patterns, disk electrical activity, mouse movements, and instantaneous values of the system clock.

Pseudorandom Numbers

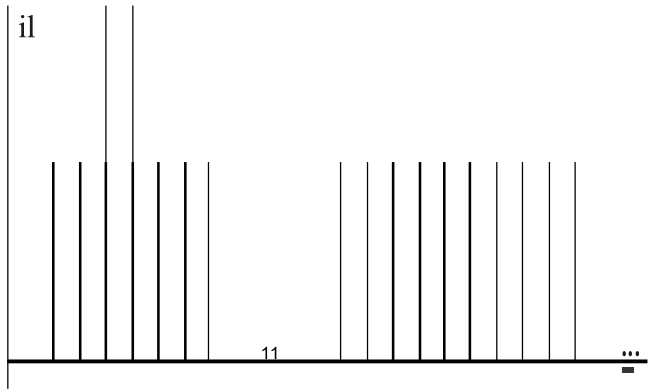
- The source, or combination of sources, serves as input to an algorithm that produces random binary output.
- The TRNG may simply involve conversion of an analog source to a binary output.

Pseudorandom Numbers

TRNG



(a) An analog signal



(b) Samples of the analog ignal

Pseudorandom Numbers

Pseudorandom Number Generator (PRNG)

- takes as input a fixed value, called the seed, and produces a sequence of output bits using a deterministic algorithm.

Pseudorandom Numbers

- There is a feedback path by which some of the output are fed back as input.
- The output bit stream is determined solely by the input value, so that an adversary who knows the algorithm and the seed can reproduce bit stream.

Pseudorandom Numbers

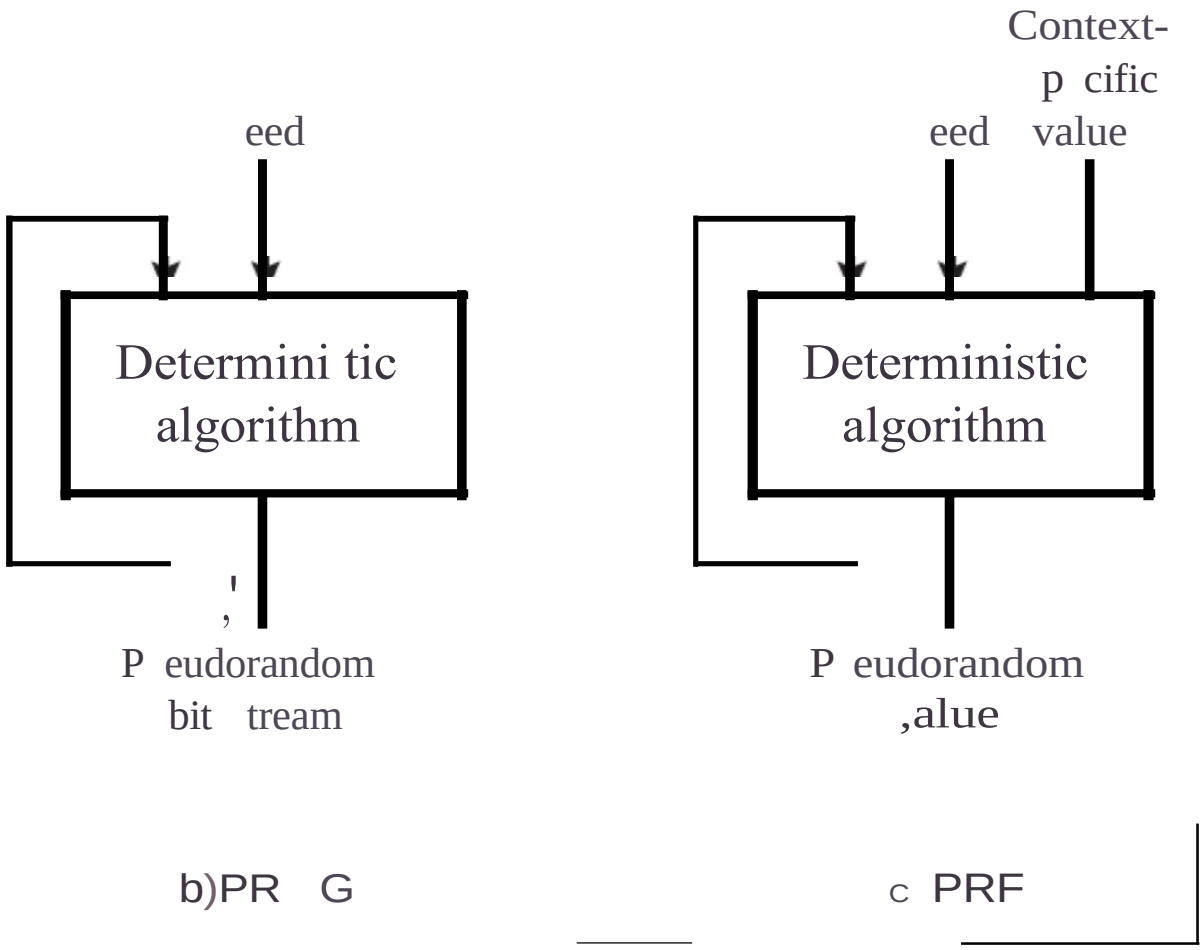
- Two different forms of PRNGs, based on application.
- **PRNG:** An algorithm used to produce an open-ended sequence of bits is referred to as a PRNG.
- App: input to a symmetric stream cipher.

Pseudorandom Numbers

- **Pseudorandom function (PRF):** produces a pseudorandom string of bits of some fixed length and takes as input seed plus some context values (a user or application ID).
- App: symmetric encrypt. keys, nonces.

Pseudorandom Numbers

PRNG and PRF



Pseudorandom Numbers

- Only difference between a PRNG and a PRF is the number of bits produced.
- The same algorithms can be used in both applications.
- Both require a seed and both must exhibit randomness and unpredictability.

Pseudorandom Numbers

- Cryptographic PRNGs have been the subject of much research over the years, and a wide variety of algorithms have been developed.
- These fall roughly into two categories:

Pseudorandom Numbers

Purpose-built algorithms

- Designed specifically and solely for the purpose of generating pseudorandom bit streams

Algorithms based on existing cryptographic algorithms

- Cryptographic algorithms have the effect of randomizing input
- Can serve as the core of PRNGs

Three broad categories of cryptographic algorithms are commonly used to create PRNGs:

- Symmetric block ciphers
- Asymmetric ciphers
- Hash functions and message authentication codes

Stream Cipher Structure

Network Security

Stream Cipher Structure

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe the basic structure of stream ciphers.

Stream Cipher Structure

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Stream Cipher Structure

- A stream cipher processes the input elements continuously, producing output one element at a time as it goes along.

Stream Cipher Structure

Stream Cipher Structure

- A typical stream cipher encrypts plaintext one byte at a time, although a stream cipher may be designed to operate on one bit at a time or on units larger than a byte at a time.

Stream Cipher Structure

- In a stream cipher structure, a key is input to a pseudorandom bit generator that produces a stream of 8-bit numbers that are apparently random.

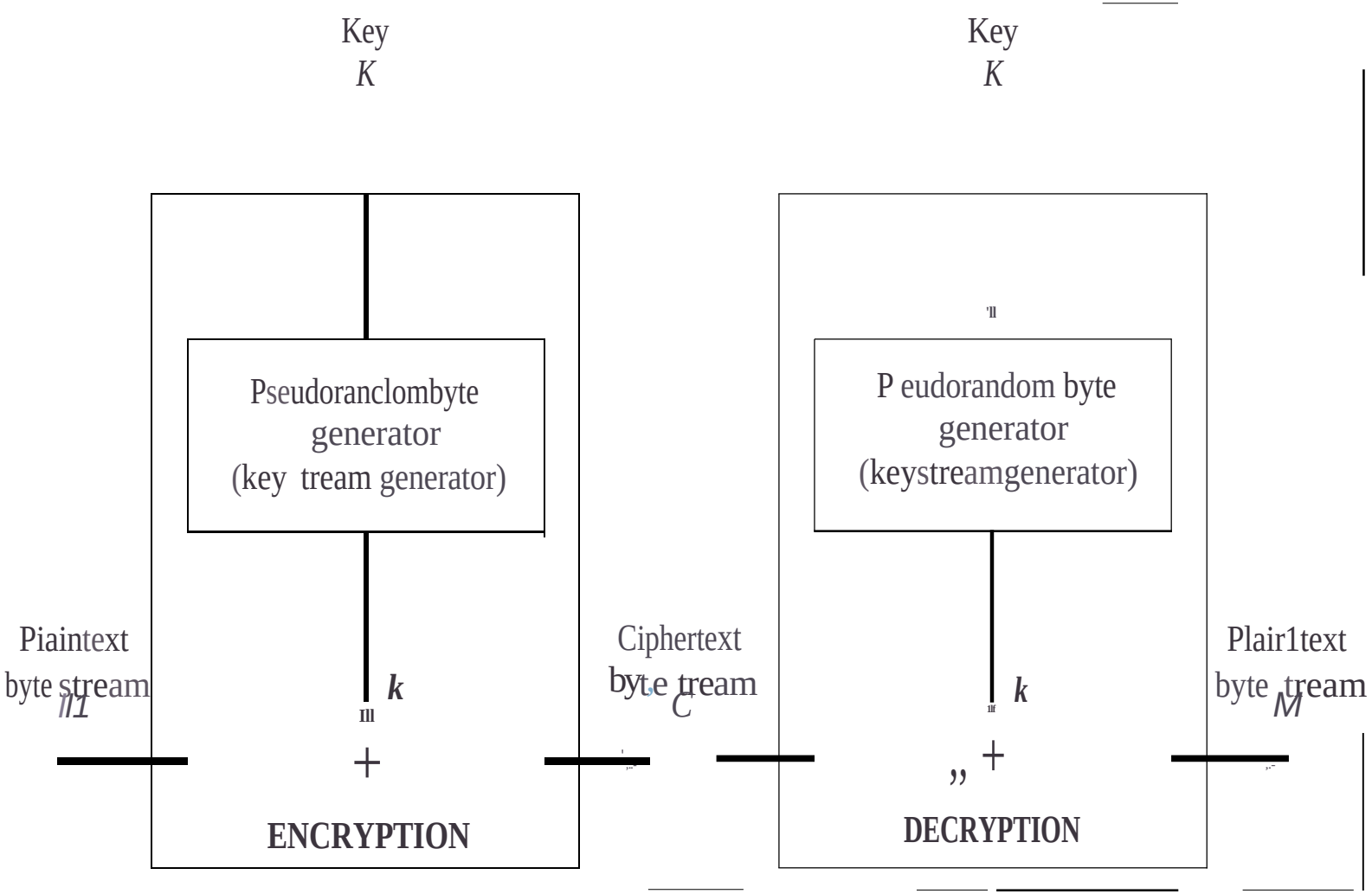
Stream Cipher Structure

- A pseudorandom stream is one that is unpredictable without knowledge of the input key and which has an apparently random character.

Stream Cipher Structure

- The output of the generator called a **keystream**, is combined one byte at a time with the plaintext stream using the bitwise exclusive-OR (XOR) operation.

Stream Cipher Structure



Stream Cipher Structure

Example

- if the next byte generated by the generator is 01101100 and the next plaintext byte is 11001100, then the resulting ciphertext byte is

```
  11001100  plaintext
⊕ 01101100  key stream
  10100000  ciphertext
```

Stream Cipher Structure

- Decryption requires the use of the same pseudorandom sequence

```
  10100000   ciphertext
⊕ 01101100   key stream
  11001100   plaintext
```

Stream Cipher Structure

Stream Cipher design considerations:

- 1. The encryption sequence should have a large period.

Stream Cipher Structure

- A pseudorandom number generator uses a function that produces a deterministic stream of bits that eventually repeats.
- The longer the period of repeat, the more difficult it will be to do cryptanalysis.

Stream Cipher Structure

- 2. The keystream should approximate the properties of a true random number stream as close as possible.

Stream Cipher Structure

- There should be an approximately equal number of 1s and 0s.
- If the keystream is treated as a stream of bytes, then all of the 256 possible byte values should appear approximately equally often.

Stream Cipher Structure

- The more random-appearing the keystream is, the more randomized the ciphertext is, making cryptanalysis more difficult.

Stream Cipher Structure

- 3. As the output of the pseudorandom number generator is conditioned on the value of the input key, to guard against brute-force attacks, the key needs to be sufficiently long.

Stream Cipher Structure

- With the current technology, a key length of at least 128 bits is desirable.
- The primary advantage of a stream cipher is that stream ciphers are almost always faster and use far less code than do block ciphers.

Stream Cipher Structure

- The advantage of a block cipher is that you can reuse keys.
- If two plaintexts are encrypted with the same key using a stream cipher, then cryptanalysis is often quite simple.

Stream Cipher Structure

End

- For applications that deal with stream of data, a stream cipher is preferred.
- For applications that deal with blocks of data (file transfer, e-mail), block ciphers may be more appropriate.

The RC4 Algorithm

Network Security

The RC4 Algorithm

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain working of RC4 algorithm.

The RC4 Algorithm

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

The RC4 Algorithm

- RC4 is a stream cipher designed in 1987 by Ron Rivest for RSA Security.
- It is a variable key-size stream cipher with byte-oriented operations.

The RC4 Algorithm

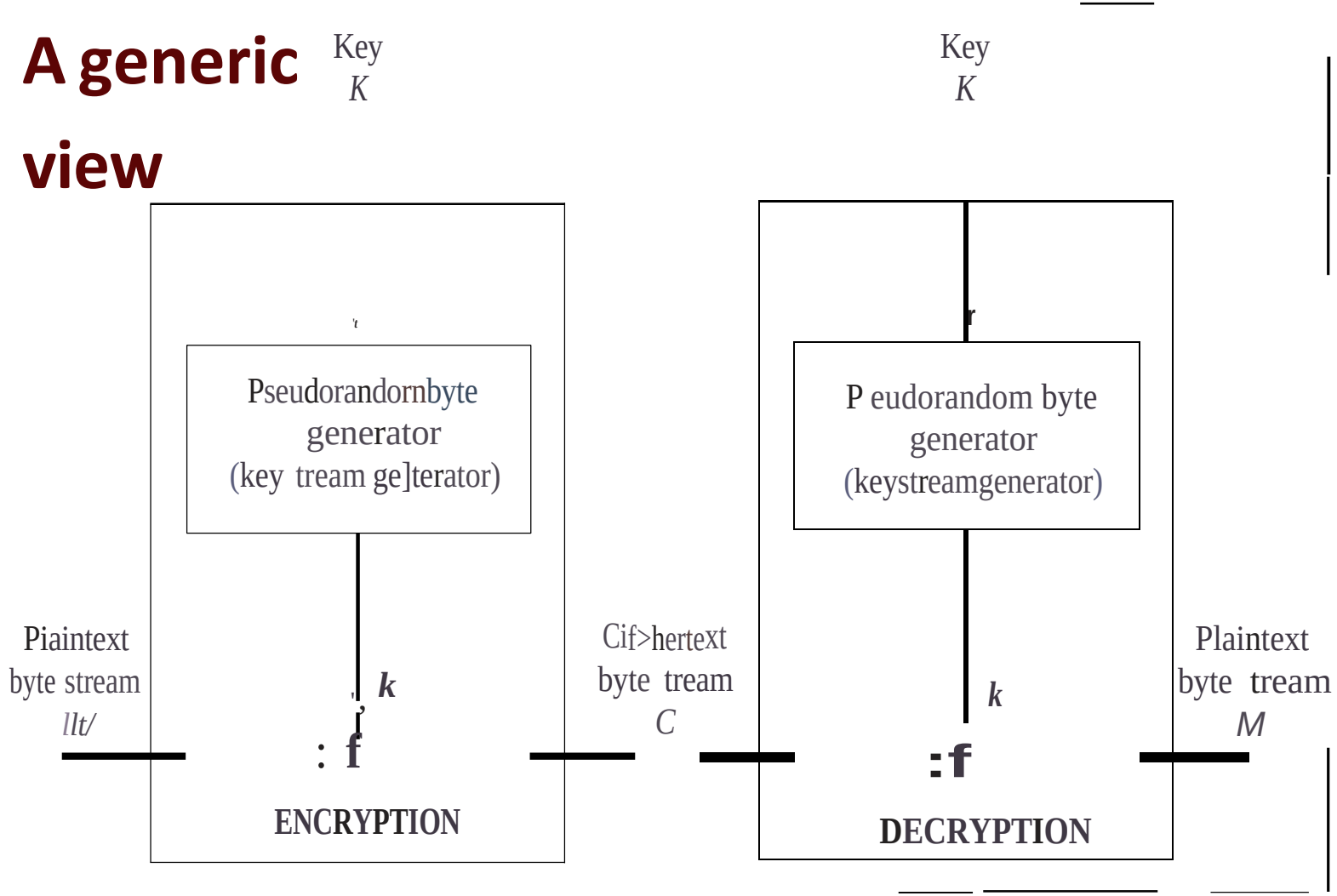
- RC4 is used in the Secure Sockets Layer/Transport Layer Security (SSL/TLS) standards that have been defined for communication between Web browsers and servers.

The RC4 Algorithm

- Also used in the Wired Equivalent Privacy (WEP) protocol and the newer WiFi Protected Access (WPA) protocol that are part of the IEEE 802.11 wireless LAN standard.

The RC4 Algorithm

A generic view



The RC4 Algorithm

- The RC4 algorithm is remarkably simple.
- A variable-length key of from 1 to 256 bytes (8 to 2048 bits) is used to initialize a 256-byte state vector S, with elements S[0], S[1], . . . , S[255].

The RC4 Algorithm

- For encryption and decryption, a byte k is generated from S by selecting one of the 255 entries in a systematic fashion.
- As each value of k is generated, the entries in S are once again permuted.

The RC4 Algorithm

Initialization of S:

- entries of S are set equal to the values from 0 through 255 in ascending order

```
for i = 0 to 255 do
S[i] = i;
T[i] = K[i mod keylen];
```

- Where T is a temporary vector.

The RC4 Algorithm

```
for i = 0 to 255 do
S[i] = i;
T[i] = K[i mod keylen];
```

- If the length of the key K is 256 bytes, then K is transferred to T.
- Otherwise, first keylen elements of T are copied from K, and then K is repeated as many times as necessary to fill out T.

The RC4 Algorithm

Next we use T to produce the initial permutation of S.

```
j = 0;
for i = 0 to 255 do
  j = (j + S[i] + T[i]) mod 256;
  Swap (S[i], S[j]);
```

The RC4 Algorithm

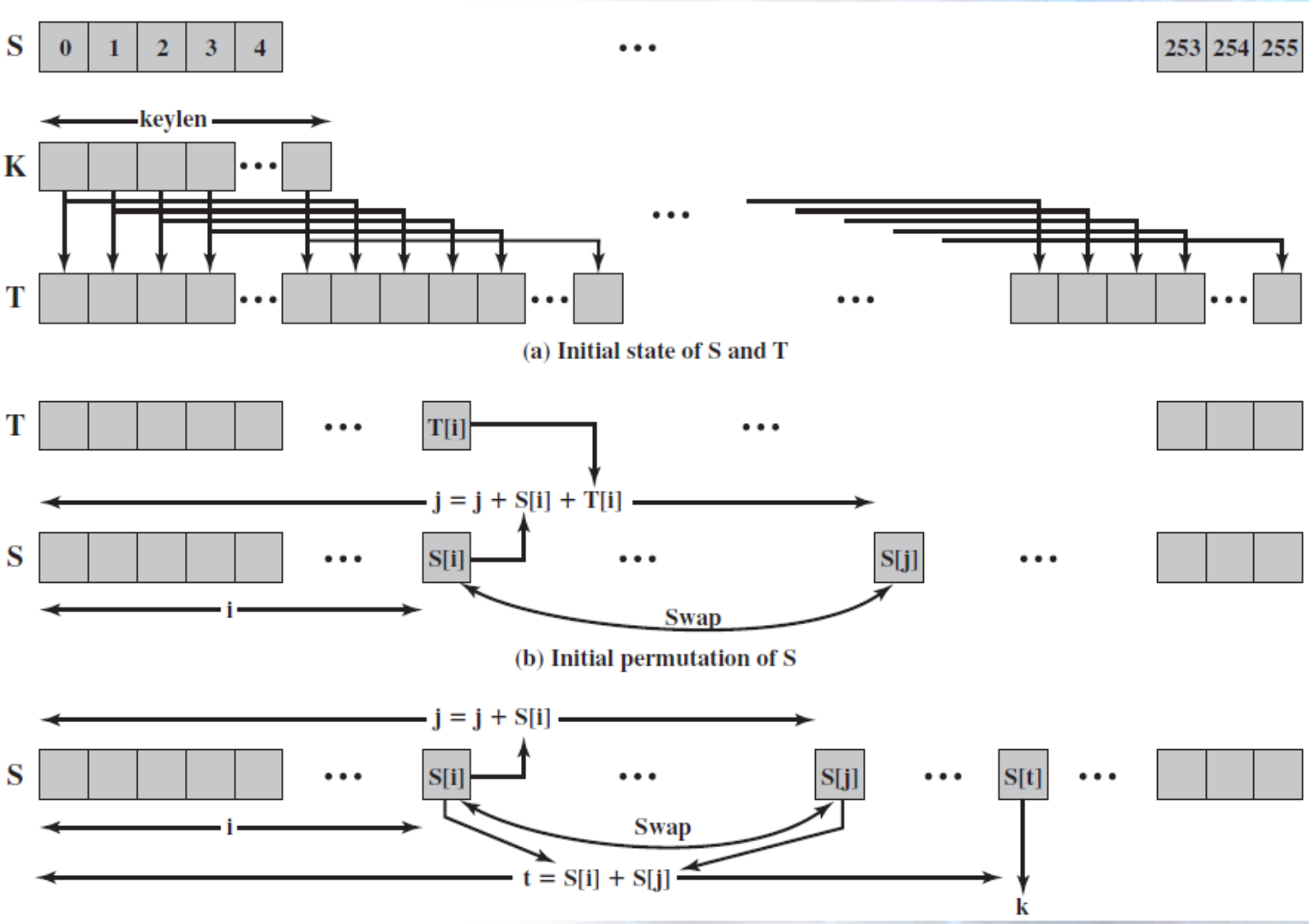
Stream Generation: Once the S vector is initialized, the input key is no longer used.

```
i, j = 0;
while (true)
  i = (i + 1) mod 256;
  j = (j + S[i]) mod 256;
  Swap (S[i], S[j]);
  t = (S[i] + S[j]) mod 256;
  k = S[t];
```

The RC4 Algorithm

- To encrypt, XOR the value k with the next byte of plaintext.
- To decrypt, XOR the value k with the next byte of ciphertext.

The RC4 Algorithm



The RC4 Algorithm

End

Strength of RC4:

- A number of papers have been published analyzing methods of attacking RC4.
- None of these approaches is practical against RC4 with a reasonable key length, such as 128 bits.

Elect. Codebook, Cipher Block Chaining

Network Security

Elect. Codebook, Cipher Block Chaining

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe electronic codebook and cipher block modes.

Elect. Codebook, Cipher Block Chaining

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Elect. Codebook, Cipher Block Chaining

- A symmetric block cipher processes one block of data at a time.
- Block length is 64 bits for DES and 3DES
- For AES, the block length is 128 bits.

Elect. Codebook, Cipher Block Chaining

- If the amount of plaintext is greater than **b-**bits, then we can break the plaintext up into **b**-bit blocks.
- When multiple blocks of plaintext are encrypted using the same key, a number of security issues arise.

Elect. Codebook, Cipher Block Chaining

- Five modes of operation have been defined by NIST (SP(Special Publication) 800- 38A) so that a block cipher can be applied in a variety of applications.

Elect. Codebook, Cipher Block Chaining

- A mode of operation is a technique for enhancing the effect of a cryptographic algorithm or adapting the algorithm for an application, such as applying a block cipher to a sequence of data blocks or a data stream.

Elect. Codebook, Cipher Block Chaining

- Electronic Codebook Mode (ECB)
- Cipher Block Chaining Mode (CBC)
- Cipher Feedback Mode (CFB)
- Output Feedback (OFB)
- Counter Mode (CTR)

Elect. Codebook, Cipher Block Chaining

Electronic Codebook Mode:

- Simplest mode
- Plaintext is handled **b** bits at a time and each block of plaintext is encrypted using the same key.

Elect. Codebook, Cipher Block Chaining

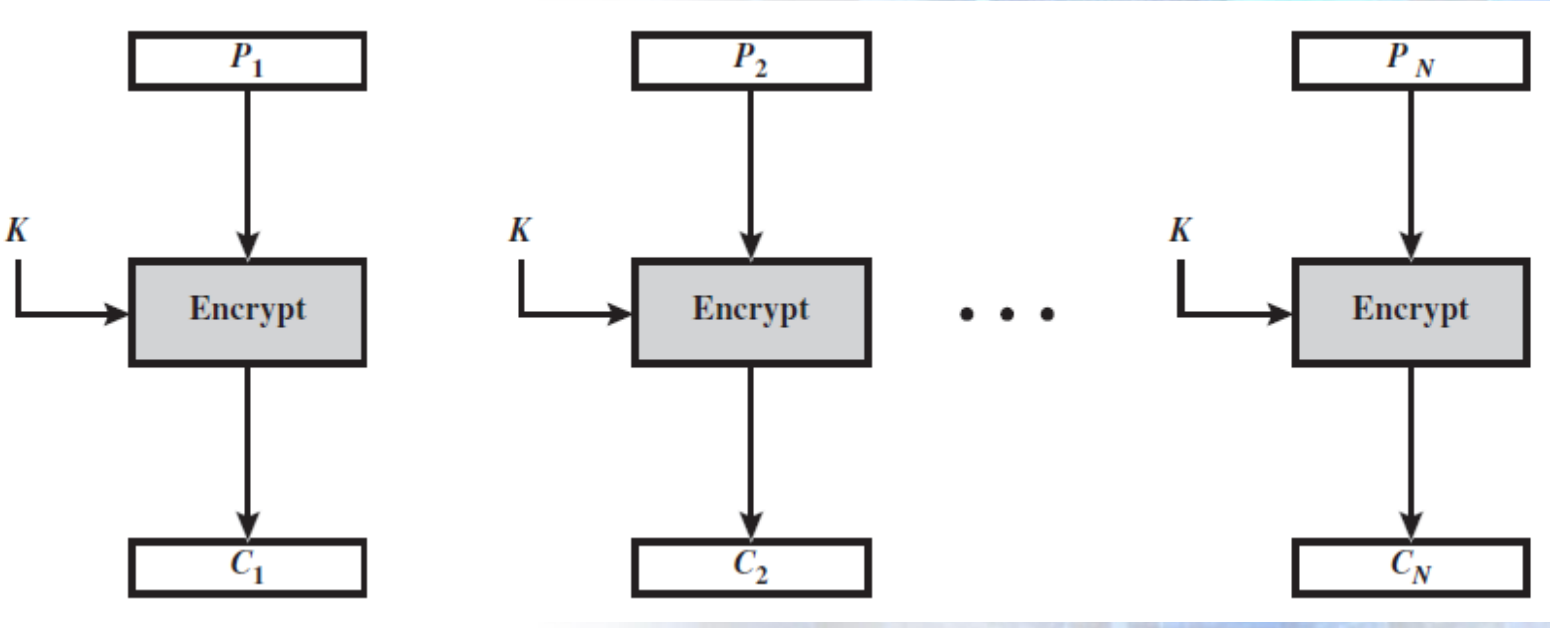
- The term codebook is used because, for a given key, there is a unique ciphertext for every **b**-bit block of plaintext.

Elect. Codebook, Cipher Block Chaining

- We can imagine a gigantic codebook in which there is an entry for every possible **b**-bit plaintext pattern showing its corresponding ciphertext.

Elect. Codebook, Cipher Block Chaining

For a message longer than b bits, the procedure is simply to break the message into b-bit blocks



Elect. Codebook, Cipher Block Chaining

- With ECB, if the same **b**-bit block of plaintext appears more than once in the message, it always produces the same ciphertext.
- Because of this, for lengthy messages, the ECB mode may not be secure.

Elect. Codebook, Cipher Block Chaining

- If the message has repetitive elements with a period of repetition a multiple of **b**-bits, these elements can be identified.
- We want to produce different ciphertext blocks for the same plaintext block if repeated .

Elect. Codebook, Cipher Block Chaining

Cipher Block Chaining Mode:

- The input to the encryption algorithm is the XOR of the current plaintext block and the preceding ciphertext block.
- The same key is used for each block.

Elect. Codebook, Cipher Block Chaining

- In effect, we have chained together the processing of the sequence of plaintext blocks.

Elect. Codebook, Cipher Block Chaining

- The input to the encryption function for each plaintext block bears no fixed relationship to the plaintext block.
- Therefore, repeating patterns of **b**-bits are not exposed.

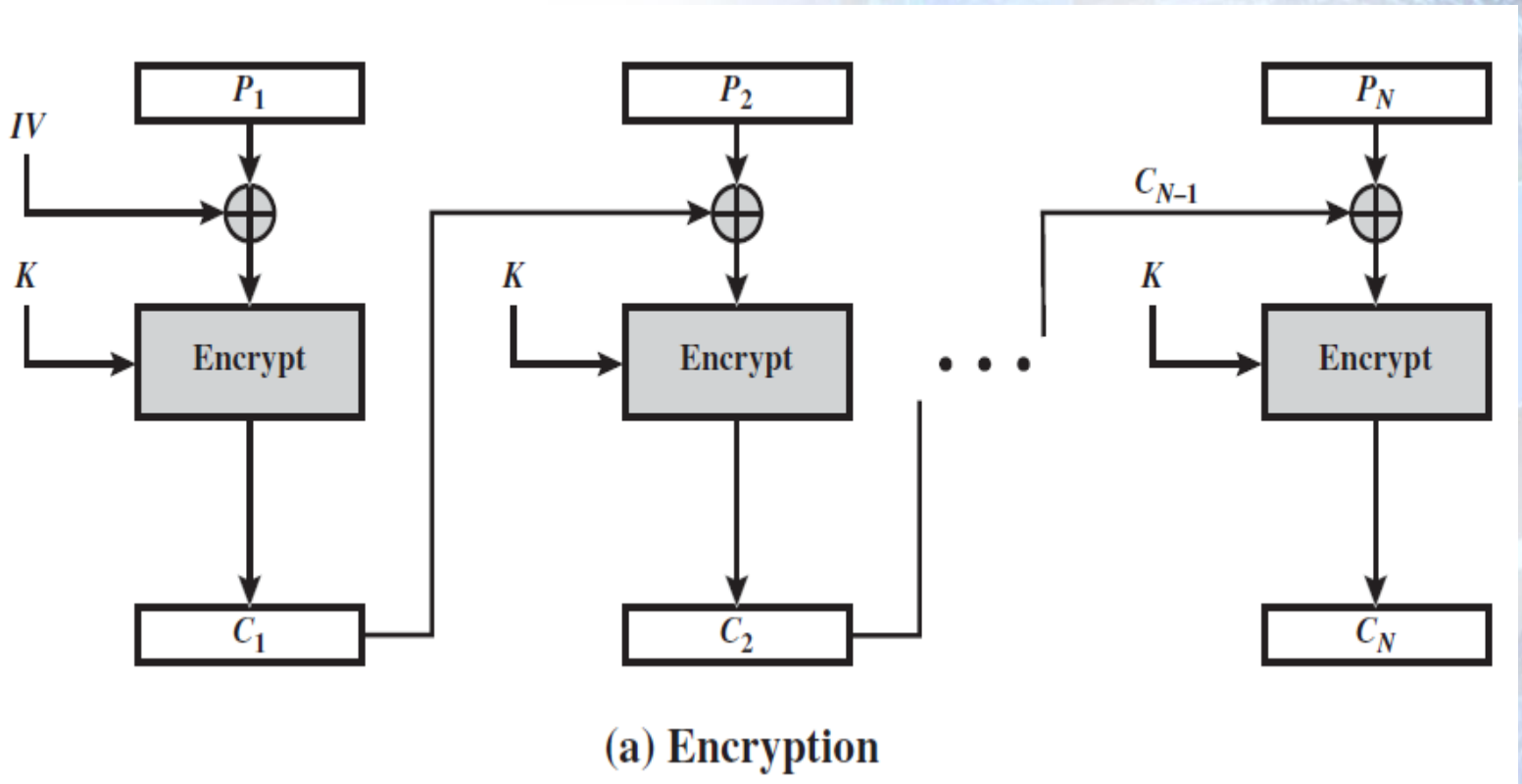
Elect. Codebook, Cipher Block Chaining

CBC Encryption:

- To produce the first block of ciphertext, an initialization vector (IV) is XORed with the first block of plaintext.
- For the jth output

$$C_j = \mathrm{E}(K, [C_{j-1} \oplus P_j])$$

Elect. Codebook, Cipher Block Chaining



(a) Encryption

Elect. Codebook, Cipher Block Chaining

- The IV must be known to both the sender and receiver but be unpredictable by a third party.

Elect. Codebook, Cipher Block Chaining

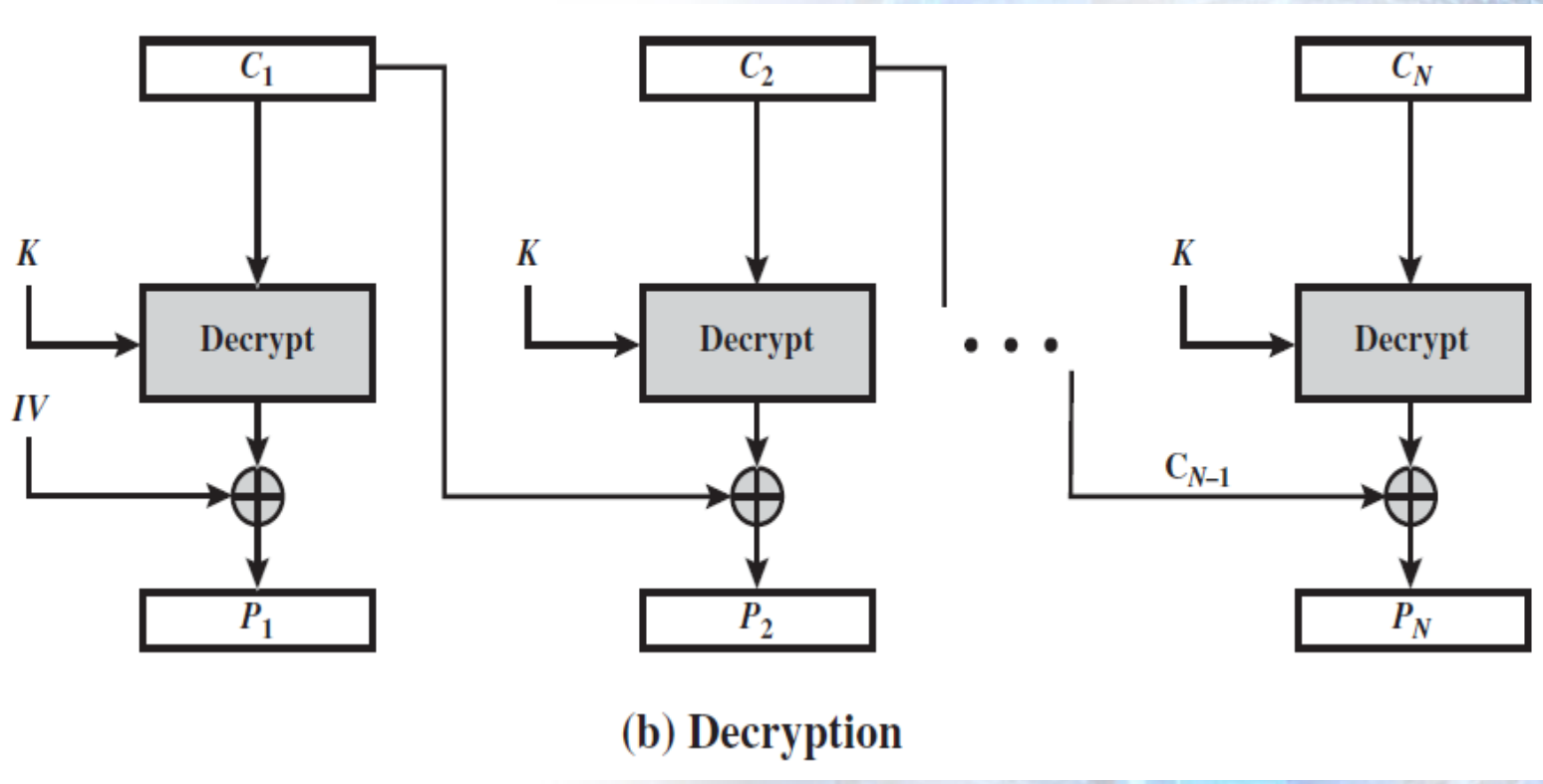
CBC Decryption:

- For decryption, each cipher block is passed through the decryption algorithm.
- The result is XORed with the preceding ciphertext block to produce the plaintext block.

Elect. Codebook, Cipher Block Chaining

- On decryption, the IV is XORed with the output of the decryption algorithm to recover the first block of plaintext.

Elect. Codebook, Cipher Block Chaining



(b) Decryption

Elect. Codebook, Cipher Block Chaining

End

- Because of the chaining mechanism of CBC, it is an appropriate mode for encrypting messages of length greater than **b**-bits.

Cipher Feedback Mode

Network Security

Cipher Feedback Mode

Objectives of the Topic

- After completing this topic, a student will be able to
  - understand cipher feedback mode.

Cipher Feedback Mode

Figures and material in this topic have been

- adapted from *"Network Security Essentials: Applications and Standards"*, 2014, by William Stallings.

Cipher Feedback Mode

- A block cipher takes a fixed-length block of text of length ***b***-bits and a key as input and produces a ***b***-bit block of ciphertext.
- NIST has defined five modes of operation so that block ciphers can be applied in a variety of applications.

Cipher Feedback Mode

- Electronic Codebook Mode (ECB)
- Cipher Block Chaining Mode (CBC)
- Cipher Feedback Mode (CFB)
- Output Feedback (OFB)
- Counter Mode (CTR)

Cipher Feedback Mode

- It is possible to convert a block cipher into a stream cipher, using one of the three CFB, OFB, and CTR modes.
- A stream cipher eliminates the need to pad a message to be an integral number of blocks.

Cipher Feedback Mode

- It also can operate in real time.
- Thus, if a character stream is being transmitted, each character can be encrypted and transmitted immediately using a character-oriented stream cipher.

Cipher Feedback Mode

- One desirable property of a stream cipher is that the ciphertext be of the same length as the plaintext.

Cipher Feedback Mode

- If 8-bit characters are being transmitted, each character should be encrypted using 8 bits.
- If more than 8 bits are used, transmission capacity is wasted.

Cipher Feedback Mode

- Assume that the unit of transmission is **s** bits; a common value is s = 8.
- Rather than blocks of **b**-bits, the plaintext is divided into segments of **s**-bits.
- As with CBC, the units of plaintext are chained together.

Cipher Feedback Mode

Encryption:

- The input to the encryption function is a b-bit shift register that is initially set to some initialization vector (IV).

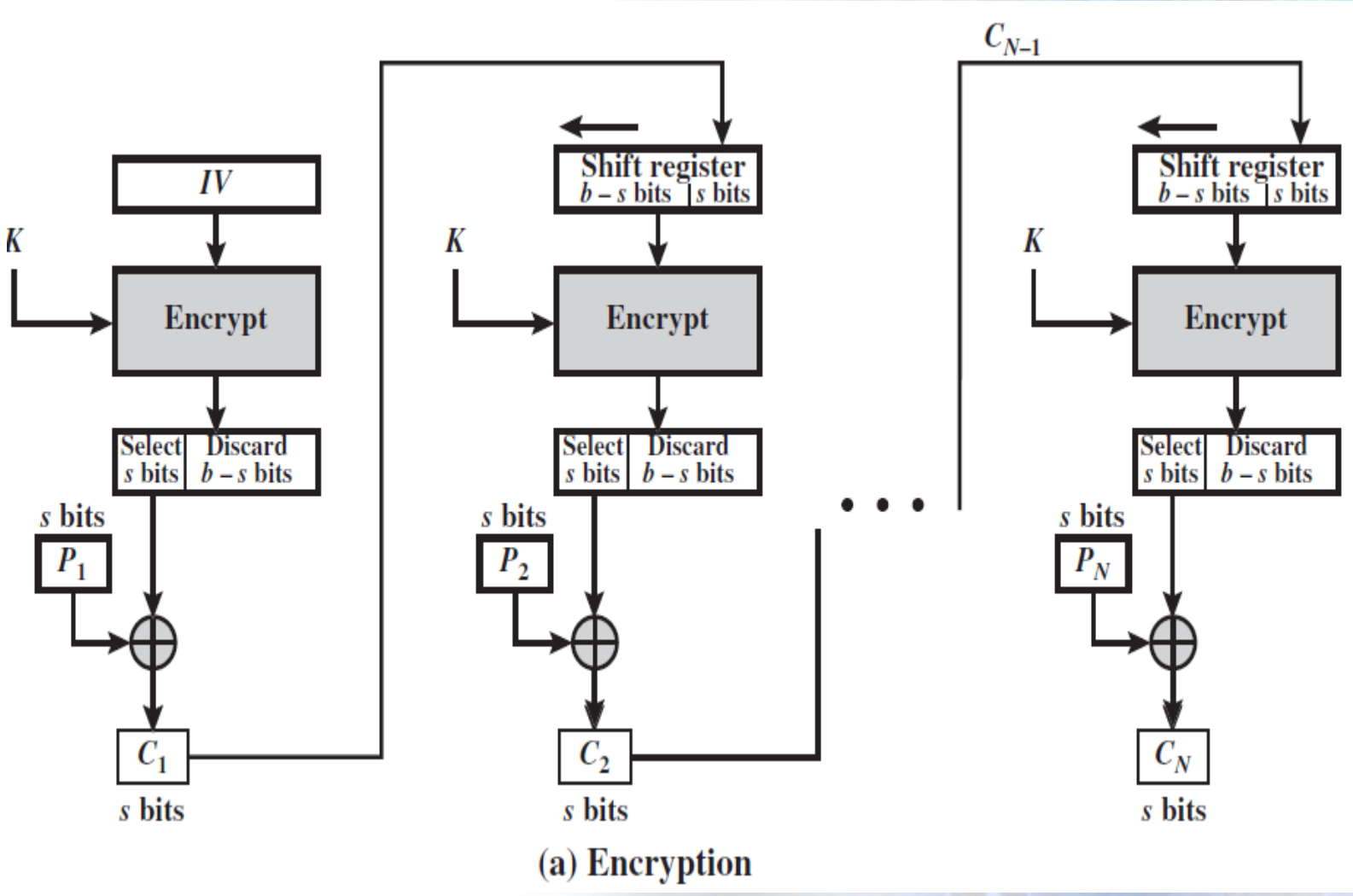
Cipher Feedback Mode

- The leftmost (most significant) s bits of the output of the encryption function are XORed with the first segment of plaintext P_1 to produce the first unit of ciphertext C_1, which is then transmitted.

Cipher Feedback Mode

- In addition, the contents of the shift register are shifted left by s bits, and C_1 is placed in the rightmost (least significant) s bits of the shift register.
- This process continues until all plaintext units have been encrypted.

Cipher Feedback Mode



(a) Encryption

Cipher Feedback Mode

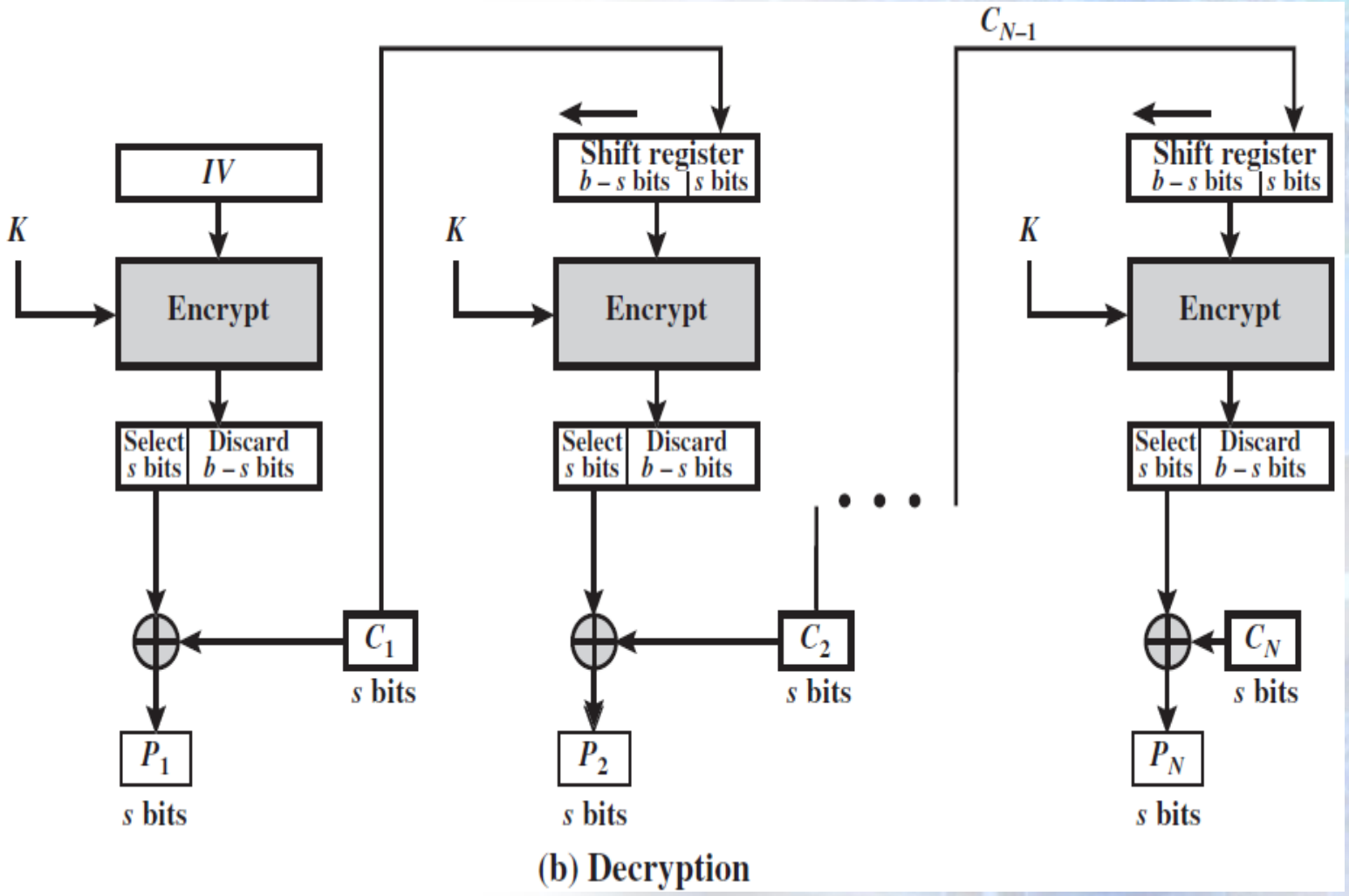
Decryption:

- the same scheme is used, except that the received ciphertext unit is XORed with the output of encryption function to produce the plaintext unit.

$$C_1 = P_1 \oplus \text{MSB}_s[\text{E}(K, \text{IV})]$$

$$P_1 = C_1 \oplus \text{MSB}_s[\text{E}(K, \text{IV})]$$

Cipher Feedback Mode



Cipher Feedback Mode

- In a typical stream cipher, the cipher takes as input some initial value and a key and generates a stream of bits, which is then XORed with the plaintext bits.

Cipher Feedback Mode

- In the case of CFB, the stream of bits that is XORed with the plaintext also depends on the plaintext.

End

Counter Mode, Output Feedback Mode

Network Security

Counter Mode, Output Feedback Mode

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain counter and output feedback modes.

Counter Mode, Output Feedback Mode

Figures and material in this topic have been adapted from

- *"Network Security Essentials"*, 2014, by William Stallings.
- W. Stallings, "*Crypto. and Network Security Principles and Practice*", Pearson Education, 2014

Counter Mode, Output Feedback Mode

- Electronic Codebook Mode (ECB)
- Cipher Block Chaining Mode (CBC)
- Cipher Feedback Mode (CFB)
- Output Feedback (OFB)
- Counter Mode (CTR)

Counter Mode, Output Feedback Mode

Output Feedback Mode

- Similar in structure to that of CFB.
- For OFB, the output of encryption function is fed back to become the input for encrypting the next block of plaintext.

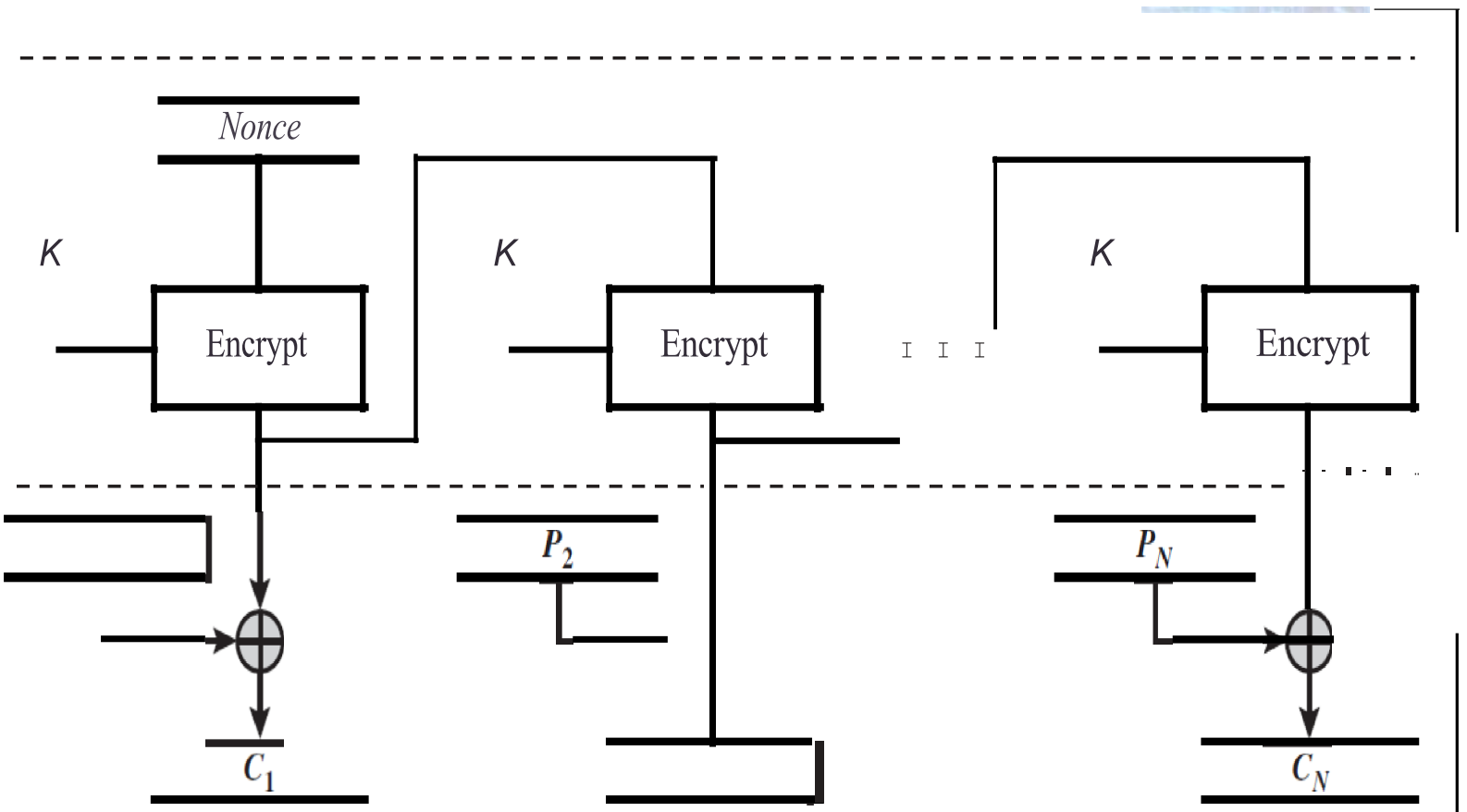
Counter Mode, Output Feedback Mode

- The OFB mode operates on full blocks of plaintext and ciphertext, whereas CFB operates on an *s*-bit subset.

Counter Mode, Output Feedback Mode

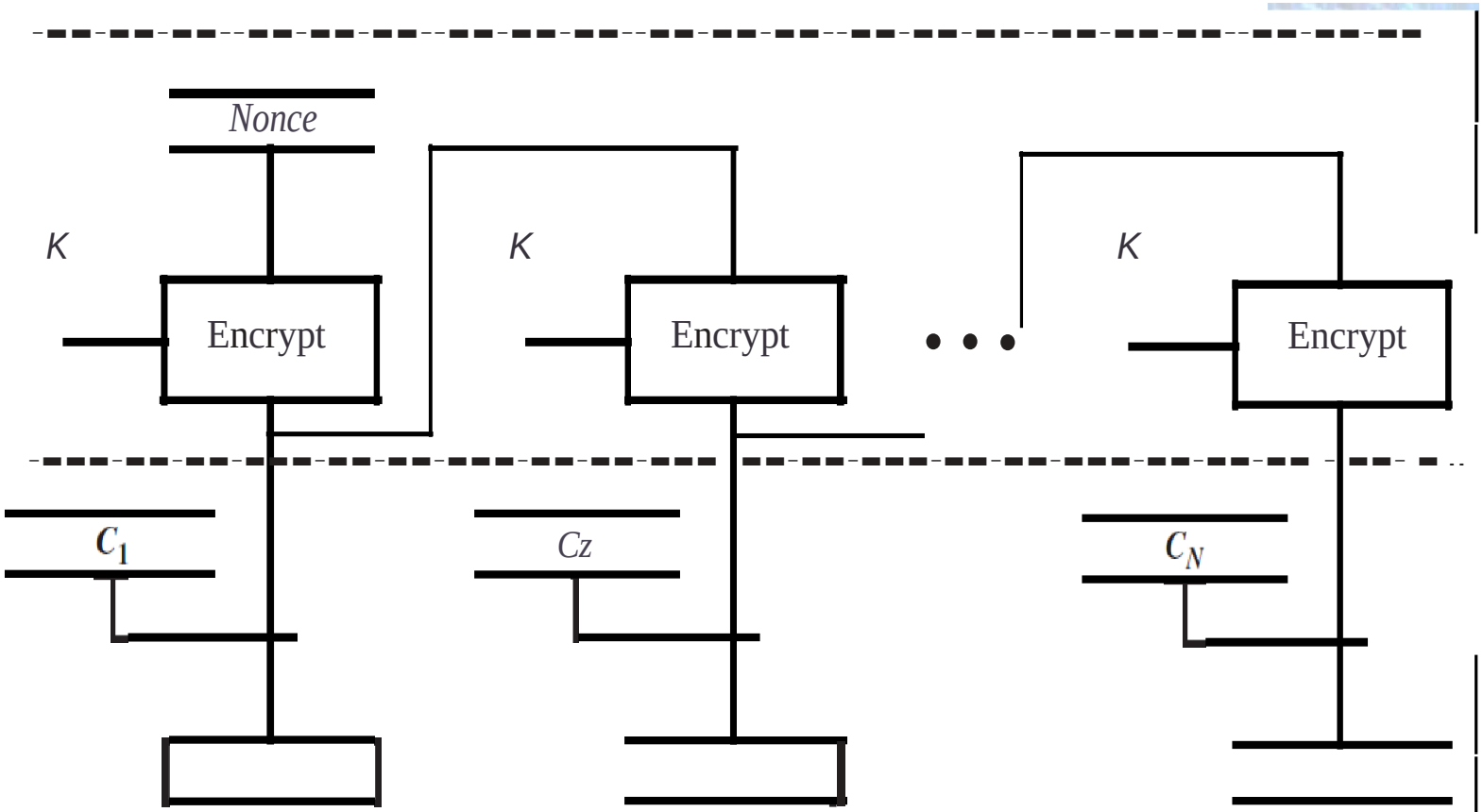
- The OFB mode requires a nonce; an initialization vector, unique to each execution of the encryption operation.
- Sequence of encryption output blocks depends only on the key and the IV and not on plaintext.

Counter Mode, Output Feedback Mode



(a) Encryption

Counter Mode, Output Feedback Mode



(b) Decryption

Counter Mode, Output Feedback Mode

- An advantage of the OFB method is that bit errors in transmission do not propagate.
- The disadvantage of OFB is that it is more vulnerable to a message stream modification attack than is CFB.

Counter Mode, Output Feedback Mode

Counter Mode

- Employed in applications to ATM (asynchronous transfer mode), network security and IPSec (IP security).
- A counter equal to the plaintext block size is used in this mode.

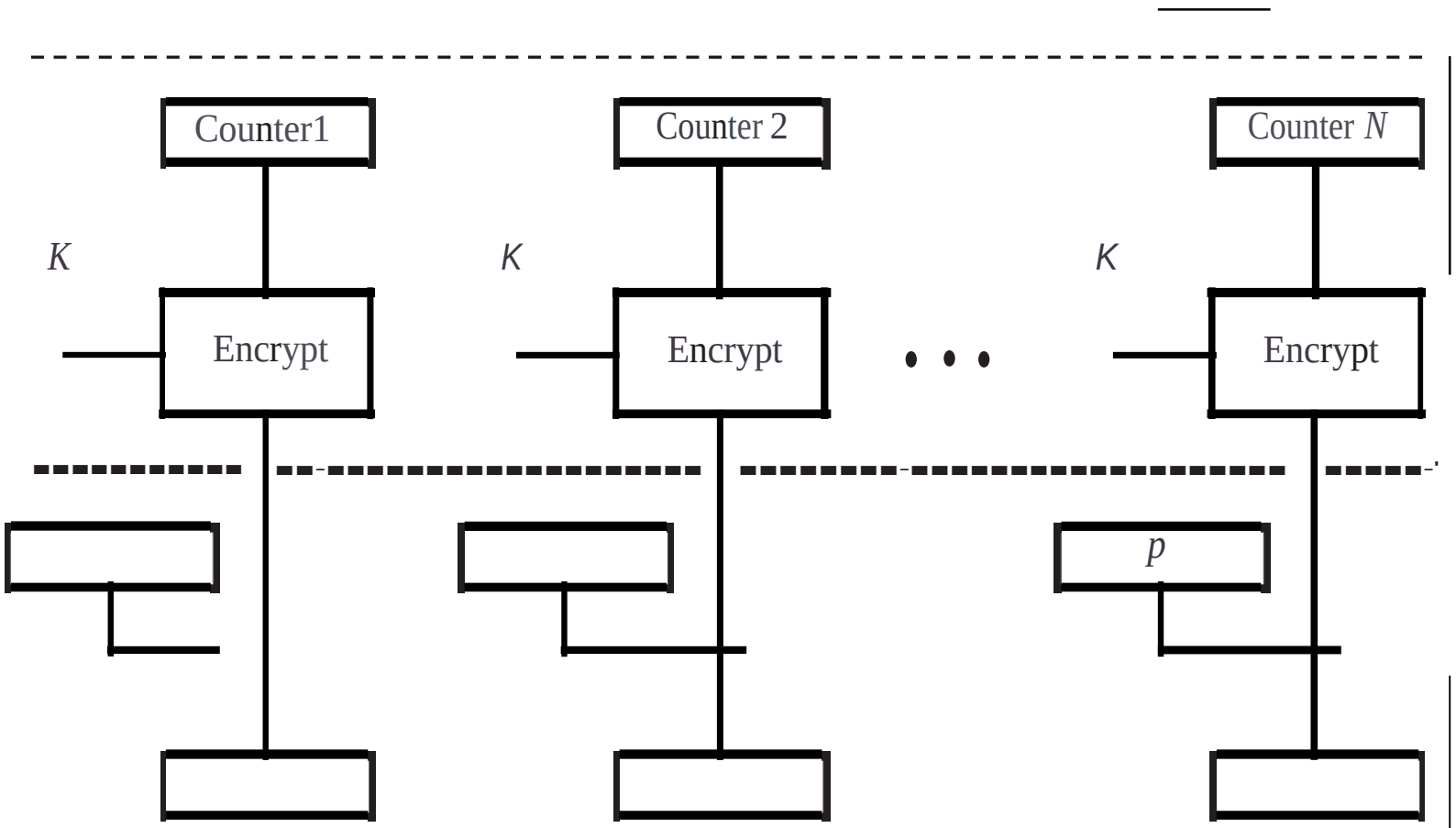
Counter Mode, Output Feedback Mode

- The counter value must be different for each plaintext block that is encrypted.
- Typically, the counter is initialized to some value and then incremented by 1 for each subsequent block (modulo 2^b, where b is block size).

Counter Mode, Output Feedback Mode

- For encryption, the counter is encrypted and then XORed with the plaintext block to produce the ciphertext block.
- There is no chaining.

Counter Mode, Output Feedback Mode

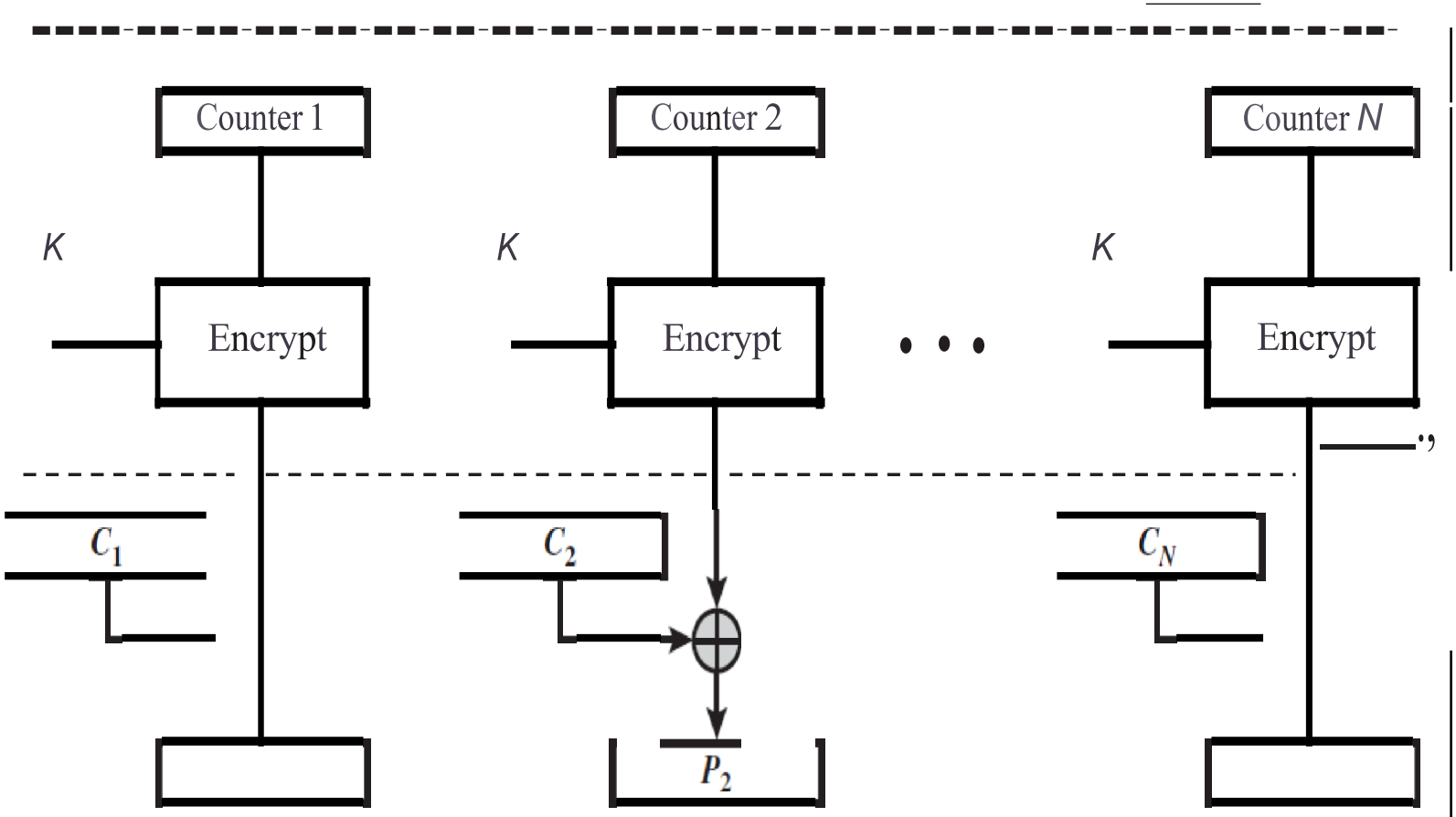


(a) Encryption

Counter Mode, Output Feedback Mode

- For decryption, the same sequence of counter values is used, with each encrypted counter XORed with a ciphertext block to recover the corresponding plaintext block.

Counter Mode, Output Feedback Mode



(b) Decryption

Counter Mode, Output Feedback Mode

Advantages of Counter Mode:

- **Preprocessing**
- when the plaintext or ciphertext input is presented, the only computation is a series of XORs, greatly enhancing throughput.

Counter Mode, Output Feedback Mode

- **Random access**
- The ith block of plaintext or ciphertext can be processed in random-access fashion
- **Provable security**
- CTR can be shown to be at least as secure as the other modes.

Counter Mode, Output Feedback Mode

- **Hardware efficiency**
- Encryption/decryption can be done in parallel on multiple blocks of plaintext or ciphertext
- **Software efficiency**
- Processors that support parallel features can be effectively utilized.

Counter Mode, Output Feedback Mode

End

- **Simplicity**
- Requires only the implementation of the encryption algorithm and not the decryption algorithm

Message Authentication

Network Security

Message Authentication

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain message authentication approaches.

Message Authentication

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Message Authentication

- Encryption protects against passive attack (eavesdropping).
- Protection against active attack (falsification of data and transactions) is known as message authentication.

Message Authentication

- Message authentication is a procedure that allows communicating parties to verify that received messages, file, document, or other collection of data are authentic.

Message Authentication

- There are two important aspects:
- to verify that the contents of the message have not been altered, and
- to verify that the source is authentic.

Message Authentication

- Also, we would like to verify a message's timeliness (it has not been artificially delayed and replayed) and sequence relative to other messages flowing between two parties.
- These are related to data integrity.

Message Authentication

Authentication Using Encryption

- We can perform authentication by the use of symmetric encryption.

Message Authentication

- We assume that only the sender and receiver share a key, so only the genuine sender would be able to encrypt a message successfully.

Message Authentication

- The receiver assumes that no alterations have been made and that sequencing is proper if the message includes an error detection code and a sequence number.

Message Authentication

- If the message includes a timestamp, the receiver is assured that the message has not been delayed beyond that normally expected for network transit.

Message Authentication

Authentication without Encryption

- An authentication tag is generated and appended to each message for transmission.

Message Authentication

- The message itself is not encrypted and can be read at destination independent of the authentication function.
- Because the message is not encrypted, message confidentiality is not provided.

Message Authentication

- We can combine encryption of a message and its authentication tag in a single algorithm.
- Typically, message authentication is provided as a separate function from message encryption.

Message Authentication

Message Authentication Code (MAC)

- Is a technique that involves the use of a secret key to generate a small block of data, known as a message authentication code , that is appended to the message.

Message Authentication

- MAC assumes that two communicating parties, say A and B, share a common secret key K_{AB}.

Message Authentication

- When A has a message to send to B, it calculates the message authentication code as a function of the message and the key: $MAC_M = F(K_{AB}, M)$.

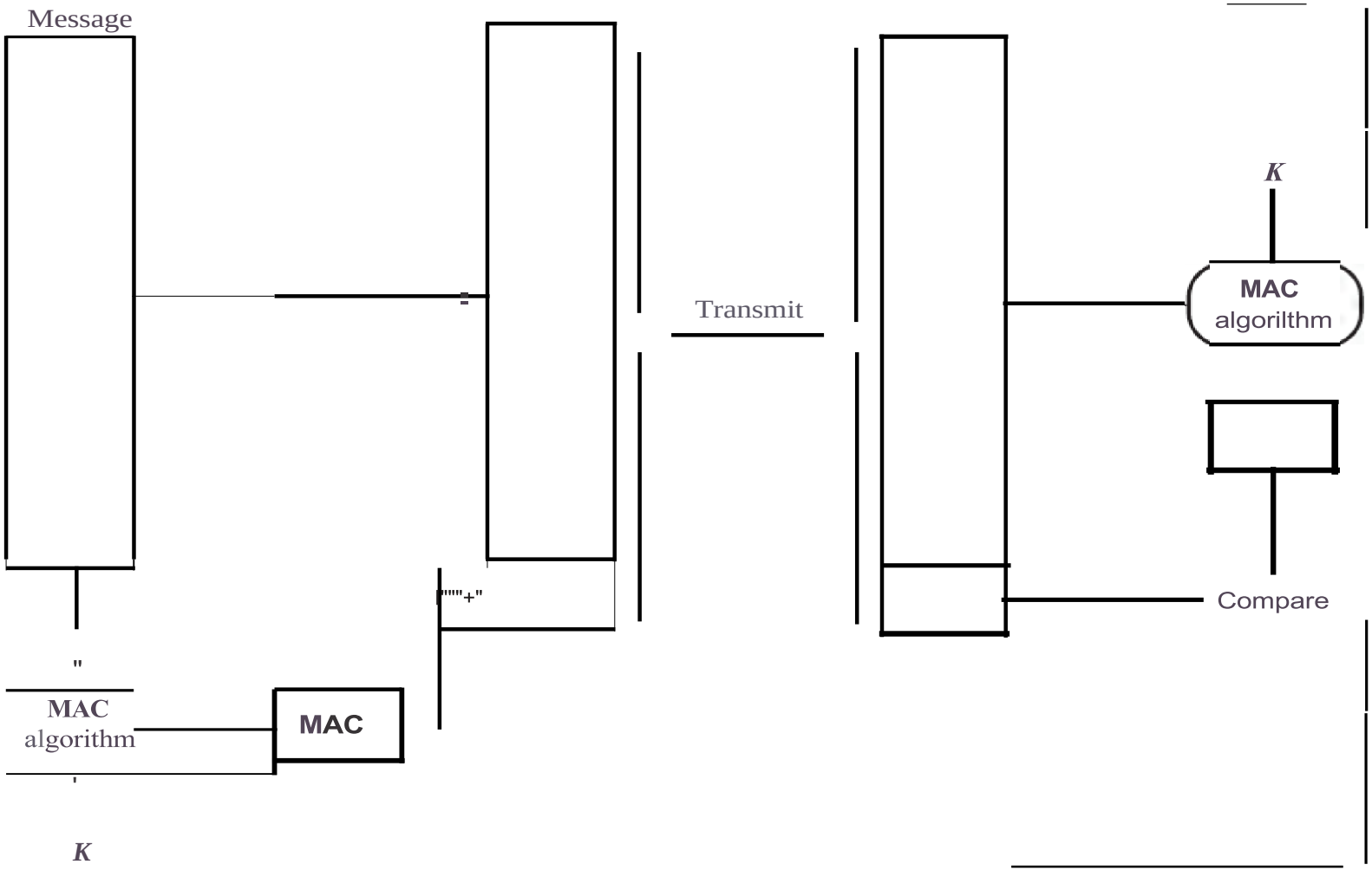
Message Authentication

- The message plus code are transmitted to the intended recipient.

Message Authentication

- The recipient performs the same calculation on the received message, using the same secret key, to generate a new message authentication code.
- The received code is compared to the calculated code.

Message Authentication



Message Authentication

- If we assume that only the receiver and the sender know the identity of the secret key, and if the received code matches the calculated code, then:

Message Authentication

- 1. The receiver is assured that message has not been altered.
- Attacker does not know the secret key. If message is altered but code remains the same, then receiver's calculation of the code will differ from the received code.

Message Authentication

- 2. The receiver is assured that the message is from the alleged sender.
- 3. If the message includes a sequence number, then the receiver can be assured of the proper sequence.

Message Authentication

End

- The NIST specification, FIPS PUB 113, recommends the use of DES.
- DES is used to encrypt the message, and the last number of bits of ciphertext are used as the code.
- A 16- or 32-bit code is typical.

One-way Hash Function

Network Security

One-way Hash Function

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain working of one-way hash function.

One-way Hash Function

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

One-way Hash Function

- Message authentication is a procedure that allows communicating parties to verify that received messages, file, document, or other collection of data are authentic.

One-way Hash Function

- There are two important aspects:
- to verify that the contents of the message have not been altered, and
- to verify that the source is authentic.

One-way Hash Function

- Also, we would like to verify a message's timeliness (it has not been artificially delayed and replayed) and sequence relative to other messages flowing between two parties.
- These are related to data integrity.

One-way Hash Function

One-way Hash Function:

- Is an alternative to the message authentication code (MAC).

One-way Hash Function

- A hash function accepts a variable-size message *M* as input and produces a fixed-size hash value h = H(M).

One-way Hash Function

- When a hash function is used to provide message authentication, the hash function value is often referred to as a message digest.

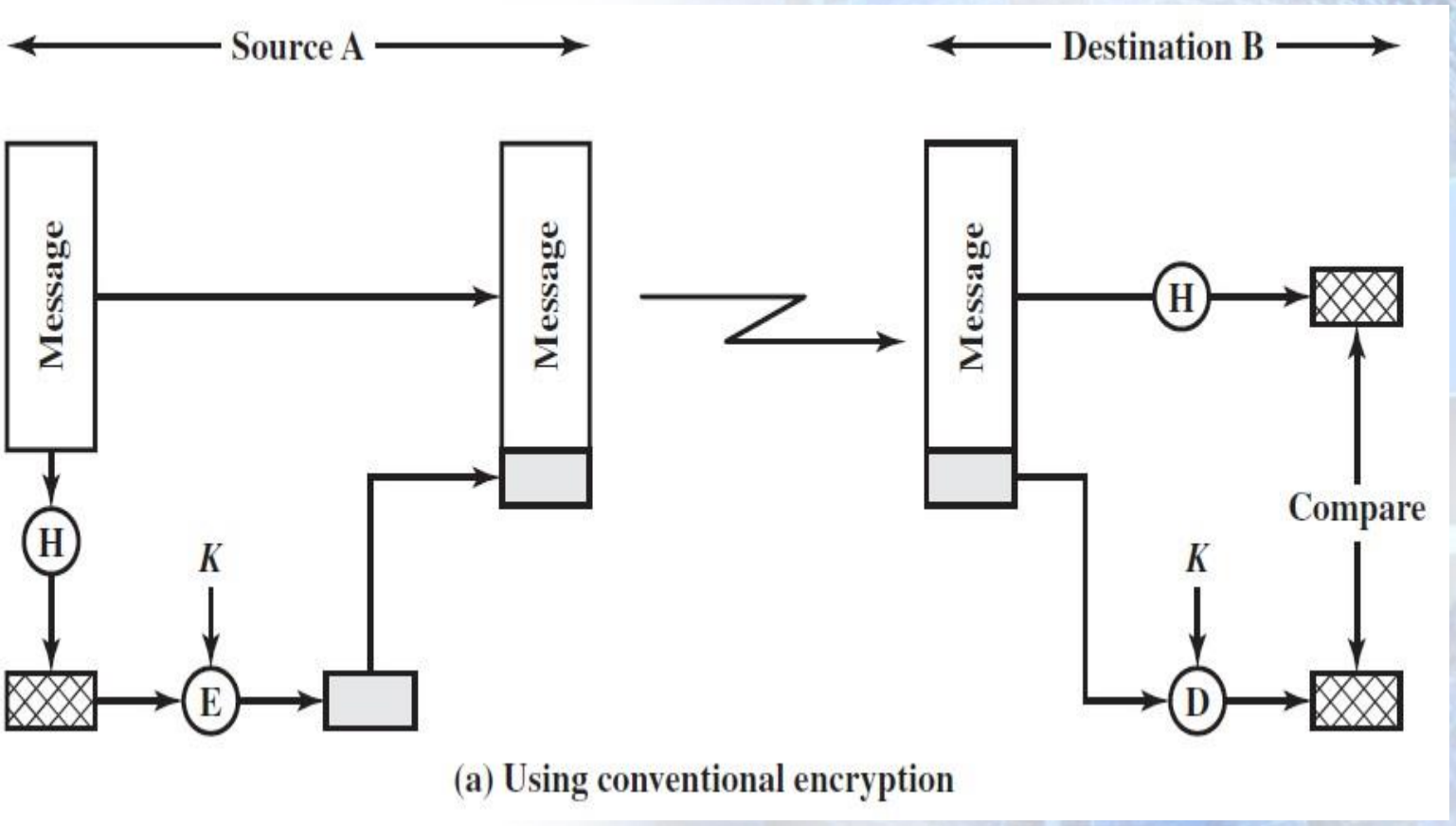
One-way Hash Function

- A hash function does not take a secret key as input.
- To authenticate a message, the message digest is sent with the message in such a way that the message digest is authentic.

One-way Hash Function

- There are three ways in which the message can be authenticated.
- **A)** The message digest can be encrypted using encryption if it is assumed that only the sender and receiver share the encryption key, then authenticity is assured.

One-way Hash Function



(a) Using conventional encryption

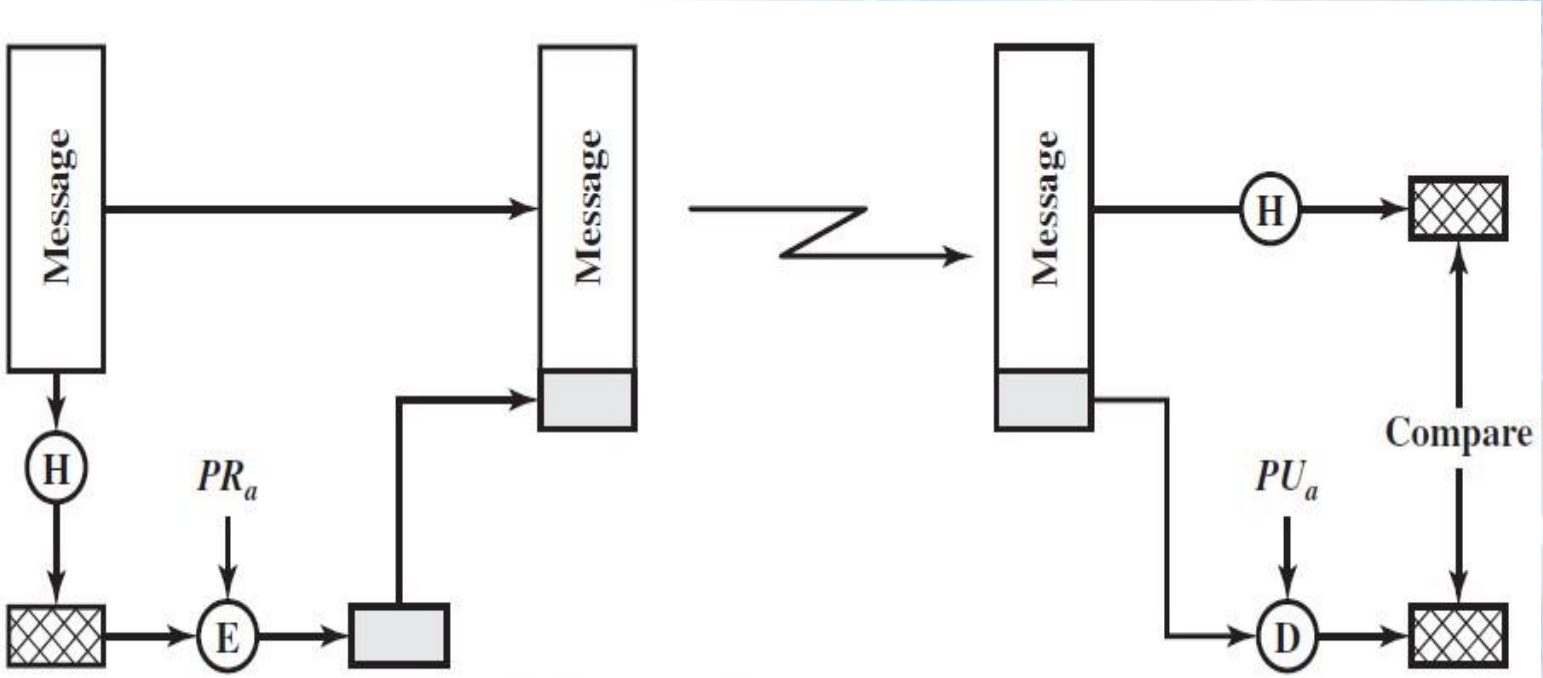
One-way Hash Function

- **B)** The message digest can be encrypted using public-key encryption.
- This approach has two advantages:
- (1) It provides a digital signature as well as message authentication.

One-way Hash Function

- (2) It does not require the distribution of keys to communicating parties.

One-way Hash Function



(b) Using public-key encryption

One-way Hash Function

- These two approaches require less computations over approaches that encrypt the entire message.
- There has been interest in developing a technique that avoids encryption altogether.

One-way Hash Function

- **C)** uses a hash function but no encryption for message authentication.
- This technique assumes that two communicating parties, say A and B, share a common secret value S_{AB}.

One-way Hash Function

- When A has a message to send to B, it calculates the hash function over the concatenation of the secret value and the message:
  $MD_M = H(S_{AB}||M)$.
- It then sends $[M||MD_M]$ to B.

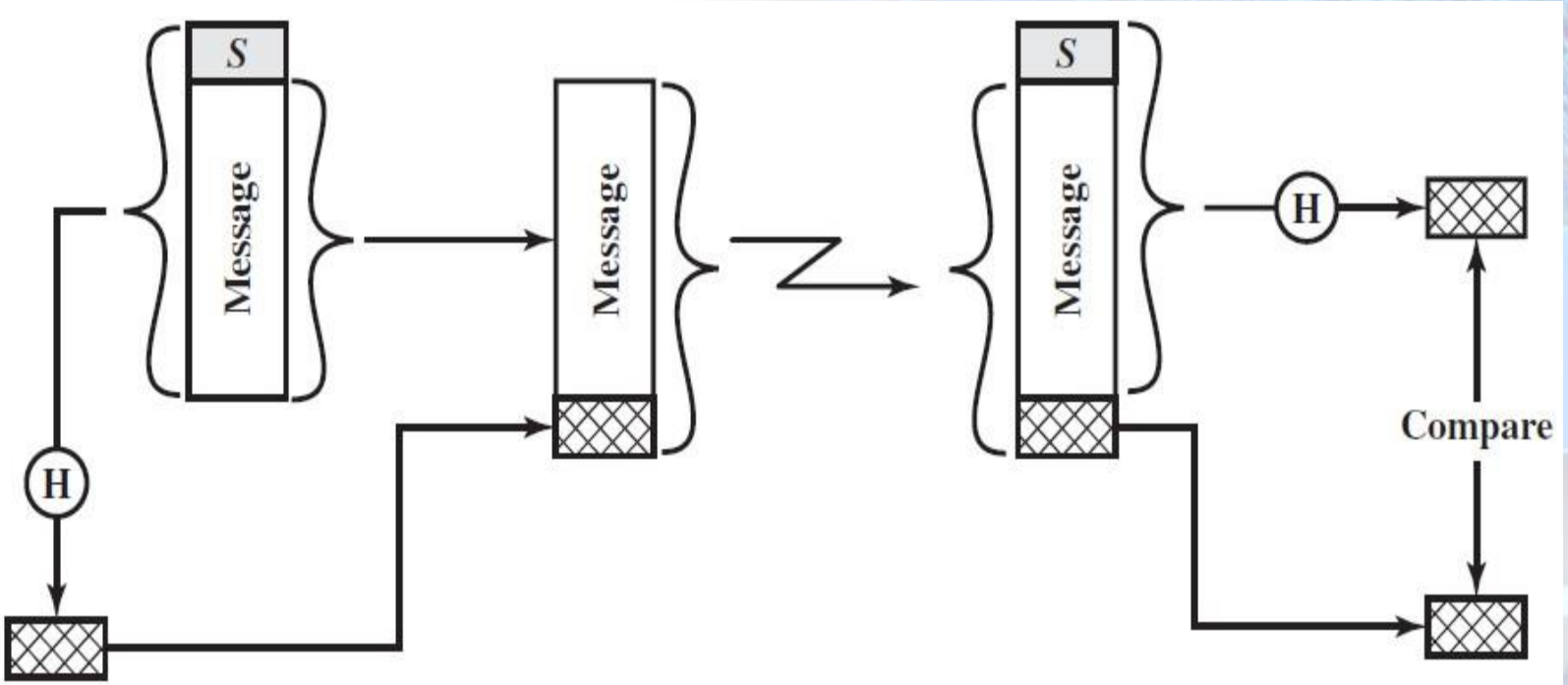
One-way Hash Function

- Because B possesses S_{AB}, it can recompute $H(S_{AB}||M)$ and verify MD_M.
- Because the secret value itself is not sent, it is not possible for an attacker to modify an intercepted message.

One-way Hash Function

- As long as the secret value remains secret, it is also not possible for an attacker to generate a false message.

One-way Hash Function



(c) Using secret value

One-way Hash Function

End

- A variation on the third technique is the one adopted for IP security
- It also has been specified for Simple Network Management Protocol (SNMP)v3.

Hash Function Requirements

Network Security

Hash Function Requirements

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain hash function requirements.

Hash Function Requirements

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Hash Function Requirements

- The purpose of a hash function is to produce a “fingerprint” of a file, message, or other block of data.
- It accepts a variable-length block of data M as input and produces a fixed-size hash value h = H(M).

Hash Function Requirements

- A “good” hash function has the property that the results of applying the function to a large set of inputs will produce outputs that are evenly distributed and apparently random.

Hash Function Requirements

- A change to any bit or bits in M results, with high probability, in a change to the hash code.
- The principal object of a hash function is data integrity.

Hash Function Requirements

- For a hash value h = H(x), we say that x is the **preimage** of h.
- In other words, x is a data block whose hash function, using the function H, is h.

Hash Function Requirements

- Because H is a many-to-one mapping, for any given hash value h, there will in general be multiple preimages.

Hash Function Requirements

- A collision occurs if we have $x \neq y$ and $H(x) = H(y)$.
- Because we are using hash functions for data integrity, collisions are clearly undesirable.

Hash Function Requirements

- To be useful for message authentication, a hash function H must have the following properties:
- 1. H can be applied to a block of data of any size.
- 2. H produces a fixed-length output.

Hash Function Requirements

- 3. H(x) is relatively easy to compute for any given x, making both hardware and software implementations practical.

Hash Function Requirements

- 4. For any given code h, it is computationally infeasible to find x such that H(x) = h.
- A hash function with this property is referred to as **one-way** or **preimage resistant**.

Hash Function Requirements

- 5. For any given block x, it is computationally infeasible to find $y \neq x$ with $H(y) = H(x)$.
- A hash function with this property is referred to as **second preimage resistant**.
- This is also referred to as **weak collision resistant**.

Hash Function Requirements

- 6. It is computationally infeasible to find any pair (x, y) such that H(x) = H(y).
- Such a hash function is referred to as **collision resistant**.
- This is sometimes referred to as **strong collision resistant**.

Hash Function Requirements

- First three properties are requirements for the practical application of a hash function to message authentication.
- The 4th property is important if the authentication technique involves the use of a secret value.

Hash Function Requirements

- The fourth property, preimage resistant, is the “one-way” property: It is easy to generate a code given a message, but virtually impossible to generate a message given a code.

Hash Function Requirements

- The 5th property prevents forgery when an encrypted hash code is used.

Hash Function Requirements

- A hash function that satisfies the first five properties in the preceding list is referred to as a weak hash function.
- If the sixth property is also satisfied, then it is referred to as a strong hash function.

Hash Function Requirements

Security of Hash Functions:

- Two approaches to attacking a secure hash function are:
- Cryptanalysis, and
- brute-force attack

Hash Function Requirements

- Cryptanalysis of a hash function involves exploiting logical weaknesses in the algorithm.
- The strength of a hash function against brute-force attacks depends on length of hash code produced by algorithm.

Hash Function Requirements

- For a hash code of length n, the level of effort required is proportional to the following:

Preimage resistant	2^n
Second preimage resistant	2^n
Collision resistant	$2^{n/2}$

End

Simple Hash Functions

Network Security

Simple Hash Functions

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain working of simple hash functions.

Simple Hash Functions

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Simple Hash Functions

- A hash function accepts a variable-length block of data M as input and produces a fixed-size hash value h = H(M).

Simple Hash Functions

- A “good” hash function has the property that the results of applying the function to a large set of inputs will produce outputs that are evenly distributed and apparently random.

Simple Hash Functions

- A change to any bit or bits in M results, with high probability, in a change to the hash code.
- The principal object of a hash function is data integrity.

Simple Hash Functions

Simple Hash Functions:

- All hash functions operate using the following general principles.
- The input (message, file, etc.) is viewed as a sequence of n-bit blocks.

Simple Hash Functions

- The input is processed one block at a time in an iterative fashion to produce an n-bit hash function.
- One of the simplest hash functions is the bit-by-bit exclusive-OR (XOR) of every block.

Simple Hash Functions

- If

C_i = ith bit of the hash code, $1 \le i \le n$

m = number of n-bit blocks in the input

b_{ij} = ith bit in jth block

$\oplus$ = XOR operation

- Then,

$$C_i = b_{i1} \oplus b_{i2} \oplus \ldots \oplus b_{im}$$

Simple Hash Functions

Simple Hash Function Using Bitwise XOR

	bit 1	bit 2	• • •	bit n
Block 1	b_{11}	b_{21}		b_{n1}
Block 2	b_{12}	b_{22}		b_{n2}
	•	•	•	•
	•	•	•	•
	•	•	•	•
Block m	b_{1m}	b_{2m}		b_{nm}
Hash code	C_1	C_2		C_n

Simple Hash Functions

- This operation produces a simple parity for each bit position and is known as a longitudinal redundancy check.
- It is reasonably effective for random data as a data integrity check.

Simple Hash Functions

- Each n-bit hash value is equally likely.
- Thus, the probability that a data error will result in an unchanged hash value is 2^{-n}.
- With more predictably formatted data, the function is less effective.

Simple Hash Functions

- For example, in most normal text files, the high-order bit of each octet is always zero.
- With a 128-bit hash value, effectiveness of the hash function is reduced from 2^{-128} to 2^{-112} on this type of data.

Simple Hash Functions

- A simple way to improve matters is to perform a 1-bit circular shift, or rotation, on the hash value after each block is processed.
- The procedure can be summarized as:

Simple Hash Functions

- 1. Initially set the n-bit hash value to zero.
- 2. Process each successive n-bit block of data:
- a. Rotate the current hash value to the left by one bit.
- b. XOR the block into the hash value.

Simple Hash Functions

- This has the effect of "randomizing" the input more completely and overcoming any regularities that appear in the input.
- Data security is at stake when an encrypted hash code is used with a plaintext message.

Simple Hash Functions

- A technique originally proposed by the National Bureau of Standards used the simple XOR applied to 64-bit blocks of the message and then an encryption of the entire message using the cipher block chaining (CBC) mode.

Simple Hash Functions

- Given a message consisting of a sequence of 64-bit blocks $X_1, X_2, \ldots, X_N$, define the hash code C as the block-by-block XOR or all blocks and append the hash code as the final block:

$$C = X_{N+1} = X_1 \oplus X_2 \oplus \ldots \oplus X_N$$

Simple Hash Functions

End

- Next, encrypt the entire message plus hash code using CBC mode to produce the encrypted message Y_1, Y_2, . . ., Y_{N-1}
- Ciphertext of this message can be manipulated so that it is not detectable by the hash code.

The Secure Hash Function (SHA)

Network Security

The Secure Hash Function (SHA)

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain working of the secure hash algorithm (SHA).

The Secure Hash Function (SHA)

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

The Secure Hash Function (SHA)

Secure Hash Algorithm (SHA)

- Is the most widely used hash function in recent years.
- Developed by the National Institute of Standards and Technology (NIST)
- FIPS 180 in 1993.

The Secure Hash Function (SHA)

- The actual standards document is entitled "Secure Hash Standard."
- SHA is based on the hash function (Message-Digest) MD4, and its design closely models MD4.

The Secure Hash Function (SHA)

- When weaknesses were discovered in SHA (now known as SHA-0), a revised version was issued as FIPS 180-1 in 1995 and is referred to as SHA-1.

The Secure Hash Function (SHA)

- In 2002, NIST produced FIPS 180-2.
- Three new versions of SHA with hash value lengths of 256, 384, and 512 bits known as SHA-256, SHA-384, and SHA-512 were defined.
- Collectively, these are known as SHA-2.

The Secure Hash Function (SHA)

Comparison of SHA Parameters

	SHA-1	SHA-224	SHA-256	SHA-384	SHA-512
Message Digest Size	160	224	256	384	512
Message Size	$< 2^{64}$	$< 2^{64}$	$< 2^{64}$	$< 2^{128}$	$< 2^{128}$
Block Size	512	512	512	1024	1024
Word Size	32	32	32	64	64
Number of Steps	80	64	64	80	80

Note: All sizes are measured in bits.

The Secure Hash Function (SHA)

- In 2005 NIST announced the intention to phase out approval of SHA-1 and move to a reliance on SHA-2 by 2010.
- We focus on SHA-512.

The Secure Hash Function (SHA)

SHA-512 Logic:

- The algorithm takes as input a message with a maximum length of less than 2^{128} bits and produces as output a 512-bit message digest.
- The input is processed in 1024-bit blocks.

The Secure Hash Function (SHA)

Step 1: Append padding bits

- Padding is added, even if the message is already of the desired length. No. of Padding bits = [1 1024]
- Padding consists of a single 1 bit followed by the necessary number of 0 bits.

The Secure Hash Function (SHA)

Step 2: Append length

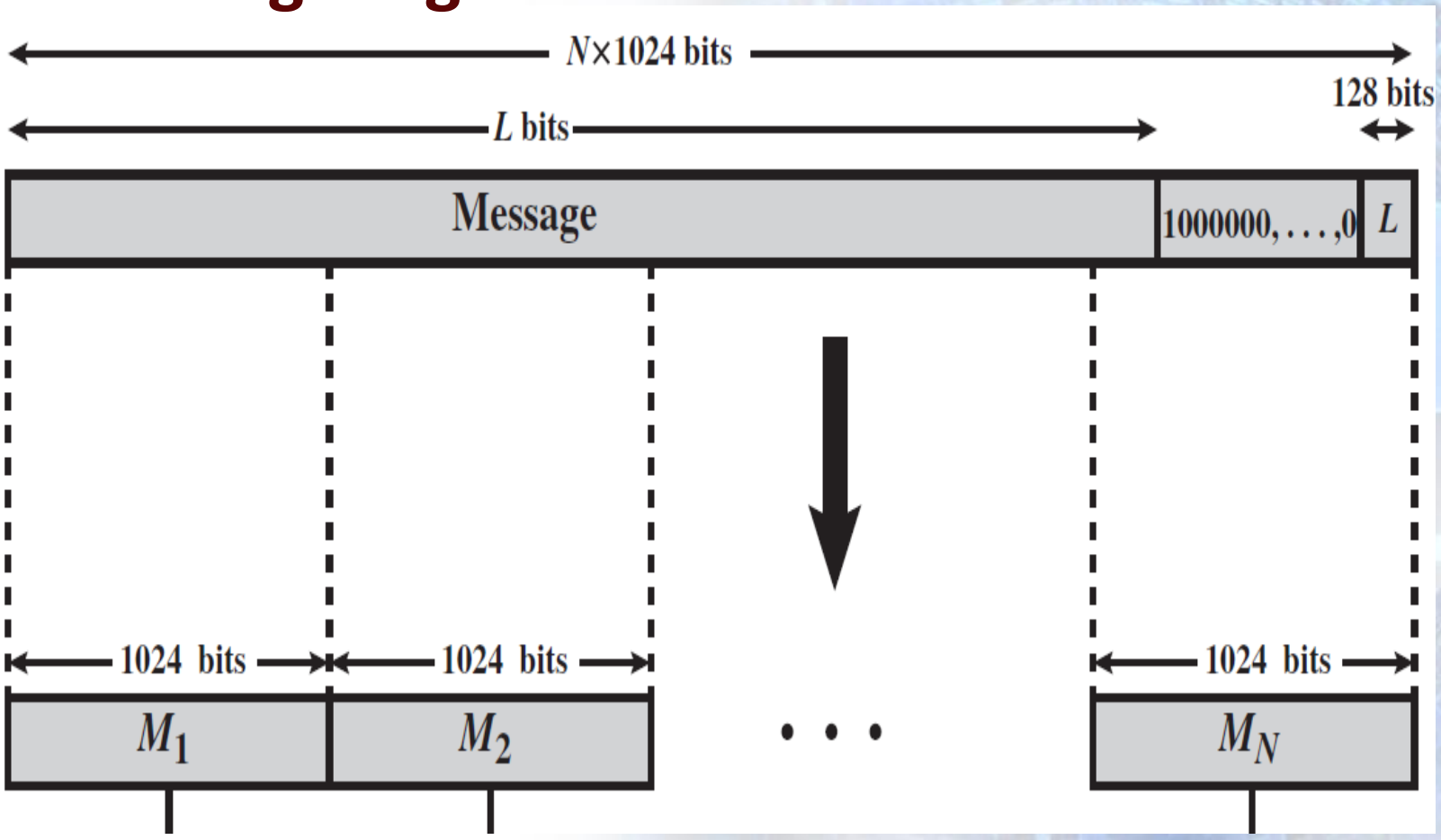
- A block of 128 bits is appended to the message.
- This block is treated as an unsigned 128-bit integer and contains the length of the original message (before the padding).

The Secure Hash Function (SHA)

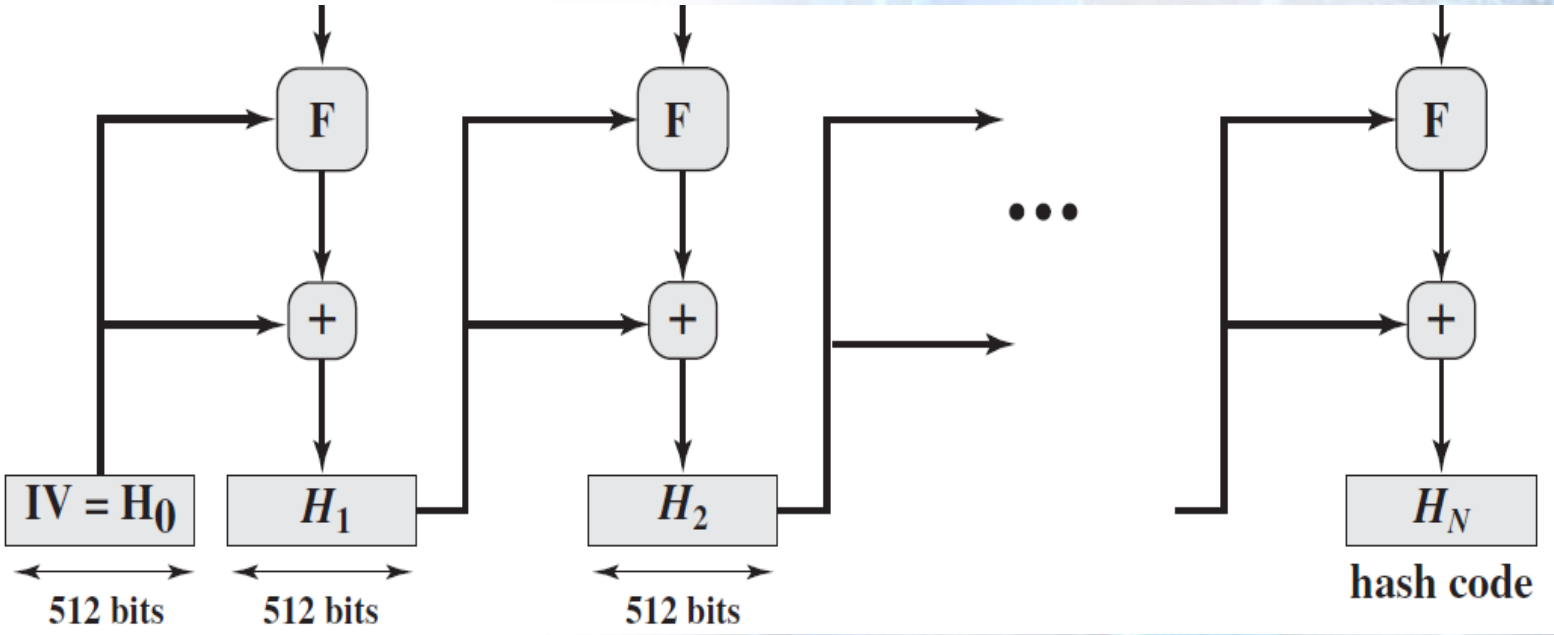
- Outcome of first two steps yields a message an integer multiple of 1024 bits in length.
- Total length of the expanded message is N × 1024 bits as the expanded message is a sequence of 1024-bit blocks M_1, M_2, . . ., $M_{N.}$

The Secure Hash Function (SHA)

Message Digest Generation of SHA-512



The Secure Hash Function (SHA)



The Secure Hash Function (SHA)

Step 3: Initialize hash buffer

- A 512-bit buffer is used to hold intermediate and final results of the hash function.
- The buffer can be represented as eight 64-bit registers (*a*, *b*, *c*, *d*, *e*, *f*, *g*, *h*).

The Secure Hash Function (SHA)

- Initialize these registers by taking the first sixty-four bits of the fractional parts of the square roots of the first eight prime numbers.

The Secure Hash Function (SHA)

Initialization of the registers

$a = 6A09E667F3BCC908$	$e = 510E527FADE682D1$
$b = BB67AE8584CAA73B$	$f = 9B05688C2B3E6C1F$
$c = 3C6EF372FE94F82B$	$g = 1F83D9ABFB41BD6B$
$d = A54FF53A5F1D36F1$	$h = 5BE0CD19137E2179$

The Secure Hash Function (SHA)

Step 4: Process message in 1024-bit (128-word) blocks

- The module labeled F consists of 80 rounds.
- Each round takes as input the 512-bit buffer value *abcdefgh* and updates the contents of the buffer.

The Secure Hash Function (SHA)

- At input to the first round, the buffer has the value of the intermediate hash value, H_{i-1}.
- Each round **t** makes use of a 64-bit value W_t derived from the current 1024-bit block being processed (M_i).

The Secure Hash Function (SHA)

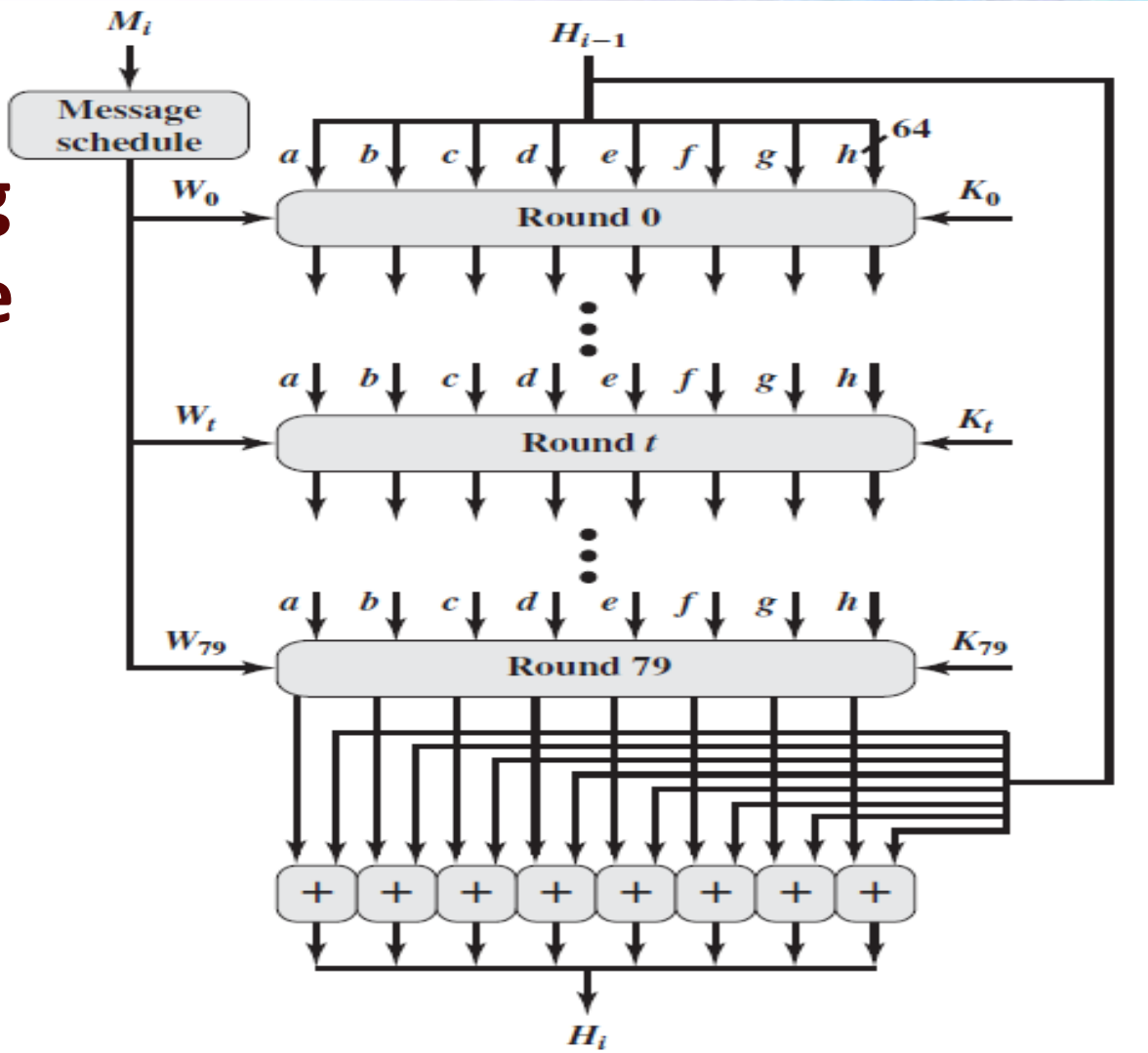
- Each round also makes use of an additive constant K_t, where t = 0 … … 79.
- The constants eliminate any regularities in the input data.

The Secure Hash Function (SHA)

- The output of the 80th round is added to the input to the first round (H_{i-1}) to produce H_i .

The Secure Hash Function (SHA)

Processing of a Single 1024-Bit Block



The Secure Hash Function (SHA)

End

Step 5 Output:

- After all N 1024-bit blocks have been processed, the output from the Nth stage is the 512-bit message digest.
- In 2012, NIST formally published SHA-3.

HMAC and its Design Objectives

Network Security

HMAC and its Design Objectives

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain design objectives of hash-based message authentication code(HMAC).

HMAC and its Design Objectives

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

HMAC and its Design Objectives

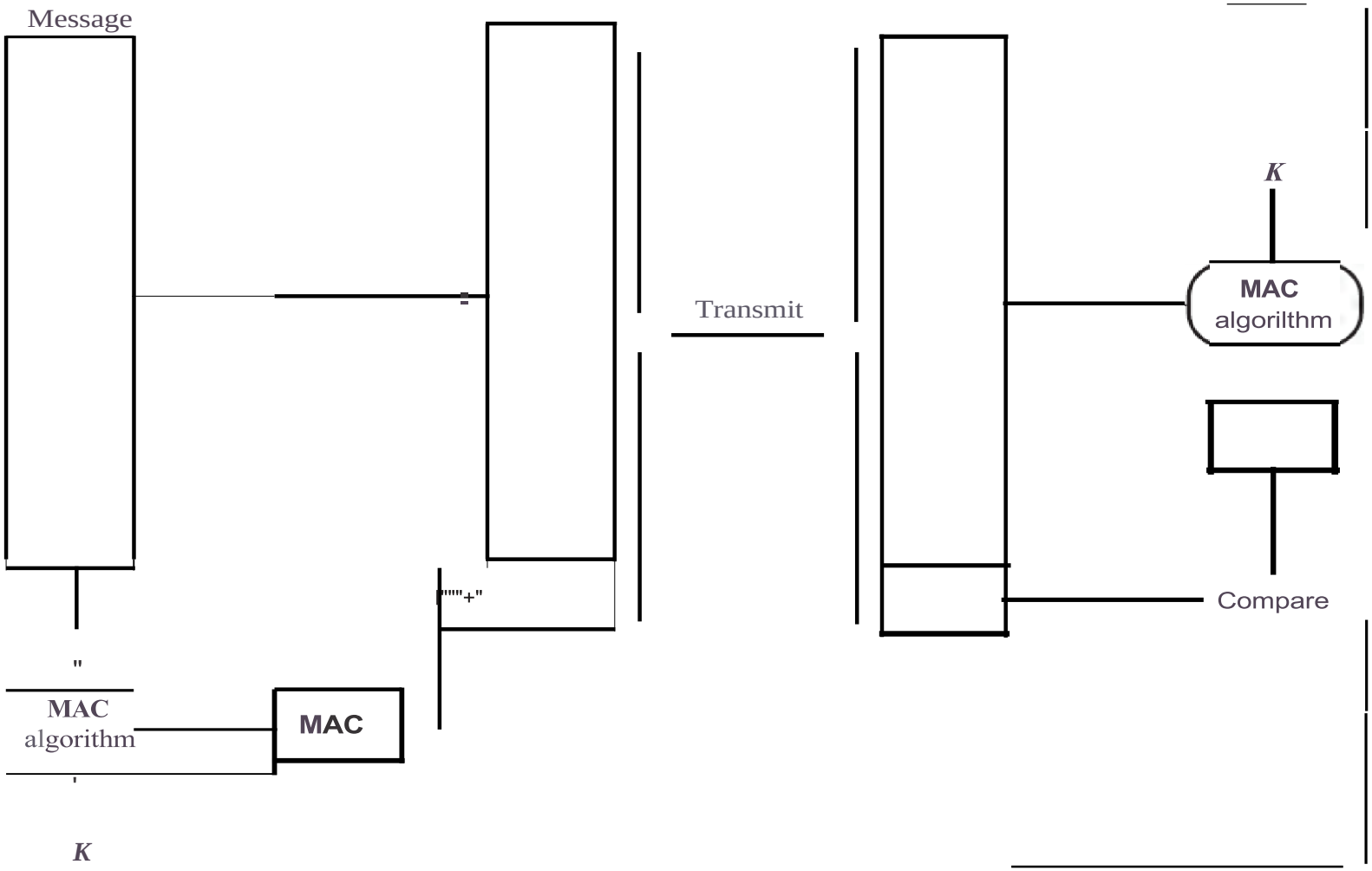
- Message authentication is a procedure that allows communicating parties to verify that received messages, file, document, or other collection of data are authentic.

HMAC and its Design Objectives

Message Authentication Code (MAC)

- is a technique that involves the use of a secret key to generate a small block of data, known as a message authentication code , that is appended to the message.

HMAC and its Design Objectives



HMAC and its Design Objectives

- There has been a growing interest in developing a MAC derived from a cryptographic hash code, such as SHA-1.
- The motivations are:

HMAC and its Design Objectives

- 1. Cryptographic hash functions generally execute faster in software than conventional encryption algorithms such as DES.
- 2. Library code for cryptographic hash functions is widely available.

HMAC and its Design Objectives

- A hash function such as SHA was not designed for use as a MAC and cannot be used directly for that purpose, because it does not rely on a secret key.

HMAC and its Design Objectives

- Among the proposals for the incorporation of a secret key into an existing hash algorithm, HMAC is the approach that has received the most support.

HMAC and its Design Objectives

- HMAC has been issued as RFC 2104,
- as a NIST standard (FIPS 198).
- as mandatory-to-implement MAC for IP Security.
- Also used in Transport Layer Security (TLS) and Secure Electronic Transaction (SET).

HMAC and its Design Objectives

- **HMAC Design Objectives:**
- RFC 2104 lists the following design objectives for HMAC.

HMAC and its Design Objectives

- 1. To use, without modifications, available hash functions.
- In particular, hash functions that perform well in software, and for which code is freely and widely available.

HMAC and its Design Objectives

- 2. To allow for easy replaceability of the embedded hash function in case faster or more secure hash functions are found or required.

HMAC and its Design Objectives

- 3. To preserve the original performance of the hash function without incurring a significant degradation.
- 4. To use and handle keys in a simple way.

HMAC and its Design Objectives

- 5. To have a well-understood cryptographic analysis of the strength of the authentication mechanism based on reasonable assumptions on the embedded hash function.

HMAC and its Design Objectives

- The first two objectives are important to the acceptability of HMAC.
- HMAC treats the hash function as a “black box.” This has two benefits.

HMAC and its Design Objectives

- First, an existing implementation of a hash function can be used as a module in implementing HMAC.

HMAC and its Design Objectives

- Second, if it is ever desired to replace a given hash function in an HMAC implementation, all that is required is to remove the existing hash function module and drop in the new module.

HMAC and its Design Objectives

- The last design objective in the preceding list is, in fact, the main advantage of HMAC over other proposed hash-based schemes.

End

HMAC Algorithm

Network Security

HMAC Algorithm

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe working of HMAC algorithm.

HMAC Algorithm

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

HMAC Algorithm

Notation:

- H = embedded hash function (e.g., SHA-1)
- IV = initial value input to hash function
- M = message input to HMAC (including the padding specified in the embedded hash function)

HMAC Algorithm

- Y_i = ith block of M, $0 \leq i \leq (L - 1)$
- L = number of blocks in M
- b = number of bits in a block
- n = length of hash code produced by embedded hash function

HMAC Algorithm

- K = secret key; recommended length is ≥ n; if key length is greater than b, the key is input to the hash function to produce an n-bit key
- K^+ = K padded with zeros on the left so that the result is b bits in length

HMAC Algorithm

- ipad = 00110110 (36 in hexadecimal) repeated b/8 times
- opad = 01011100 (5C in hexadecimal) repeated b/8 times

HMAC Algorithm

- 1. Append zeros to the left end of K to create a b-bit string K^+ (e.g., if K is of length 160 bits and b = 512, K will be appended with 44 zero bytes).
- 2. Bitwise exclusive-OR K^+ with ipad to produce the b-bit block S_i.

HMAC Algorithm

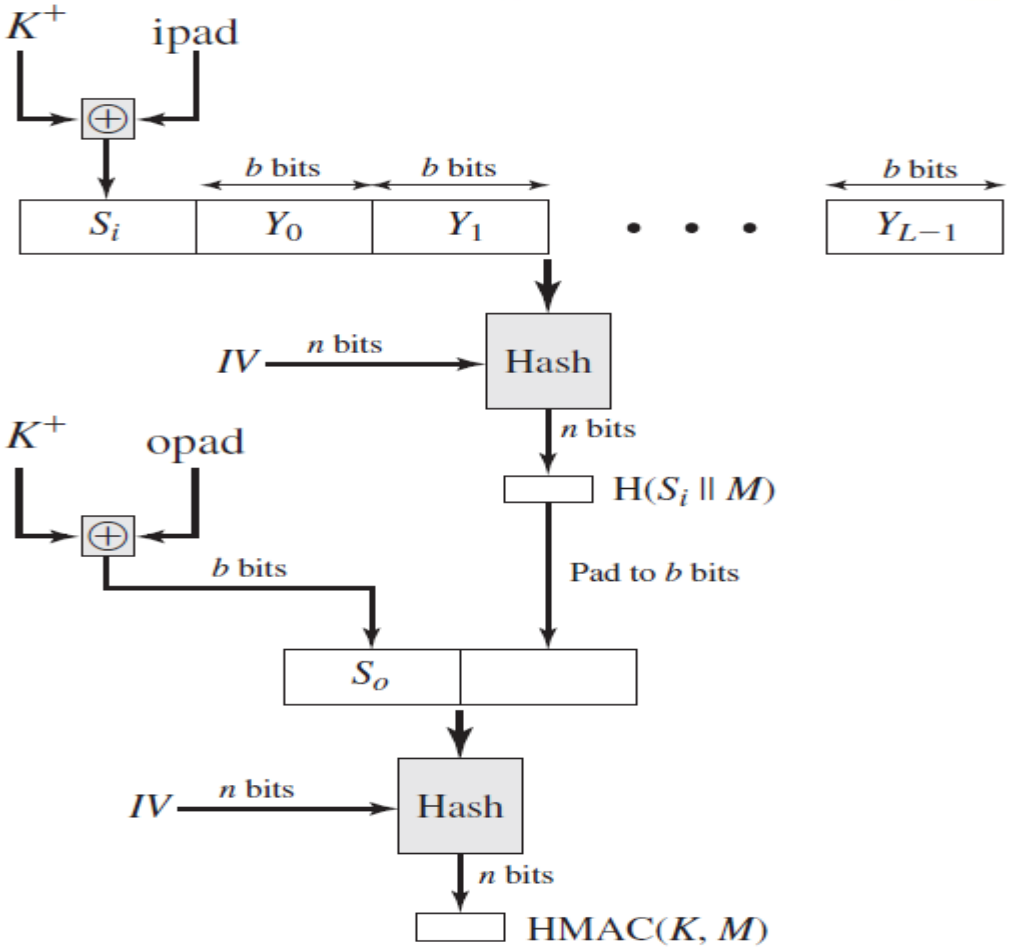
- 3. Append M to S_i.
- 4. Apply H to the stream generated in step 3.
- 5. XOR K^+ with opad to produce the b-bit block S_o.
- 6. Append the hash result from step 4 to S_o.

HMAC Algorithm

- 7. Apply H to the stream generated in step 6 and output the result.

HMAC Algorithm

$$\text{HMAC}(K, M) = \text{H}[(K^+ \oplus \text{opad}) \| \text{H}[(K^+ \oplus \text{ipad}) \| M]]$$



HMAC Algorithm

- Note that the XOR with ipad results in flipping one-half of the bits of K.
- Similarly, the XOR with opad results in flipping one-half of the bits of K, using a different set of bits.

HMAC Algorithm

- In effect, by passing S_i and S_o through the hash algorithm, we have pseudorandomly generated two keys from K.

HMAC Algorithm

- HMAC should execute in approximately the same time as the embedded hash function for long messages.

HMAC Algorithm

- HMAC adds three executions of the basic hash function (for S_i, S_o, and the block produced from the inner hash).

HMAC Algorithm

End

Security of HMAC:

- The appeal of HMAC is that its designers have been able to prove an exact relationship between the strength of the embedded hash function and the strength of HMAC.

Cipher-Based MAC

Network Security

Cipher-Based MAC

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe working of Cipher-based message authentication code.

Cipher-Based MAC

Figures and material in this topic have been adapted from

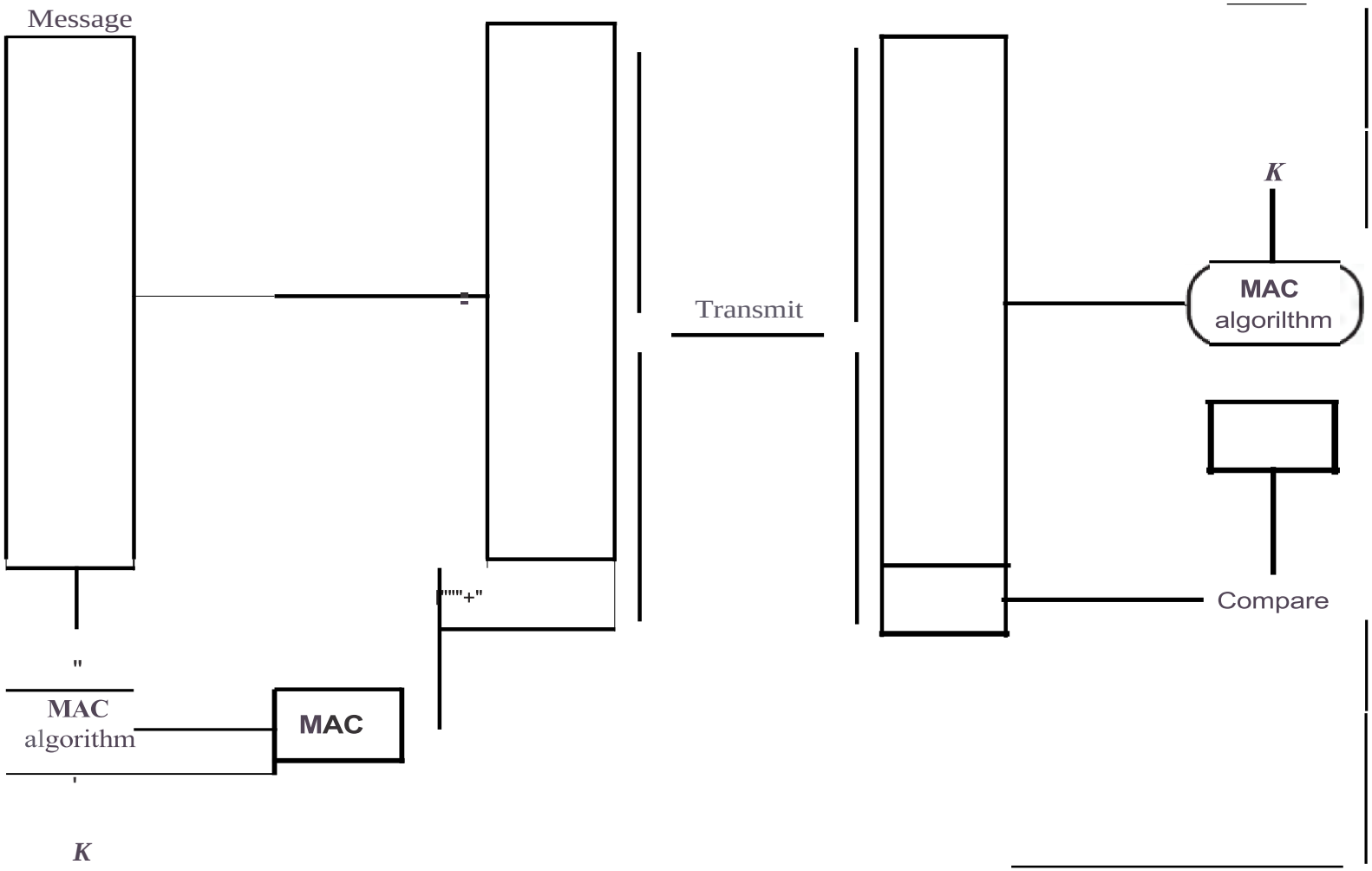
- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Cipher-Based MAC

Message Authentication Code (MAC)

- is a technique that involves the use of a secret key to generate a small block of data, known as a message authentication code , that is appended to the message.

Cipher-Based MAC



Cipher-Based MAC

Cipher-based Message Authentication Code (CMAC):

- Is a message authentication code based on AES and triple DES.
- It is specified in NIST Special Publication 800-38B.

Cipher-Based MAC

Message Length is Integer Multiple of Block Size:

- First, let us consider the operation of CMAC when the message is an integer multiple **n** of the cipher block length **b**.

Cipher-Based MAC

- For AES, b = 128, and for triple DES, b=64.
- The message is divided into **n** blocks ($M_1, M_2, \ldots, M_n$).

Cipher-Based MAC

- The algorithm makes use of a k-bit encryption key K and an n-bit key, K_1.
- For AES, the key size k is 128, 192, or 256 bits.
- For triple DES, the key size is 112 or 168 bits.

Cipher-Based MAC

- Lets assume that T is the message authentication code, also referred to as the tag
- Tlen = bit length of T
- $MSB_s(X)$ = the s leftmost bits of the bit string X.

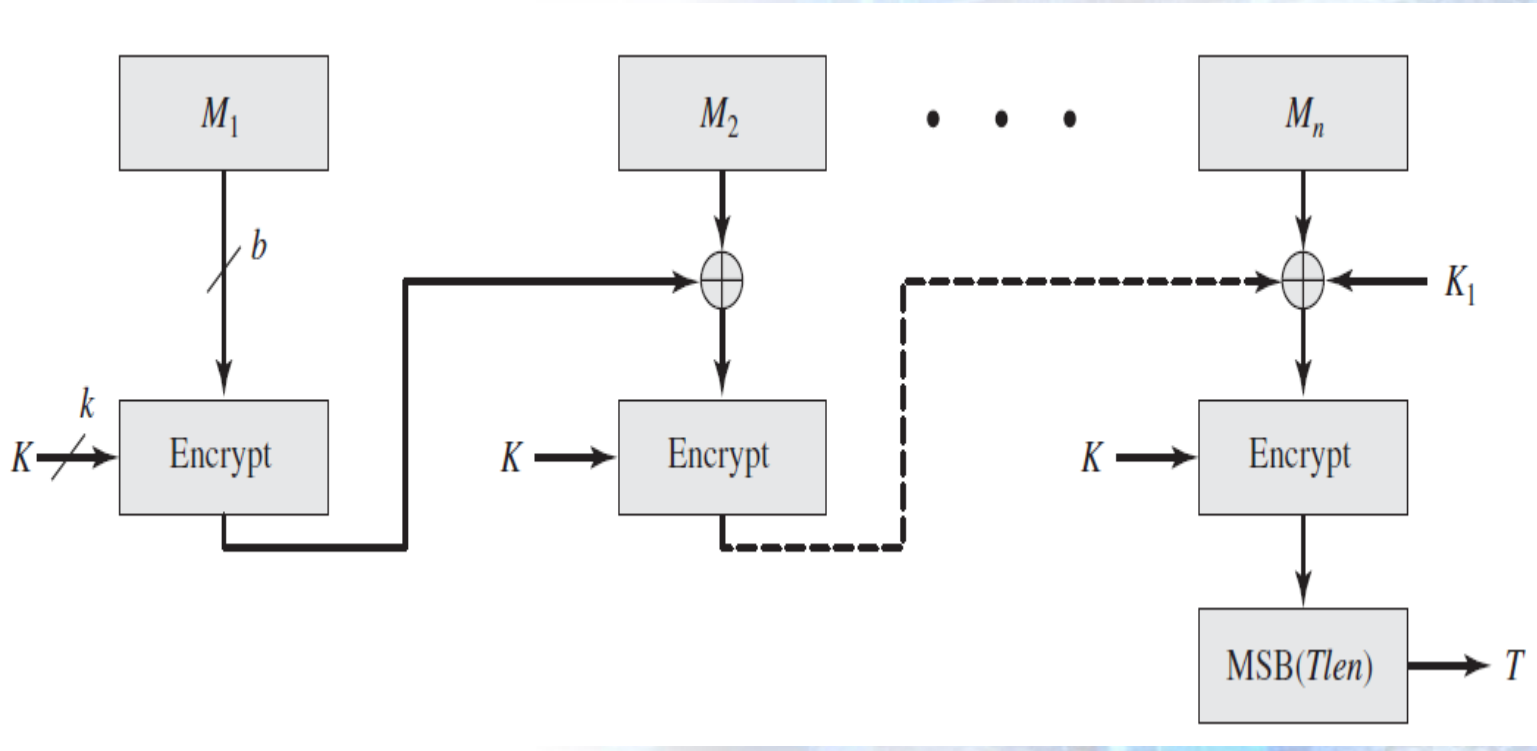
Cipher-Based MAC

Calculation of CMAC

$$
\begin{aligned}
C_1 &= \mathrm{E}(K, M_1) \\
C_2 &= \mathrm{E}(K, [M_2 \oplus C_1]) \\
C_3 &= \mathrm{E}(K, [M_3 \oplus C_2]) \\
&\cdot \\
&\cdot \\
&\cdot \\
C_n &= \mathrm{E}(K, [M_n \oplus C_{n-1} \oplus K_1]) \\
T &= \mathrm{MSB}_{Tlen}(C_n)
\end{aligned}
$$

Cipher-Based MAC

Message Length is Integer Multiple of Block Size



Cipher-Based MAC

Message Length is not Integer Multiple of Block Size:

- In this case, the final block is padded to the right (least significant bits) with a 1 and as many 0s as necessary so that the final block is also of length b.

Cipher-Based MAC

- The CMAC operation then proceeds as before, except that a different n-bit key K_2 is used instead of K_1.
- To generate the two *n*-bit keys, the block cipher is applied to the block that consists entirely of 0 bits.

Cipher-Based MAC

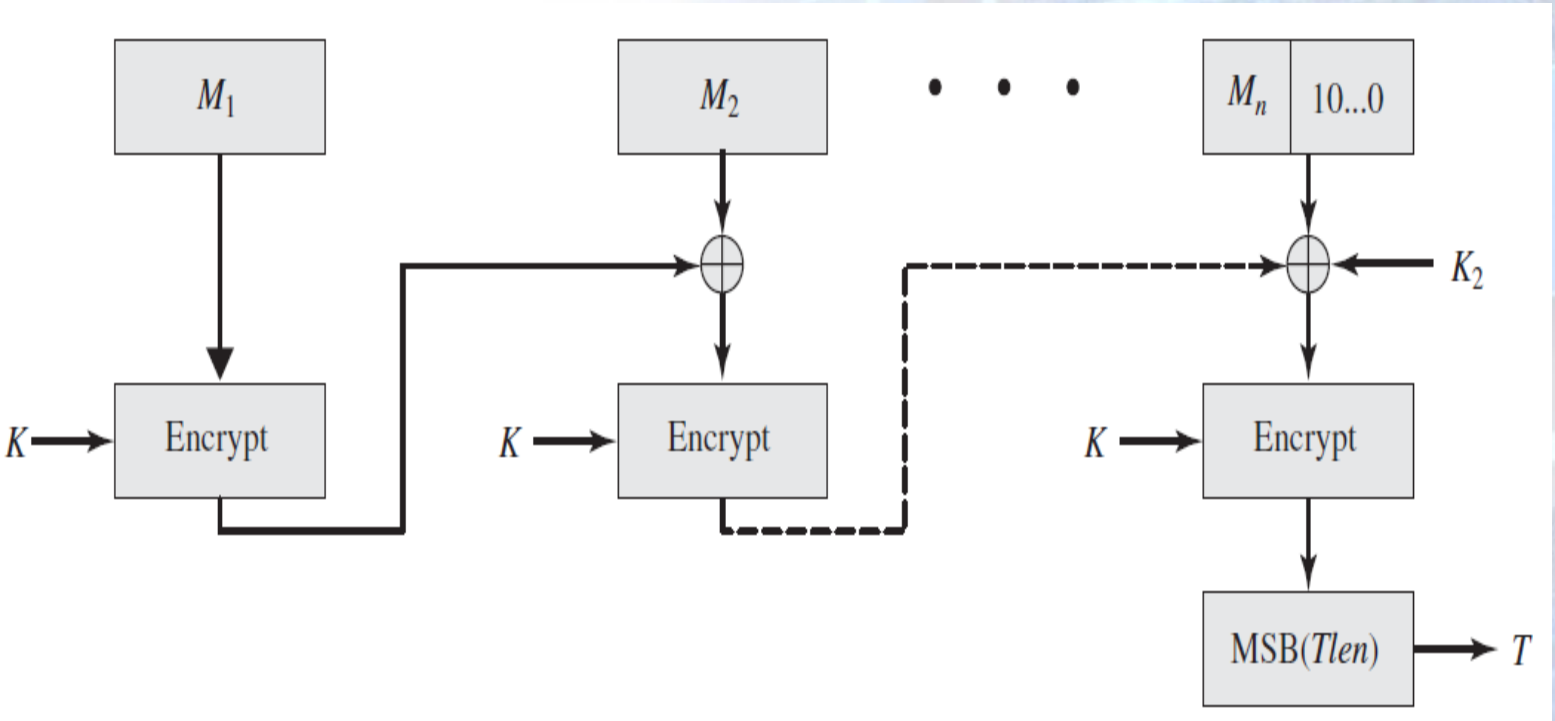
- The first subkey is derived from the resulting ciphertext by a left shift of one bit and, conditionally, by XORing a constant that depends on the block size.

Cipher-Based MAC

- The second subkey is derived in the same manner from the first subkey.

Cipher-Based MAC

Message Length is not Integer Multiple of Block Size



Counter With Cipher Block Chaining-MAC

Network Security

Counter With Cipher Block Chaining-MAC

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe working of Counter with Cipher Block Chaining-MAC.

Counter With Cipher Block Chaining-MAC

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Counter With Cipher Block Chaining-MAC

- The Counter with Cipher Block Chaining-Message Authentication Code (CCM) mode of operation, was standardized by NIST specifically to support security requirements of IEEE 802.11 WiFi wireless local area networks.

Counter With Cipher Block Chaining-MAC

- It can be used in any networking application requiring authenticated encryption.
- It is defined in NIST SP 800-38C.

Counter With Cipher Block Chaining-MAC

- CCM is a variation of the encrypt-and-MAC approach to authenticated encryption.
- It is referred to as an authenticated encryption mode.

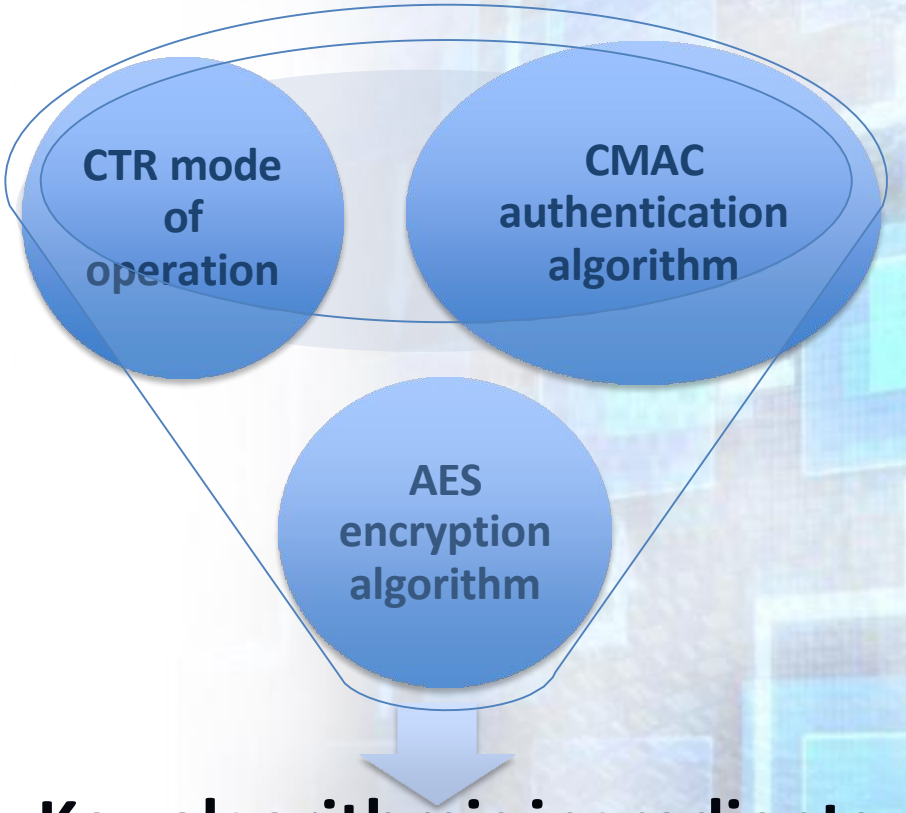
Counter With Cipher Block Chaining-MAC

- “Authenticated encryption” is a term used to describe encryption systems that protect confidentiality and authenticity of communications simultaneously .

Counter With Cipher Block Chaining-MAC

- The key algorithmic ingredients of CCM are AES encryption algorithm, the Counter mode (CTR) of operation, and the CMAC authentication algorithm.
- A single key K is used for both encryption and MAC algorithms.

Counter With Cipher Block Chaining-MAC



Counter With Cipher Block Chaining-MAC

- The input to the CCM encryption process consists of three elements.
- 1. Data that will be both authenticated and encrypted. This is the plaintext message P of data block.

Counter With Cipher Block Chaining-MAC

- 2. Associated data A that will be authenticated but not encrypted.
- An example is a protocol header that must be transmitted in the clear for proper protocol operation but which needs to be authenticated.

Counter With Cipher Block Chaining-MAC

- 3. A nonce N that is assigned to the payload and the associated data.
- This is a unique value that is different for every instance during lifetime of a protocol association and is intended to prevent replay attacks.

Counter With Cipher Block Chaining-MAC

Authentication

- For authentication, the input includes the nonce, the associated data, and the plaintext.
- This input is formatted as a sequence of blocks B_0 through B_r.

Counter With Cipher Block Chaining-MAC

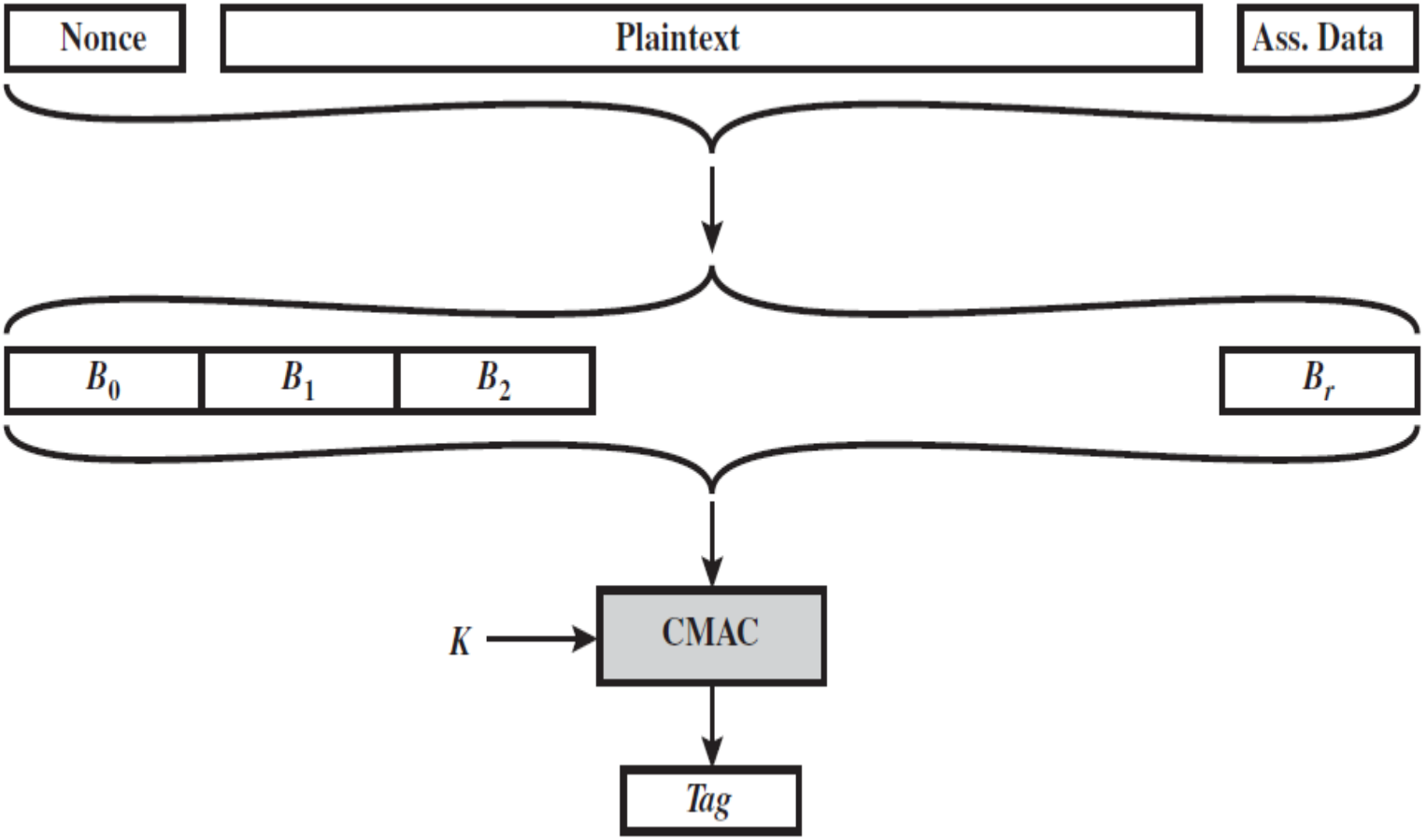
- The first block contains the nonce plus some formatting bits that indicate the lengths of the N, A, and P elements.
- This is followed by zero or more blocks that contain *A*, followed by zero of more blocks that contain *P.*

Counter With Cipher Block Chaining-MAC

- The resulting sequence of blocks serves as input to the CMAC algorithm, which produces a MAC value with length *Tlen*, which is less than or equal to the block length.

Counter With Cipher Block Chaining-MAC

Authentication



Counter With Cipher Block Chaining-MAC

Encryption

- For encryption, a sequence of counters is generated that must be independent of the nonce.
- The authentication tag is encrypted in CTR mode using the single counter Ctr0 .

Counter With Cipher Block Chaining-MAC

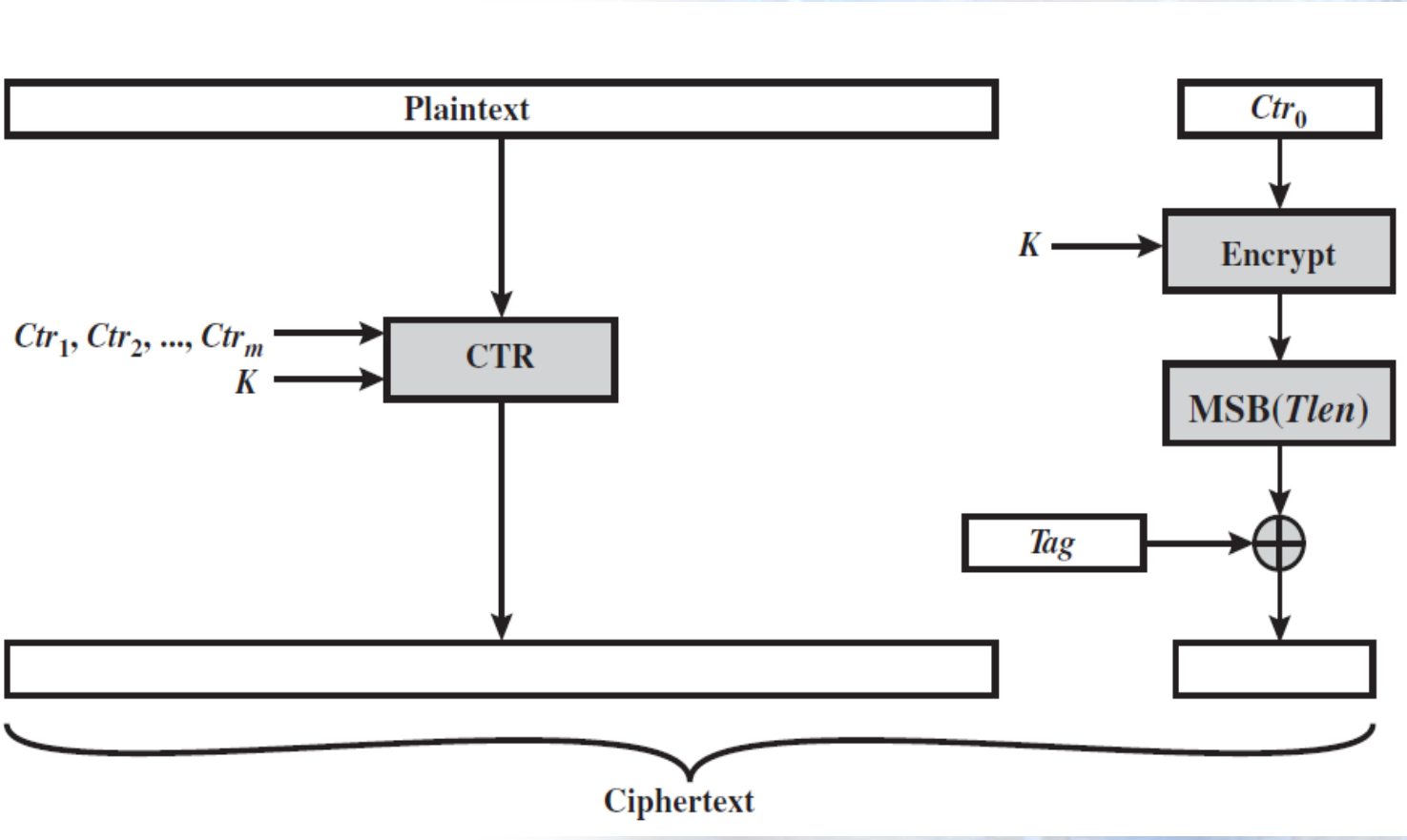
- The Tlen most significant bits of the output are XORed with the tag to produce an encrypted tag.
- The remaining counters are used for the CTR mode encryption of the plaintext.

Counter With Cipher Block Chaining-MAC

- The encrypted plaintext is concatenated with the encrypted tag to form the ciphertext output.

Counter With Cipher Block Chaining-MAC

Encryption



Public-Key Encryption Structure

Network Security

Public-Key Encryption Structure

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain structure of Public-key encryption.

Public-Key Encryption Structure

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Public-Key Encryption Structure

- Public-key encryption, first publicly proposed by Diffie and Hellman in 1976.

Public-Key Encryption Structure

- Public-key algorithms are based on mathematical functions rather than on simple operations on bit patterns, such as are used in symmetric encryption algorithms.

Public-Key Encryption Structure

- More important, public-key cryptography is asymmetric, involving the use of two separate keys—in contrast to the symmetric conventional encryption, which uses only one key.

Public-Key Encryption Structure

- The use of two keys has profound consequences in the areas of confidentiality, key distribution, and authentication.

Public-Key Encryption Structure

Structure

- A public-key encryption scheme has six ingredients.
- **Plaintext:** This is the readable message or data that is fed into the algorithm as input.

Public-Key Encryption Structure

- **Encryption algorithm:** The encryption algorithm performs various transformations on the plaintext.

Public-Key Encryption Structure

- **Public and private key:** This is a pair of keys; one is used for encryption, the other is used for decryption.
- The exact transformations performed by the encryption algorithm depend on the public or private key.

Public-Key Encryption Structure

- The public key of the pair is made public for others to use, while the private key is known only to its owner.

Public-Key Encryption Structure

- **Ciphertext:** This is the scrambled message produced as output.
- It depends on the plaintext and the key.
- For a given message, two different keys will produce two different ciphertexts.

Public-Key Encryption Structure

- **Decryption algorithm:** This algorithm accepts the ciphertext and the matching key and produces the original plaintext.

Public-Key Encryption Structure

- A general-purpose public-key cryptographic algorithm relies on one key for encryption and a different but related key for decryption.

Public-Key Encryption Structure

Working

- 1. Each user generates a pair of keys to be used for the encryption and decryption of messages.

Public-Key Encryption Structure

- 2. Each user places one of the two keys in a public register or other accessible file.
- This is the public key. The companion key is kept private.
- Each user maintains a collection of public keys obtained from others.

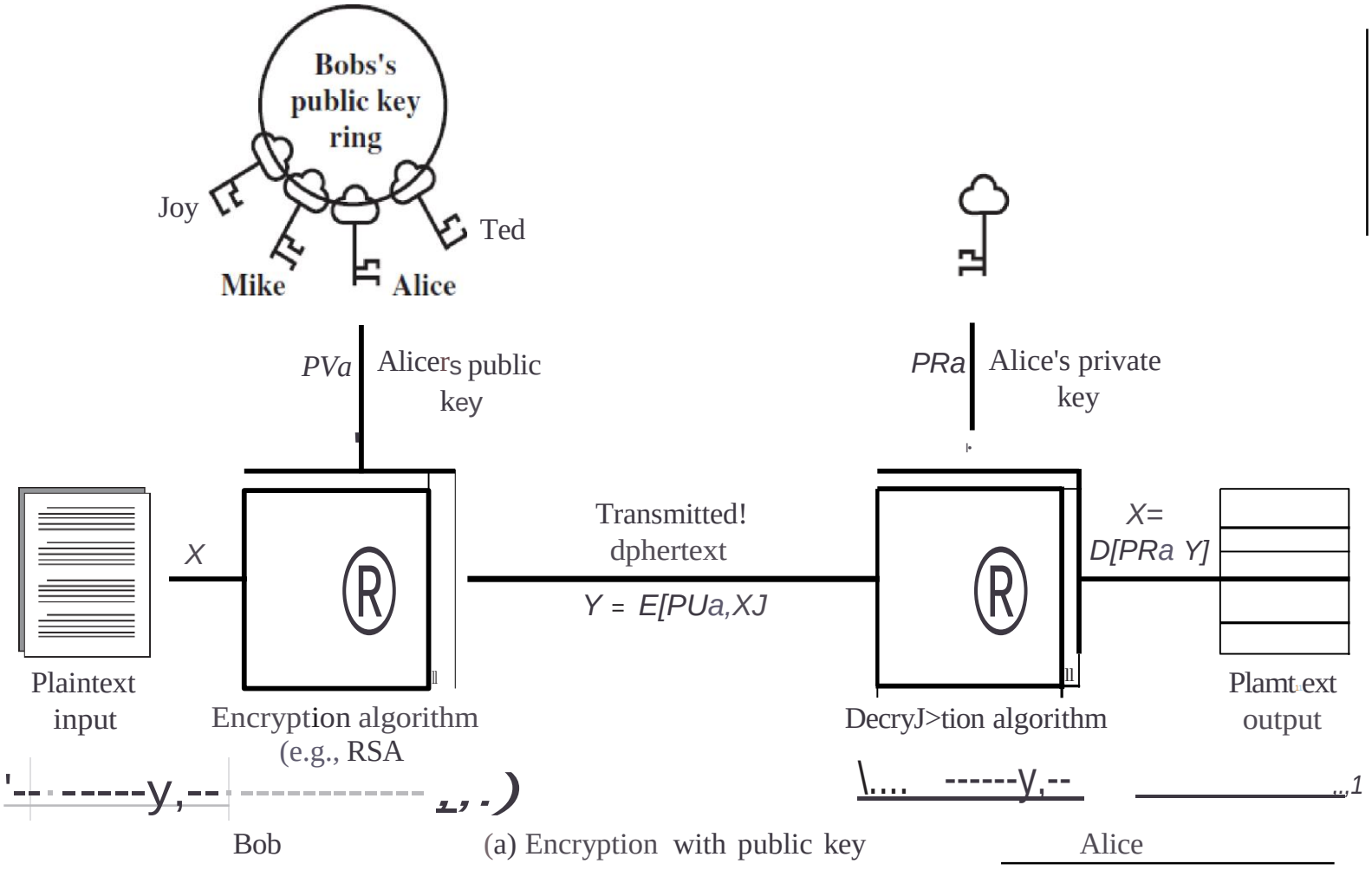
Public-Key Encryption Structure

- 3. If Bob wishes to send a private message to Alice, Bob encrypts the message using Alice's public key.

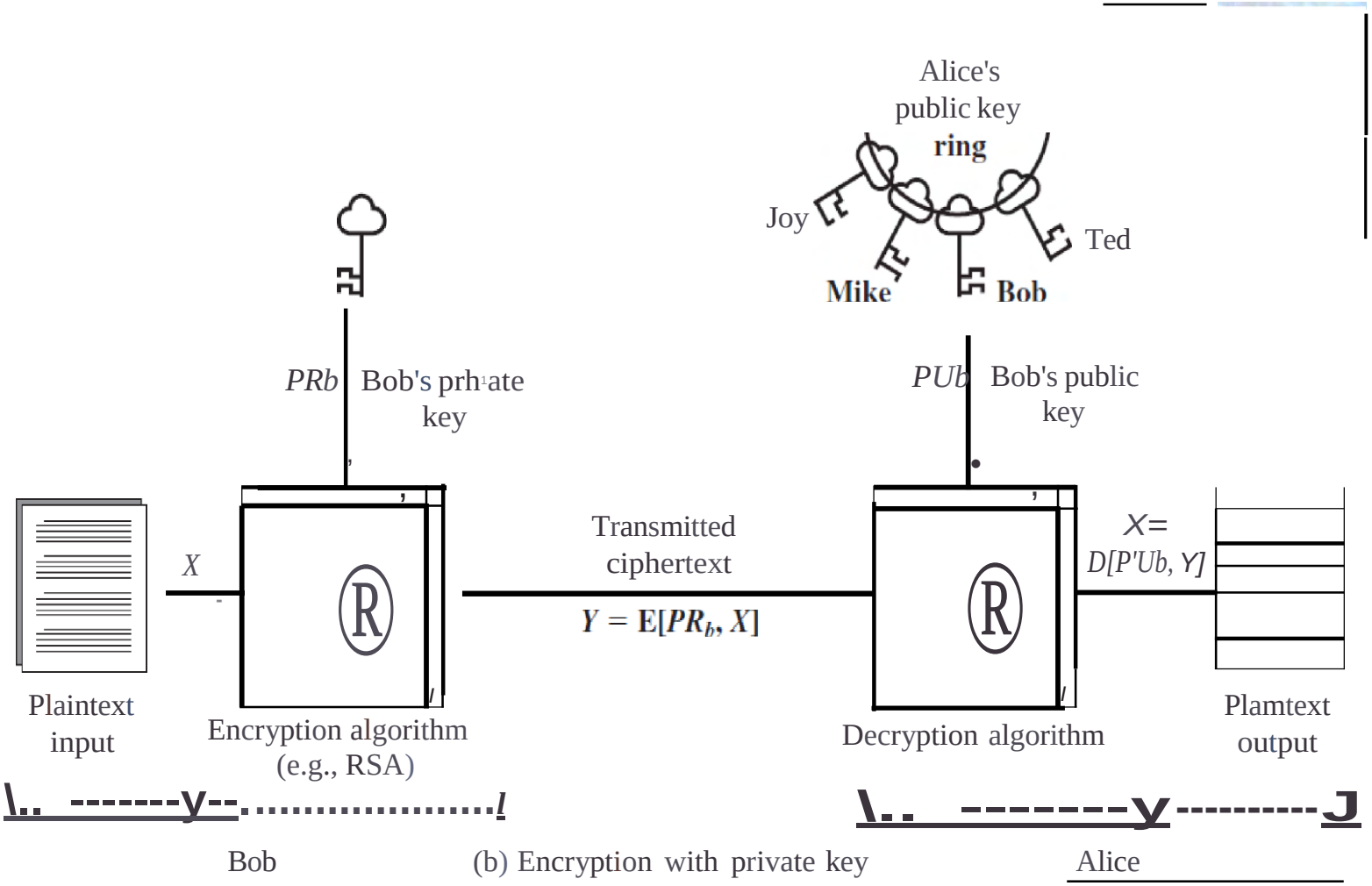
Public-Key Encryption Structure

- 4. When Alice receives the message, she decrypts it using her private key.
- No other recipient can decrypt the message because only Alice knows Alice's private key.

Public-Key Encryption Structure



Public-Key Encryption Structure



Applications/Requirements for Public-key

Network Security

Applications/Requirements for Public-key

Objectives of the Topic

- After completing this topic, a student will be able to
  - Describe applications and requirements for public-key cryptosystems.

Applications/Requirements for Public-key

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Applications/Requirements for Public-key

- Public-key cryptography is asymmetric, involving the use of two separate keys.

Applications/Requirements for Public-key

- With this approach, all participants have access to public keys, and private keys are generated locally by each participant and therefore need never be distributed.

Applications/Requirements for Public-key

- As long as a user protects his or her private key, incoming communication is secure.
- At any time, a user can change the private key and publish its companion public key to replace the old public key.

Applications/Requirements for Public-key

Misconceptions

- 1. Public-key encryption is more secure from cryptanalysis than conventional encryption.

Applications/Requirements for Public-key

- 2. Public-key encryption is a general-purpose technique that has made conventional encryption obsolete.

Applications/Requirements for Public-key

- 3. There is a feeling that key distribution is trivial when using public-key encryption, compared to the rather cumbersome handshaking involved with key distribution centers for conventional encryption.

Applications/Requirements for Public-key

Applications

- Public-key systems are characterized by the use of a cryptographic type of algorithm with two keys, one held private and one available publicly.

Applications/Requirements for Public-key

- Depending on the application, the sender uses either the sender's private key, the receiver's public key, or both to perform some type of cryptographic function.

Applications/Requirements for Public-key

- We can classify the use of public-key cryptosystems into three categories:
- Encryption/Decryption
- Digital Signatures
- Key Exchange

Applications/Requirements for Public-key

- **Encryption/decryption:**
- The sender encrypts a message with the recipient's public key.

Applications/Requirements for Public-key

- **Digital signature:**
- The sender “signs” a message with its private key. Signing is achieved by a cryptographic algorithm applied to the message or to a small block of data that is a function of the message.

Applications/Requirements for Public-key

- **Key exchange:**
- Two sides cooperate to exchange a session key.
- Several different approaches are possible, involving the private key(s) of one or both parties.

Applications/Requirements for Public-key

- Some public-key algorithms are suitable for all three applications, whereas others can be used only for one or two of these applications.

Applications/Requirements for Public-key

Algorithm	Encryption/Decryption	Digital Signature	Key Exchange
RSA	Yes	Yes	Yes
Diffie-Hellman	No	No	Yes
DSS	No	Yes	No
Elliptic curve	Yes	Yes	Yes

Applications/Requirements for Public-key

Requirements

- A public-key cryptosystem depends on a cryptographic algorithm based on two related keys.

Applications/Requirements for Public-key

- Diffie and Hellman lay out the conditions that such algorithms must fulfill
- 1. It is computationally easy for a party B to generate a pair (public key PU_b, private key PR_b).

Applications/Requirements for Public-key

- 2. It is computationally easy for a sender A, knowing the public key and the message to be encrypted, M, to generate the corresponding ciphertext:
- $C = E(PU_b, M)$

Applications/Requirements for Public-key

- 3. It is computationally easy for the receiver B to decrypt the resulting ciphertext using the private key to recover the original message:
- $M = D(PR_b, C) = D[PR_b, E(PU_b,M)]$

Applications/Requirements for Public-key

- 4. It is computationally infeasible for an opponent, knowing the public key, PU_b, to determine the private key, PR_b.

Applications/Requirements for Public-key

- 5. It is computationally infeasible for an opponent, knowing the public key, PU_b, and a ciphertext, C, to recover the original message, M.

Applications/Requirements for Public-key

End

- 6. Either of the two related keys can be used for encryption, with the other used for decryption.
- $M = D[PU_b, E(PR_b, M)] = D[PR_b, E(PU_b,M)]$
- This requirement is useful but not necessary.

The RSA Public-Key Encryption Algorithm

Network Security

The RSA Public-Key Encryption Algorithm

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain working of the RSA Public-Key encryption algorithm.

The RSA Public-Key Encryption Algorithm

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

The RSA Public-Key Encryption Algorithm

- RSA is the best known, and widely used general public key encryption scheme.
- It was first published by Rivest, Shamir & Adleman of MIT in 1978.

The RSA Public-Key Encryption Algorithm

- The RSA scheme is a cipher in which the plaintext and ciphertext are integers between 0 and n - 1 for some n.
- A typical size for n is 1024 bits, or 309 decimal digits. That is, n is less than 2^{1024}.

The RSA Public-Key Encryption Algorithm

- RSA is based on exponentiation in a finite (Galois) field over integers modulo a prime.
- Security due to cost of factoring large numbers.

The RSA Public-Key Encryption Algorithm

Description

- Plaintext is encrypted in blocks, with each block having a binary value less than some number n.
- The block size must be less than or equal to $\log_2(n) + 1$; in practice, the block size is i bits, where $2^i < n \leq 2^{i+1}$.

The RSA Public-Key Encryption Algorithm

- Encryption and decryption are of the following form, for some plaintext block M and ciphertext block C.
- $C = M^e \bmod n$
- $M = C^d \bmod n = (M^e)^d \bmod n = M^{ed} \bmod n$

The RSA Public-Key Encryption Algorithm

- Both sender and receiver must know the value of n.
- The sender knows the value of e, and only the receiver knows the value of d.

The RSA Public-Key Encryption Algorithm

- Here, the public key of PU = {e, n} and the private key of PR = {d, n}.
- For this algorithm to be satisfactory for public-key encryption, following requirements must be met:

The RSA Public-Key Encryption Algorithm

- 1. It is possible to find values of e, d, and n such that $M^{ed} \bmod n = M$ for all $M < n$.
- 2. It is relatively easy to calculate $M^{e} \bmod n$ and $C^{d} \bmod n$ for all values of $M < n$.
- 3. It is infeasible to determine d given e and n.

The RSA Public-Key Encryption Algorithm

Summary

Key Generation

Select p, q	p and q both prime, $p \neq q$
Calculate $n = p \times q$	
Calculate $\phi(n) = (p-1)(q-1)$	
Select integer e	$\gcd(\phi(n), e) = 1;\ 1 < e < \phi(n)$
Calculate d	$de \bmod \phi(n) = 1$
Public key	$KU = \{e, n\}$
Private key	$KR = \{d, n\}$

Encryption

Plaintext:	$M < n$
Ciphertext:	$C = M^e \pmod{n}$

Decryption

Ciphertext:	C
Plaintext:	$M = C^d \pmod{n}$

The RSA Public-Key Encryption Algorithm

Example

- **Key Generation**
- 1. Select two prime numbers, p= 17 and q= 11.
- 2. Calculate n = pq = 17 × 11 = 187.
- 3. Calculate $\omega(n) = (p-1)(q-1) = 16 \times 10 = 160$.

The RSA Public-Key Encryption Algorithm

- 4. Select e such that e is relatively prime to $\varphi(n) = 160$ and less than $\varphi(n)$; we choose e=7.
- 5. Determine d such that de mod 160 =1 and d < 160.The correct value is d=23, because 23 × 7=161= (1 × 160)+1.

The RSA Public-Key Encryption Algorithm

- The resulting keys are public key PU={7, 187} and private key PR= {23, 187}.
- **Encryption**
- Lets use these keys for a plaintext input of *M* = 88.
- Here, we need to calculate C= 88^7 mod 187.

The RSA Public-Key Encryption Algorithm

- **Decryption**
- We need to calculate $M = 11^{23} \bmod 187$
- Above expressions can be evaluated by exploiting the properties of modular arithmetic.

The RSA Public-Key Encryption Algorithm

The Security of RSA

- There are two possible approaches to defeating the RSA algorithm.
- The first is the brute-force approach: Try all possible private keys.

The RSA Public-Key Encryption Algorithm

- Thus, the larger the number of bits in e and d, the more secure the algorithm.
- However, because the calculations involved are complex, the larger the size of the key, the slower the system will run.

The RSA Public-Key Encryption Algorithm

- Most discussions of the cryptanalysis of RSA have focused on the task of factoring n into its two prime factors.
- For a large n with large prime factors, factoring is a hard problem.

The RSA Public-Key Encryption Algorithm

- A large key size such as a 1024-bit key size (about 300 decimal digits) is considered strong enough for virtually all applications.

End

Diffie-Hellman Algorithm

Network Security

Diffie-Hellman Algorithm

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe the Diffie-Hellman algorithm.

Diffie-Hellman Algorithm

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Diffie-Hellman Algorithm

- The first published public-key algorithm that defined public-key cryptography was published by Diffie and Hellman.
- It is generally referred to as the Diffie – Hellman key exchange.

Diffie-Hellman Algorithm

- A number of commercial products employ this key exchange technique.

Diffie-Hellman Algorithm

- Purpose of the algorithm is to enable two users to exchange a secret key securely that then can be used for subsequent encryption of messages
- The algorithm itself is limited to the exchange of the keys.

Diffie-Hellman Algorithm

- Depends for its effectiveness on the difficulty of computing discrete logarithms.

Diffie-Hellman Algorithm

The Algorithm

- Lets assume that there are two publicly known numbers: a prime number q and an integer α that is a primitive root of q.

Diffie-Hellman Algorithm

- For a prime number p, if α is a primitive root of p, then $\alpha, \alpha^2, \ldots, \alpha^{p-1}$ are distinct (mod p).
- E.g. for prime number 19, its primitive roots are 2, 3, 10, 13, 14, and 15.
- Suppose the users A and B wish to create a shared key.

Diffie-Hellman Algorithm

- User A selects a random integer $X_A < q$ and computes $Y_A = \alpha^{XA} \bmod q$.
- Similarly, user B independently selects a random integer $X_B < q$ and computes $Y_B = \alpha^{XB} \bmod q$.

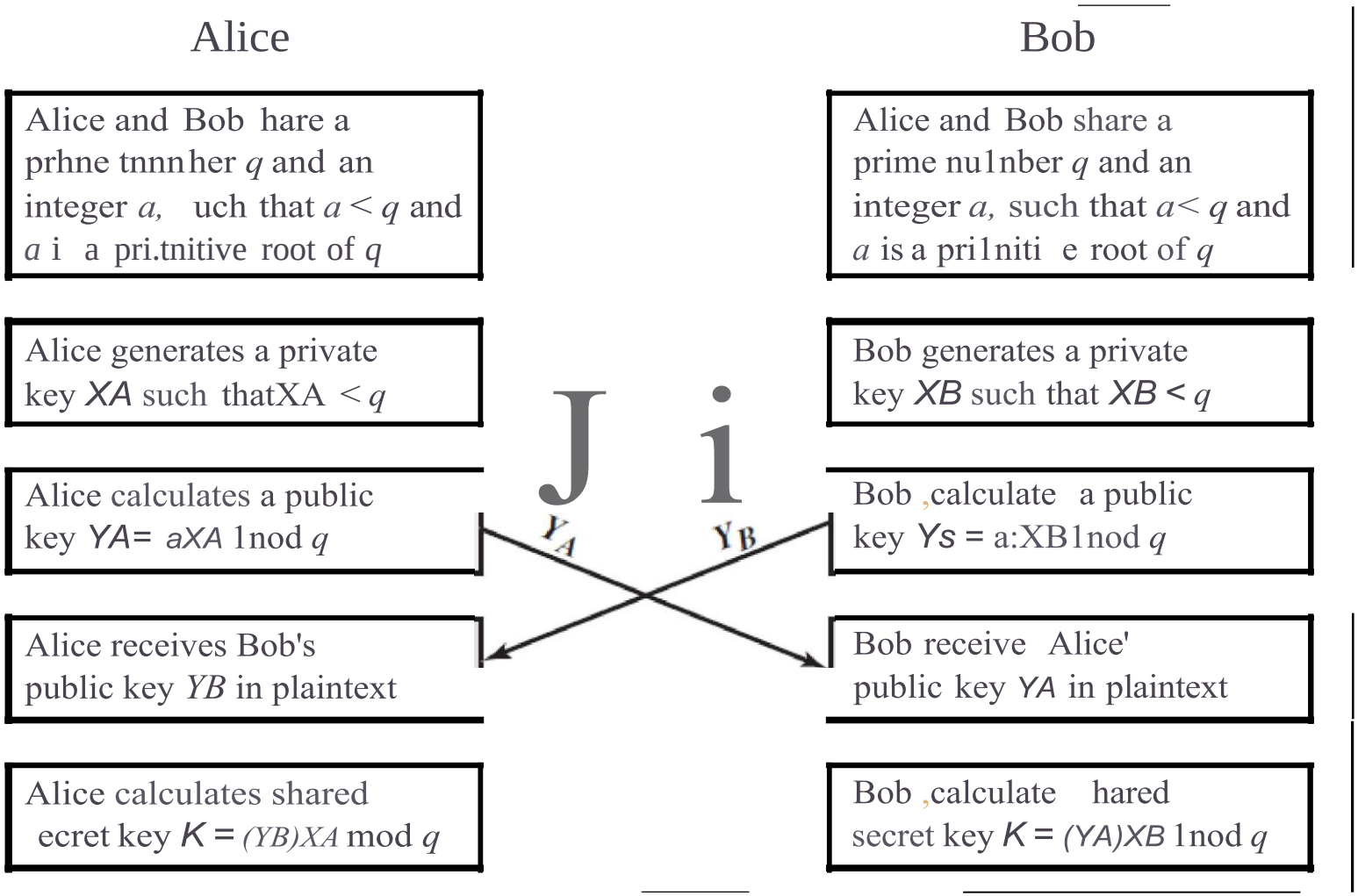
Diffie-Hellman Algorithm

- Each side keeps the X value private and makes the Y value available publicly to the other side.
- Thus, X_A is A's private key and Y_A is A's corresponding public key,
- The same applies for B.

Diffie-Hellman Algorithm

- User A computes the key as $K = (Y_B)^{XA} \bmod q$ and
- User B computes the key as $K = (Y_A)^{XB} \bmod q$.
- The result is that the two sides have exchanged a secret value.

Diffie-Hellman Algorithm



Diffie-Hellman Algorithm

Example:

- Lets take q = 353 and a primitive root of 353, $\alpha = 3$.
- A and B select private keys $X_A = 97$ and $X_B = 233$, respectively.

Diffie-Hellman Algorithm

- Each computes its public key:
- A computes $Y_A = 3^{97} \bmod 353 = 40$.
- B computes $Y_B = 3^{233} \bmod 353 = 248$.
- After they exchange public keys, each can compute the common secret key:

Diffie-Hellman Algorithm

- A computes $K = (Y_B)^{XA} \bmod 353 = 248^{97} \bmod 353 = 160$.
- B computes $K = (Y_A)^{XB} \bmod 353 = 40^{233} \bmod 353 = 160$.
- an attacker would have available the following information:
- $q = 353$; $\alpha = 3$; $Y_A = 40$; $Y_B = 248$.

Diffie-Hellman Algorithm

- In this simple example, it would be possible by brute force to determine the secret key 160.

Diffie-Hellman Algorithm

End

Security of the Diffie-Hellman algorithm:

- While it is relatively easy to calculate exponentials modulo a prime, it is very difficult to calculate discrete logarithms.
- For large primes, the latter task is considered infeasible.

Key Exchange, Man-in-the-Middle Attack

Network Security

Key Exchange, Man-in-the-Middle Attack

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe Man-in-the-Middle Attack while performing key exchange.

Key Exchange, Man-in-the-Middle Attack

Figures and material in this topic have been adapted from

- *"Network Security Essentials : Applications and Standards"*, 2014, by William Stallings.

Key Exchange, Man-in-the-Middle Attack

Key Exchange Protocol: An Example

- Suppose that user A wishes to set up a connection with user B and use a secret key to encrypt messages on that connection.

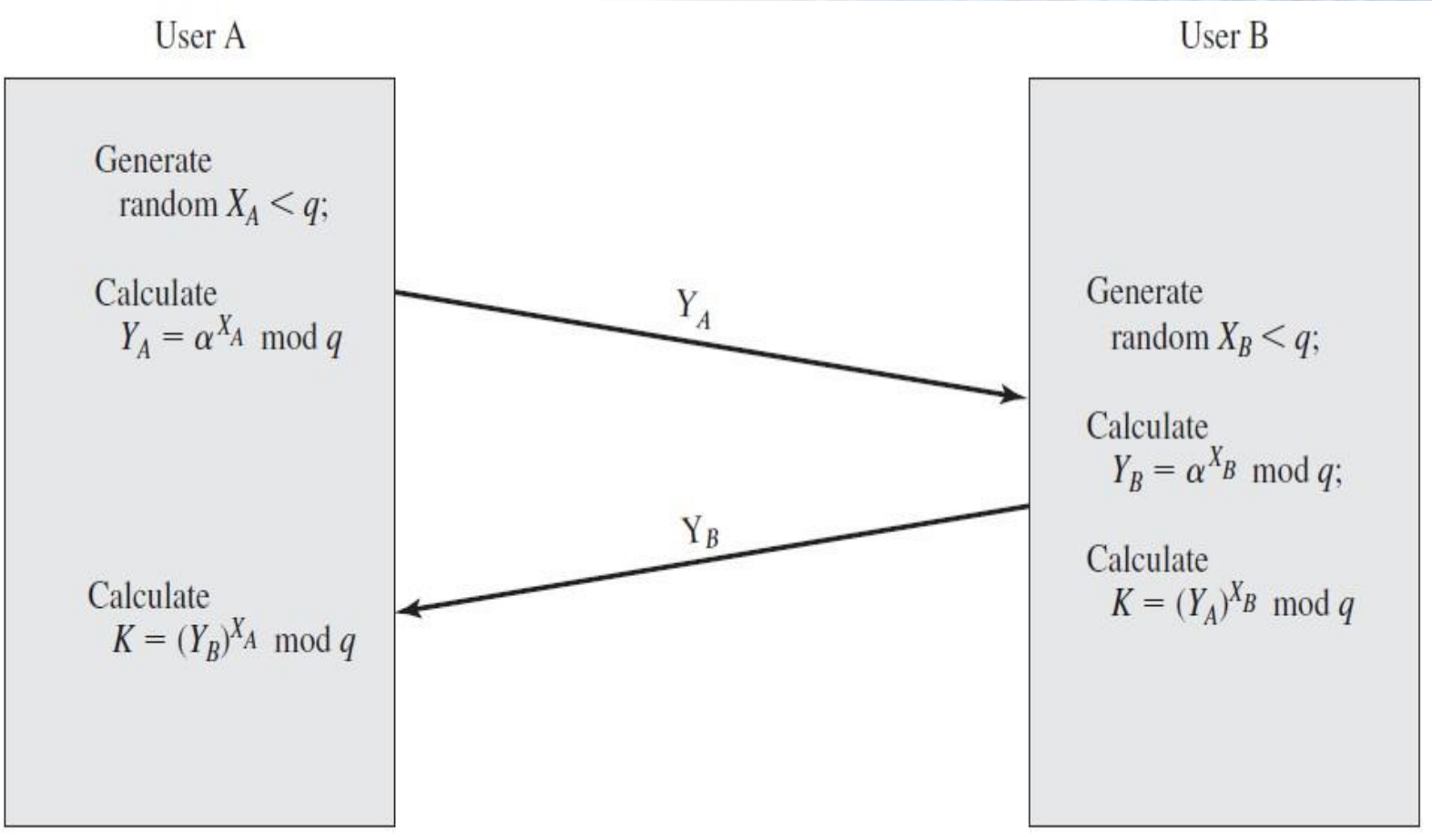
Key Exchange, Man-in-the-Middle Attack

- User A can generate a one-time private key X_A, calculate public value Y_A, and send that to user B.
- User B responds by generating a private value X_B, calculating Y_B, and sending Y_B to user A.

Key Exchange, Man-in-the-Middle Attack

- Both users can now calculate the key.
- The necessary public values q and α would need to be known ahead of time.

Key Exchange, Man-in-the-Middle Attack



Key Exchange, Man-in-the-Middle Attack

Key Exchange Protocol: Another Example

- Suppose that a group of users (e.g., all users on a LAN) each generate a long-lasting private value X_i (for user i) and calculate a public value Y_i.

Key Exchange, Man-in-the-Middle Attack

- These public values, together with global public values for q and α, are stored in some central directory.

Key Exchange, Man-in-the-Middle Attack

- At any time, user *j* can access user *i*'s public value, calculate a secret key, and use that to send an encrypted message to user *i*.

Key Exchange, Man-in-the-Middle Attack

- If the central directory is trusted, then this form of communication provides both confidentiality and a degree of authentication.

Key Exchange, Man-in-the-Middle Attack

- However, the technique does not protect against replay attacks.

Key Exchange, Man-in-the-Middle Attack

Man-in-the-Middle Attack

- Suppose Alice and Bob wish to exchange keys, and Darth is the adversary.
- The man-in-the-middle attack proceeds as follows

Key Exchange, Man-in-the-Middle Attack

- 1. Darth prepares for the attack by generating two random private keys X_{D1} and X_{D2} and then computing the corresponding public keys Y_{D1} and Y_{D2}.

Key Exchange, Man-in-the-Middle Attack

- 2. Alice transmits Y_A to Bob.
- 3. Darth intercepts Y_A and transmits Y_{D1} to Bob. Darth also calculates $K_2 = (Y_A)X_{D2} \bmod q$.

Key Exchange, Man-in-the-Middle Attack

- 4. Bob receives Y_{D1} and calculates $K_1 = (Y_{D1})X_B \bmod q$.
- 5. Bob transmits Y_B to Alice.
- 6. Darth intercepts Y_B and transmits Y_{D2} to Alice. Darth calculates $K_1 = (Y_B)X_{D1} \bmod q$.

Key Exchange, Man-in-the-Middle Attack

- 7. Alice receives Y_{D2} and calculates $K_2 = (Y_{D2})X_A \bmod q$.

Key Exchange, Man-in-the-Middle Attack

- At this point, Bob and Alice think that they share a secret key, but instead Bob and Darth share secret key K1 and Alice and Darth share secret key K2.
- All future communication bet. Bob and Alice works in following way.

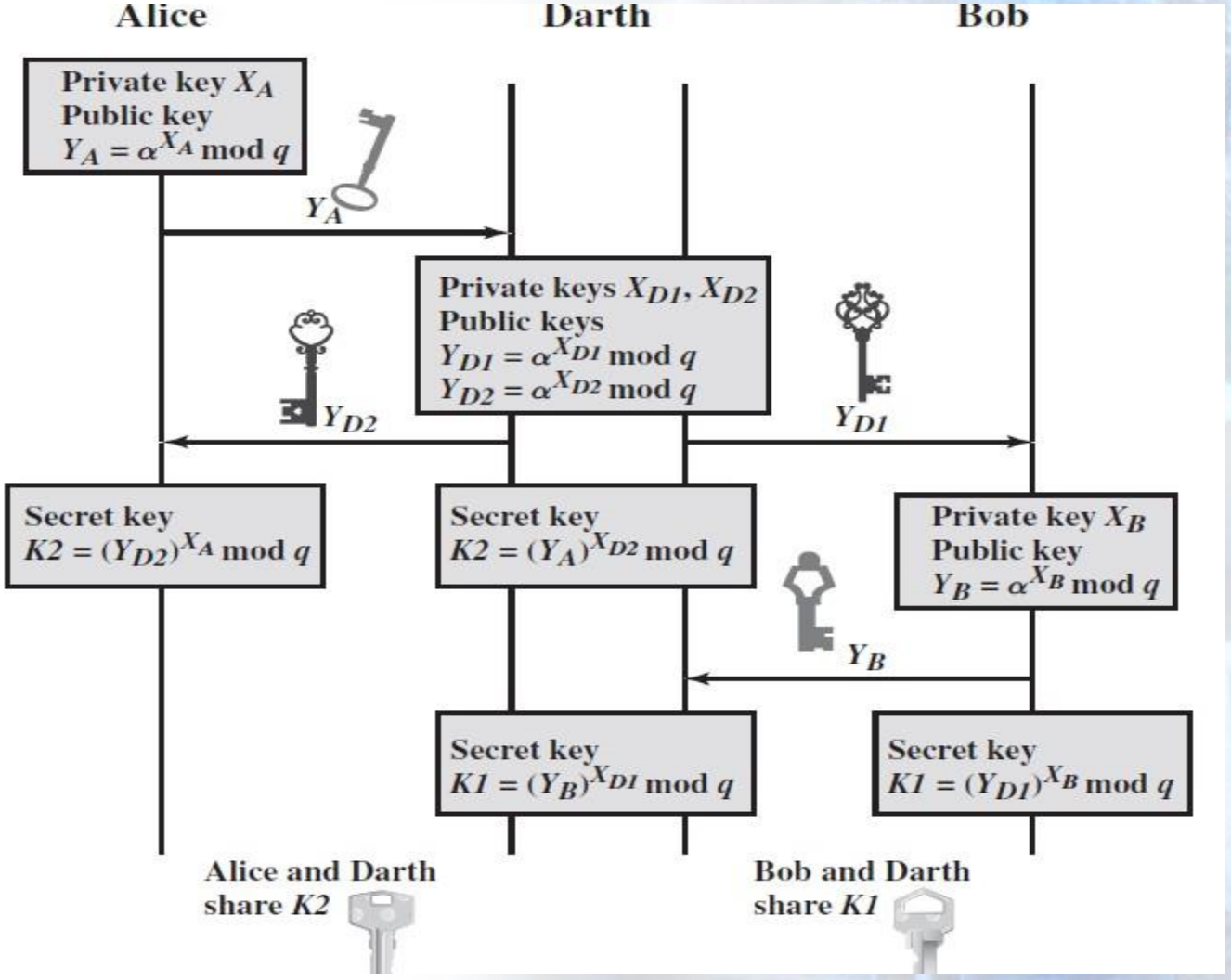
Key Exchange, Man-in-the-Middle Attack

- 1. Alice sends an encrypted message M: E(K2, M).
- 2. Darth intercepts the encrypted message and decrypts it to recover M.
- 3. Darth sends Bob E(K1, M) or E(K1, M'), where M' is any message.

Key Exchange, Man-in-the-Middle Attack

- In the first case, Darth simply wants to eavesdrop on the communication without altering it. In the second case, Darth wants to modify the message going to Bob.

Key Exchange, Man-in-the-Middle Attack



Key Exchange, Man-in-the-Middle Attack

- The key exchange protocol is vulnerable to such an attack because it does not authenticate the participants.

End

Digital Signature Standard (DSS)

Network Security

Digital Signature Standard (DSS)

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain Digital Signature Standard (DSS).

Digital Signature Standard (DSS)

Figures and material in this topic have been adapted from

- *W. Stalling's "Network Security Essentials "*, 2014.
- *W. Stalling's "Cryptography and Network Security Principles and Practice"*, 2014.

Digital Signature Standard (DSS)

- The most important development from the work on public-key cryptography is the digital signature.
- It provides a set of security capabilities that would be difficult to implement in any other way.

Digital Signature Standard (DSS)

- The National Institute of Standards and Technology (NIST) has published Federal Information Processing Standard FIPS 186, known as the Digital Signature Standard (DSS) or the Digital Signature Algorithm (DSA).

Digital Signature Standard (DSS)

- The DSA makes use of the Secure Hash Algorithm (SHA).
- The DSA was originally proposed in 1991 and revised in 1993 in response to public feedback concerning the security of the scheme.

Digital Signature Standard (DSS)

- There was a further minor revision in 1996.
- In 2000, an expanded version of the standard was issued as FIPS 186-2, subsequently updated to FIPS 186-3 in 2009.

Digital Signature Standard (DSS)

The DSA Approach

- employs an algorithm designed to provide only the digital signature function.
- it is a public-key technique.
- Unlike RSA, it cannot be used for encryption or key exchange.

Digital Signature Standard (DSS)

- **The RSA Approach for Digital Signatures:**
- When RSA is used for digital signatures, the message to be signed is input to a hash function that produces a secure hash code of fixed length.

Digital Signature Standard (DSS)

- This hash code is then encrypted using the sender's private key to form the signature.
- Both the message and the signature are then transmitted.
- The recipient takes the message and produces a hash code.

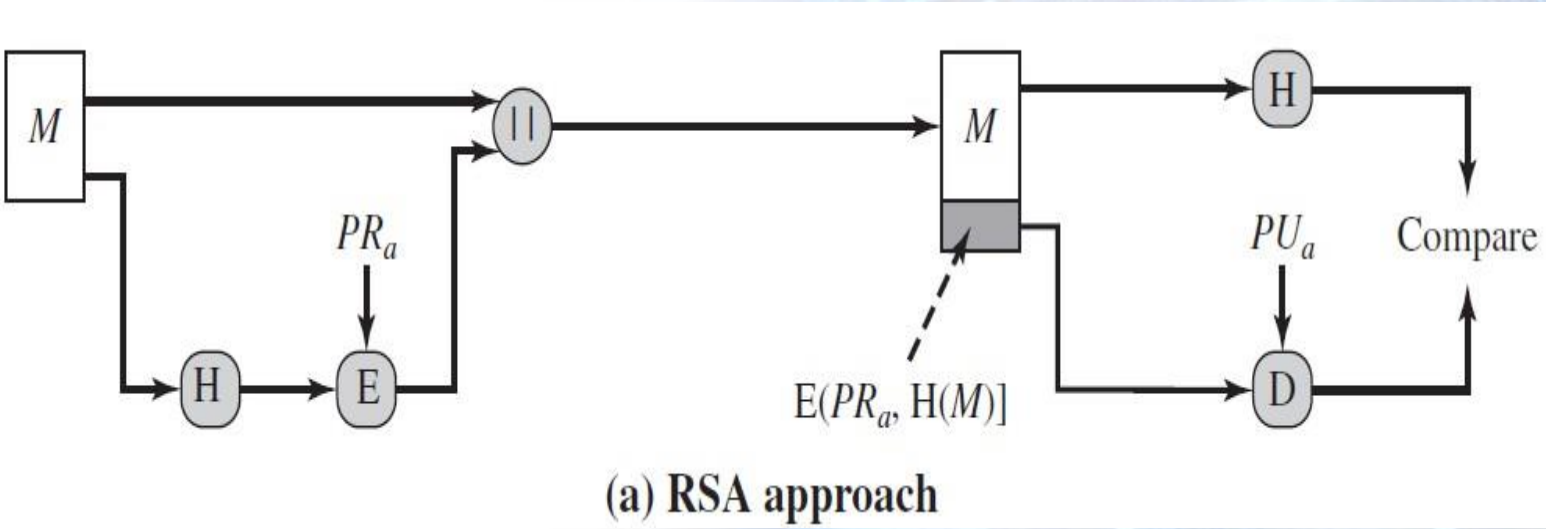
Digital Signature Standard (DSS)

- The recipient also decrypts the signature using the sender's public key.
- If the calculated hash code matches the decrypted signature, the signature is accepted as valid.

Digital Signature Standard (DSS)

- Because only the sender knows the private key, only the sender could have produced a valid signature.

Digital Signature Standard (DSS)



(a) RSA approach

Digital Signature Standard (DSS)

- **The DSA Approach:**
- also makes use of a hash function.
- The hash code is provided as input to a signature function along with a random number k generated for this particular signature.

Digital Signature Standard (DSS)

- The signature function also depends on the sender's private key (PRa) and a set of parameters known to a group of communicating principals.

Digital Signature Standard (DSS)

- We can consider this set to constitute a global public key (PUG).
- The result is a signature consisting of two components, labeled s and r.

Digital Signature Standard (DSS)

- At the receiving end, the hash code of the incoming message is generated.
- This plus the signature is input to a verification function.

Digital Signature Standard (DSS)

- The verification function also depends on the global public key as well as the sender's public key (PUa), which is paired with the sender's private key.

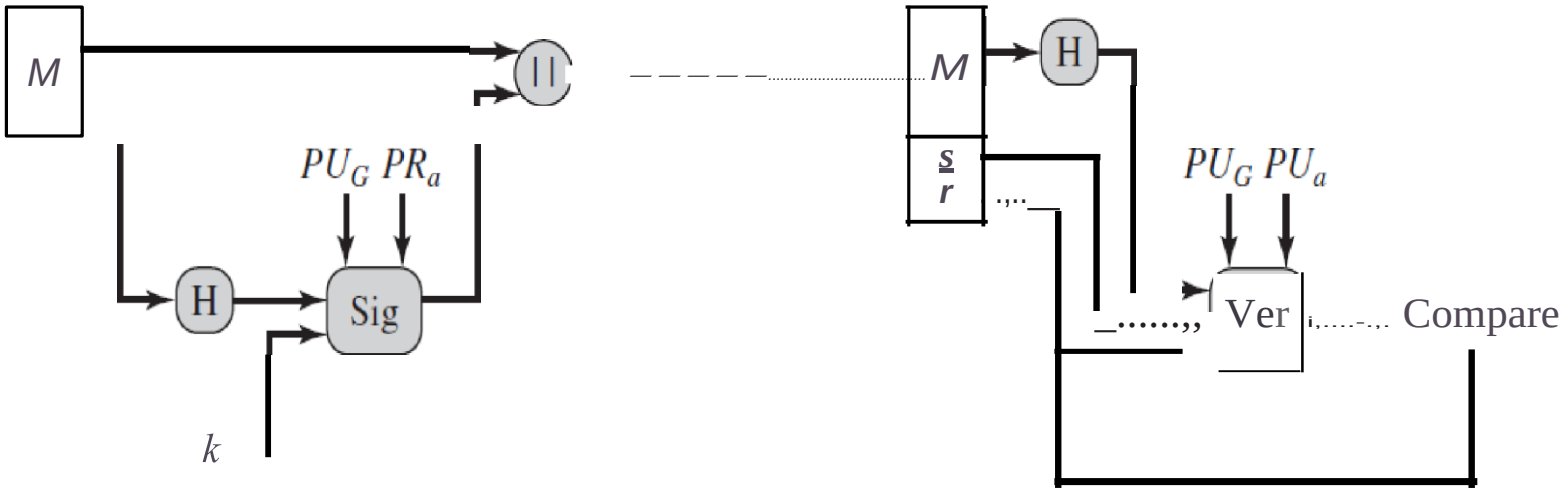
Digital Signature Standard (DSS)

- The output of the verification function is a value that is equal to the signature component r if the signature is valid.

Digital Signature Standard (DSS)

- The signature function is such that only the sender, with knowledge of the private key, could have produced the valid signature.

Digital Signature Standard (DSS)



(b) DSA approach

Elliptic-Curve Cryptography (ECC)

Network Security

Elliptic-Curve Cryptography (ECC)

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe Elliptic-Curve Cryptography (ECC).

Elliptic-Curve Cryptography (ECC)

Figures and material in this topic have been adapted from

- *W. Stalling's "Network Security Essentials "*, 2014.
- *W. Stalling's "Cryptography and Network Security Principles and Practice"*, 2014.

Elliptic-Curve Cryptography (ECC)

- Most of the products and standards that use public-key cryptography for encryption and digital signatures use RSA.

Elliptic-Curve Cryptography (ECC)

- The key length for secure RSA use has increased over recent years, and this has put a heavier processing load on applications using RSA.

Elliptic-Curve Cryptography (ECC)

- This burden has ramifications, especially for electronic commerce sites that conduct large numbers of secure transactions.

Elliptic-Curve Cryptography (ECC)

- A competing system challenges RSA: elliptic curve cryptography (ECC).
- It is showing up in standardization efforts, including the IEEE P1363 Standard for Public-Key Cryptography.

Elliptic-Curve Cryptography (ECC)

- The principal attraction of ECC, compared to RSA, is that it appears to offer equal security for a far smaller key size, thereby reducing processing overhead.

Elliptic-Curve Cryptography (ECC)

- Although the theory of ECC has been around for some time, it is only recently that products have begun to appear and that there has been sustained cryptanalytic interest in probing for weaknesses.

Elliptic-Curve Cryptography (ECC)

- Accordingly, the confidence level in ECC is not yet as high as that in RSA.

Elliptic-Curve Cryptography (ECC)

- An elliptic curve is defined by an equation in two variables with coefficients.
- For cryptography, the variables and coefficients are restricted to elements in a finite field.

Elliptic-Curve Cryptography (ECC)

- The addition operation in ECC is the counterpart of modular multiplication in RSA, and multiple addition is the counterpart of modular exponentiation.

Elliptic-Curve Cryptography (ECC)

Analog of Diffie-Hellman Key Exchange

- First pick a large integer q, which is either a prime number p or an integer of the form 2^m, and elliptic curve parameters a and b.

Elliptic-Curve Cryptography (ECC)

- This defines the elliptic group of points $E_q(a, b)$.
- Next, pick a base point $G = (x_1, y_1)$ in $E_p(a, b)$ whose order is a very large value n.

Elliptic-Curve Cryptography (ECC)

- 1. A selects an integer n_A less than n.
- This is A's private key.
- A then generates a public key $P_A = n_A \times G$; the public key is a point in $E_q(a, b)$.

Elliptic-Curve Cryptography (ECC)

- 2. B similarly selects a private key n_B and computes a public key P_B.
- 3. A generates the secret key $k = n_A \times P_B$. B generates the secret key $k = n_B \times P_A$.

Elliptic-Curve Cryptography (ECC)

- The two calculations in step 3 produce the same result because $n_A \times P_B = n_A \times (n_B \times G) = n_B \times (n_A \times G) = n_B \times P_A$
- To break this scheme, an attacker would need to be able to compute k given G and kG, which is assumed to be hard.

Elliptic-Curve Cryptography (ECC)

Elliptic Curve Encryption/Decryption:

- It requires a point G and an elliptic group $E_q(a, b)$ as parameters.
- Each user A selects a private key n_A and generates a public key $P_A = n_A \times G$.

Elliptic-Curve Cryptography (ECC)

- To encrypt and send a message P_m to B, A chooses a random positive integer k and produces the ciphertext C_m consisting of the pair of points:
- $C_m = \{kG, P_m + kP_B\}$
- Note that A has used B's public key P_B.

Elliptic-Curve Cryptography (ECC)

- To decrypt the ciphertext, B multiplies the first point in the pair by B's private key and subtracts the result from the second point:
- $P_m + kP_B - n_B(kG) = P_m + k(n_BG) - n_B(kG) = P_m$

Elliptic-Curve Cryptography (ECC)

- A has masked the message P_m by adding kP_B to it.
- Nobody but A knows the value of k, so even though P_B is a public key, nobody can remove the mask kP_B.

Elliptic-Curve Cryptography (ECC)

End

- There is a computational advantage to using ECC with a shorter key length than a comparably secure RSA.

Digital Signatures

Network Security

Digital Signatures

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain the use of digital signatures.

Digital Signatures

Figures and material in this topic have been adapted from

- *W. Stalling's "Network Security Essentials "*, 2014.
- *W. Stalling's "Cryptography and Network Security Principles and Practice"*, 2014.

Digital Signatures

- Data appended to a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery (e.g., by the recipient).

Digital Signatures

- Message authentication protects two parties who exchange messages from any third party.
- It does not protect the two parties against each other. Several forms of dispute bet. the two are possible.

Digital Signatures

- Suppose that John sends an authenticated message to Mary.
- Consider the following disputes that could arise.

Digital Signatures

- 1. Mary may forge a different message and claim that it came from John. Mary would simply have to create a message and append an authentication code using the key that John and Mary share.

Digital Signatures

- E.g. an electronic funds transfer takes place, and the receiver increases the amount of funds transferred and claims that the larger amount had arrived from the sender.

Digital Signatures

- 2. John can deny sending the message. Because it is possible for Mary to forge a message, there is no way to prove that John did in fact send the message.

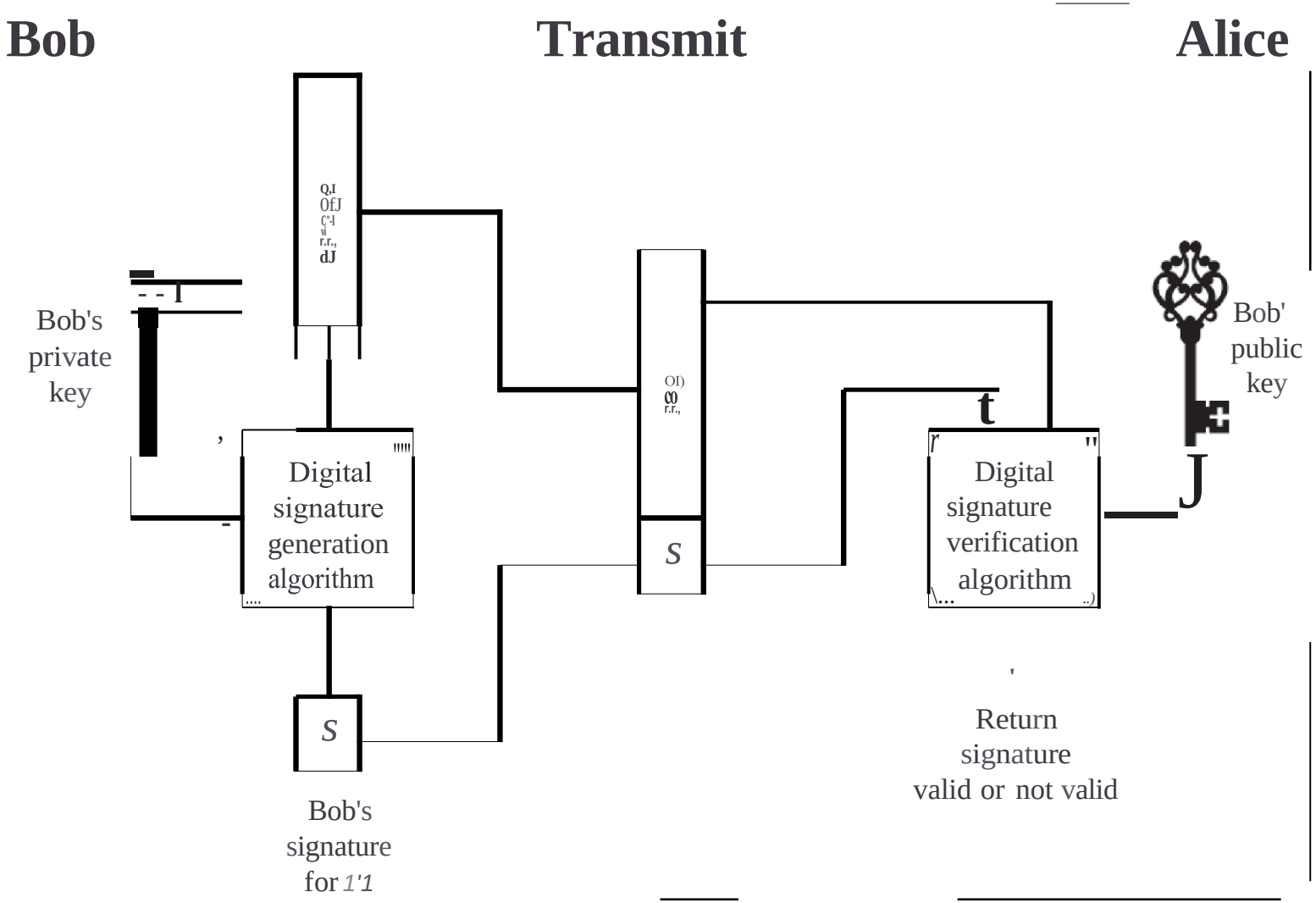
Digital Signatures

- E.g. an electronic mail message contains instructions to a stockbroker for a transaction that subsequently turns out badly. The sender pretends that the message was never sent.

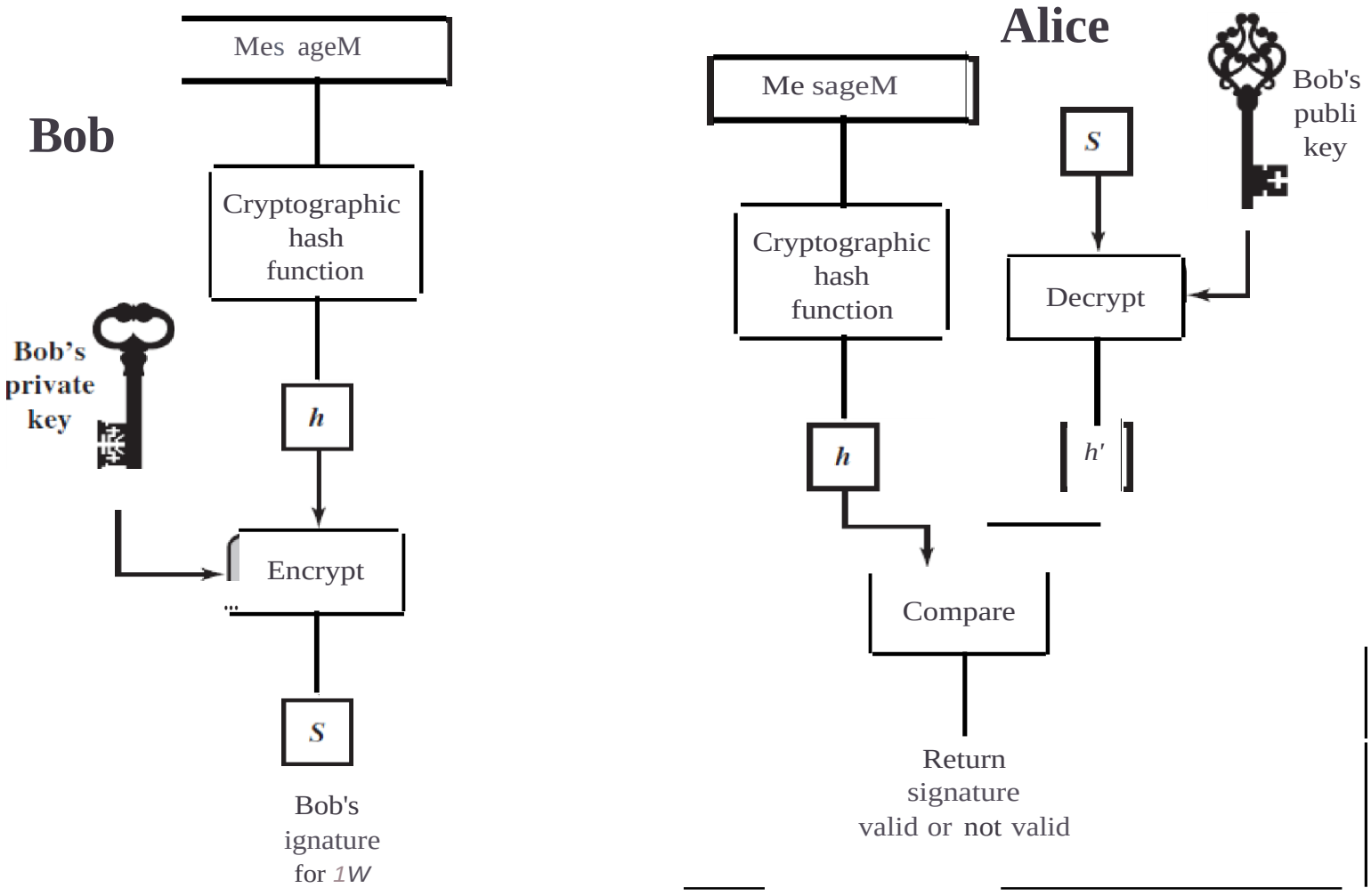
Digital Signatures

- In situations where there is not complete trust between sender and receiver, we use the digital signature.

Digital Signatures



Digital Signatures



Digital Signatures

Properties

- It must verify the author and the date and time of the signature.
- It must authenticate the contents at the time of the signature.
- It must be verifiable by third parties, to resolve disputes.

Digital Signatures

Attacks and Forgeries

- Assume that A denotes the user whose signature method is being attacked, and C denotes the attacker.

Digital Signatures

- **Key-only attack:** C only knows A's public key.
- **Known message attack:** C is given access to a set of messages and their signatures

Digital Signatures

- **Generic chosen message attack:** C chooses a list of messages before attempting to breaks A's signature scheme, independent of A's public key.
- C then obtains from A valid signatures for the chosen messages.

Digital Signatures

- The attack is generic, because it does not depend on A's public key; the same attack is used against everyone.

Digital Signatures

- **Directed chosen message attack:** Similar to the generic attack, except that the list of messages to be signed is chosen after C knows A's public key but before any signatures are seen.

Digital Signatures

- **Adaptive chosen message attack:** C is allowed to use A as an "oracle." This means that C may request from A signatures of messages that depend on previously obtained message-signature pairs.

Digital Signatures

Digital Signature Requirements

- The signature must be a bit pattern that depends on the message being signed.
- The signature must use some information unique to the sender to prevent both forgery and denial.

Digital Signatures

- It must be relatively easy to produce the digital signature.
- It must be relatively easy to recognize and verify the digital signature.

Digital Signatures

- It must be computationally infeasible to forge a digital signature, either by constructing a new message for an existing digital signature or by constructing a fraudulent digital signature for a given message.

Digital Signatures

- It must be practical to retain a copy of the digital signature in storage.

End

Symmetric Key Distribution

Network Security

Symmetric Key Distribution

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe how symmetric key can be distributed with symmetric encryption.

Symmetric Key Distribution

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stalling.

Symmetric Key Distribution

- For symmetric encryption to work, the two parties to an exchange must share the same key, and that key must be protected from access by others.

Symmetric Key Distribution

- Frequent key changes are usually desirable to limit the amount of data compromised if an attacker learns the key.

Symmetric Key Distribution

- The strength of any cryptographic system rests with the “key distribution technique” --- the means of delivering a key to two parties that wish to exchange data, without allowing others to see the key.

Symmetric Key Distribution

Key Distribution Options

- For two parties A and B, there are the following options:
- 1. A key could be selected by A and physically delivered to B.

Symmetric Key Distribution

- 2. A third party could select the key and physically deliver it to A and B.
- 3. If A and B have recently used a key, one party could transmit the new key to the other, using the old key to encrypt the new key.

Symmetric Key Distribution

- 4. If A and B each have an encrypted connection to a third party C, C could deliver a key on the encrypted links to A and B.

Symmetric Key Distribution

- Options 1 and 2 call for manual delivery of a key.
- For link encryption, this is a reasonable requirement, because each link encryption device is only going to be exchanging data with its partner on the other end of the link.

Symmetric Key Distribution

- However, for end-to-end encryption over a network, manual delivery is awkward.

Symmetric Key Distribution

- In a distributed system, any given host may need to engage in exchanges with many other hosts over time.
- Each device needs a number of keys supplied dynamically.
- Difficult in a wide-area distributed system.

Symmetric Key Distribution

- Option 3 is a possibility for either link encryption or end-to-end encryption, but if an attacker ever succeeds in gaining access to one key, then all subsequent keys are revealed.

Symmetric Key Distribution

- To provide keys for end-to-end encryption, option 4 is preferable.
- For option 4 , two kinds of keys are used:

Symmetric Key Distribution

- **Session key:** When two end systems wish to communicate, they establish a logical connection.
- For the duration of that logical connection, called a session, all user data are encrypted with a one-time session key.

Symmetric Key Distribution

- At the conclusion of the session, the session key is destroyed.
- **Permanent key:** is a key used between entities for the purpose of distributing session keys.

Symmetric Key Distribution

- A necessary element of option 4 is a key distribution center (KDC) .
- The operation of a KDC proceeds as follows:

Symmetric Key Distribution

- 1. When host A wishes to set up a connection to host B, it transmits a connection request packet to the KDC.
- Communication bet. A and KDC is encrypted using a master key shared only by A and the KDC.

Symmetric Key Distribution

- 2. If KDC approves the connection request, it generates a unique one-time session key.
- It encrypts the session key using the permanent key it shares with A and delivers the encrypted session key to A.

Symmetric Key Distribution

- Similarly, it encrypts the session key using the permanent key it shares with B and delivers the encrypted session key to B.

Symmetric Key Distribution

- 3. A and B can now set up a logical connection and exchange messages and data, all encrypted using the temporary session key.

End

What is Kerberos?

Network Security

What is Kerberos?

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain Kerberos.

What is Kerberos?

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stalling.

What is Kerberos?

- Kerberos is a key distribution and user authentication service developed at MIT as part of Project Athena.

What is Kerberos?

- The problem that Kerberos addresses is this:
- Assume an open distributed environment in which users at workstations wish to access services on servers distributed throughout network.

What is Kerberos?

- We would like for servers to be able to restrict access to authorized users and to be able to authenticate requests for service.
- A workstation cannot be trusted to identify its users correctly to network services.

What is Kerberos?

- In particular, the following three threats exist:
- 1. A user may gain access to a particular workstation and pretend to be another user operating from that workstation.

What is Kerberos?

- 2. A user may alter the network address of a workstation so that the requests sent from the altered workstation appear to come from the impersonated workstation.

What is Kerberos?

- 3. A user may eavesdrop on exchanges and use a replay attack to gain entrance to a server or to disrupt operations.

What is Kerberos?

- In any of these cases, an unauthorized user may be able to gain access to services and data that he or she is not authorized to access.

What is Kerberos?

- Rather than building elaborate authentication protocols at each server, Kerberos provides a centralized authentication server whose function is to authenticate users to servers and servers to users.

What is Kerberos?

- Kerberos relies exclusively on symmetric encryption, making no use of public-key encryption.

What is Kerberos?

Motivation

- If a set of users is provided with dedicated personal computers that have no network connections, then a user's resources and files can be protected by physically securing each computer.

What is Kerberos?

- When these users instead are served by a centralized time-sharing system, the time-sharing operating system can enforce access-control policies based on user identity and use the logon procedure to identify users.

What is Kerberos?

- More common is a distributed architecture consisting of dedicated users (clients) and distributed or centralized servers.

What is Kerberos?

- In this environment, there are three approaches to security.

What is Kerberos?

- 1. Rely on each individual client workstation to assure the identity of its user or users and rely on each server to enforce a security policy based on user identification (ID).

What is Kerberos?

- 2. Require that client systems authenticate themselves to servers, but trust the client system concerning the identity of its user.

What is Kerberos?

- 3. Require the user to prove his or her identity for each service invoked. Also require that servers prove their identity to clients.

What is Kerberos?

- In a small, closed environment in which all systems are owned and operated by a single organization, the first or perhaps the second strategy may suffice.

What is Kerberos?

- In a more open environment in which network connections to other machines are supported, the third approach is needed to protect user information and resources housed at the server.

What is Kerberos?

End

- Kerberos supports this third approach.
- Kerberos assumes a distributed client/server architecture and employs one or more Kerberos servers to provide an authentication service.

A Simple Authentication Dialogue

Network Security

A Simple Authentication Dialogue

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain a simple authentication dialogue.

A Simple Authentication Dialogue

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stalling.

A Simple Authentication Dialogue

- Version 4 of Kerberos makes use of DES, in a rather elaborate protocol, to provide the authentication service.
- To develop understanding about the full protocol, lets look at a simple dialogue.

A Simple Authentication Dialogue

- In an unprotected network environment, any client can apply to any server for service.
- The obvious security risk is that of impersonation.

A Simple Authentication Dialogue

- An opponent can pretend to be another client and obtain unauthorized privileges on server machines.
- To counter this threat, servers must be able to confirm the identities of clients who request service.

A Simple Authentication Dialogue

- Each server can be required to undertake this task for each client/server interaction, but in an open environment, this places a substantial burden on each server.

A Simple Authentication Dialogue

- An alternative is to use an authentication server (AS) that knows the passwords of all users and stores these in a centralized database.
- The AS shares a unique secret key with each server.

A Simple Authentication Dialogue

- If C = client, AS = authentication server, V = server, ID_C = identifier of user on C, ID_V = identifier of V, P_C = password of user on C, AD_C = network address of C, K_v = secret key shared by AS and V, then In a simple authentication scenario

A Simple Authentication Dialogue

- A user logs on to a workstation and requests access to server V.

A Simple Authentication Dialogue

- The client module C in the user's workstation requests the user's password and then sends a message to the AS that includes the user's ID, the server's ID, and the user's password.

A Simple Authentication Dialogue

- The AS checks its database to see if the user has supplied the proper password for this user ID and whether this user is permitted access to server V.

A Simple Authentication Dialogue

- If both tests are passed, the AS accepts the user as authentic and must now convince the server that this user is authentic.

A Simple Authentication Dialogue

- To do so, the AS creates a ticket that contains the user's ID and network address and the server's ID.
- This ticket is encrypted using the secret key shared by the AS and this server.
- This ticket is then sent back to C.

A Simple Authentication Dialogue

- As the ticket is encrypted, it cannot be altered by C or by an opponent.
- With this ticket, C can now apply to V for service.
- C sends a message to V containing C's ID and the ticket.

A Simple Authentication Dialogue

- V decrypts the ticket and verifies that the user ID in the ticket is the same as the unencrypted user ID in the message.
- If the two match, the server considers the user authenticated and grants the requested service.

A Simple Authentication Dialogue

$$\textbf{(1)}\ \mathrm{C} \rightarrow \mathrm{AS}: \quad ID_C \| P_C \| ID_V$$

$$\textbf{(2)}\ \mathrm{AS} \rightarrow \mathrm{C}: \quad Ticket$$

$$\textbf{(3)}\ \mathrm{C} \rightarrow \mathrm{V}: \quad ID_C \| Ticket$$

$$Ticket = E(K_v, [ID_C \| AD_C \| ID_V])$$

A Simple Authentication Dialogue

- In message (3), the ticket is encrypted to prevent alteration.
- Server's ID is included -- server can verify that it has decrypted the ticket properly.
- ID_C is included to indicate that this ticket has been issued on behalf of C.

A Simple Authentication Dialogue

- **A possible attack:** An opponent could capture the ticket transmitted in message (2), then use the name ID_C and transmit a message of form (3) from another workstation.

A Simple Authentication Dialogue

End

- The server would receive a valid ticket that matches the user ID and grant access to the user on that other workstation.
- To prevent this attack, the AS includes in the ticket the network address from which original request came.

A More Secure Authentication Dialogue

Network Security

A More Secure Authentication Dialogue

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe a more secure authentication dialogue.

A More Secure Authentication Dialogue

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stalling.

A More Secure Authentication Dialogue

- Two issues with the simple authentication dialogue :
- 1. The number of times a user has to enter a password should be minimized.
- 2. A plaintext transmission of the password should be avoided.

A More Secure Authentication Dialogue

- Suppose each ticket can be used only once.
- If user C logs on to a workstation in the morning and checks his or her mail at a mail server, C has to supply a password to get a ticket for the mail server.

A More Secure Authentication Dialogue

- Similarly, if a user wishes to access a print server, a mail server, a file server, and so on, the first instance of each access would require a new ticket and hence require the user to enter the password.

A More Secure Authentication Dialogue

- This authentication scheme employs a new server, known as the **ticket-granting server** (TGS).
- TGS, issues tickets to users who have been authenticated to AS.
- The user first requests a ticket-granting ticket ($Ticket_{tgs}$) from the AS.

A More Secure Authentication Dialogue

- The client module in the user workstation saves this ticket.
- Each time the user requires access to a new service, the client applies to the TGS, using the ticket to authenticate itself.

A More Secure Authentication Dialogue

- The TGS then grants a ticket for the particular service.
- The client saves each service-granting ticket and uses it to authenticate its user to a server each time a particular service is requested.

A More Secure Authentication Dialogue

Details

- 1. The client requests a ticket-granting ticket on behalf of the user by sending its user's ID to the AS, together with the TGS ID, indicating a request to use the TGS service.

A More Secure Authentication Dialogue

- 2. The AS responds with a ticket that is encrypted with a key that is derived from the user's password (K_C), which is already stored at the AS.

A More Secure Authentication Dialogue

- When this response arrives at the client, the client prompts the user for his or her password, generates the key, and attempts to decrypt the incoming message.

A More Secure Authentication Dialogue

- If correct password is supplied, the ticket is successfully recovered.
- Thus, we have used the password to obtain credentials from Kerberos without having to transmit the password in plaintext.

A More Secure Authentication Dialogue

- The ticket-granting ticket is to be reusable.
- The client now has a reusable ticket and need not bother the user for a password for each new service request.

A More Secure Authentication Dialogue

- To avoid an opponent from capturing and using the ticket, the ticket includes a timestamp, indicating the date and time at which the ticket was issued, and a lifetime, indicating the length of time for which the ticket is valid.

A More Secure Authentication Dialogue

- 3. The client requests a service-granting ticket on behalf of the user. For this purpose, the client transmits a message to the TGS containing the user's ID, the ID of the desired service, and the ticket-granting ticket.

A More Secure Authentication Dialogue

- 4. The TGS decrypts the incoming ticket using a key shared only by the AS and the TGS (K_{tgs}) and verifies the success of the decryption by the presence of its ID. It checks to make sure that the lifetime has not expired.

A More Secure Authentication Dialogue

- Then it compares the user ID and network address with the incoming information to authenticate the user. If user is permitted access to the server V, the TGS issues a ticket to grant access to the requested service.

A More Secure Authentication Dialogue

- 5. The client requests access to a service on behalf of the user. For this purpose, the client transmits a message to the server containing the user's ID and the service granting ticket. The server authenticates by using the contents of the ticket.

A More Secure Authentication Dialogue

Once per user logon se sion:

,(1) C---+ AS: *lDc* II *IDtgs*

,(2) AS ---+ C: E.(Kc *Tickettg*)

Once per typ,e of service:

,(3) C---+ TGS: */De* 11*IDv* II *Tickettg*

,(4) TGS--c: *Ticketv*

Once per servi e session:

,(5) C---+ V: *IDc* II *Ticketv*

Tickeltgs == *E(Ktgs [IDc* II *ADc* 11 *IDtgs* II *TS1* II *Lifetin1e1])*

Ticket!)== E(Kv, [!De II *ADc* II *IDv* II *TS2*III *Lifetin1e2])*

A More Secure Authentication Dialogue

- This new scenario satisfies the two requirements of only one password query per user session and protection of the user password.

End

The Version 4 Authentication Dialogue

Network Security

The Version 4 Authentication Dialogue

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain Kerberos V4 authentication dialogue.

The Version 4 Authentication Dialogue

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stalling.

The Version 4 Authentication Dialogue

- Two issues with the more secure authentication dialogue:
- First problem is the lifetime associated with the ticket-granting ticket.

The Version 4 Authentication Dialogue

- If this lifetime is very short (e.g., minutes), then the user will be repeatedly asked for a password.
- If the lifetime is long (e.g., hours), then an opponent has a greater opportunity for replay.

The Version 4 Authentication Dialogue

- An opponent could capture a copy of the ticket-granting ticket and then wait for the legitimate user to log out.
- Then opponent could forge the legitimate user's network address and send the message to the TGS.

The Version 4 Authentication Dialogue

- This would give the opponent unlimited access to the resources and files available to the legitimate user.
- A similar issue arises when an opponent captures a service-granting ticket.

The Version 4 Authentication Dialogue

- Thus, we arrive at an additional requirement.
- A network service (the TGS or an application service) must be able to prove that the person using a ticket is the same person to whom that ticket was issued.

The Version 4 Authentication Dialogue

- The second problem is that servers should authenticate themselves to users.
- An opponent can sabotage the configuration so that messages to a server were directed to another location.

The Version 4 Authentication Dialogue

Kerberos Solution:

- The threat is that an opponent will steal the ticket and use it before it expires.
- Let the AS provide both the client and the TGS with a secret piece of information in a secure manner.

The Version 4 Authentication Dialogue

- Then client can prove its identity to TGS by revealing secret information, again in a secure manner.
- Kerberos uses an encryption key as the secure information; this is referred to as a session key.

The Version 4 Authentication Dialogue

- The client sends a message to the AS requesting access to the TGS.
- The AS responds with a message, encrypted with a key derived from the user's password (K_C), that contains the ticket.

The Version 4 Authentication Dialogue

- The encrypted message also contains a copy of the session key, $K_{C,tgs}$.
- Because this session key is inside the message encrypted with K_C, only the user's client can read it.

The Version 4 Authentication Dialogue

- The same session key is included in the ticket, which can be read only by the TGS.
- Thus, the session key has been securely delivered to both C and the TGS.

The Version 4 Authentication Dialogue

(1) C As *!De||IDtg* ||TS1

(2) AS C E(*Kc,* [*Kctgs* [|*ID'tgs*|| TS2 || *Lifetime2*||*Tickettgs]*

Tickeltgs = *E(Ktgs, [Kc,tgs* ||**IDc**|| AD*c* ||ID*tgs* ||TS2 ||Lifetimez])

(a) Authentication Service Exchanee to obtain ticket-„-autin ticket

The Version 4 Authentication Dialogue

- Message (1) includes a timestamp, so that the AS knows that the message is timely.
- Message (2) includes several elements of the ticket in a form accessible to C.
- C learns that this ticket is for TGS and when it expires.

The Version 4 Authentication Dialogue

- Now C sends the TGS a message that includes the ticket plus the ID of the requested service.
- C also transmits an authenticator, which includes the ID and address of C's user and a timestamp.

The Version 4 Authentication Dialogue

- The authenticator is intended for use only once and has a very short lifetime.
- Now TGS can decrypt the ticket with the key that it shares with AS.
- This ticket indicates that user C has been provided with the session key $K_{C,tgs}$.

The Version 4 Authentication Dialogue

- The TGS uses the session key to decrypt the authenticator.
- The TGS can then check the name and address from the authenticator with that of the ticket and with the network address of the incoming message.

The Version 4 Authentication Dialogue

- If all match, then the TGS is assured that the sender of the ticket is indeed the ticket's real owner.

The Version 4 Authentication Dialogue

(3) C TGS *lDv* || *Tickettgs* || *Authenticatorc*

(4) TGS-:l' C *E(Kc,tgs [Kc,v* || *!Dv* || *TS4* || *Ticketv])*

Tickeftgs == E(Ktgs, *[Kc,tgs* 11IDc11ADc 11*IDtgs* 11TS211Lifetirne2])

Ticketv == E(Kv, [Kc,v 11ID'c 11ADc11IDv11TS4 || Lifehrne4])

Authenticatorc = E(Kc,tgs [IDc || AD'c 11TS3])

(b) Ticket-Gr.anting Ser,vice Exchange to obtain ervice-granting ticket

The Version 4 Authentication Dialogue

- C now has a reusable service-granting ticket for V. When C presents this ticket, it also sends an authenticator.
- The server can decrypt the ticket, recover the session key, and decrypt the authenticator.

The Version 4 Authentication Dialogue

- If mutual authentication is required, the server returns the value of the timestamp from the authenticator, incremented by 1, and encrypted in the session key.
- C can decrypt this message.

The Version 4 Authentication Dialogue

(5) C -4- **V** *Ticketv* ||*Authentie,atorc*

(6) V **C** E(Kc,v-[TS5 + 1]I) (for mutual authentication)

Ticketv == E *Kv* [Kc,v ||ID'c [|ADc ||IDv||TS4 ||Lifetime4])

*Authenticator*c == E K.c v [ID'c ||ADc ||TS.5])

(c) **Client/Server Authentication Exchange to obtain·ervice**

Rationale For Elements Of Kerberos 4

Network Security

Rationale For Elements Of Kerberos 4

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe rationale for elements of Kerberos V4 authentication dialogue.

Rationale For Elements Of Kerberos 4

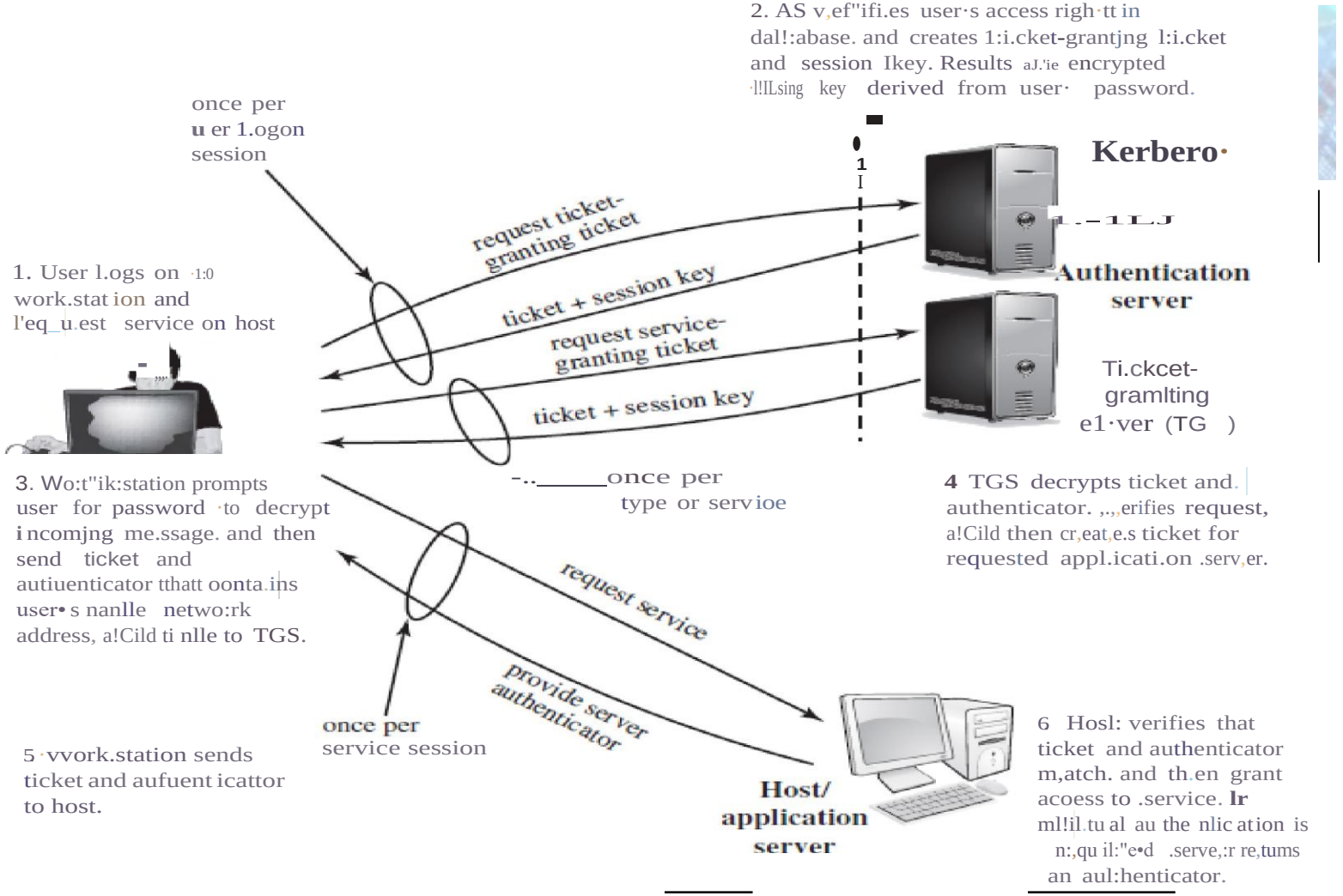
Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Rationale For Elements Of Kerberos 4

- Kerberos is a key distribution and user authentication service developed at MIT.

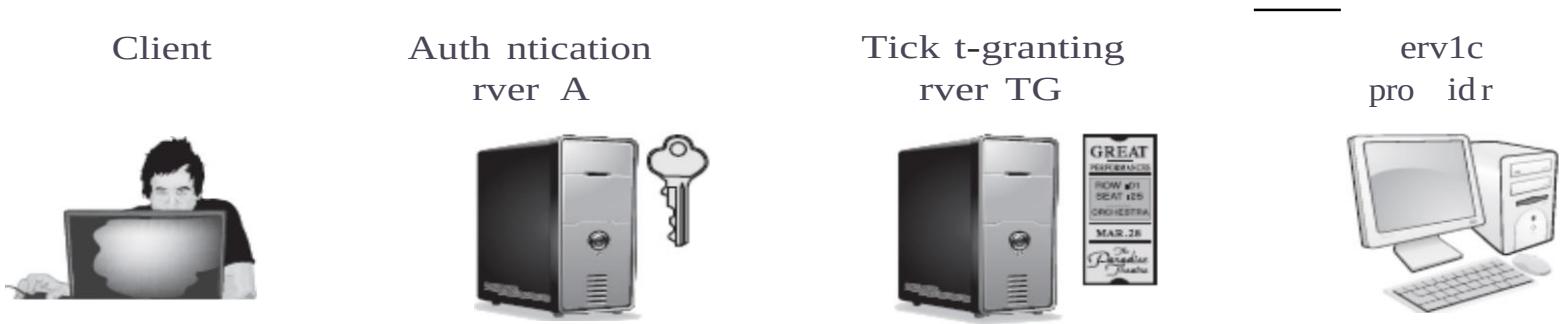
Rationale For Elements Of Kerberos 4



Rationale For Elements Of Kerberos 4

- Broadly, the Kerberos exchanges can be categorized as:
- Authentication Service Exchange
- Ticket-Granting Service Exchange
- Client/Server Authentication Exchange

Rationale For Elements Of Kerberos 4



I1 nt aut 1ent1· catJ· on____,...

IDc II *IDtgs* II *T* 1

har dk an d. tic k t-

EKo [Kc.tgs II *ID1gs* II *T* 2 II *Lifetim* 2 II *Tickef1gsJJ*

-----*Tickeftgs,* ervr ID.andcli ntauth ntication---

ID., II *Tickeftgs* II *A11the11ticatorc*

har d k y and **ticket**

EKc,tgs, [Kc,v II *ID_.,* II *T* -t II *Ticket.,])*

Ticket" and cli nt auth ntication

Ticket., II *Autltenticatorc*

rvic grant d---+

E(Kc.v, *[T* s + 1]

Rationale For Elements Of Kerberos 4

Authentication Service Exchange

Message (1)	Client requests ticket-granting ticket.
ID_C	Tells AS identity of user from this client.
ID_{tgs}	Tells AS that user requests access to TGS.
TS_1	Allows AS to verify that client's clock is synchronized with that of AS.
Message (2)	AS returns ticket-granting ticket.
K_c	Encryption is based on user's password, enabling AS and client to verify password, and protecting contents of message (2).
$K_{c,tgs}$	Copy of session key accessible to client created by AS to permit secure exchange between client and TGS without requiring them to share a permanent key.
ID_{tgs}	Confirms that this ticket is for the TGS.
TS_2	Informs client of time this ticket was issued.
$Lifetime_2$	Informs client of the lifetime of this ticket.
$Ticket_{tgs}$	Ticket to be used by client to access TGS.

Rationale For Elements Of Kerberos 4

Kerberos Version 4 Message Exchanges

(1) $C \rightarrow AS \quad ID_c \| ID_{tgs} \| TS_1$

(2) $AS \rightarrow C \quad E(K_c, [K_{c,tgs} \| ID_{tgs} \| TS_2 \| Lifetime_2 \| Ticket_{tgs}])$

$$Ticket_{tgs} = E(K_{tgs}, [K_{c,tgs} \| ID_C \| AD_C \| ID_{tgs} \| TS_2 \| Lifetime_2])$$

(a) Authentication Service Exchange to obtain ticket-granting ticket

Rationale For Elements Of Kerberos 4

Ticket-Granting Service Exchange

Message (3)	Client requests service-granting ticket.
ID_V	Tells TGS that user requests access to server V.
$Ticket_{tgs}$	Assures TGS that this user has been authenticated by AS.
$Authenticator_c$	Generated by client to validate ticket.
Message (4)	TGS returns service-granting ticket.
$K_{c,tgs}$	Key shared only by C and TGS protects contents of message (4).
$K_{c,v}$	Copy of session key accessible to client created by TGS to permit secure exchange between client and server without requiring them to share a permanent key.
ID_V	Confirms that this ticket is for server V.
TS_4	Informs client of time this ticket was issued.
$Ticket_V$	Ticket to be used by client to access server V.
$Ticket_{tgs}$	Reusable so that user does not have to reenter password.
K_{tgs}	Ticket is encrypted with key known only to AS and TGS, to prevent tampering.
$K_{c,tgs}$	Copy of session key accessible to TGS used to decrypt authenticator, thereby authenticating ticket.

Rationale For Elements Of Kerberos 4

Ticket-Granting Service Exchange

ID_C	Indicates the rightful owner of this ticket.
AD_C	Prevents use of ticket from workstation other than one that initially requested the ticket.
ID_{tgs}	Assures server that it has decrypted ticket properly.
TS_2	Informs TGS of time this ticket was issued.
$Lifetime_2$	Prevents replay after ticket has expired.
$Authenticator_c$	Assures TGS that the ticket presenter is the same as the client for whom the ticket was issued has very short lifetime to prevent replay.
$K_{c,tgs}$	Authenticator is encrypted with key known only to client and TGS, to prevent tampering.
ID_C	Must match ID in ticket to authenticate ticket.
AD_C	Must match address in ticket to authenticate ticket.
TS_3	Informs TGS of time this authenticator was generated.

Rationale For Elements Of Kerberos 4

Kerberos Version 4 Message Exchanges

(3) C → TGS $ID_v \| Ticket_{tgs} \| Authenticator_c$

(4) TGS → C $E(K_{c,tgs}, [K_{c,v} \| ID_v \| TS_4 \| Ticket_v])$

$$Ticket_{tgs} = E(K_{tgs}, [K_{c,tgs} \| ID_C \| AD_C \| ID_{tgs} \| TS_2 \| Lifetime_2])$$

$$Ticket_v = E(K_v, [K_{c,v} \| ID_C \| AD_C \| ID_v \| TS_4 \| Lifetime_4])$$

$$Authenticator_c = E(K_{c,tgs}, [ID_C \| AD_C \| TS_3])$$

(b) Ticket-Granting Service Exchange to obtain service-granting ticket

Rationale For Elements Of Kerberos 4

Client/Server Authentication Exchange

Message (5)	Client requests service.
$Ticket_V$	Assures server that this user has been authenticated by AS.
$Authenticator_c$	Generated by client to validate ticket.
Message (6)	Optional authentication of server to client.
$K_{c,v}$	Assures C that this message is from V.
$TS_5 + 1$	Assures C that this is not a replay of an old reply.
$Ticket_v$	Reusable so that client does not need to request a new ticket from TGS for each access to the same server.
K_v	Ticket is encrypted with key known only to TGS and server, to prevent tampering.
$K_{c,v}$	Copy of session key accessible to client; used to decrypt authenticator, thereby authenticating ticket.
ID_C	Indicates the rightful owner of this ticket.
AD_C	Prevents use of ticket from workstation other than one that initially requested the ticket.

Rationale For Elements Of Kerberos 4

Client/Server Authentication Exchange

ID_V	Assures server that it has decrypted ticket properly.
TS_4	Informs server of time this ticket was issued.
$Lifetime_4$	Prevents replay after ticket has expired.
$Authenticator_c$	Assures server that the ticket presenter is the same as the client for whom the ticket was issued; has very short lifetime to prevent replay.
$K_{c,v}$	Authenticator is encrypted with key known only to client and server, to prevent tampering.
ID_C	Must match ID in ticket to authenticate ticket.
AD_c	Must match address in ticket to authenticate ticket.
TS_5	Informs server of time this authenticator was generated.

Rationale For Elements Of Kerberos 4

Kerberos Version 4 Message Exchanges

(5) C → V	$Ticket_v \| Authenticator_c$
(6) V → C	$E(K_{c,v}, [TS_5 + 1])$ (for mutual authentication)

$$Ticket_v = E(K_v, [K_{c,v} \| ID_C \| AD_C \| ID_v \| TS_4 \| Lifetime_4])$$

$$Authenticator_c = E(K_{c,v}, [ID_C \| AD_C \| TS_5])$$

(c) Client/Server Authentication Exchange to obtain service

Kerberos Realms And Multiple Kerberi

Network Security

Kerberos Realms And Multiple Kerberi

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe Kerberos Realms And Multiple Kerberi.

Kerberos Realms And Multiple Kerberi

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Kerberos Realms And Multiple Kerberi

- A full-service Kerberos environment consisting of a Kerberos server, a number of clients, and a number of application servers requires the following:

Kerberos Realms And Multiple Kerberi

- 1. The Kerberos server must have the user ID and hashed passwords of all participating users in its database.
- All users are registered with the Kerberos server.

Kerberos Realms And Multiple Kerberi

- 2. The Kerberos server must share a secret key with each server.
- All servers are registered with the Kerberos server.
- Such an environment is referred to as a **Kerberos realm**.

Kerberos Realms And Multiple Kerberi

- A Kerberos realm is a set of managed nodes that share the same Kerberos database.
- The Kerberos database resides on the Kerberos master computer system, which should be kept in a physically secure room.

Kerberos Realms And Multiple Kerberi

- A read-only copy of the Kerberos database might also reside on other Kerberos computer systems.
- All changes to the database must be made on the master computer system with the Kerberos master password.

Kerberos Realms And Multiple Kerberi

- A Kerberos principal is a service or user that is known to Kerberos system.
- Each Kerberos principal is identified by its name, which consist of three parts: a service/user name, an instance name, and a realm name.

Kerberos Realms And Multiple Kerberi

- Networks of clients and servers under different administrative organizations typically constitute different realms.

Kerberos Realms And Multiple Kerberi

- Users in one realm may need access to servers in other realms, and some servers may be willing to provide service to users from other realms, provided that those users are authenticated.

Kerberos Realms And Multiple Kerberi

- For two realms to support interrealm authentication, a third requirement is added:
- **3.** The Kerberos server in each interoperating realm shares a secret key with the server in other realm. The two servers are registered with each other.

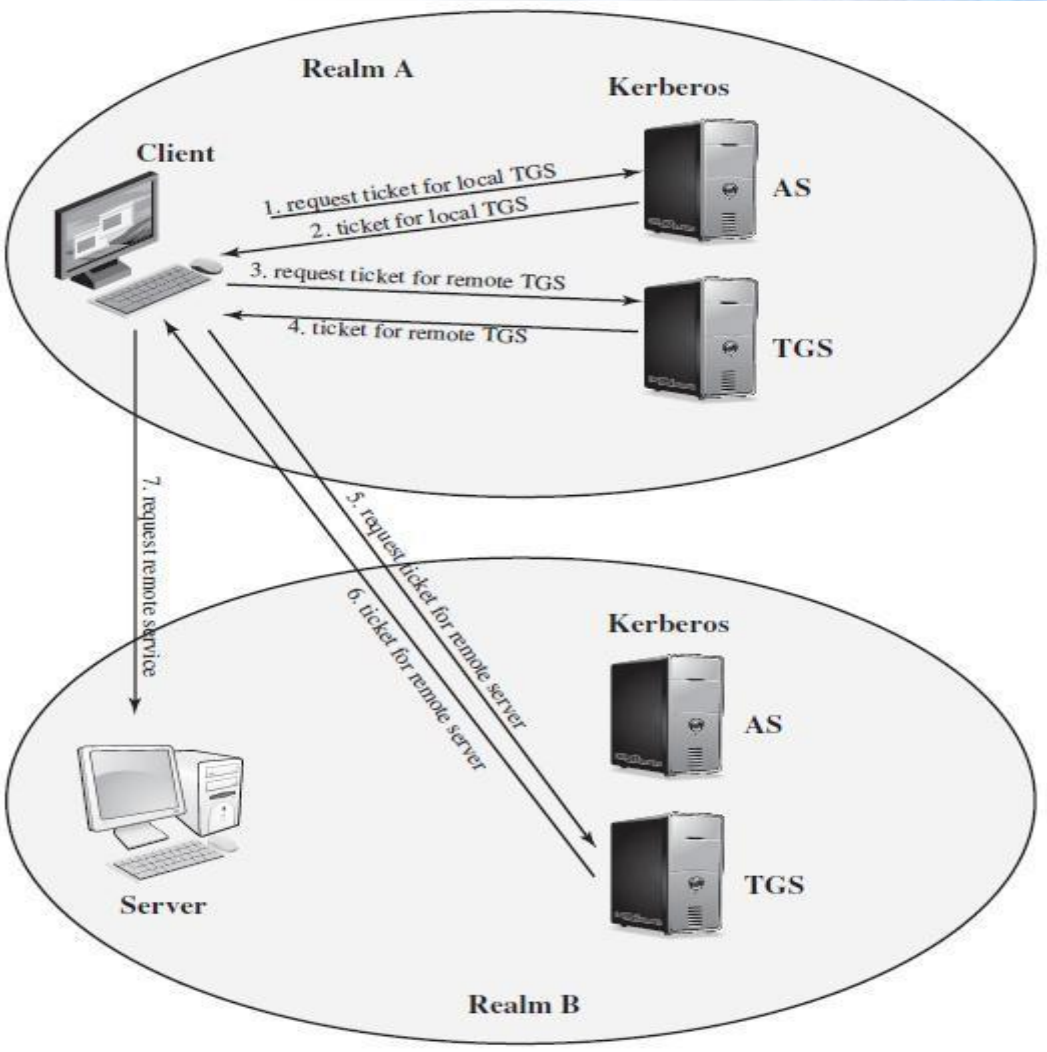
Kerberos Realms And Multiple Kerberi

- A user wishing service on a server in another realm needs a ticket for that server.
- The user's client follows the usual procedures to gain access to the local TGS and then requests a ticket-granting ticket for a remote TGS.

Kerberos Realms And Multiple Kerberi

- The client can then apply to the remote TGS for a service-granting ticket for the desired server in the realm of the remote TGS.

Kerberos Realms And Multiple Kerberi



Kerberos Realms And Multiple Kerberi

(1) C AS: *lD'cII lDtg IITS1*

(2) AS C: *E(Kc [Kc,tg, IIID1g II TS2II Lifetime2II Ticket1g])*

(3) C ros: *IDtgrem,II Ticket1g IIAuthenticatorc*

(4) TGS C: *E(Kc,tg [Kctg, remII !Dtgreni II TS4II Tickettgrern])*

(5) C TGSrem: *lD'vrem:II Tickettgrem IIAuthenticatorc*

(6) TGSrern C: *E(Kc,tgrem, [K'vremIIID remII* rs611 *TicketvrernJI)*

(7) C Vrern: *TicketvrernII Authenticatorc*

Kerberos Realms And Multiple Kerberi

- The ticket presented to the remote server (Vrem) indicates the realm in which the user was originally authenticated.
- The server chooses whether to honor the remote request.

Kerberos Realms And Multiple Kerberi

End

- This foregoing approach does not scale well to many realms.
- If there are N realms, N(N - 1)/2 secure key exchanges so that each Kerberos realm can interoperate with all other Kerberos realms.

Differences Between Kerberos 4 And 5

Network Security

Differences Between Kerberos 4 And 5

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain differences between versions 4 and 5 of Kerberos.

Differences Between Kerberos 4 And 5

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Differences Between Kerberos 4 And 5

- Version 5 is intended to address the limitations of version 4 in two areas:
- environmental shortcomings and
- technical deficiencies.

Differences Between Kerberos 4 And 5

Environmental Shortcomings:

- Kerberos version 4 was developed for use within the Project Athena environment and, accordingly, did not fully address the need to be of general purpose.

Differences Between Kerberos 4 And 5

- **1. Encryption system dependence:**
- Version 4 requires the use of DES.
- Export restriction on DES as well as doubts about the strength of DES were thus of concern.

Differences Between Kerberos 4 And 5

- In version 5, ciphertext is tagged with an encryption-type identifier so that any encryption technique may be used.

Differences Between Kerberos 4 And 5

- Encryption keys are tagged with a type and a length, allowing the same key to be used in different algorithms and allowing the specification of different variations on a given algorithm.

Differences Between Kerberos 4 And 5

- **2. Internet protocol dependence:**
- Version 4 requires the use of Internet Protocol (IP) addresses.
- Other address types, such as the ISO network address, are not accommodated.

Differences Between Kerberos 4 And 5

- Version 5 network addresses are tagged with type and length, allowing any network address type to be used.

Differences Between Kerberos 4 And 5

- **3. Message byte ordering:**
- In version 4, sender of a message employs a byte ordering of its own choosing and tags the message to indicate LSB in lowest address or MSB in lowest address.

Differences Between Kerberos 4 And 5

- This techniques works but does not follow established conventions.

Differences Between Kerberos 4 And 5

- In version 5, all message structures are defined using Abstract Syntax Notation One (ASN.1) and Basic Encoding Rules (BER), which provide an unambiguous byte ordering.

Differences Between Kerberos 4 And 5

- **4. Ticket lifetime:**
- Lifetime values in version 4 are encoded in an 8-bit quantity in units of five minutes.
- The maximum lifetime is $2^8 * 5 = 1280$ mins.
- This may be inadequate for a long-running simulation.

Differences Between Kerberos 4 And 5

- In version 5, tickets include an explicit start time and end time, allowing tickets with arbitrary lifetimes.

Differences Between Kerberos 4 And 5

- **5. Authentication forwarding:**
- Version 4 does not allow credentials issued to one client to be forwarded to some other host and used by some other client.

Differences Between Kerberos 4 And 5

- For example, a client issues a request to a print server that then accesses the client's file from a file server, using the client's credentials for access.
- Version 5 provides this capability.

Differences Between Kerberos 4 And 5

- **6. Interrealm authentication:**
- In version 4, interoperability among N realms requires N^2 Kerberos-to-Kerberos relationships.
- Version 5 requires fewer relationships.

Differences Between Kerberos 4 And 5

Technical Deficiencies:

- **1. Double encryption:** Kerberos Version 4 messages (2) and (4) are encrypted twice—The second encryption is not necessary and is computationally wasteful.

Differences Between Kerberos 4 And 5

- **2. PCBC encryption:**
- Encryption in version 4 makes use of a nonstandard mode of DES known as propagating cipher block chaining (PCBC).

Differences Between Kerberos 4 And 5

- This mode is vulnerable to an attack involving the interchange of ciphertext blocks.
- Version 5 provides explicit integrity mechanisms using the standard CBC mode for encryption.

Differences Between Kerberos 4 And 5

- **3. Session keys:**
- Each ticket includes a session key to be used by the client.
- Same ticket may be used repeatedly to gain service, an opponent may replay messages from an old session to client or the server.

Differences Between Kerberos 4 And 5

- In version 5, it is possible for a client and server to negotiate a subsession key, which is to be used only for that one connection.

Differences Between Kerberos 4 And 5

End

- **4. Password attacks:**
- Both versions are vulnerable to a password attack.
- Version 5 employs a preauthentication mechanism which makes password attacks more difficult, but it does not prevent them.

The Version 5 Authentication Dialogue

Network Security

The Version 5 Authentication Dialogue

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe authentication dialogue of Kerberos V5.

The Version 5 Authentication Dialogue

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

The Version 5 Authentication Dialogue

- Lets first, consider the **authentication service exchange**.
- The first message is a client request for a ticket-granting ticket.
- It includes the ID of the user and the TGS.
- In Version 5, following new elements are added:

The Version 5 Authentication Dialogue

- **Realm:** Indicates realm of user
- **Options:** Used to request that certain flags be set in the returned ticket

The Version 5 Authentication Dialogue

- **Times:** Used by the client to request the settings in the ticket:
- —from: the desired start time for the requested ticket
- —till: the requested expiration time for the requested ticket
- —rtime: requested renew-till time

The Version 5 Authentication Dialogue

- **Nonce:** A random value to be repeated in message (2) to assure that the response is fresh and has not been replayed by an opponent.

The Version 5 Authentication Dialogue

- Message (2) returns a ticket-granting ticket, identifying information for the client, and a block encrypted using the encryption key based on the user's password.

The Version 5 Authentication Dialogue

- This block includes the session key to be used between the client and the TGS, times specified in message (1), the nonce from message (1), and TGS identifying information.

The Version 5 Authentication Dialogue

- An important component in the ticket is the flags that reflect the status of this ticket and the requested options.
- These flags introduce significant new functionality in version 5.

The Version 5 Authentication Dialogue

Authentication Service Exchange to obtain ticket-granting ticket

(1) $C \rightarrow AS$ $Options \| ID_c \| Realm_c \| ID_{tgs} \| Times \| Nonce_1$

(2) $AS \rightarrow C$ $Realm_C \| ID_C \| Ticket_{tgs} \| E(K_c, [K_{c,tgs} \| Times \| Nonce_1 \| Realm_{tgs} \| ID_{tgs}])$

$Ticket_{tgs} = E(K_{tgs}, [Flags \| K_{c,tgs} \| Realm_c \| ID_C \| AD_C \| Times])$

The Version 5 Authentication Dialogue

- Let us now look at the **ticket-granting service exchange** for version 5.
- Message (3) includes an authenticator, a ticket, and the name of the requested service.

The Version 5 Authentication Dialogue

- For version 5, it also includes requested times and options for the ticket and a nonce—all with functions similar to those of message (1).

The Version 5 Authentication Dialogue

- Message (4) has the same structure as message (2).
- It returns a ticket plus information needed by the client, with the information encrypted using the session key now shared by the client and the TGS.

The Version 5 Authentication Dialogue

Ticket-Granting Service Exchange to obtain service-granting ticket

(3) $C \rightarrow TGS$ $Options \| ID_v \| Times \| Nonce_2 \| Ticket_{tgs} \| Authenticator_c$

(4) $TGS \rightarrow C$ $Realm_c \| ID_C \| Ticket_v \| E(K_{c,tgs}, [K_{c,v} \| Times \| Nonce_2 \| Realm_v \| ID_v])$

$$Ticket_{tgs} = E(K_{tgs}, [Flags \| K_{c,tgs} \| Realm_c \| ID_C \| AD_C \| Times])$$

$$Ticket_v = E(K_v, [Flags \| K_{c,v} \| Realm_c \| ID_C \| AD_C \| Times])$$

$$Authenticator_c = E(K_{c,tgs}, [ID_C \| Realm_c \| TS_1])$$

The Version 5 Authentication Dialogue

- Finally, for the **client/server authentication exchange**, several new features appear in version 5.
- In message (5), the client may request as an option that mutual authentication is required.

The Version 5 Authentication Dialogue

- The authenticator includes several new fields:
- **Subkey:** The client's choice for an encryption key to be used to protect this specific application session.

The Version 5 Authentication Dialogue

- **Sequence number:** An optional field.
- Messages may be sequence numbered to detect replays.
- If mutual authentication is required, the server responds with message (6).

The Version 5 Authentication Dialogue

- This message includes the timestamp from the authenticator.
- The subkey field, if present, overrides the subkey field, if present, in message (5).

The Version 5 Authentication Dialogue

Client/Server Authentication Exchange to obtain service

(5) $\mathbf{C} \rightarrow \mathbf{V}$ $Options \| Ticket_v \| Authenticator_c$

(6) $\mathbf{V} \rightarrow \mathbf{C}$ $E_{K_{c,v}}[TS_2 \| Subkey \| Seq\ \#]$

$$Ticket_v = E(K_v, [Flag \| K_{c,v} \| Realm_c \| ID_C \| AD_C \| Times])$$

$$Authenticator_c = E(K_{c,v}, [ID_C \| Relam_c \| TS_2 \| Subkey \| Seq\ \#])$$

Public-Key Certificates

Network Security

Public-Key Certificates

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe Public-Key Certificates.

Public-Key Certificates

Figures and material in this topic have been adapted from

- William Stallings, *"Network Security Essentials"*, 2014.
- William Stallings, *"Cryptography and Network Security Principles and Practice"*, 2014

Public-Key Certificates

- On the face of it, the point of public-key encryption is that the public key is public.
- Any participant can send his public key to any other participant or broadcast it to the community at large.

Public-Key Certificates

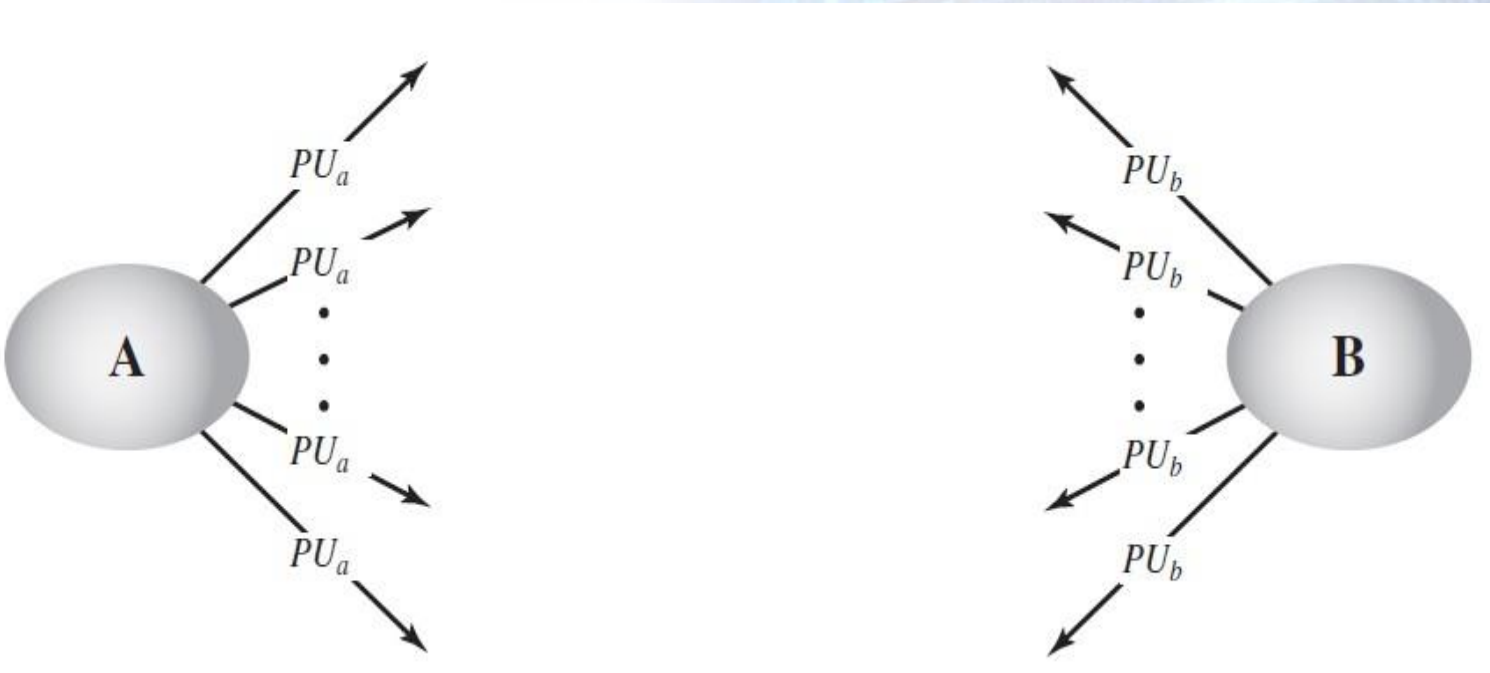
- Several techniques proposed for the distribution of public keys can be grouped as:
- Public announcement
- Publicly available directory
- Public-key authority
- Public-key certificates

Public-Key Certificates

- **1. Public Announcement:**
- Users append their public key to messages they send to public forums such as USENET newsgroups and Internet mailing lists.

Public-Key Certificates

Uncontrolled Public-Key Distribution



Public-Key Certificates

- **Major weakness:**
- Anyone can forge such a public announcement.
- Some user could pretend to be user A and send a public key to another participant or broadcast such a public key.

Public-Key Certificates

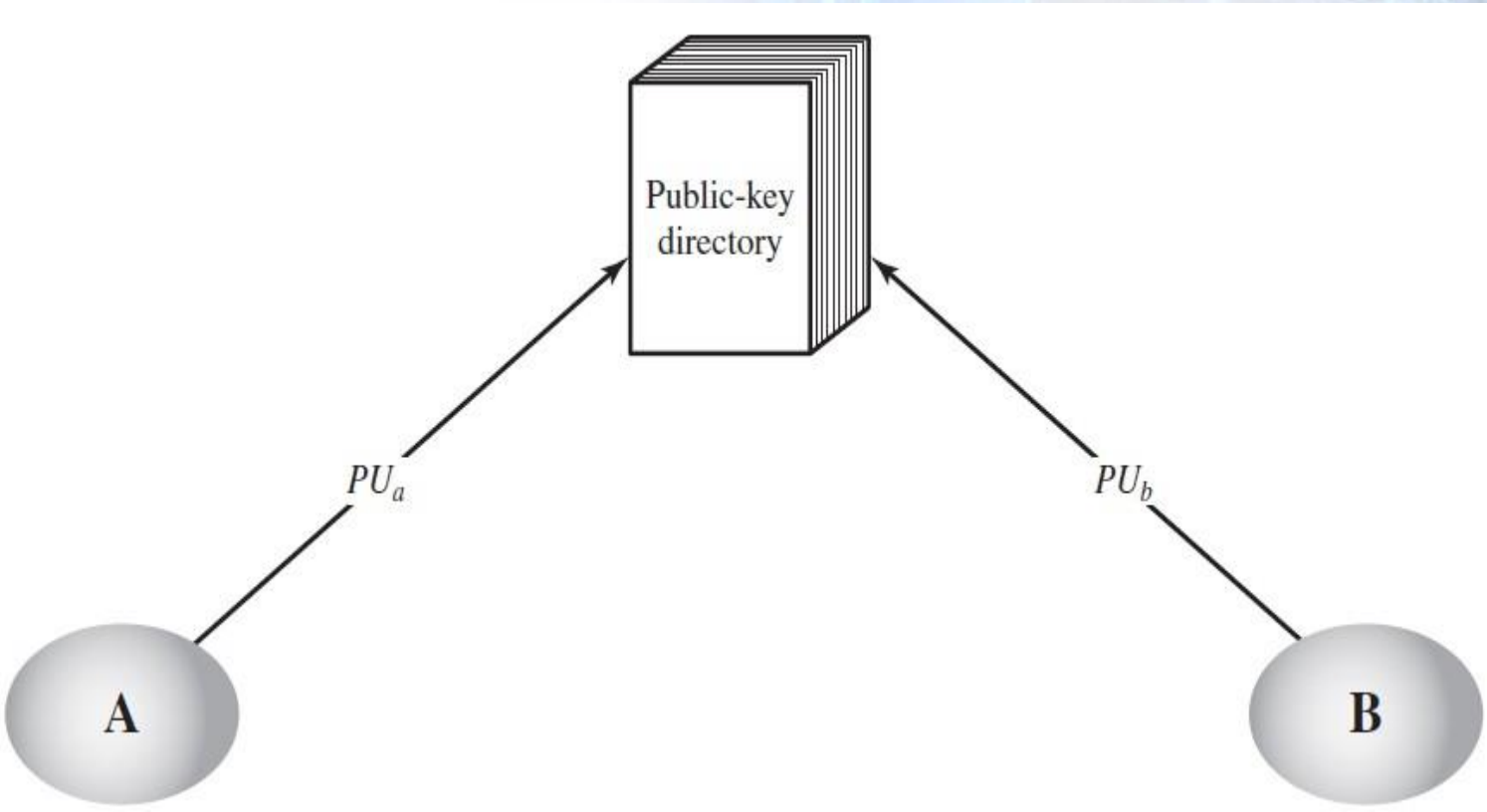
- **Publicly Available Directory**
- A greater degree of security can be achieved by maintaining a publicly available dynamic directory of public keys.
- Responsibility of some trusted organization.

Public-Key Certificates

- For each participant, a {name, public key}.
- Each participant registers a public key by secure authenticated communication.
- A participant may replace the existing key with a new one at anytime.

Public-Key Certificates

Public-Key Publication



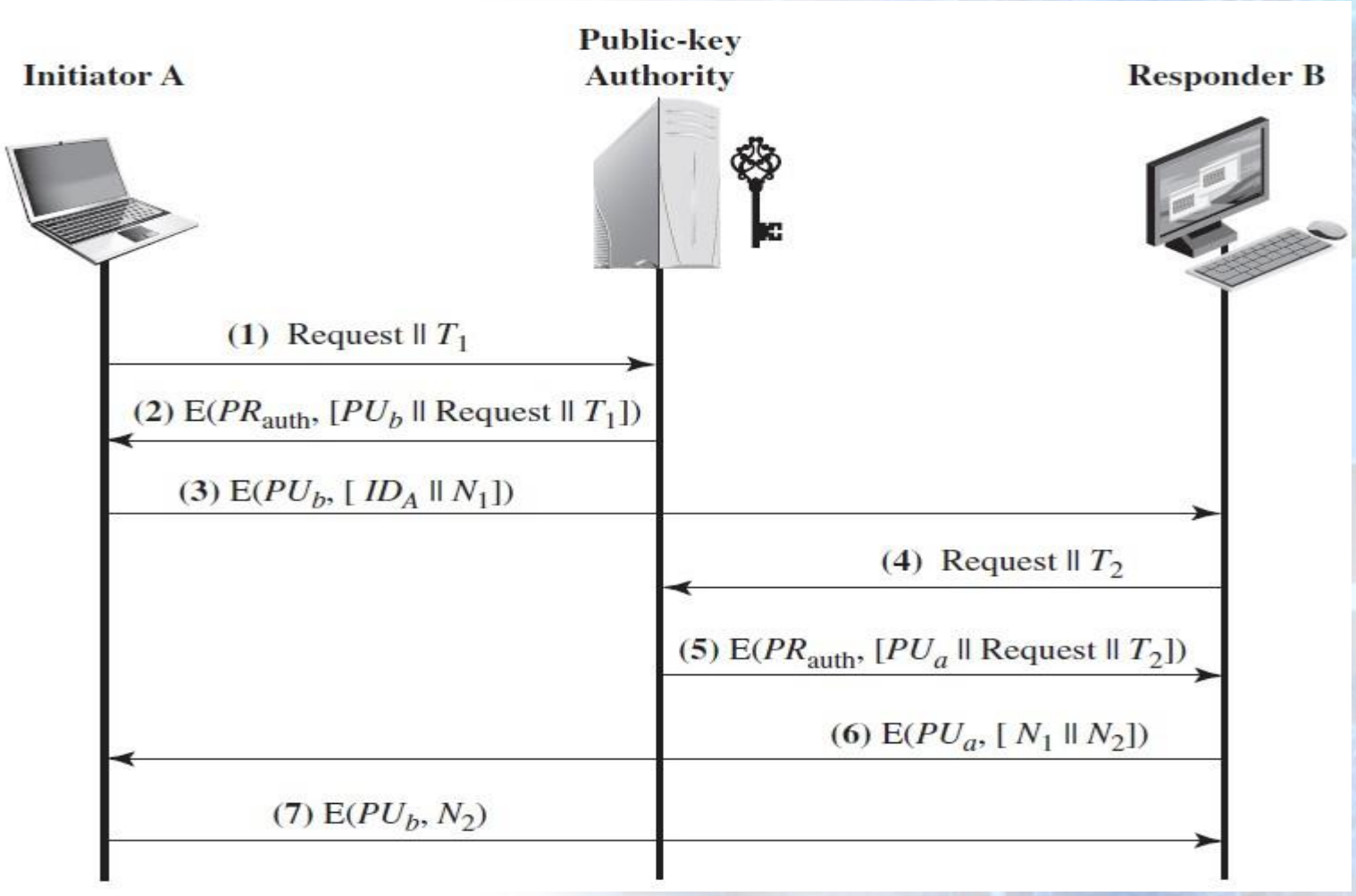
Public-Key Certificates

- If an adversary succeeds in obtaining the private key of the directory authority, he can authoritatively pass out counterfeit public keys and then impersonate a participant and eavesdrop on messages sent to him.

Public-Key Certificates

- **Public-Key Authority**
- Each participant reliably knows a public key for the authority, with only the authority knowing the corresponding private key.

Public-Key Certificates



Public-Key Certificates

- **Public-Key Certificates:**
- In previous case, a user has to appeal to authority for a public key for every other user that it wishes to contact.
- This is somewhat of a bottleneck in the system.

Public-Key Certificates

- Also, the directory of names and public keys maintained by the authority is vulnerable to tampering.
- An alternative approach is to use certificates.

Public-Key Certificates

- Certificates can be used by participants to exchange keys without contacting a public-key authority, in a way that is as reliable as if the keys were obtained directly from a public-key authority.

Public-Key Certificates

- A certificate consists of a public key, an identifier of the key owner, and the whole block signed by a trusted third party.
- TTP is a certificate authority (CA), such as a government agency or a financial institution.

Public-Key Certificates

- A user can present his public key to CA in a secure manner and obtain a certificate.
- The user can then publish the certificate.
- Anyone needing this user's public key can obtain certificate and verify it's validity – attached signature.

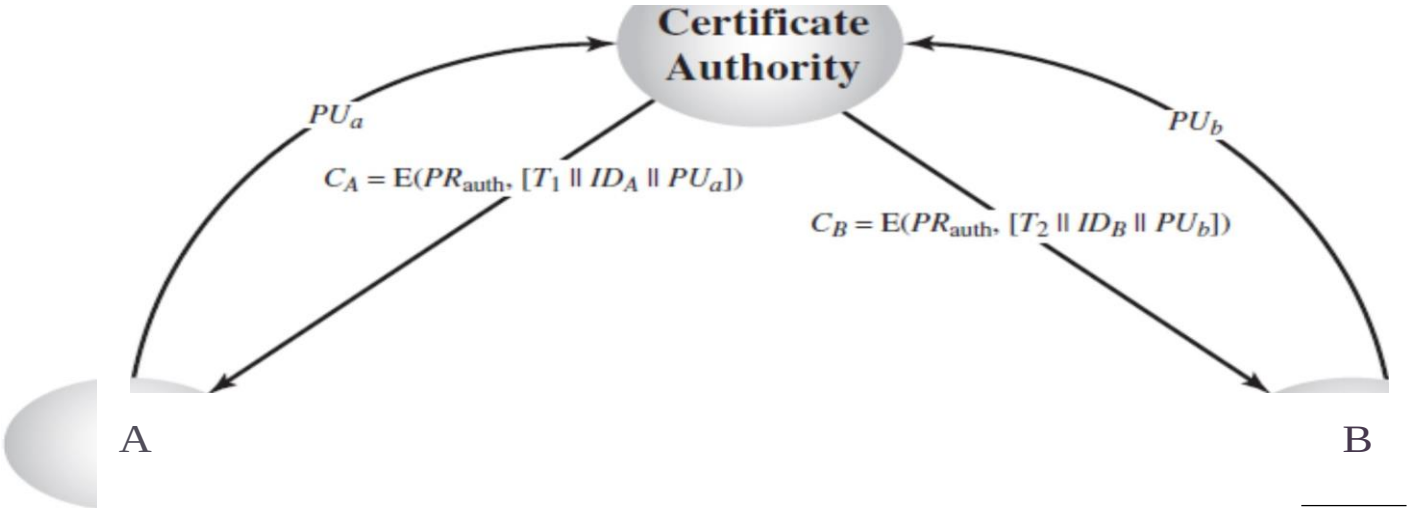
Public-Key Certificates

- **Requirements:**
- 1. Any participant can read a certificate to determine the name and public key of the certificate's owner.
- 2. Any participant can verify that certificate originated from the certificate authority and is not counterfeit.

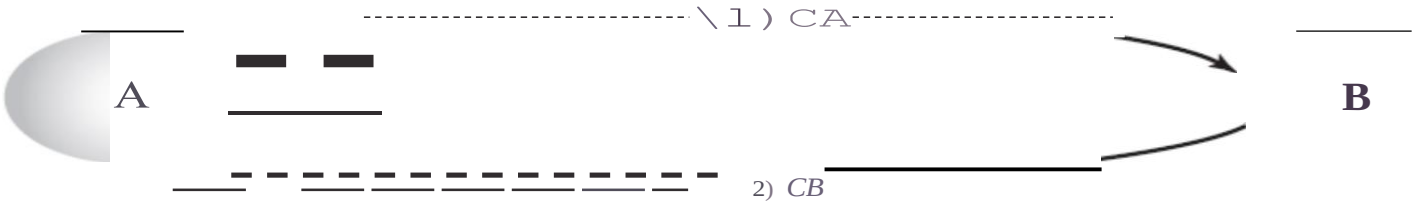
Public-Key Certificates

- 3. Only the certificate authority can create and update certificates.

Public-Key Certificates



a) Obtaining c rtifi at from C



b Ex hanging c rtificat

Public-Key Certificates

- One scheme has become universally accepted for public-key certificates: the X.509 standard.

End

Public-Key Distribution of Secret Keys

Network Security

Public-Key Distribution of Secret Keys

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe Public-Key Distribution of Secret Keys.

Public-Key Distribution of Secret Keys

Figures and material in this topic have been adapted from

- William Stallings, *"Network Security Essentials"*, 2014.
- William Stallings, *"Cryptography and Network Security Principles and Practice"*, 2014

Public-Key Distribution of Secret Keys

- Because of the inefficiency of public-key cryptosystems, they are almost never used for the direct encryption of sizable block of data, but are limited to relatively small blocks.

Public-Key Distribution of Secret Keys

- One of the most important uses of a public-key cryptosystem is to encrypt secret keys for distribution.

Public-Key Distribution of Secret Keys

Simple Secret Key Distribution:

- If A wishes to communicate with B, the following procedure is employed:

Public-Key Distribution of Secret Keys

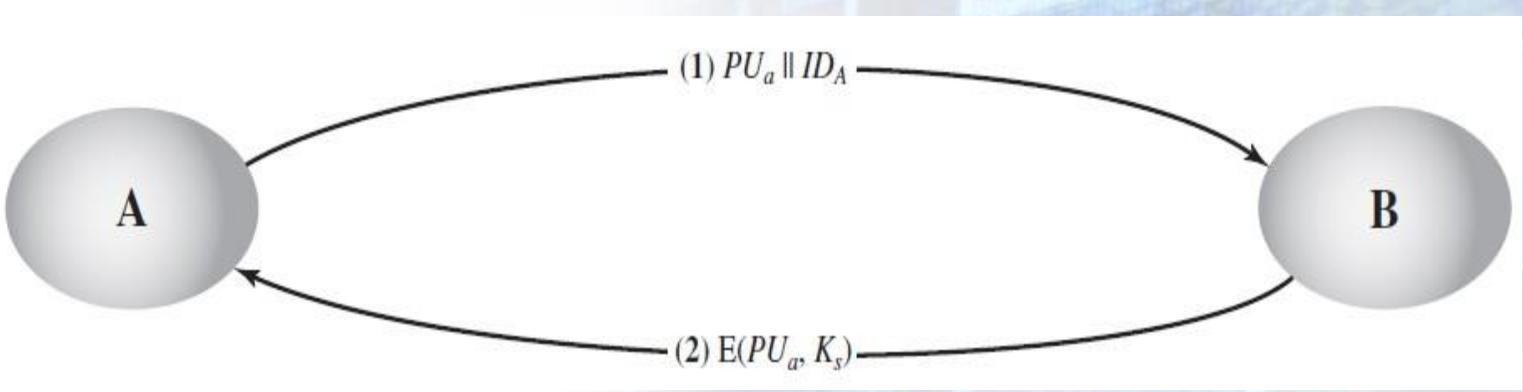
- 1. A generates a $\{PU_a, PR_a\}$ key pair and transmits a message to B consisting of PU_a and an identifier of A, ID_A.
- 2. B generates a secret session key, K_s, and transmits it to A, which is encrypted with A's public key.

Public-Key Distribution of Secret Keys

- 3. A computes $D(PR_a, E(PU_a, K_s))$ to recover the secret key.
- Because only A can decrypt the message, only A and B will know K_s.
- 4. A discards PU_a and PR_a and B discards PU_a.

Public-Key Distribution of Secret Keys

Simple Use of Public-Key Encryption to Establish a Session Key



Public-Key Distribution of Secret Keys

- A and B can now securely communicate using conventional encryption and the session key K_s.
- At the completion of the exchange, both A and B discard K_s.

Public-Key Distribution of Secret Keys

- No keys exist before the start of the communication and none exist after the completion of communication.
- Risk of compromise of the keys is minimal.
- Communication is also secure from eavesdropping.

Public-Key Distribution of Secret Keys

- However, if an adversary, D, has control of the intervening communication channel, then D can compromise the communication in the following fashion without being detected:

Public-Key Distribution of Secret Keys

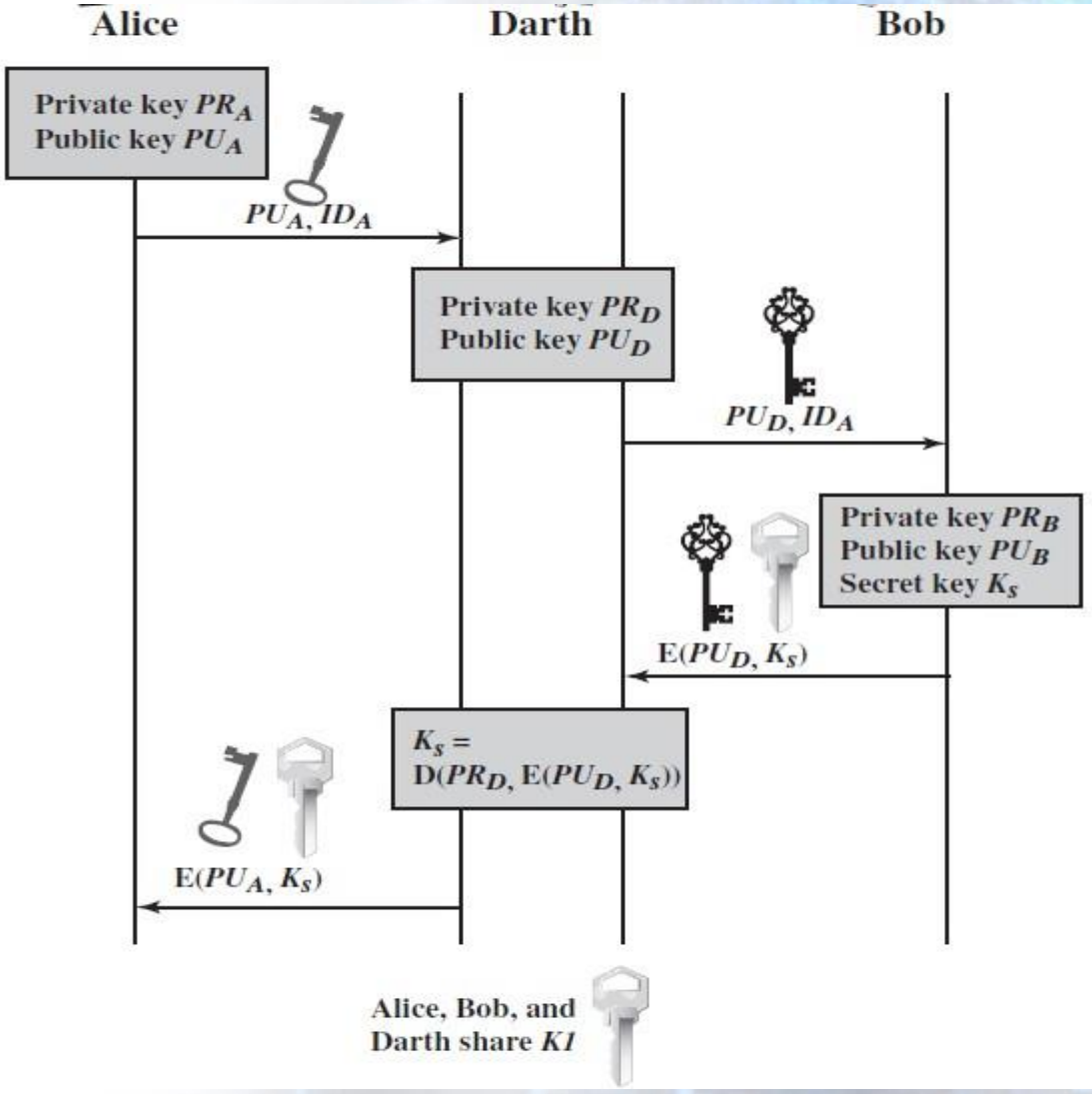
- 1. A generates a $\{PU_a, PR_a\}$ key pair and transmits a message intended for B consisting of PU_a and an identifier of A, ID_A.
- 2. D intercepts the message, creates its own $\{PU_d, PR_d\}$ key pair and transmits $PU_d \,||\, ID_A$ to B.

Public-Key Distribution of Secret Keys

- 3. B generates a secret key, K_s, and transmits $E(PU_d, K_s)$.
- 4. D intercepts the message and learns K_s by computing $D(PR_d, E(PU_d, K_s))$.
- 5. D transmits $E(PU_a, K_s)$ to A.

Public-Key Distribution of Secret Keys

Another Man-in-the-Middle Attack



Public-Key Distribution of Secret Keys

- The result is that both A and B know K_s and are unaware that K_s has also been revealed to D.
- A and B can now exchange messages using K_s.
- D simply eavesdrops.

Public-Key Distribution of Secret Keys

Public-Key Distribution of Secret Keys:

- We need to protect distribution of the secret key against both active and passive attacks.
- Assume A and B have exchanged public keys by public certificates.

Public-Key Distribution of Secret Keys

- **1.** A uses B's public key to encrypt a message to B containing an identifier of A (ID_A) and a nonce ($N1$), which is used to identify this transaction uniquely.

Public-Key Distribution of Secret Keys

- **2.** B sends a message to A encrypted with *PUa* and containing A's *N*1 and a new nonce (*N*2) generated by B.
- As only B could have decrypted message (1), presence of *N*1 in message (2) assures A that sender is B.

Public-Key Distribution of Secret Keys

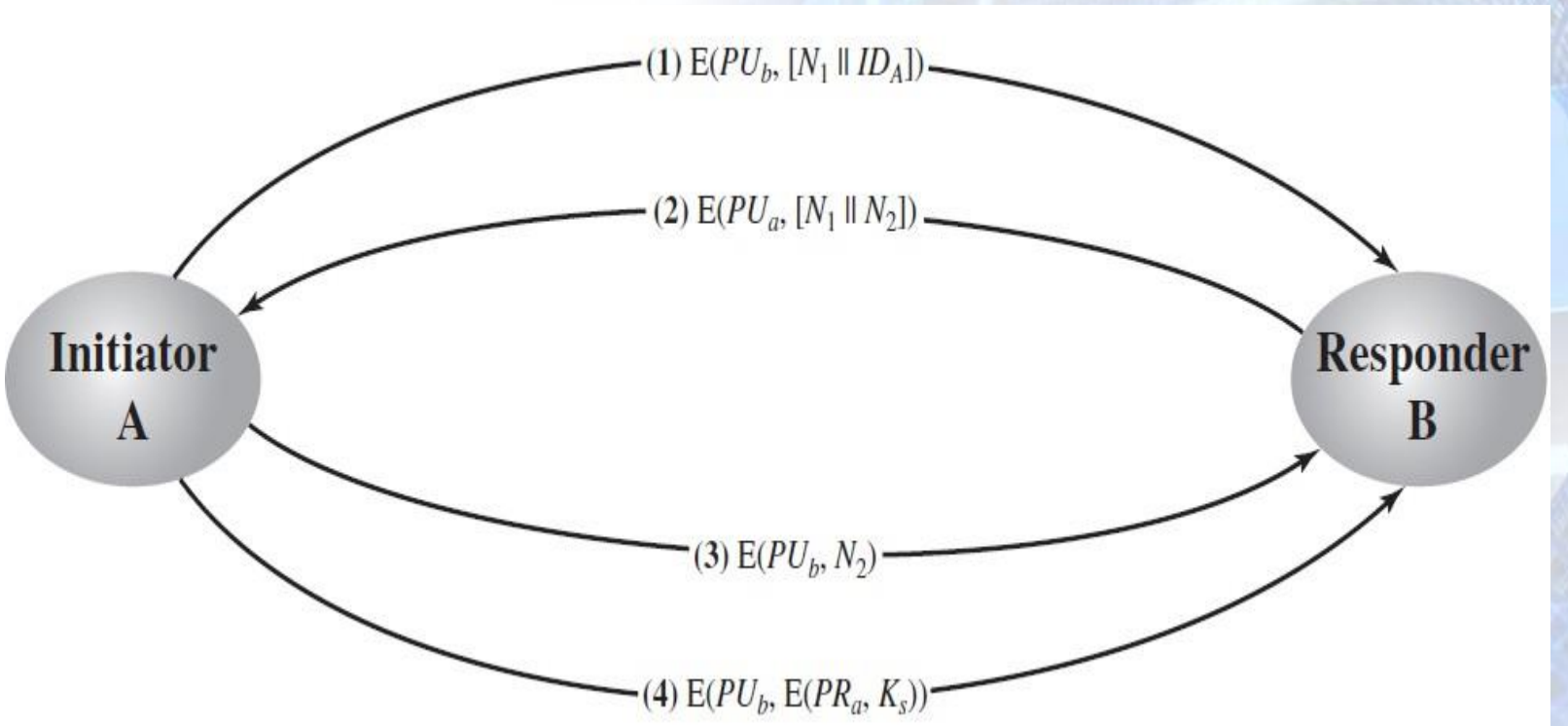
- **3.** A returns *N*2, encrypted using B's public key, to assure B that its correspondent is A.
- **4.** A selects a secret key *Ks* and sends *M* = E(*PUb*, E(*PRa*, *Ks*)) to B.

Public-Key Distribution of Secret Keys

- Encryption of this message with B's public key ensures that only B can read it; encryption with A's private key ensures that only A could have sent it.
- **5.** B computes D(*PUa*, D(*PRb*, *M*)) to recover the secret key.

Public-Key Distribution of Secret Keys

Public-Key Distribution of Secret Keys



Certificates of X.509 Certificates

Network Security

Certificates of X.509 Certificates

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain basics of X.509 Certificates.

Certificates of X.509 Certificates

Figures and material in this topic have been adapted from

- William Stallings, *"Network Security Essentials: Applications and Standards"*, 2014.

Certificates of X.509 Certificates

- ITU-T recommendation X.509 is part of the X.500 series of recommendations that define a directory service, which is a server or distributed set of servers that maintains a database of information about users.

Certificates of X.509 Certificates

- X.509 defines a framework for the provision of authentication services by the X.500 directory to its users.
- The directory may serve as a repository of public-key certificates.

Certificates of X.509 Certificates

- Also, X.509 defines alternative authentication protocols based on the use of public-key certificates.
- X.509 certificate format is used in S/MIME, IP Security, and SSL/TLS .

Certificates of X.509 Certificates

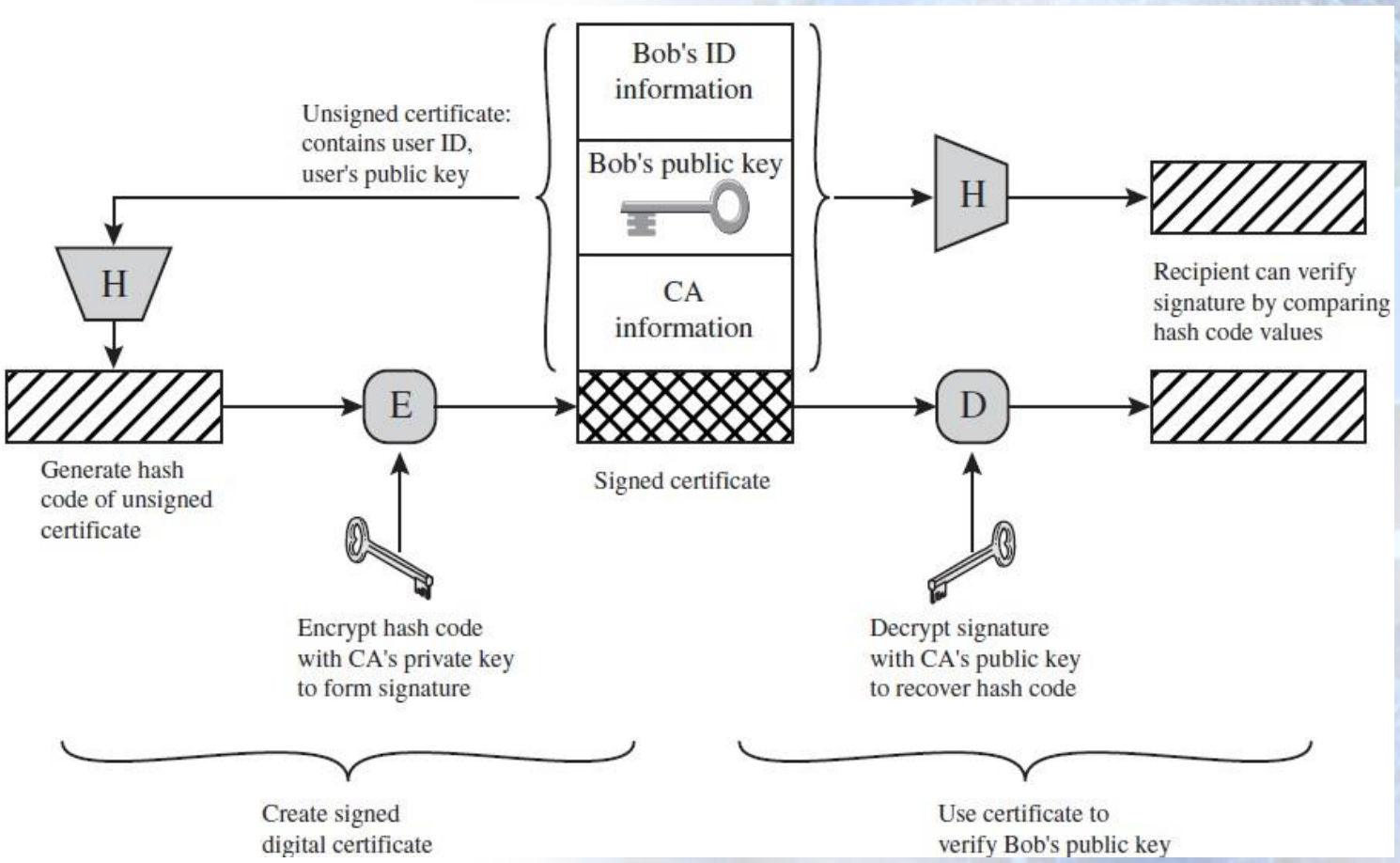
- X.509 was initially issued in 1988.
- It was subsequently revised in 1993 to address some of the security concerns.
- A third version was issued in 1995 and revised in 2000.

Certificates of X.509 Certificates

- X.509 is based on the use of public-key cryptography and digital signatures.
- The standard does not dictate the use of a specific algorithm but recommends RSA.

Certificates of X.509 Certificates

Public-Key Certificate Use



Certificates of X.509 Certificates

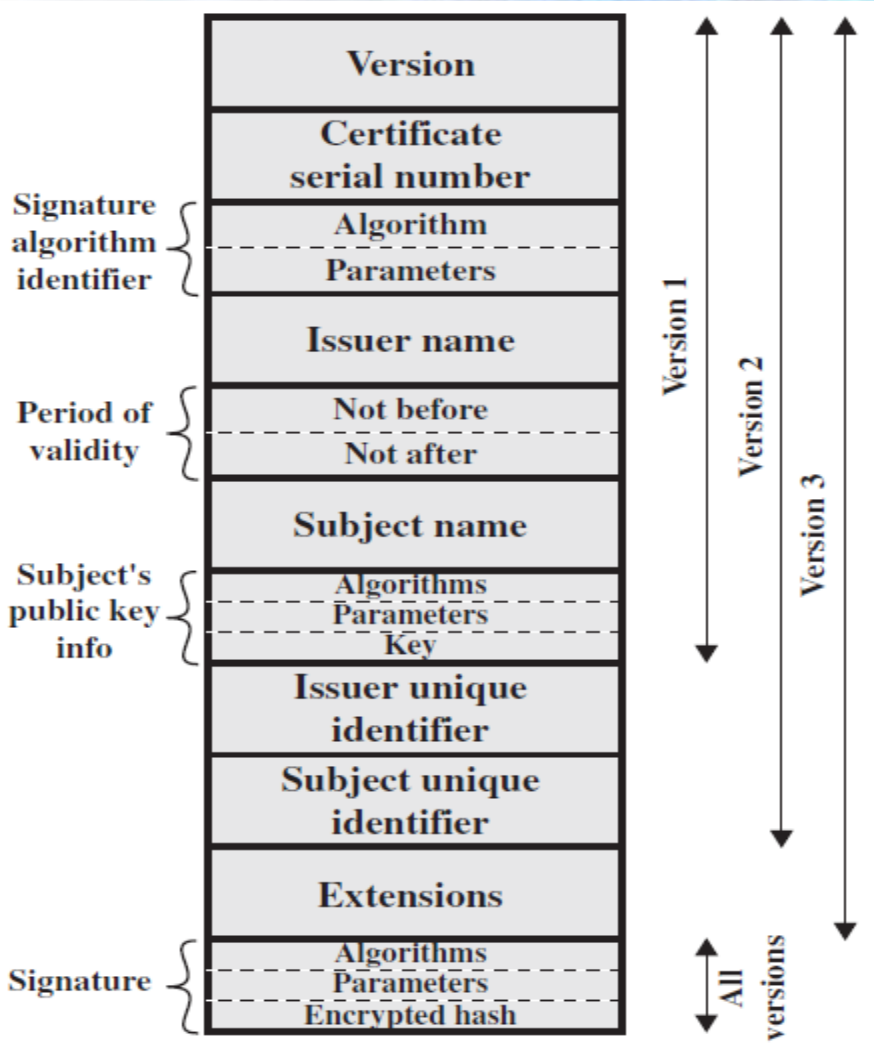
- The heart of X.509 scheme is public-key certificate associated with each user.
- These user certificates are created by some trusted certification authority (CA) and placed in the directory by the CA or by the user.

Certificates of X.509 Certificates

- The directory server only provides an easily accessible location for users to obtain certificates.

Certificates of X.509 Certificates

X.509 Format



Certificates of X.509 Certificates

- **Version:** Differentiates among versions of the certificate format.
- Default version is 1.
- If the issuer unique identifier or subject unique identifier are present, the value must be version 2.

Certificates of X.509 Certificates

- If one or more extensions are present, the version must be version 3.
- **Serial number:** An integer value unique within the issuing CA that is unambiguously associated with this certificate.

Certificates of X.509 Certificates

- **Signature algorithm identifier:** The algorithm used to sign the certificate together with any associated parameters.
- This information is also repeated in the signature field at the end of the certificate.

Certificates of X.509 Certificates

- **Issuer name:** X.500 name of the CA that created and signed this certificate.
- **Period of validity:** Consists of two dates: the first and last on which the certificate is valid.

Certificates of X.509 Certificates

- **Subject name:** The name of the user to whom this certificate refers.
- This certificate certifies the public key of the subject who holds corresponding private key.

Certificates of X.509 Certificates

- **Subject's public-key information:** The public key of the subject, plus an identifier of the algorithm for which this key is to be used, together with any associated parameters.

Certificates of X.509 Certificates

- **Issuer unique identifier:** An optional-bit string field used to identify uniquely the issuing CA in the event the X.500 name has been reused for different entities.

Certificates of X.509 Certificates

- **Subject unique identifier:** An optional-bit string field used to identify uniquely the subject in the event the X.500 name has been reused for different entities.

Certificates of X.509 Certificates

- **Extensions:** A set of one or more extension fields. Extensions were added in version 3.
- **Signature:** contains hash code of other fields encrypted with CA's private key. It includes signature algorithm ID.

Certificates of X.509 Certificates

Notation to define a certificate

$$CA \ll A \gg = CA\{V, SN, AI, CA, UCA, A, UA, Ap, T^A\}$$

where

$Y \ll X \gg$ = the certificate of user X issued by certification authority Y

$Y\{I\}$ = the signing of I by Y. It consists of I with an encrypted hash code appended

V = version of the certificate

SN = serial number of the certificate

AI = identifier of the algorithm used to sign the certificate

CA = name of certificate authority

UCA = optional unique identifier of the CA

A = name of user A

UA = optional unique identifier of the user A

Ap = public key of user A

T^A = period of validity of the certificate

Certificates of X.509 Certificates

End

- The CA signs the certificate with its private key.
- If the corresponding public key is known to a user, then that user can verify that a certificate signed by the CA is valid.

Obtaining And Revoking A Certificate

Network Security

Obtaining And Revoking A Certificate

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe how to obtain and revoke a certificate.

Obtaining And Revoking A Certificate

Figures and material in this topic have been adapted from

- William Stallings, *"Network Security Essentials: Applications and Standards"*, 2014.

Obtaining And Revoking A Certificate

- User certificates generated by a CA have the following characteristics:
- 1. Any user with access to the public key of the CA can verify the user public key that was certified.

Obtaining And Revoking A Certificate

- 2. No party other than the certification authority can modify the certificate without this being detected.

Obtaining And Revoking A Certificate

- If there is a large community of users, it is more practical to have a number of CAs, each of which securely provides its public key to some fraction of the users.

Obtaining And Revoking A Certificate

- Now suppose A has obtained a certificate from CA X1 and B has obtained a certificate from CA X2.
- If A does not securely know the public key of X2, then B's certificate, issued by X2, is useless to A.

Obtaining And Revoking A Certificate

- A can read B's certificate, but A cannot verify the signature.
- However, if the two CAs have securely exchanged their own public keys, the following procedure will enable A to obtain B's public key.

Obtaining And Revoking A Certificate

- **Step 1:** A obtains from directory the certificate of X2 signed by X1.
- As A securely knows X1's public key, A can obtain X2's public key from its certificate and verify it by means of X1's signature on certificate.

Obtaining And Revoking A Certificate

- **Step 2:** A then goes back to the directory and obtains the certificate of B signed by X2.
- Because A now has a trusted copy of X2's public key, A can verify the signature and securely obtain B's public key.

Obtaining And Revoking A Certificate

- A has used a chain of certificates to obtain B's public key:
- X1 <<X2>> X2 << B>>
- B can obtain A's public key with reverse chain
- X2 <<X1>> X1<< A >>
- A chain with *N* elements is:
- X1 <<X2>> X2<< X3 >> … X*N* << B >>

Obtaining And Revoking A Certificate

- In this case, each pair of CAs in the chain (Xi, Xi+1) must have created certificates for each other.

Obtaining And Revoking A Certificate

- All these certificates of CAs by CAs need to appear in the directory, and the user needs to know how they are linked to follow a path to another user's public key certificate.

Obtaining And Revoking A Certificate

- X.509 suggests that CAs be arranged in a hierarchy so that navigation is straightforward.
- Lets indicate the hierarchical relationship among the CAs with connected circles.

Obtaining And Revoking A Certificate

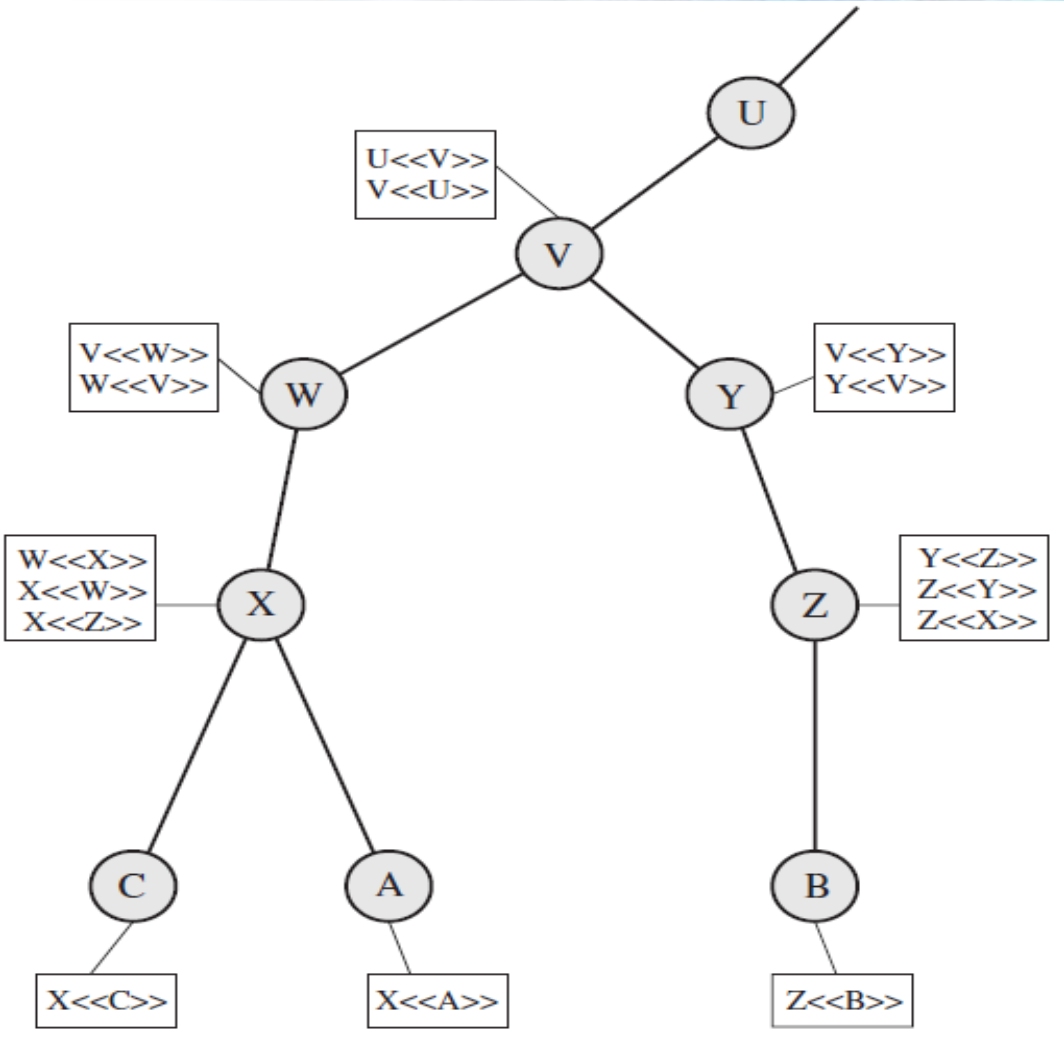
- Let certificates maintained in the directory for each CA entry be indicated by associated boxes.
- The directory entry for each CA includes two types of certificates:

Obtaining And Revoking A Certificate

- **Forward certificates:** Certificates of X generated by other CAs.
- **Reverse certificates:** Certificates generated by X that are the certificates of other CAs.

Obtaining And Revoking A Certificate

X.509 Hierarchy: An Example



Obtaining And Revoking A Certificate

- User A can establish a certification path to B:
- X <<W>> W<< V>> V <<Y>> Y<<Z>> Z<< B>>
- When A has obtained these certificates, it can unwrap the certification path in sequence to recover a B's public key.

Obtaining And Revoking A Certificate

Revocation of Certificates:

- Each certificate includes a period of validity.
- A new certificate is issued just before the expiration of the old one.

Obtaining And Revoking A Certificate

- It may be desirable on occasion to revoke a certificate before it expires, for one of the following reasons.
- **1.** The user's private key is assumed to be compromised.

Obtaining And Revoking A Certificate

- **2.** The user is no longer certified by this CA
- The subject's name has changed, or the certificate was not issued in conformance with the CA's policies.
- **3.** The CA's certificate is assumed to be compromised.

Obtaining And Revoking A Certificate

End

- Each CA must maintain a list consisting of all revoked but not expired certificates issued by that CA.
- Each certificate revocation list (CRL) should be posted on the directory.

X.509 Version 3

Network Security

X.509 Version 3

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain version 3 of X.509.

X.509 Version 3

Figures and material in this topic have been adapted from

- William Stallings, *"Network Security Essentials: Applications and Standards"*, 2014.

X.509 Version 3

- X.509 was initially issued in 1988.
- It was subsequently revised in 1993 to address some of the security concerns.
- A third version was issued in 1995 and revised in 2000.

X.509 Version 3

- Following are the requirements not satisfied by the X.509 version 2 format:

X.509 Version 3

- 1. The subject field is inadequate to convey the identity of a key owner to a public-key user.
- X.509 names may be relatively short and lacking in obvious identification details that may be needed by the user.

X.509 Version 3

- 2. The subject field is also inadequate for many applications, which typically recognize entities by an Internet e-mail address, a URL, or some other Internet related identification.

X.509 Version 3

- 3. There is a need to indicate security policy information.
- This enables a security application or function, such as IPSec, to relate an X.509 certificate to a given policy.

X.509 Version 3

- 4. There is a need to limit the damage that can result from a faulty or malicious CA by setting constraints on the applicability of a particular certificate.

X.509 Version 3

- 5. We should be able to identify different keys used by the same owner at different times.

X.509 Version 3

- Version 3 includes a number of optional extensions that may be added to the version 2 format.
- The certificate extensions fall into three main categories:

X.509 Version 3

1. Key and Policy Information:

- These extensions convey additional information about the subject and issuer keys, plus indicators of certificate policy.

X.509 Version 3

- A certificate policy is a named set of rules that indicates the applicability of a certificate to a particular community and/or class of application with common security requirements.

X.509 Version 3

- **Authority key identifier:** Identifies the public key to be used to verify the signature on this certificate or CRL.
- **Subject key identifier:** Identifies the public key being certified.

X.509 Version 3

- **Key usage:** Indicates a restriction imposed as to the purposes for which, and the policies under which, the certified public key may be used.

X.509 Version 3

- **Private-key usage period:** Indicates the period of use of the private key corresponding to the public key.

X.509 Version 3

- **Certificate policies:** lists policies that the certificate is recognized as supporting, together with optional qualifier information.

X.509 Version 3

- **Policy mappings:** allow an issuing CA to indicate that one or more of that issuer's policies can be considered equivalent to another policy used in the subject CA's domain.

X.509 Version 3

2. Certificate Subject and Issuer Attributes:

- These extensions support alternative names, in alternative formats, for a certificate subject or certificate issuer and can convey additional information about the certificate subject.

X.509 Version 3

- **Subject alternative name:**
- Contains one or more alternative names, using any of a variety of forms.
- **Issuer alternative name:** Contains one or more alternative names, using any of a variety of forms.

X.509 Version 3

- **Subject directory attributes:** Conveys any desired X.500 directory attribute values for the subject of this certificate.

X.509 Version 3

3. Certification Path Constraints:

- These extensions allow constraint specifications to be included in certificates issued for CAs by other CAs.

X.509 Version 3

- **Basic constraints:** a certification path length constraint may be specified.
- **Name constraints:** Indicates a name space within which all subject names in subsequent certificates must be located.

X.509 Version 3

End

- **Policy constraints:** Specifies constraints that may require explicit certificate policy identification or inhibit policy mapping for the remainder of the certification path.

Public Key Infrastructure X.509 (PKIX)

Network Security

Public Key Infrastructure X.509 (PKIX)

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain elements of Public Key Infrastructure X.509 (PKIX).

Public Key Infrastructure X.509 (PKIX)

Figures and material in this topic have been adapted from

- William Stallings, *"Network Security Essentials: Applications and Standards"*, 2014.

Public Key Infrastructure X.509 (PKIX)

- The principal objective for developing a PKI is to enable secure, convenient, and efficient acquisition of public keys.

Public Key Infrastructure X.509 (PKIX)

- RFC 4949 (Internet Security Glossary) defines public-key infrastructure (PKI) as:

Public Key Infrastructure X.509 (PKIX)

- The set of hardware, software, people, policies, and procedures needed to create, manage, store, distribute, and revoke digital certificates based on asymmetric cryptography.

Public Key Infrastructure X.509 (PKIX)

- The Internet Engineering Task Force (IETF) Public Key Infrastructure X.509 (PKIX) working group has been the driving force behind setting up a generic model based on X.509 on the Internet.

Public Key Infrastructure X.509 (PKIX)

- The elements of the PKIX model are:
- End entity
- Certification authority (CA)
- Registration authority (RA)
- CRL issuer
- Repository

Public Key Infrastructure X.509 (PKIX)

- **End entity:**
- A generic term used to denote end users, devices (e.g., servers, routers), or any other entity that can be identified in the subject field of a public-key certificate.

Public Key Infrastructure X.509 (PKIX)

- End entities typically consume and/or support PKI-related services.

Public Key Infrastructure X.509 (PKIX)

- **Certification authority (CA):**
- The issuer of certificates and (usually) certificate revocation lists (CRLs).

Public Key Infrastructure X.509 (PKIX)

- It may also support a variety of administrative functions, although these are often delegated to one or more Registration Authorities.

Public Key Infrastructure X.509 (PKIX)

- **Registration authority (RA):**
- An optional component that can assume a number of administrative functions from the CA.

Public Key Infrastructure X.509 (PKIX)

- The RA is often associated with the end entity registration process but can assist in a number of other areas as well.

Public Key Infrastructure X.509 (PKIX)

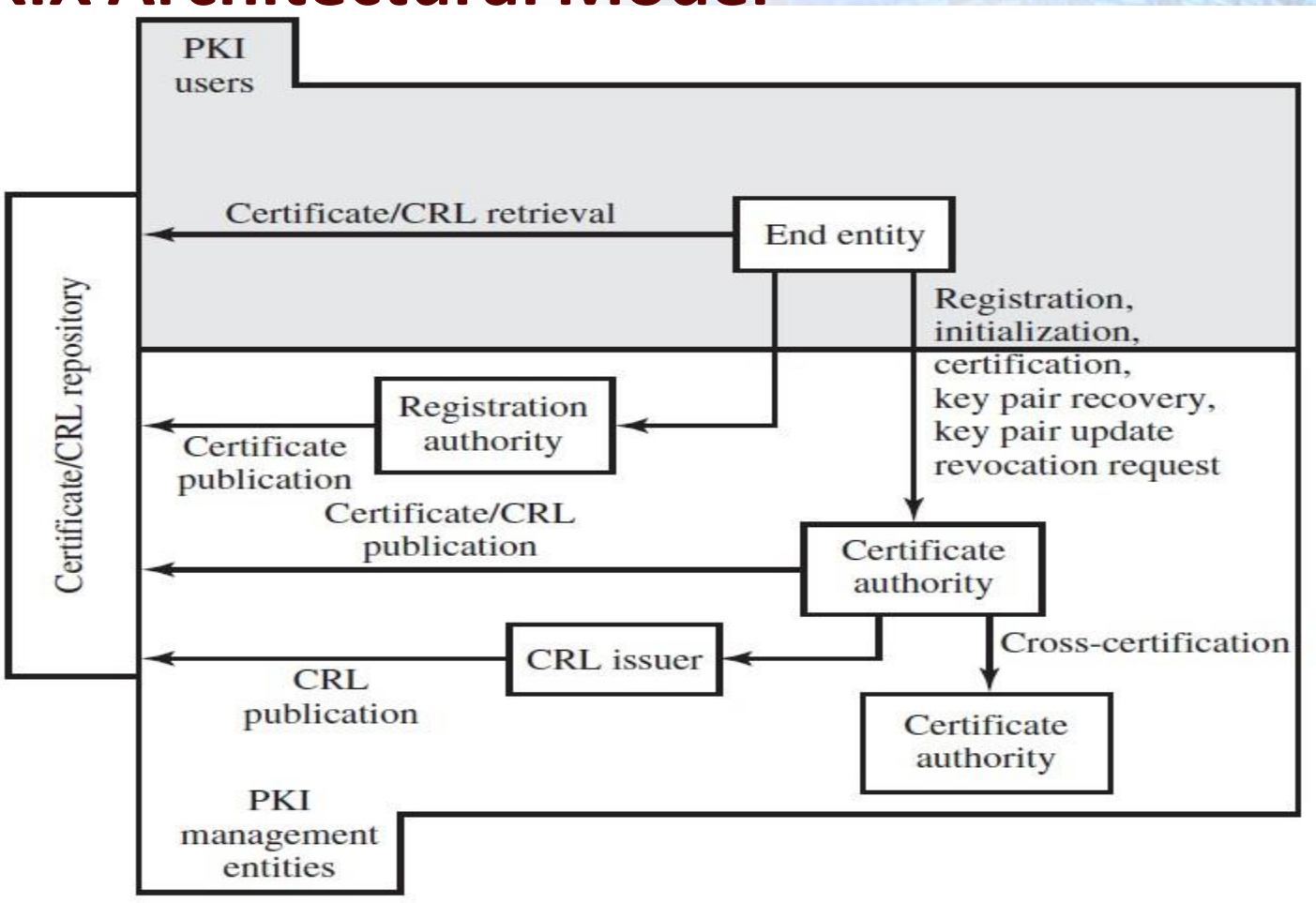
- **CRL issuer:**
- An optional component that a CA can delegate to publish CRLs.

Public Key Infrastructure X.509 (PKIX)

- **Repository:**
- A generic term used to denote any method for storing certificates and CRLs so that they can be retrieved by end entities.

Public Key Infrastructure X.509 (PKIX)

PKIX Architectural Model



PKIX Management Functions

Network Security

PKIX Management Functions

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe PKIX Management functions.

PKIX Management Functions

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

PKIX Management Functions

- The principal objective for developing a PKI is to enable secure, convenient, and efficient acquisition of public keys.

PKIX Management Functions

- PKIX identifies a number of management functions that potentially need to be supported by management protocols.

PKIX Management Functions

- **Registration:**
- This is the process whereby a user first makes itself known to a CA (directly or through an RA), prior to that CA issuing a certificate or certificates for that user.

PKIX Management Functions

- Registration begins the process of enrolling in a PKI.
- Registration usually involves some offline or online procedure for mutual authentication.

PKIX Management Functions

- Typically, the end entity is issued one or more shared secret keys used for subsequent authentication.

PKIX Management Functions

- **Initialization:** Before a client system can operate securely, it is necessary to install key materials that have the appropriate relationship with keys stored elsewhere in the infrastructure.

PKIX Management Functions

- For example, the client needs to be securely initialized with the public key and other assured information of the trusted CA(s), to be used in validating certificate paths.

PKIX Management Functions

- **Certification:** This is the process in which a CA issues a certificate for a user's public key, returns that certificate to the user's client system, and/or posts that certificate in a repository.

PKIX Management Functions

- **Key pair recovery:**
- Key pairs can be used to support digital signature creation and verification, encryption and decryption, or both.

PKIX Management Functions

- We have to provide a mechanism to recover the necessary decryption keys when normal access to the keying material is no longer possible, otherwise it will not be possible to recover the encrypted data.

PKIX Management Functions

- Loss of access to the decryption key can result from forgotten passwords/PINs, corrupted disk drives, damage to hardware tokens, and so on.

PKIX Management Functions

- Key pair recovery allows end entities to restore their encryption/decryption key pair from an authorized key backup facility (typically, the CA that issued the end entity's certificate).

PKIX Management Functions

- **Key pair update:**
- All key pairs need to be updated regularly (i.e., replaced with a new key pair) and new certificates issued.
- Update is required when the certificate lifetime expires and as a result of certificate revocation.

PKIX Management Functions

- **Revocation request:** An authorized person advises a CA of an abnormal situation requiring certificate revocation.
- Reasons include private key compromise, change in affiliation, and name change.

PKIX Management Functions

End

- **Cross certification:** Two CAs exchange information used in establishing a cross-certificate.
- A cross-certificate is a certificate issued by one CA to another CA that contains a CA signature key used for issuing certificates.

Identity Management Architecture

Network Security

Identity Management Architecture

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain identity management architecture.

Identity Management Architecture

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Identity Management Architecture

- Identity management is a centralized, automated approach to provide enterprise-wide access to resources by employees and other authorized individuals.

Identity Management Architecture

- The focus of identity management is defining an identity for each user (human or process), associating attributes with the identity, and enforcing a means by which a user can verify identity.

Identity Management Architecture

- The central concept of an identity management system is the use of single sign-on (SSO).
- SSO enables a user to access all network resources after a single authentication.

Identity Management Architecture

- In following, we list the principal elements of an identity management system.
- **Authentication:** Confirmation that a user corresponds to the user name provided.

Identity Management Architecture

- **Authorization:** Granting access to specific services and/or resources based on the authentication.
- **Accounting:** A process for logging access and authorization.

Identity Management Architecture

- **Provisioning:** The enrollment of users in the system.
- **Workflow automation:** Movement of data in a business process.

Identity Management Architecture

- **Delegated administration:** The use of role-based access control to grant permissions.
- **Password synchronization:** Creating a process for single sign-on (SSO) or reduced sign-on (RSO).

Identity Management Architecture

- Single sign-on enables a user to access all network resources after a single authentication. RSO may involve multiple sign-ons but requires less user effort than if each resource and service maintained its own authentication facility.

Identity Management Architecture

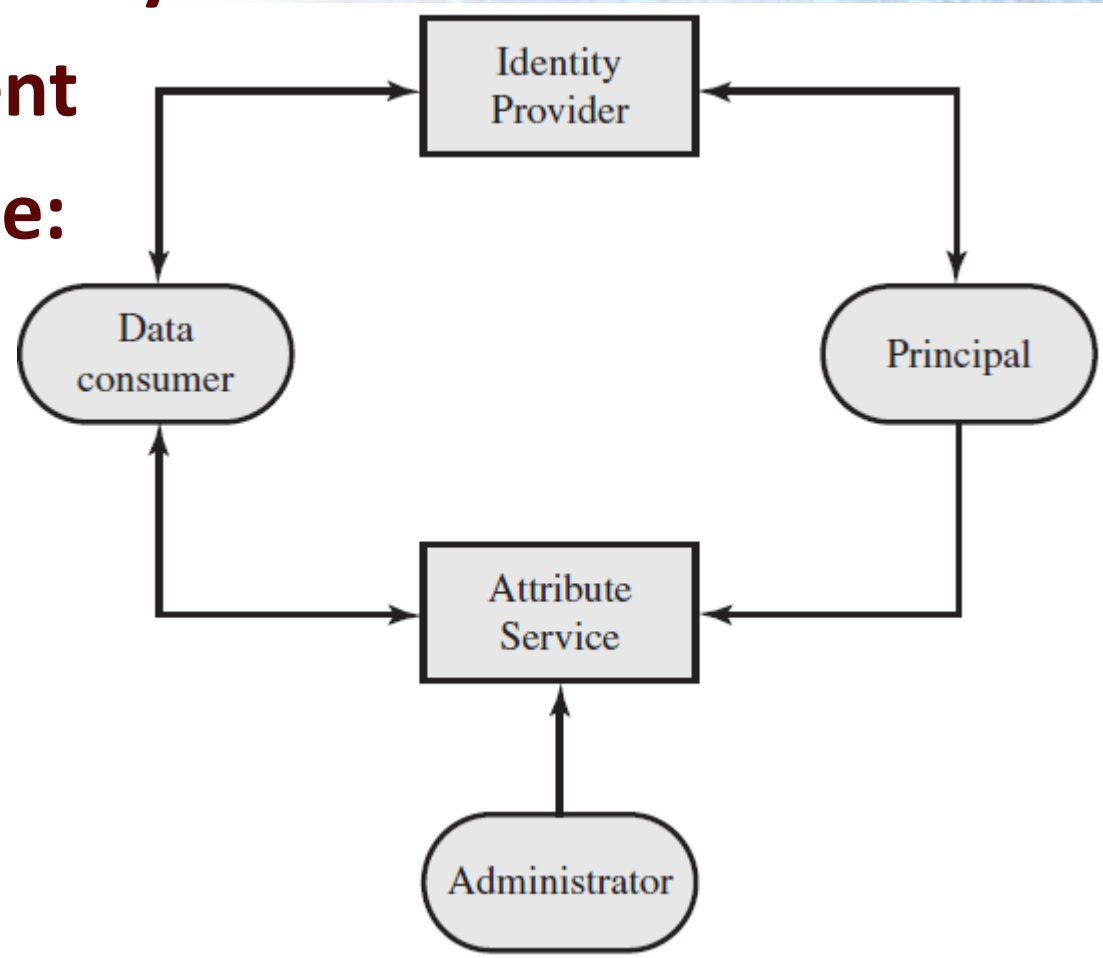
- **Self-service password reset:** Enables the user to modify his or her password.

Identity Management Architecture

- **Federation:** A process where authentication and permission will be passed on from one system to another—usually across multiple enterprises, thereby reducing the number of authentications needed by the user.

Identity Management Architecture

Generic Identity Management Architecture: Entities and data flows



Identity Management Architecture

- A **principal** is an identity holder.
- Typically, this is a human user that seeks access to resources and services on the network.
- User devices, agent processes, and server systems may also function as principals.

Identity Management Architecture

- Principals authenticate themselves to an **identity provider**.
- The identity provider associates authentication information with a principal, as well as attributes and one or more identifiers.

Identity Management Architecture

- Digital identities incorporate attributes other than simply an identifier and authentication information (such as passwords and biometric information).

Identity Management Architecture

- An **attribute service** manages the creation and maintenance of such attributes.
- E.g, a user needs to provide a shipping address each time an order is placed at a new Web merchant.
- It needs to be revised when the user moves.

Identity Management Architecture

- Identity management enables the user to provide this information once, so that it is maintained in a single place and released to data consumers in accordance with authorization and privacy policies.

Identity Management Architecture

- Users may create some of the attributes to be associated with their digital identity, such as address.
- **Administrators** may also assign attributes to users, such as roles, access permissions, and employee information.

Identity Management Architecture

- **Data consumers** are entities that obtain and employ data maintained and provided by identity and attribute providers, which are often used to support authorization decisions and to collect audit information.

Identity Management Architecture

End

- For example, a database server or file server is a data consumer that needs a client's credentials so as to know what access to provide to that client.

Federated Identity Operation

Network Security

Federated Identity Operation

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain federated identity operation and the standards used.

Federated Identity Operation

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Federated Identity Operation

- Identity federation is an extension of identity management to multiple security domains such as autonomous internal business units, external business partners, and other third-party applications and services.

Federated Identity Operation

- The goal is to provide the sharing of digital identities so that a user can be authenticated a single time and then access applications and resources across multiple domains.

Federated Identity Operation

- Being autonomous, a centralized control is not suitable.
- The cooperating organizations must form a federation based on agreed standards and mutual levels of trust to securely share digital identities.

Federated Identity Operation

- Federated identity management refers to the agreements, standards, and technologies that enable the portability of identities, identity attributes, and entitlements across multiple enterprises.

Federated Identity Operation

- This will allow an employee to log onto her corporate intranet and be authenticated to perform authorized functions and access authorized services on that intranet.

Federated Identity Operation

- The employee could then access their health benefits from an outside health-care provider without having to reauthenticate.

Federated Identity Operation

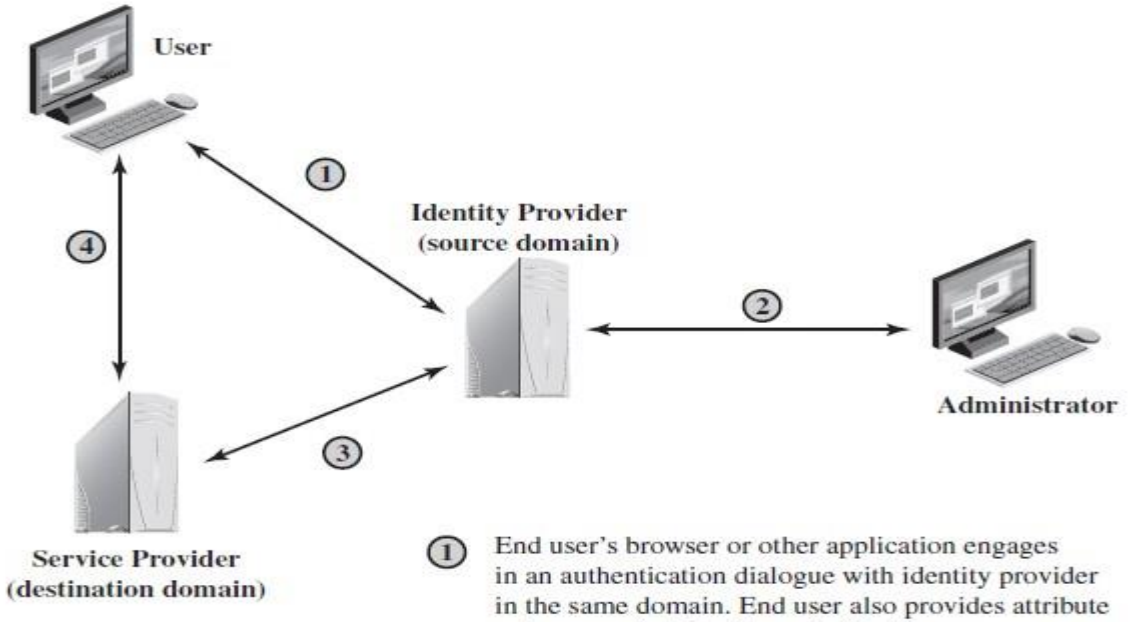
- Beyond SSO, federated identity management provides other capabilities:
- A standardized means of representing attributes such as account numbers, organizational roles, physical location, and file ownership.

Federated Identity Operation

- Another key function is identity mapping.
- Different security domains may represent identities and attributes differently.

Federated Identity Operation

Federated Identity Operation



1. End user's browser or other application engages in an authentication dialogue with identity provider in the same domain. End user also provides attribute values associated with user's identity.
2. Some attributes associated with an identity, such as allowable roles, may be provided by an administrator in the same domain.
3. A service provider in a remote domain, which the user wishes to access, obtains identity information, authentication information, and associated attributes from the identity provider in the source domain.
4. Service provider opens session with remote user and enforces access control restrictions based on user's identity and attributes.

Federated Identity Operation

- The power of this approach is for federated identity management, in which the service provider is in a different domain as the user and identity provider.

Federated Identity Operation

- Federated identity management uses a number of standards as the building blocks for secure identity exchange across different domains or heterogeneous systems.

Federated Identity Operation

- **The Extensible Markup Language (XML):** A markup language that uses sets of embedded tags to characterize text elements within a document to indicate their appearance, function, meaning, or context.

Federated Identity Operation

- **The Simple Object Access Protocol (SOAP):**
- enables applications to request services from one another with XML-based requests and receive responses as data formatted with XML.

Federated Identity Operation

- **WS-Security:**
- A set of SOAP extensions for implementing message integrity and confidentiality in Web services.

Federated Identity Operation

End

- **Security Assertion Markup Language (SAML):**
- An XML-based language for the exchange of security information between online business partners.

Federated Identity Scenarios

Network Security

Federated Identity Scenarios

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe federated identity scenarios.

Federated Identity Scenarios

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Federated Identity Scenarios

- **Scenario 1:**
- Workplace.com contracts with Health.com to provide employee health benefits.
- The organizations are part of a federation that cooperatively exchanges user identifiers.

Federated Identity Scenarios

- An employee uses a Web interface to sign on to Workplace.com and goes through authentication there.
- This enables the employee to access authorized services and resources at Workplace.com.

Federated Identity Scenarios

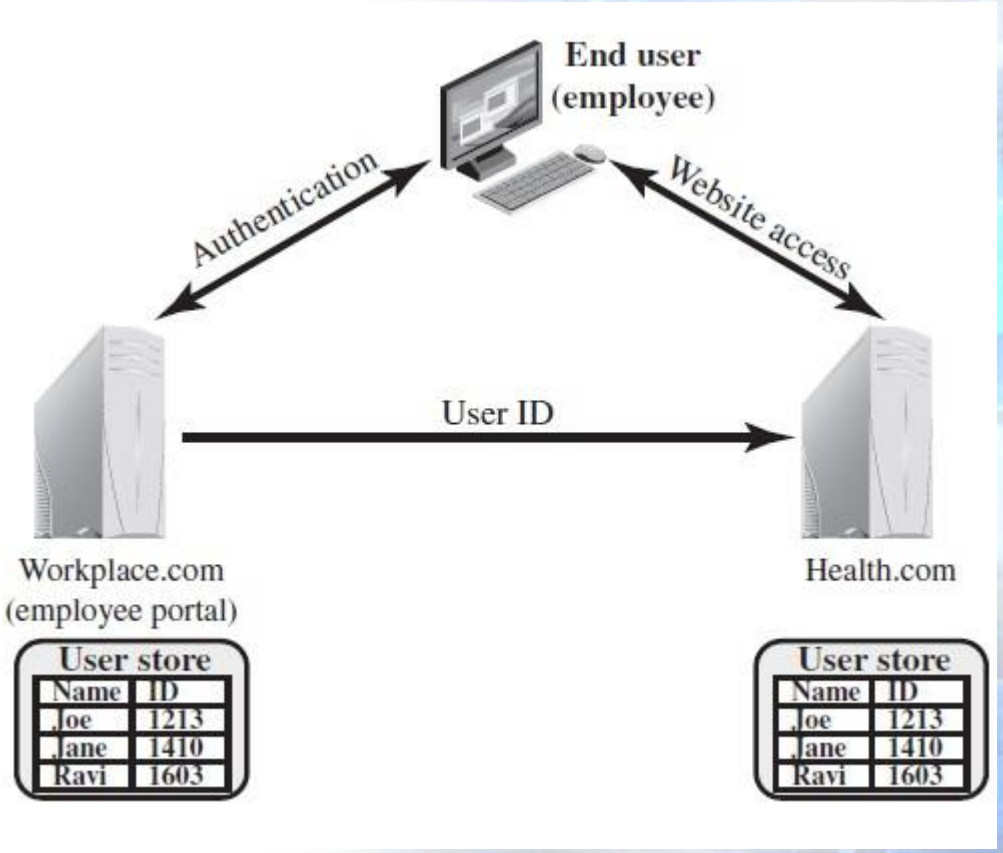
- When employee clicks on a link to access health benefits, her browser is redirected to Health.com.
- At the same time, the Workplace.com software passes the user's identifier to Health.com in a secure manner.

Federated Identity Scenarios

- Health.com maintains user identities for every employee at Workplace.com and associates with each identity health-benefits information and access rights.
- Linkage between two companies is based on account information.

Federated Identity Scenarios

Federation based on account linking



Federated Identity Scenarios

- **Scenario 2:**
- PartsSupplier. com is a regular supplier of parts to Workplace.com.
- A role-based access-control (RBAC) scheme is used for access to information.

Federated Identity Scenarios

- An engineer of Workplace.com authenticates at the employee portal at Workplace.com and clicks on a link to access information at PartsSupplier.com.

Federated Identity Scenarios

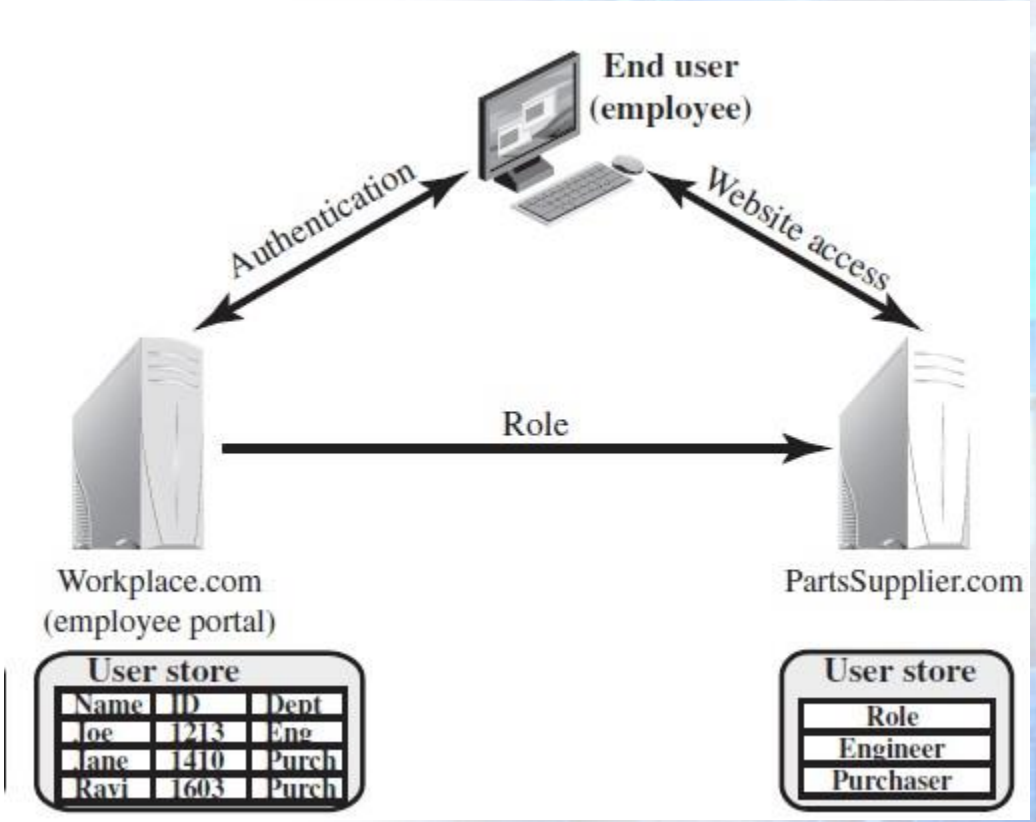
- Because the user is authenticated in the role of an engineer, he is taken to the technical documentation of PartsSupplier.com's Web site without having to sign on.

Federated Identity Scenarios

- For this scenario, PartsSupplier.com does not have identity information for individual employees at Workplace.com.
- The linkage between the two federated partners is in terms of roles.

Federated Identity Scenarios

Federation based on roles



Federated Identity Scenarios

- **Scenario 3:**
- Workplace.com has a purchasing agreement with PinSupplies.com, and PinSupplies.com has a business relationship with E-Ship.com.

Federated Identity Scenarios

- An employee of WorkPlace.com signs on and is authenticated.
- He goes to a procurement application that provides a list of WorkPlace.com's suppliers and parts that can be ordered.

Federated Identity Scenarios

- The user clicks on the PinSupplies button and is presented with a purchase order Web page (HTML page).
- The employee fills out the form and clicks the submit button.

Federated Identity Scenarios

- The procurement application generates an XML/SOAP document that it inserts into the envelope body of an XML-based message.

Federated Identity Scenarios

- The procurement application then inserts user's credentials and Workplace.com's organizational identity in header of message.
- It posts the message to PinSupplies.com's purchasing Web service.

Federated Identity Scenarios

- This service authenticates the incoming message and processes the request.
- The purchasing Web service then sends a SOAP message to its shipping partner to fulfill the order.

Federated Identity Scenarios

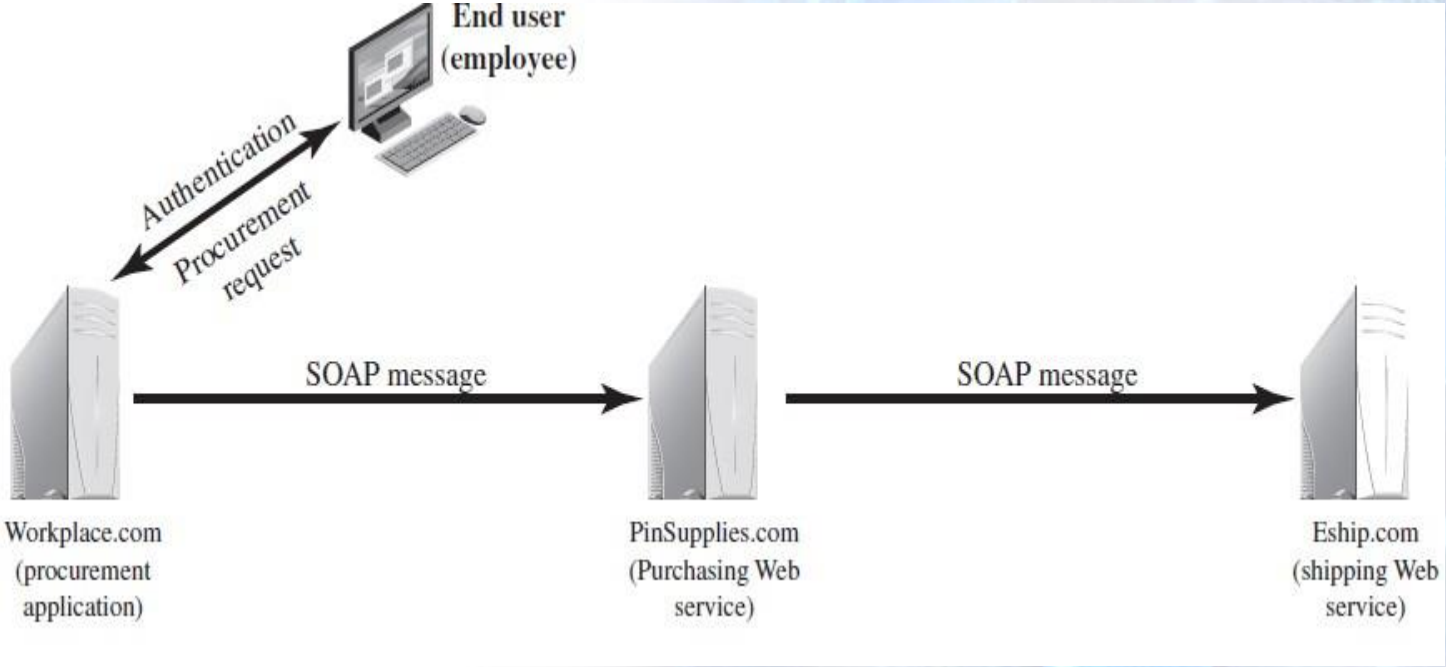
- The message includes a PinSupplies.com security token in the envelope header and the list of items to be shipped as well as the end user's shipping information in the envelope body.

Federated Identity Scenarios

- The shipping Web service authenticates the request and processes the shipment order.

Federated Identity Scenarios

Federation based on roles



Elements of Network Access Control

Network Security

Elements of Network Access Control

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe the elements of network access control.

Elements of Network Access Control

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Elements of Network Access Control

- Network access control (NAC) is an umbrella term for managing access to a network.

Elements of Network Access Control

- NAC authenticates users logging into the network and determines what data they can access and actions they can perform.
- NAC also examines the health of the user's computer (the endpoints).

Elements of Network Access Control

- **Elements of a Network Access Control System:**
- NAC systems deal with three categories of components:

Elements of Network Access Control

- **1. Access requestor (AR):** The AR is node that is attempting to access network and may be any device that is managed by the NAC system.
- E.g. workstations, servers, printers, cameras, and other IP-enabled devices.

Elements of Network Access Control

- ARs are also referred to as **supplicants**, or simply, clients.

Elements of Network Access Control

- **2. Policy server:**
- Based on the AR's posture and an enterprise's defined policy, the policy server determines what access should be granted.

Elements of Network Access Control

- The policy server often relies on backend systems, including antivirus, patch management, or a user directory, to help determine the host's condition.

Elements of Network Access Control

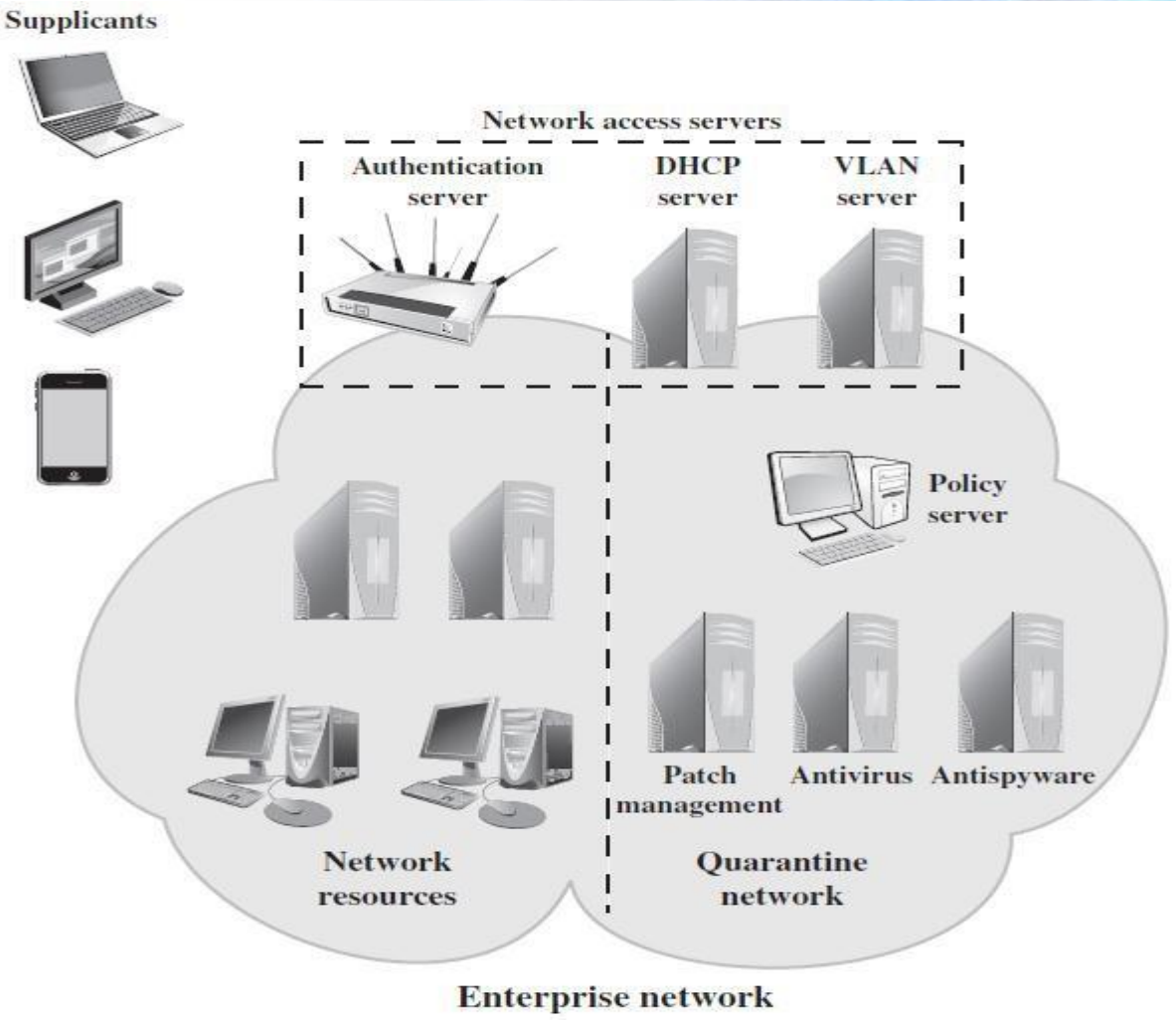
- **3. Network access server (NAS):** The NAS functions as an access control point for users in remote locations connecting to an enterprise's internal network.

Elements of Network Access Control

- Also called a **media gateway**, a **remote access server (RAS)**, or a **policy server**, an NAS may include its own authentication services or rely on a separate authentication service from the policy server.

Elements of Network Access Control

Network Access Control Context



Elements of Network Access Control

- A variety of different ARs seek access to an enterprise network by applying to some type of NAS.
- The first step is to authenticate the AR.
- This involves some sort of secure protocol and the use of cryptographic keys.

Elements of Network Access Control

- Authentication may be performed by the NAS, or the NAS may mediate the authentication process.

Elements of Network Access Control

- In the latter case, authentication takes place between the supplicant and an authentication server that is part of the policy server or that is accessed by the policy server.
- Authentication has a number of purposes:

Elements of Network Access Control

- The authentication verifies a supplicant's claimed identity, which enables the policy server to determine what access privileges, if any, the AR may have.

Elements of Network Access Control

- The authentication exchange may result in the establishment of session keys to enable future secure communication between the supplicant and resources on the enterprise network.

Elements of Network Access Control

- The policy server or a supporting server will perform checks on the AR to determine if it should be permitted interactive remote access connectivity.
- For example, user's antimalware software must be up-to-date, OS must be patched.

Elements of Network Access Control

- These checks should be performed before granting the AR access to the enterprise network.

Elements of Network Access Control

- If an authorized user's remote computer does not pass the health check, the user and remote computer should be denied network access or have limited access to a quarantine network so that authorized personnel can fix the security deficiencies.

Elements of Network Access Control

End

- Once an AR has been authenticated and cleared for a certain level of access to the enterprise network, the NAS can enable the AR to interact with resources in the enterprise network.

Network Access Enforcement Methods

Network Security

Network Access Enforcement Methods

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe network access enforcement methods.

Network Access Enforcement Methods

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Network Access Enforcement Methods

- Network access control (NAC) is an umbrella term for managing access to a network.

Network Access Enforcement Methods

- NAC authenticates users logging into network and determines what data they can access and actions they can perform.
- NAC also examines health of endpoints (e.g. computers, mobile devices).

Network Access Enforcement Methods

- NAC systems deal with three categories of components:
- **1. Access requestor (AR):** is node that is attempting to access network and may be any device that is managed by the NAC system. E.g. servers, printers, cameras etc.

Network Access Enforcement Methods

- **2. Policy server:**
- determines what access should be granted.
- It often relies on backend systems, including antivirus, patch management, or a user directory, to help determine the host's condition.

Network Access Enforcement Methods

- **3. Network access server (NAS):**
- It functions as an access control point for users in remote locations connecting to an enterprise's internal network.

Network Access Enforcement Methods

- **Network Access Enforcement Methods:**
- are the actions that are applied to ARs to regulate access to the enterprise network.

Network Access Enforcement Methods

- Many vendors support multiple enforcement methods simultaneously, allowing the customer to tailor the configuration by using one or a combination of methods.

Network Access Enforcement Methods

- The following are common NAC enforcement methods.

Network Access Enforcement Methods

- **IEEE 802.1X:** This is a link layer protocol that enforces authorization before a port is assigned an IP address.
- It makes use of the Extensible Authentication Protocol for authentication.

Network Access Enforcement Methods

- **Virtual local area networks (VLANs):**
- In this approach, the enterprise network, consisting of an interconnected set of LANs, is segmented logically into a number of virtual LANs.

Network Access Enforcement Methods

- The NAC system decides to which of the network's VLANs it will direct an AR, based on whether the device needs security remediation, Internet access only, or some level of network access to enterprise resources.

Network Access Enforcement Methods

- VLANs can be created dynamically and VLAN membership, of both enterprise servers and ARs, may overlap.
- That is, an enterprise server or an AR may belong to more than one VLAN.

Network Access Enforcement Methods

- **Firewall:** A firewall provides a form of NAC by allowing or denying network traffic between an enterprise host and an external user.

Network Access Enforcement Methods

- **DHCP management:**
- The Dynamic Host Configuration Protocol (DHCP) is an Internet protocol that enables dynamic allocation of IP addresses to hosts.
- A DHCP server intercepts DHCP requests and assigns IP addresses instead.

Network Access Enforcement Methods

- NAC enforcement occurs at the IP layer based on subnet and IP assignment.
- A DCHP server is easy to install and configure, but is subject to various forms of IP spoofing, providing limited security.

Network Access Enforcement Methods

End

- There are a number of other enforcement methods available from vendors.
- The ones mentioned above are perhaps the most common, and IEEE 802.1X is by far the most commonly implemented solution.

Extensible Authentication Protocol

Network Security

Extensible Authentication Protocol

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe basics of extensible authentication protocol.

Extensible Authentication Protocol

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Extensible Authentication Protocol

- EAP provides a generic transport service for the exchange of authentication information between a client system and an authentication server.

Extensible Authentication Protocol

- EAP is defined in RFC 3748.
- It acts as a framework for network access and authentication protocols.

Extensible Authentication Protocol

- EAP provides a set of protocol messages that can encapsulate various authentication methods to be used between a client and an authentication server.

Extensible Authentication Protocol

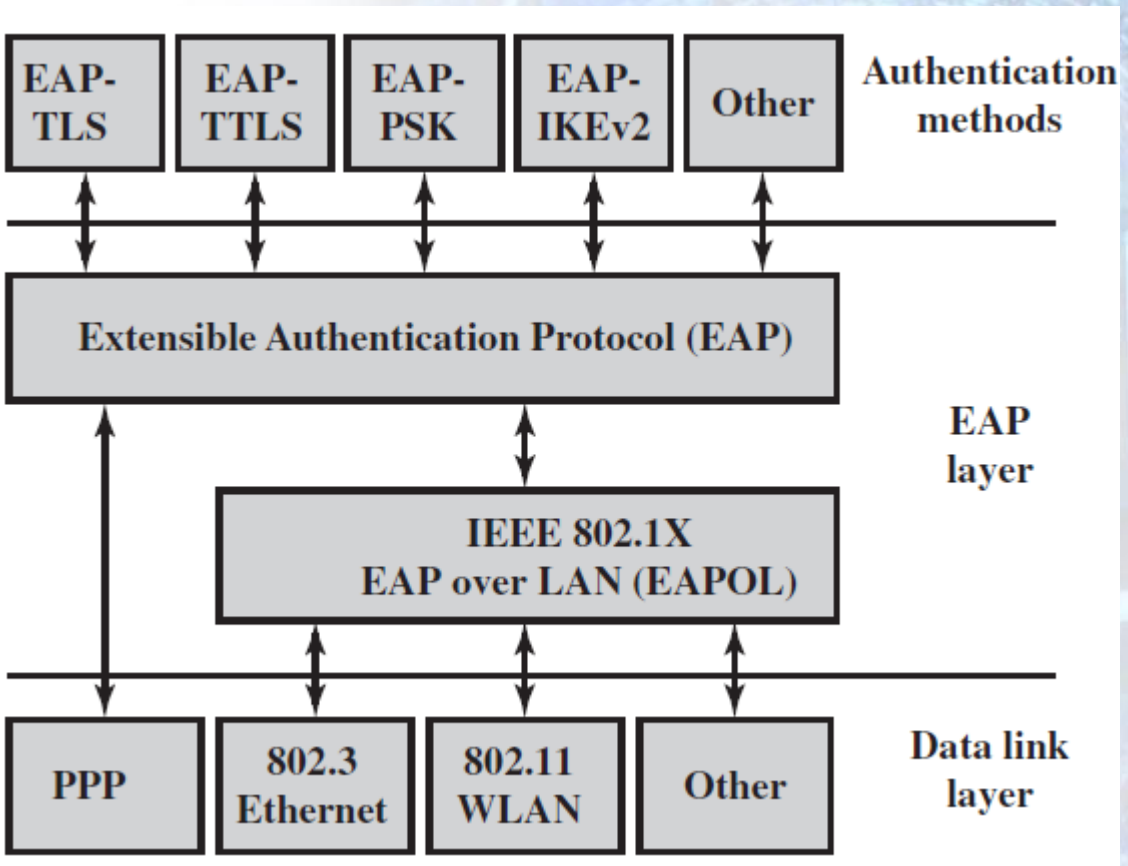
- EAP can operate over a variety of network and link level facilities.
- E.g. point-to-point links, LANs, and other networks.

Extensible Authentication Protocol

- The protocol layers that form the context for EAP are shown next.

Extensible Authentication Protocol

EAP Layered Context



Extensible Authentication Protocol

- **Authentication Methods:**
- EAP supports multiple authentication methods.
- This is what is meant by referring to EAP as *extensible*.
- Commonly supported EAP methods are:

Extensible Authentication Protocol

- **EAP-TLS (EAP Transport Layer Security):**
- It is defined RFC 5216.
- It defines how the TLS protocol can be encapsulated in EAP messages.
- It uses the handshake protocol in TLS, not its encryption method.

Extensible Authentication Protocol

- Client and server authenticate each other using digital certificates.
- Client generates a pre-master secret key by encrypting a random number with the server's public key and sends it to the server.

Extensible Authentication Protocol

- Both client and server use the pre-master to generate the same secret key.

Extensible Authentication Protocol

- **EAP-TTLS (EAP Tunneled TLS):**
- It is defined in RFC 5281.
- EAP-TTLS is like EAP-TLS, except only the server has a certificate to authenticate itself to the client first.

Extensible Authentication Protocol

- As in EAP-TLS, a secure connection (the “tunnel”) is established with secret keys.
- This connection is used to continue the authentication process.

Extensible Authentication Protocol

- The client and possibly the server are authenticated again using any EAP method or legacy method such as PAP (Password Authentication Protocol) and CHAP (Challenge-Handshake Authentication Protocol).

Extensible Authentication Protocol

- **EAP-GPSK (EAP Generalized Pre-Shared Key):**
- It is defined in RFC 5433.
- It is an EAP method for mutual authentication and session key derivation using a Pre-Shared Key (PSK).

Extensible Authentication Protocol

- This method is efficient in terms of message flows and computational costs, but requires the existence of pre-shared keys between each peer and EAP server.

Extensible Authentication Protocol

- The set up of these pairwise secret keys is part of the peer registration.
- It is designed for authentication over insecure networks such as IEEE 802.11.

Extensible Authentication Protocol

End

- **EAP-IKEv2:** is based on the Internet Key Exchange protocol version 2 (IKEv2).
- It supports mutual authentication and session key establishment using a variety of methods.
- It is defined in RFC 5106.

EAP Protocol Exchanges

Network Security

EAP Protocol Exchanges

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe working of EAP protocol exchanges.

EAP Protocol Exchanges

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

EAP Protocol Exchanges

- The authentication information and authentication protocol information are carried in Extensible Authentication Protocol (EAP) messages.

EAP Protocol Exchanges

- A successful authentication is the one for which the authenticator decides to allow access by the peer, and the peer decides to use this access.
- Following components are involved:

EAP Protocol Exchanges

- **EAP peer:** Client computer that is attempting to access a network.
- **EAP authenticator:** An access point or NAS that requires EAP authentication prior to granting access to a network.

EAP Protocol Exchanges

- **Authentication server:** negotiates use of a specific EAP method with an EAP peer, validates EAP peer's credentials and authorizes access to the network.
- is a Remote Authentication Dial-In User Service (RADIUS)

EAP Protocol Exchanges

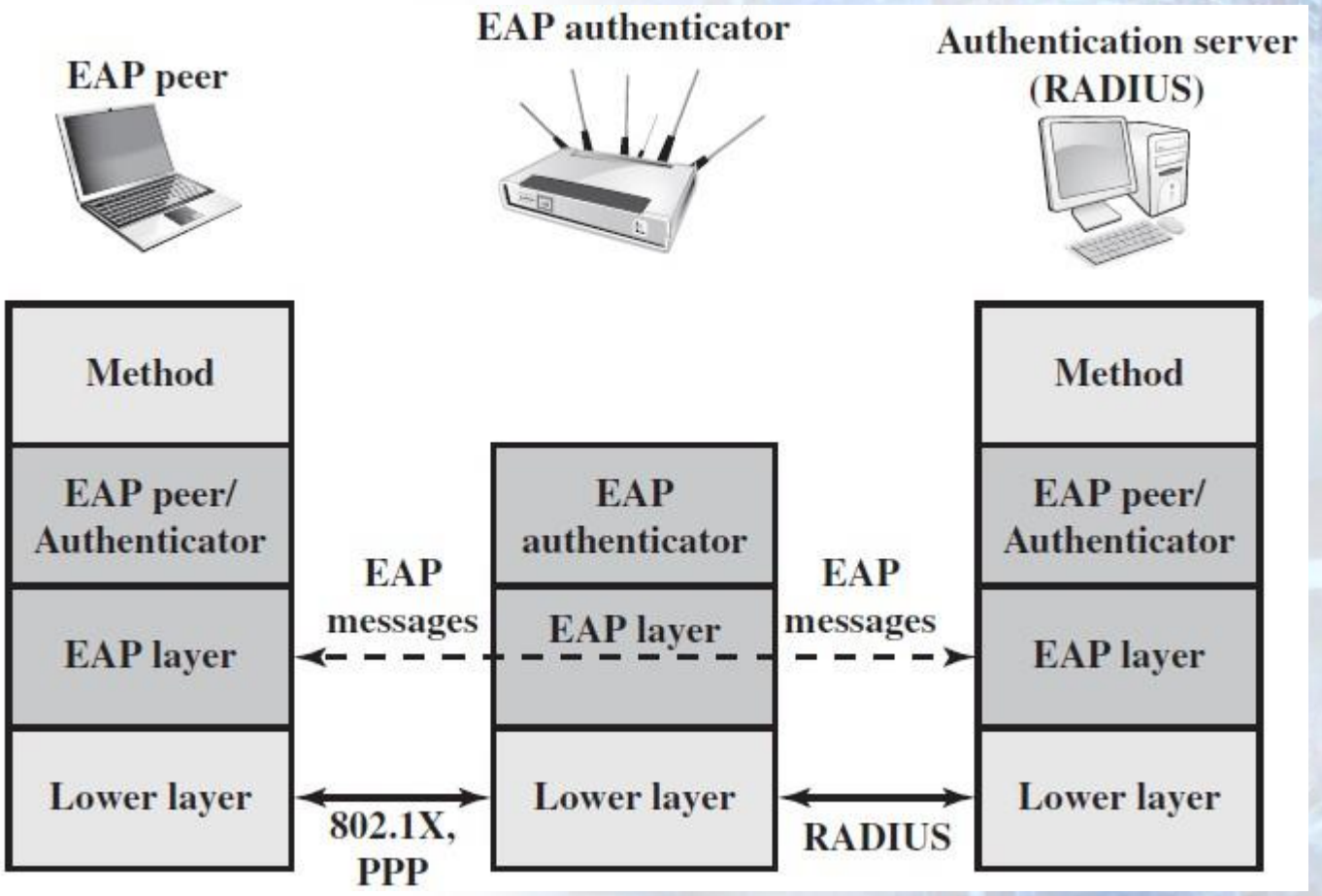
- The authentication server functions as a backend server that can authenticate peers as a service to a number of EAP authenticators.

EAP Protocol Exchanges

- The EAP authenticator then makes the decision of whether to grant access.
- This is referred to as the **EAP pass-through mode**.

EAP Protocol Exchanges

EAP Protocol Exchanges



EAP Protocol Exchanges

- As a first step, a lower-level protocol, such as PPP or IEEE 802.1X, is used to connect to the EAP authenticator.
- The software entity in the EAP peer that operates at this level is referred to as the supplicant.

EAP Protocol Exchanges

- EAP messages containing the appropriate information for a chosen EAP method are then exchanged between the EAP peer and the authentication server.

EAP Protocol Exchanges

- EAP messages include the following fields:
- **Code:** Identifies the Type of EAP message. The codes are Request (1), Response (2), Success (3), and Failure (4).
- **Identifier:** Used to match Responses with Requests.

EAP Protocol Exchanges

- **Length:** Indicates the length, in octets, of the EAP message, including the Code, Identifier, Length, and Data fields.
- **Data:** Contains information related to authentication.

EAP Protocol Exchanges

- After a lower-level exchange that established the need for an EAP exchange, the authenticator sends a Request to the peer to request an identity, and the peer sends a Response with the identity information.

EAP Protocol Exchanges

- This is followed by a sequence of Requests by the authenticator and Responses by the peer for the exchange of authentication information.

EAP Protocol Exchanges

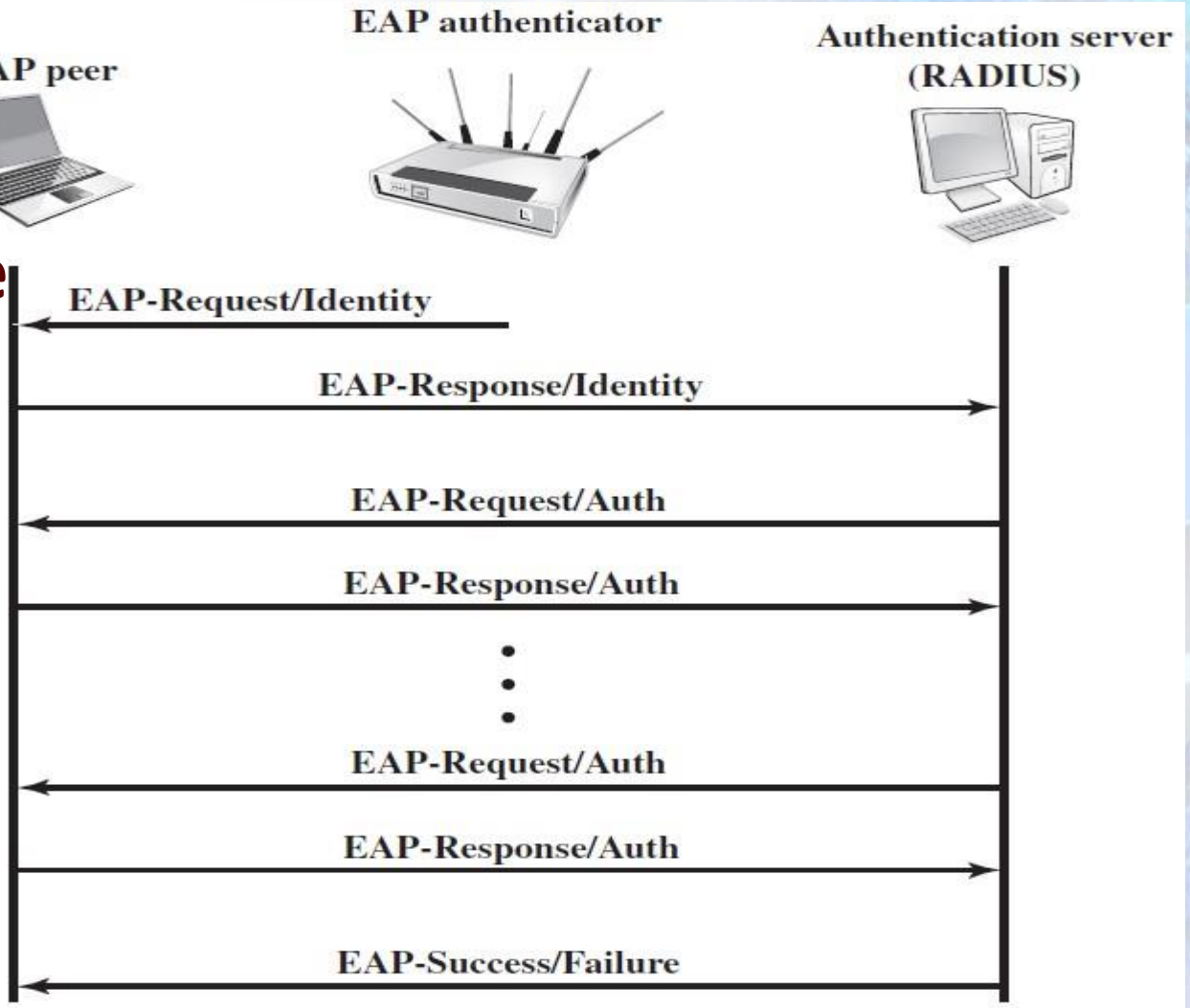
- The information exchanged and the number of Request–Response exchanges needed depend on the authentication method.

EAP Protocol Exchanges

- This continues until either (1) the authenticator determines that it cannot authenticate peer and transmits an EAP Failure or (2) the authenticator transmits an EAP Success indicating a successful authentication.

EAP Protocol Exchanges

EAP Message Flow in Pass-Through Mode



IEEE 802.1X Port-Based NAC

Network Security

IEEE 802.1X Port-Based NAC

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain basics of IEEE 802.1X access control.

IEEE 802.1X Port-Based NAC

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

IEEE 802.1X Port-Based NAC

- IEEE 802.1X Port-Based Network Access Control was designed to provide access control functions for LANs.

IEEE 802.1X Port-Based NAC

Terminology Related to IEEE 802.1X

Authenticator

An entity at one end of a point-to-point LAN segment that facilities authentication of the entity to the other end of the link.

Authentication exchange

The two-party conversation between systems performing an authentication process.

Authentication process

The cryptographic operations and supporting data frames that perform the actual authentication.

Authentication server (AS)

An entity that provides an authentication service to an authenticator. This service determines, from the credentials provided by supplicant, whether the supplicant is authorized to access the services provided by the system in which the authenticator resides.

IEEE 802.1X Port-Based NAC

Terminology Related to IEEE 802.1X

Authentication transport

The datagram session that actively transfers the authentication exchange between two systems.

Bridge port

A port of an IEEE 802.1D or 802.1Q bridge.

Edge port

A bridge port attached to a LAN that has no other bridges attached to it.

Network access port

A point of attachment of a system to a LAN. It can be a physical port, such as a single LAN MAC attached to a physical LAN segment, or a logical port, for example, an IEEE 802.11 association between a station and an access point.

IEEE 802.1X Port-Based NAC

Terminology Related to IEEE 802.1X

Port access entity (PAE)

The protocol entity associated with a port. It can support the protocol functionality associated with the authenticator, the supplicant, or both.

Supplicant

An entity at one end of a point-to-point LAN segment that seeks to be authenticated by an authenticator attached to the other end of that link.

IEEE 802.1X Port-Based NAC

- The terms supplicant, network access point, and authentication server correspond to the EAP terms peer, authenticator, and authentication server, respectively.

IEEE 802.1X Port-Based NAC

- Until the AS authenticates a supplicant (using an authentication protocol), the authenticator only passes control and authentication messages between the supplicant and the AS.

IEEE 802.1X Port-Based NAC

- The 802.1X control channel is unblocked, but the 802.11 data channel is blocked.

IEEE 802.1X Port-Based NAC

- Once a supplicant is authenticated and keys are provided, the authenticator can forward data from the supplicant, subject to predefined access control limitations for supplicant to network.
- Now data channel is unblocked.

IEEE 802.1X Port-Based NAC

- 802.1X uses the concepts of controlled and uncontrolled ports.
- Ports are logical entities defined within the authenticator and refer to physical network connections.

IEEE 802.1X Port-Based NAC

- Each logical port is mapped to one of these two types of physical ports.

IEEE 802.1X Port-Based NAC

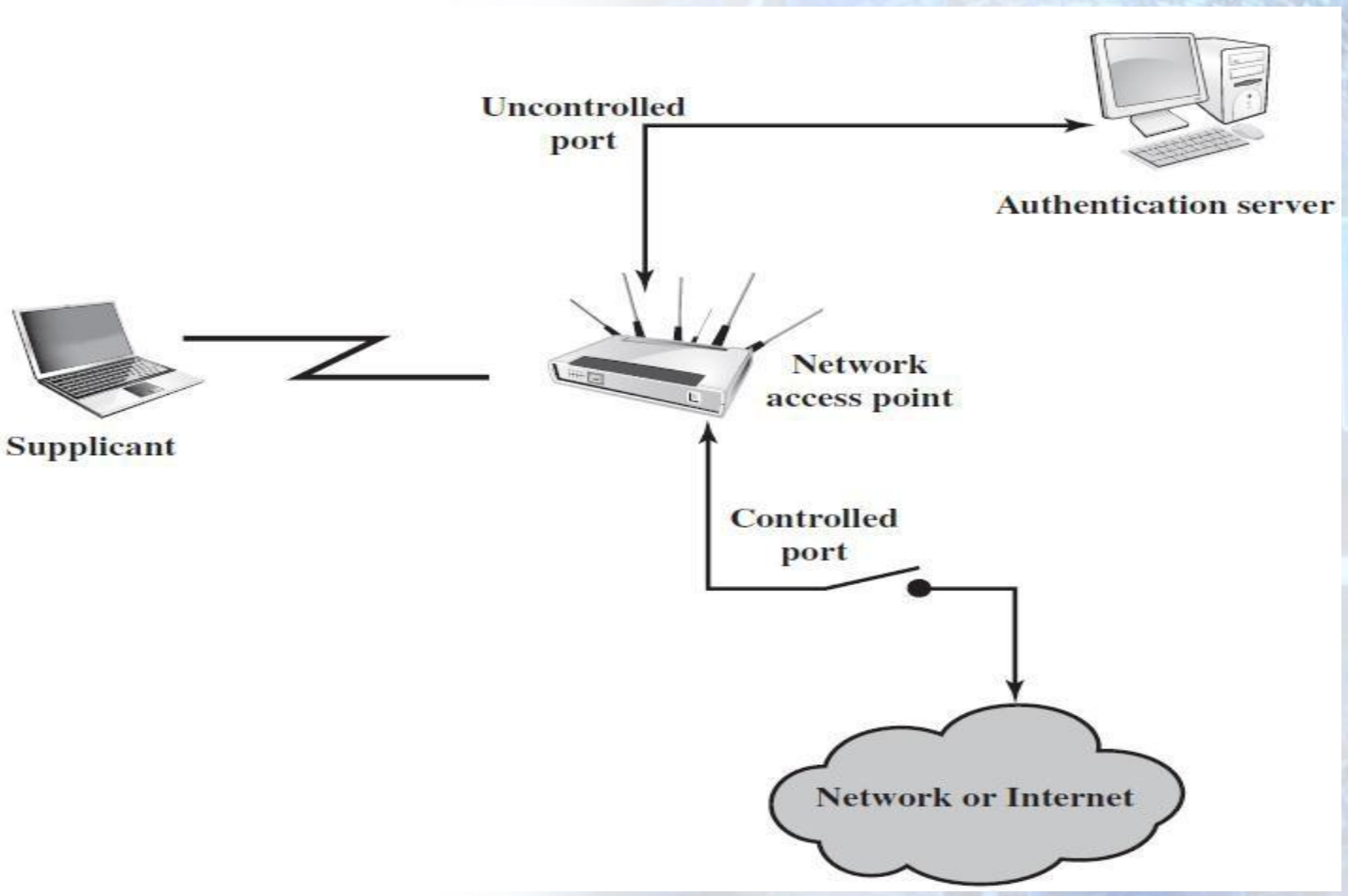
- An uncontrolled port allows the exchange of protocol data units (PDUs) between the supplicant and the AS, regardless of the authentication state of the supplicant.

IEEE 802.1X Port-Based NAC

- A controlled port allows the exchange of PDUs between a supplicant and other systems on the network only if the current state of the supplicant authorizes such an exchange.

IEEE 802.1X Port-Based NAC

802.1X Access Control



Working of IEEE 802.1X Port-Based NAC

Network Security

Working of IEEE 802.1X Port-Based NAC

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain working of IEEE 802.1X access control.

Working of IEEE 802.1X Port-Based NAC

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Working of IEEE 802.1X Port-Based NAC

- IEEE 802.1X Port-Based Network Access Control was designed to provide access control functions for LANs.

Working of IEEE 802.1X Port-Based NAC

- The essential element defined in 802.1X is a protocol known as EAPOL (EAP over LAN).
- EAPOL operates at the network layers and makes use of an IEEE 802 LAN, such as Ethernet or Wi-Fi, at the link level.

Working of IEEE 802.1X Port-Based NAC

- EAPOL enables a supplicant to communicate with an authenticator and supports the exchange of EAP packets for authentication.
- The most common EAPOL packets are listed next:

Working of IEEE 802.1X Port-Based NAC

Common EAPOL Frame Types

Frame Type	Definition
EAPOL-EAP	Contains an encapsulated EAP packet.
EAPOL-Start	A supplicant can issue this packet instead of waiting for a challenge from the authenticator.
EAPOL-Logoff	Used to return the state of the port to unauthorized when the supplicant if finished using the network.
EAPOL-Key	Used to exchange cryptographic keying information.

Working of IEEE 802.1X Port-Based NAC

- When the supplicant first connects to the LAN, it does not know the MAC address of the authenticator.
- Actually it doesn’t know whether there is an authenticator present at all.

Working of IEEE 802.1X Port-Based NAC

- By sending an **EAPOL-Start** packet to a special group-multicast address reserved for IEEE 802.1X authenticators, a supplicant can determine presence of authenticator and let it know that the supplicant is ready.

Working of IEEE 802.1X Port-Based NAC

- In many cases, the authenticator will already be notified that a new device has connected from some hardware notification.
- In this case, the authenticator may preempt the **Start** message with its own message.

Working of IEEE 802.1X Port-Based NAC

- In either case the authenticator sends an **EAP-Request Identity** message encapsulated in an **EAPOL-EAP** packet.
- The EAPOL-EAP is the EAPOL frame type used for transporting EAP packets.

Working of IEEE 802.1X Port-Based NAC

- Authenticator uses the **EAP-Key** packet to send cryptographic keys to the supplicant once it has decided to admit it to network.
- The **EAP-Logoff** packet indicates that supplicant wishes to be disconnected from the network.

Working of IEEE 802.1X Port-Based NAC

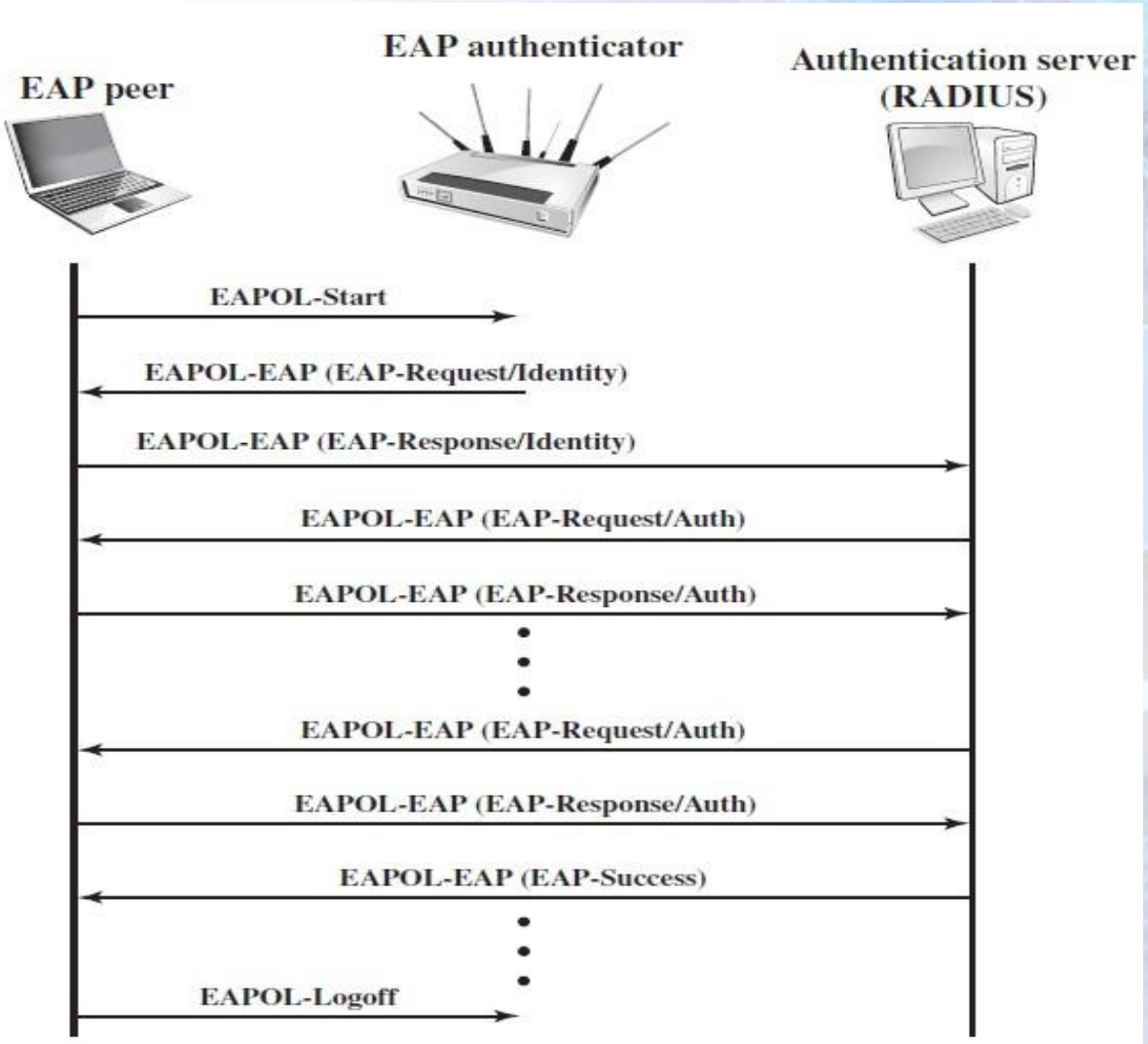
- The EAPOL packet format includes the following fields:
- **Protocol version:** version of EAPOL.
- **Packet type:** indicates start, EAP, key, logoff, etc.

Working of IEEE 802.1X Port-Based NAC

- **Packet body length:** If the packet includes a body, this field indicates the body length.
- **Packet body:** The payload for this EAPOL packet. An example is an EAP packet.

Working of IEEE 802.1X Port-Based NAC

Example Timing Diagram



Cloud Computing and its Elements

Network Security

Cloud Computing and its Elements

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain basics of Cloud Computing.

Cloud Computing and its Elements

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Cloud Computing and its Elements

- There is a growing interest in many organizations to move information technology (IT) operations to an Internet-connected infrastructure known as enterprise cloud computing.

Cloud Computing and its Elements

The NIST Definition of Cloud Computing: NIST SP-800-145

Cloud computing: A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This cloud model promotes availability and is composed of five essential characteristics, three service models, and four deployment models.

Cloud Computing and its Elements

Elements:

- **Broad network access:** Capabilities are available over network and accessed through standard mechanisms that promote use by client platforms (e.g., mobile phones, laptops, and PDAs).

Cloud Computing and its Elements

- **Rapid elasticity:** the ability to expand and reduce resources according to your specific service requirement.
- **Measured service:** automatically control and optimize resource use by leveraging a metering capability.

Cloud Computing and its Elements

- **On-demand self-service:** A consumer can unilaterally provision computing capabilities.
- **Resource pooling:** The provider's computing resources are pooled to serve multiple consumers.

Cloud Computing and its Elements

Service Models:

- **1. Software as a service (SaaS):**
- The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure.
- E.g. Gmail.

Cloud Computing and its Elements

- **2. Platform as a service (PaaS):** the capability provided to consumer is to deploy onto the cloud consumer-created or acquired applications created using programming languages and tools supported by provider.

Cloud Computing and its Elements

- **3. Infrastructure as a service (IaaS):** The capability provided to the consumer is to provision processing, storage, networks, and other fundamental computing resources.

Cloud Computing and its Elements

Deployment models

- **1. Public cloud:** The cloud infrastructure is made available to the general public.
- The cloud provider is responsible both for cloud infrastructure and for the control of data and operations within the cloud.

Cloud Computing and its Elements

- **2. Private cloud:** The cloud infrastructure is operated solely for an organization.
- The cloud provider (CP) is responsible only for the infrastructure and not for the control.

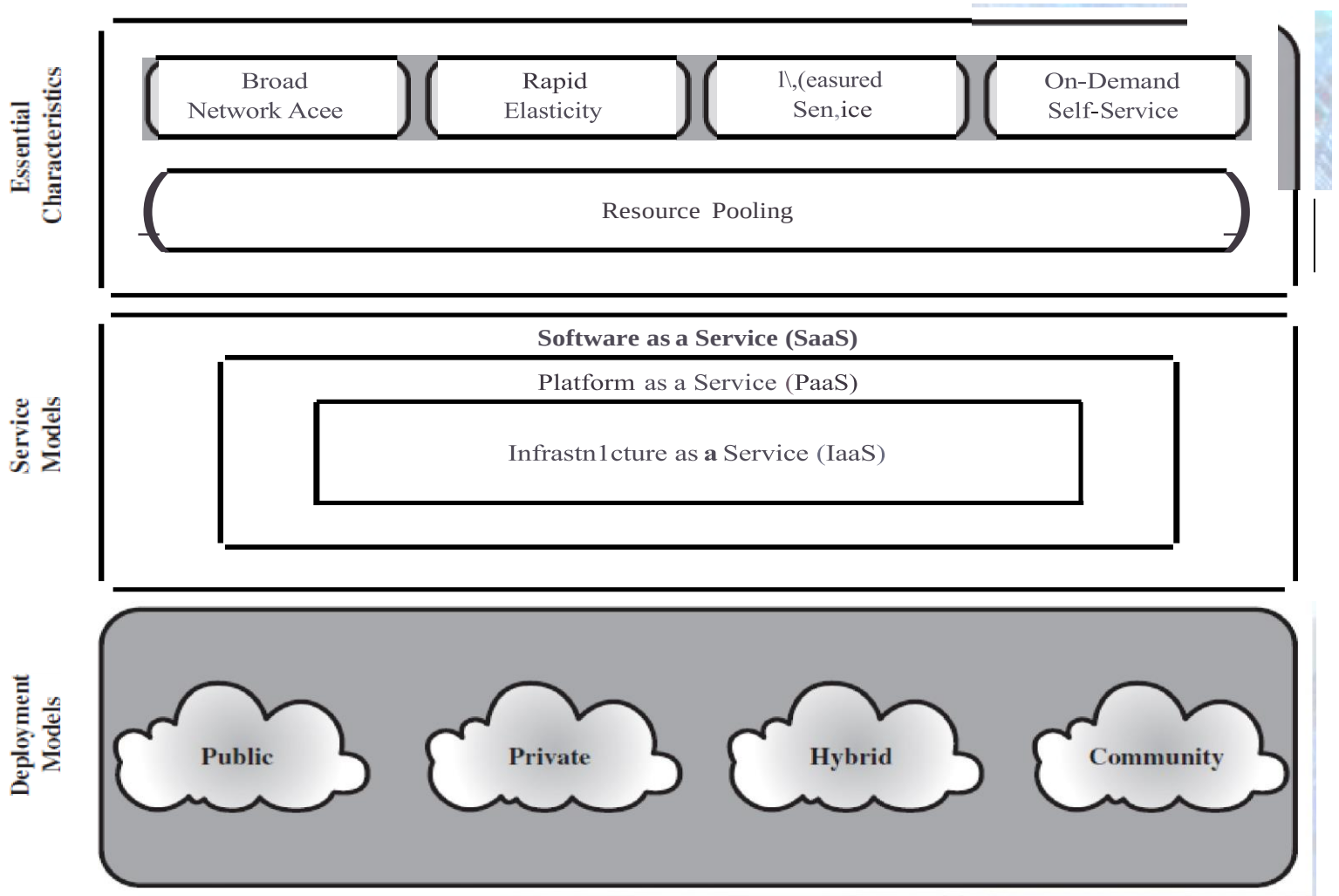
Cloud Computing and its Elements

- **3. Community cloud:** The cloud infrastructure is shared by several organizations and supports a specific community.
- may be managed by organizations or third party and may exist on or off premise.

Cloud Computing and its Elements

- **4. Hybrid cloud:** The cloud infrastructure is a composition of two or more clouds (private, community, or public) that remain unique entities but are bound together by technology that enables data and application portability.

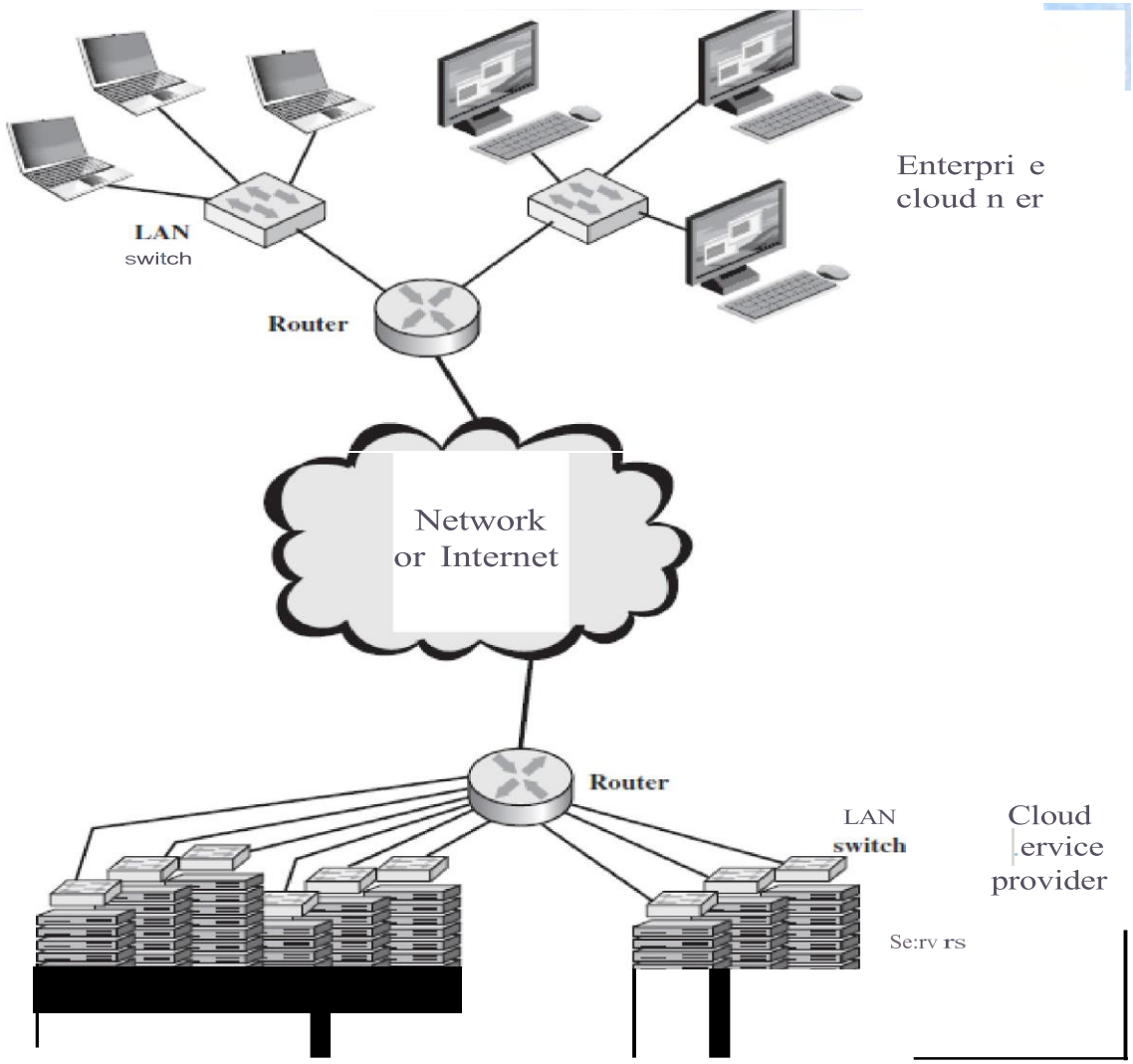
Cloud Computing and its Elements



Cloud Computing and its Elements

- Next an enterprise maintaining workstations within LAN(s), which are connected by a router through the Internet to the cloud service provider is shown.

Cloud Computing and its Elements



Cloud Computing Reference Architecture

Network Security

Cloud Computing Reference Architecture

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe the cloud computing reference architecture.

Cloud Computing Reference Architecture

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Cloud Computing Reference Architecture

NIST SP 500-292 (NIST Cloud Computing Reference Architecture)

The NIST cloud computing reference architecture focuses on the requirements of "what" cloud services provide, not a "how to" design solution and implementation. The reference architecture is intended to facilitate the understanding of the operational intricacies in cloud computing. It does not represent the system architecture of a specific cloud computing system; instead it is a tool for describing, discussing, and developing a system-specific architecture using a common framework of reference.

Cloud Computing Reference Architecture

- NIST developed the reference architecture with the following **objectives**:
- to illustrate and understand the various cloud services in the context of an overall cloud computing conceptual model.

Cloud Computing Reference Architecture

- to provide a technical reference for consumers to understand, discuss, categorize, and compare cloud services

Cloud Computing Reference Architecture

- to facilitate the analysis of candidate standards for security, interoperability, and portability and reference implementations

Cloud Computing Reference Architecture

- The reference architecture defines **five major actors** in terms of the roles and responsibilities:
- **Cloud consumer:** A person or organization that maintains a business relationship with, and uses service from, cloud providers.

Cloud Computing Reference Architecture

- **Cloud provider:** A person, organization, or entity responsible for making a service available to interested parties.

Cloud Computing Reference Architecture

- **Cloud auditor:** A party that can conduct independent assessment of cloud services, information system operations, performance, and security of the cloud implementation.

Cloud Computing Reference Architecture

- **Cloud broker:** An entity that manages the use, performance, and delivery of cloud services, and negotiates relationships between CPs and cloud consumers.

Cloud Computing Reference Architecture

- **Cloud carrier:** An intermediary that provides connectivity and transport of cloud services from CPs to cloud consumers.

Cloud Computing Reference Architecture

- A **cloud provider** can provide one or more of the cloud services to meet IT and business requirements of **cloud consumers**.

Cloud Computing Reference Architecture

- For each of the three service models (SaaS, PaaS, IaaS), the CP provides the storage and processing facilities needed to support that service model, together with a cloud interface for cloud service consumers.

Cloud Computing Reference Architecture

- The **cloud carrier** is a networking facility that provides connectivity and transport of cloud services between cloud consumers and CPs.

Cloud Computing Reference Architecture

- A **cloud broker** is useful when cloud services are too complex for a cloud consumer to easily manage.
- Three areas of support can be offered by a cloud broker:

Cloud Computing Reference Architecture

- A **cloud broker** is useful when cloud services are too complex for a cloud consumer to easily manage.
- Three areas of support can be offered by a cloud broker:

Cloud Computing Reference Architecture

- **Service intermediation:** These are value-added services, such as identity management, performance reporting, and enhanced security.

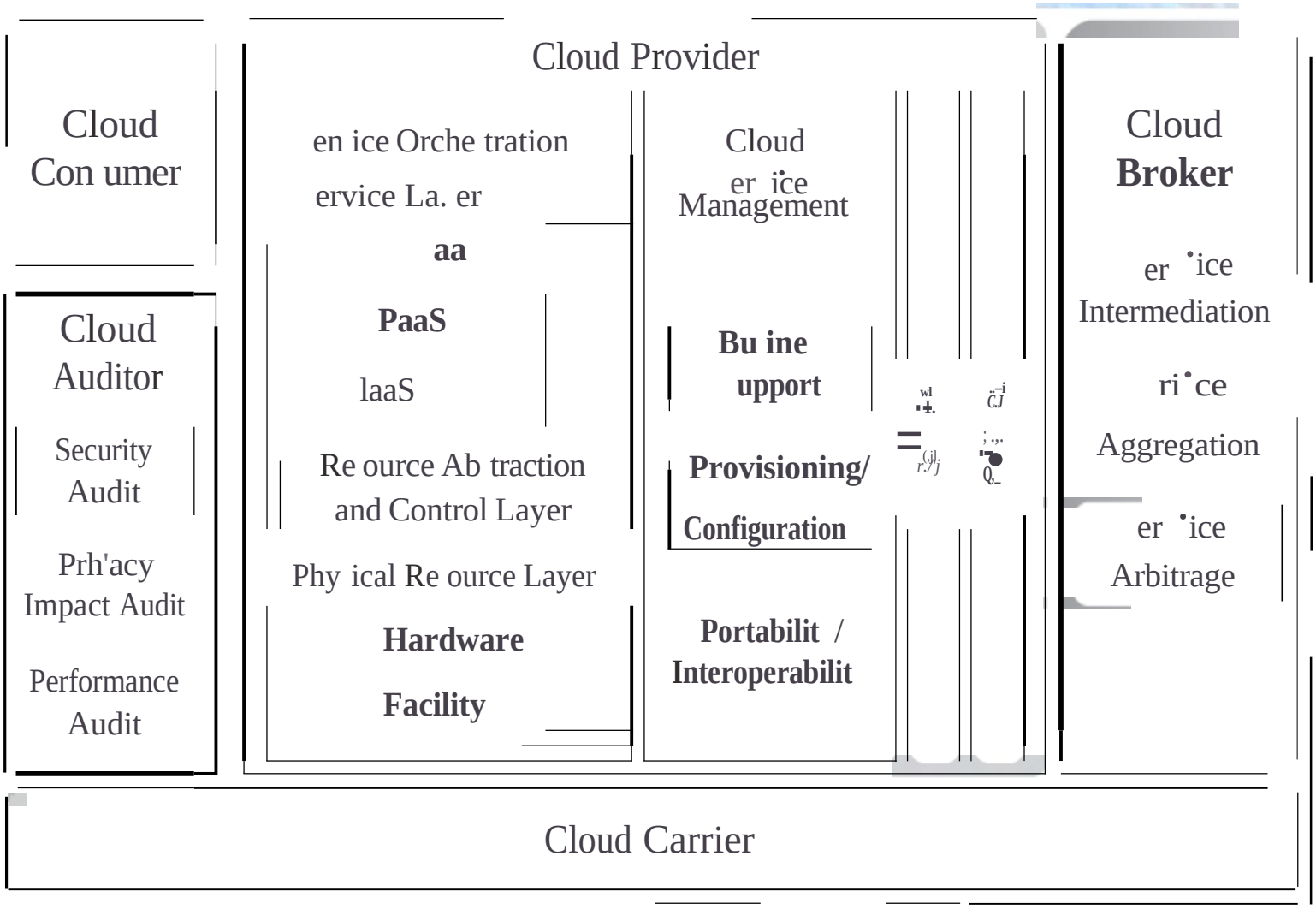
Cloud Computing Reference Architecture

- **Service aggregation:** The broker combines multiple cloud services to meet consumer needs not specifically addressed by a single CP, or to optimize performance or minimize cost.

Cloud Computing Reference Architecture

- **Service arbitrage:** means a broker has the flexibility to choose services from multiple agencies.
- A **cloud auditor** can evaluate the services provided by a CP in terms of security controls, privacy impact, performance.

Cloud Computing and its Elements



Cloud Security Risks, Countermeasures

Network Security

Cloud Security Risks, Countermeasures

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe cloud security risks and countermeasures.

Cloud Security Risks, Countermeasures

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Cloud Security Risks, Countermeasures

- In general terms, security controls in cloud computing are similar to the security controls in any IT environment.

Cloud Security Risks, Countermeasures

- However, because of the operational models and technologies used to enable cloud service, cloud computing may present risks that are specific to the cloud environment.

Cloud Security Risks, Countermeasures

- In this regard, the essential concept is that enterprise loses a substantial amount of control over resources, services, and applications but must maintain accountability for security and privacy policies.

Cloud Security Risks, Countermeasures

- The Cloud Security Alliance lists the following as the top cloud specific security threats, together with suggested countermeasures:

Cloud Security Risks, Countermeasures

- **Abuse and nefarious use of cloud computing:**
- For many CPs, it is relatively easy to register and begin using cloud services, some even offering free limited trial periods.

Cloud Security Risks, Countermeasures

- This enables attackers to get inside the cloud to conduct various attacks, such as spamming, malicious code attacks, and denial of service.
- PaaS providers have traditionally suffered most from this kind of attacks.

Cloud Security Risks, Countermeasures

- **Countermeasures:**
- Stricter initial registration and validation processes.
- Enhanced credit card fraud monitoring and coordination.
- Comprehensive introspection of customer network traffic.

Cloud Security Risks, Countermeasures

- **Insecure interfaces and APIs:**
- CPs expose a set of software interfaces or APIs that customers use to manage and interact with cloud services.
- Protect against both accidental and malicious attempts.

Cloud Security Risks, Countermeasures

- **Countermeasures:**
- Analyze the security model of CP interfaces.
- Ensure that strong authentication and access controls are implemented in concert with encrypted transmission.

Cloud Security Risks, Countermeasures

- **Malicious insiders:**
- Under the cloud computing paradigm, an organization relinquishes direct control over many aspects of security.
- The risk of malicious insider activity.
- E.g. CP system administrators.

Cloud Security Risks, Countermeasures

- **Countermeasures:**
- Enforce strict supply chain management and conduct a comprehensive supplier assessment.
- Specify human resource requirements as part of legal contract.

Cloud Security Risks, Countermeasures

- **Shared technology issues:**
- IaaS vendors deliver their services in a scalable way by sharing infrastructure.
- CPs typically approach this risk by the use of isolated virtual machines for individual clients.

Cloud Security Risks, Countermeasures

- This approach is still vulnerable to attack, by both insiders and outsiders.

Cloud Security Risks, Countermeasures

- **Countermeasures:**
- Implement security best practices for installation/configuration.
- Monitor environment for unauthorized changes/activity.
- Promote strong authentication and access control.

Cloud Security Risks, Countermeasures

- **Data loss or leakage:**
- For many clients, the most devastating impact from a security breach is the loss or leakage of data.

Cloud Security Risks, Countermeasures

- **Countermeasures:**
- Implement strong API access control.
- Encrypt and protect integrity of data in transit.
- Analyze data protection at both design and run time.

Cloud Security Risks, Countermeasures

- **Account or service hijacking:**
- With stolen credentials, attackers can access critical areas of services.
- This compromises the confidentiality, integrity, and availability of those services.

Cloud Security Risks, Countermeasures

End

- **Countermeasures:**
- Prohibit the sharing of account credentials between users and services.
- Leverage strong two-factor authentication techniques.
- Employ proactive monitoring to detect unauthorized activity.

Data Protection In The Cloud

Network Security

Data Protection In The Cloud

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain how to protect data in the cloud.

Data Protection In The Cloud

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Data Protection In The Cloud

- There are many ways to compromise data.
- Alteration of records without a backup of the original content.
- Unlinking a record from a larger context may render it unrecoverable as can storage on unreliable media.

Data Protection In The Cloud

- Loss of an encoding key may result in effective destruction.
- Unauthorized parties must be prevented from gaining access to sensitive data.

Data Protection In The Cloud

- Database environments used in cloud computing can vary significantly.
- **Multi-instance model**:
- provides a unique DBMS running on a virtual machine for each cloud subscriber.

Data Protection In The Cloud

- This gives the subscriber complete control over role definition, user authorization, and other administrative tasks related to security.

Data Protection In The Cloud

- **Multi-tenant model**:
- provides a predefined environment for the cloud subscriber that is shared with other tenants, typically through tagging data with a subscriber identifier.

Data Protection In The Cloud

- Tagging gives the appearance of exclusive use of the instance, but relies on the CP to establish and maintain a sound secure database environment.

Data Protection In The Cloud

- Data must be secured while at rest, in transit, and in use, and access to the data must be controlled.
- The client can employ encryption to protect data in transit, though this involves key management responsibilities for CP.

Data Protection In The Cloud

- For data at rest, the ideal security measure is for the client to encrypt the database and only store encrypted data in the cloud, with the CP having no access to the encryption key.

Data Protection In The Cloud

- A straightforward solution to the security problem in this context is to encrypt the entire database and not provide the encryption/decryption keys to the service provider .

Data Protection In The Cloud

- The user has little ability to access individual data items based on searches or indexing on key parameters.

Data Protection In The Cloud

- The user would have to download entire tables from the database, decrypt the tables, and work with the results.
- To provide more flexibility it must be possible to work with the database in its encrypted form.

Data Protection In The Cloud

- An example of such an approach can involve four entities.
- **Data owner:** An organization that produces data to be made available for controlled release, either within the organization or to external users.

Data Protection In The Cloud

- **User:** Human entity that presents requests to the system.
- After authentication, the user is granted access.
- **Client:** Frontend that transforms user queries into queries on the encrypted data stored on the server.

Data Protection In The Cloud

- **Server:** An organization that receives the encrypted data from a data owner and makes them available for distribution to clients.

Data Protection In The Cloud

- The server can be owned by the data owner.
- Typically, it is a facility owned and maintained by an external provider.
- For our discussion, the server is a cloud server.

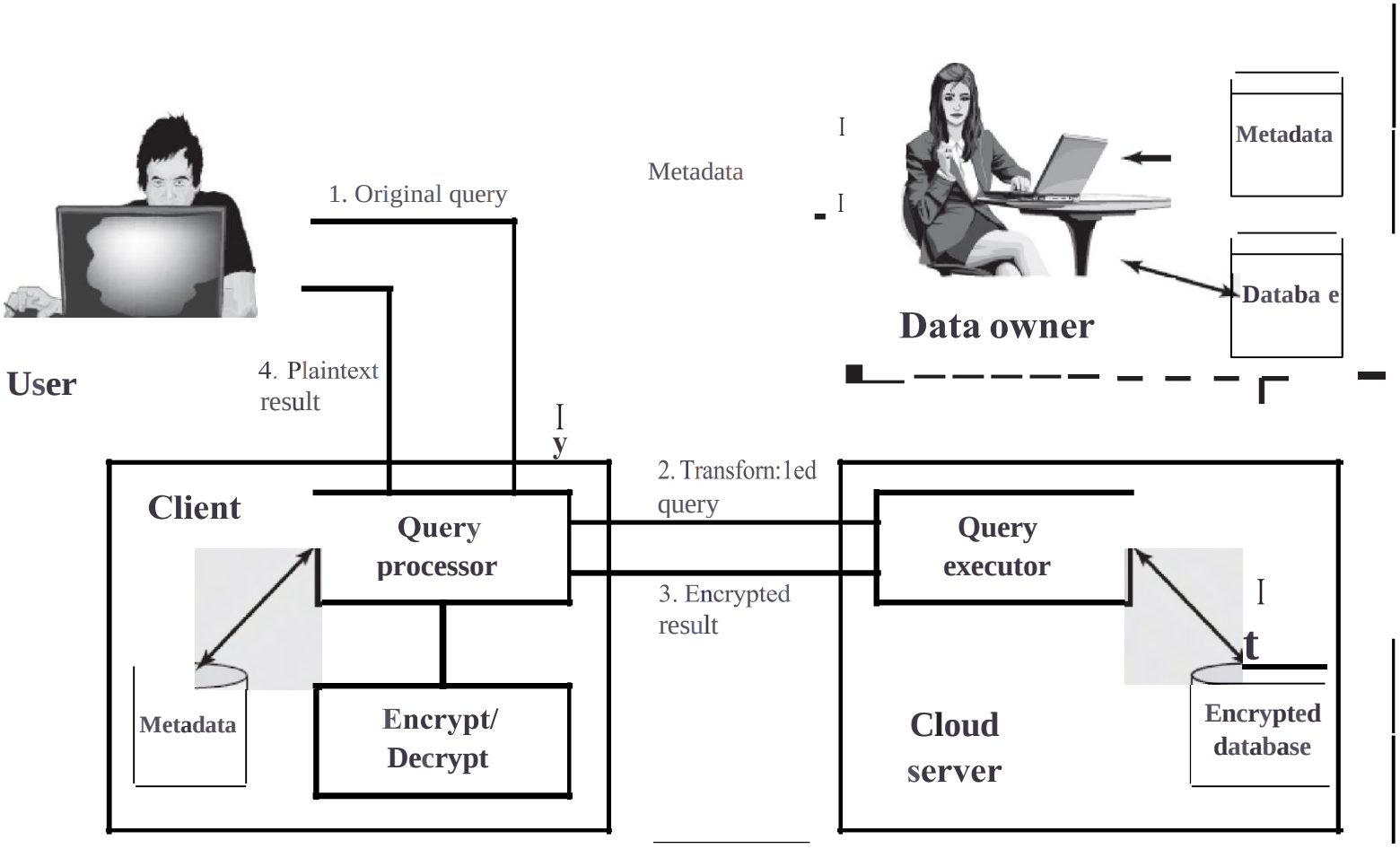
Data Protection In The Cloud

- Now, suppose that each individual item in the database is encrypted separately, all using the same encryption key.
- The encrypted database is stored at the server, but the server does not have the encryption key.

Data Protection In The Cloud

- The data are secure at the server.
- The client system does have a copy of the encryption key.
- A user at the client can retrieve a record from the database with the following sequence:

Data Protection In The Cloud



Cloud Security As A Service

Network Security

Cloud Security As A Service

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe cloud security as a service.

Cloud Security As A Service

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Cloud Security As A Service

- The term security as a service (SecaaS) means a package of security services offered by a service provider that offloads much of the security responsibility from an enterprise to the security service provider.

Cloud Security As A Service

- Among the services, authentication, antivirus, antimalware/-spyware, intrusion detection, and security event management are provided.

Cloud Security As A Service

- In the context of cloud computing, cloud security as a service, designated SecaaS, is a segment of the SaaS offering of a CP.

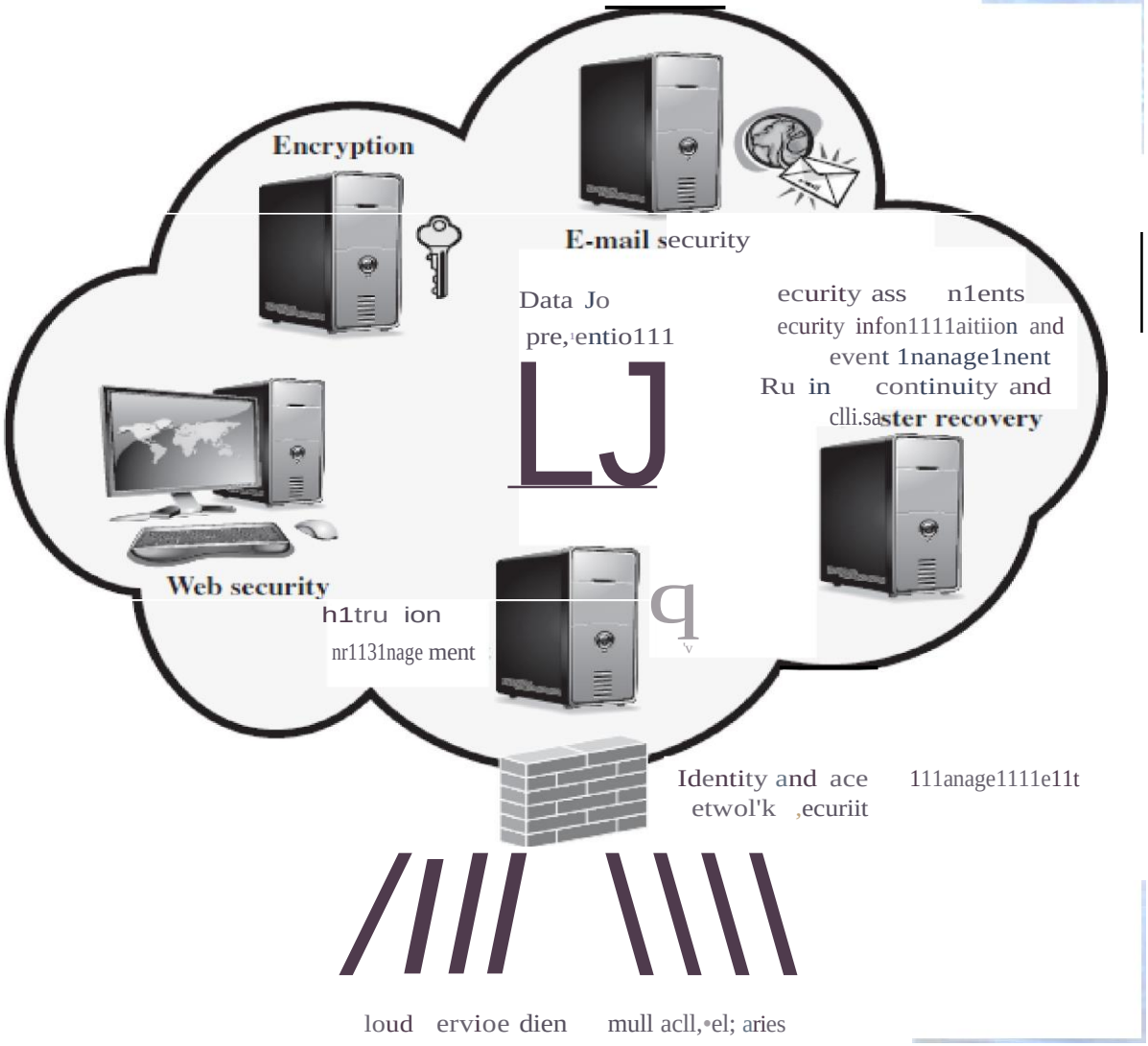
Cloud Security As A Service

- The Cloud Security Alliance defines SecaaS as the provision of security applications and services via the cloud either to cloud-based infrastructure and software or from the cloud to customers' on-premise systems.

Cloud Security As A Service

- The Cloud Security Alliance has identified the following SecaaS categories of service:

Cloud Security As A Service



Cloud Security As A Service

- **Identity and access management (IAM)** includes people, processes that are used to manage access to enterprise resources by assuring that the identity of an entity is verified, and then granting the correct level of access.

Cloud Security As A Service

- **Data loss prevention (DLP)** is the monitoring, protecting, and verifying the security of data at rest, in motion, and in use.
- Much of DLP can be implemented by the cloud client.

Cloud Security As A Service

- The cloud service provider (CSP) can also provide DLP services, such as implementing rules about what functions can be performed on data in various contexts.

Cloud Security As A Service

- **Web security** is real-time protection offered either on premise through software/ appliance installation or via the cloud by proxying or redirecting Web traffic to the CP.

Cloud Security As A Service

- **E-mail security** provides control over inbound and outbound e-mail, protecting the organization from phishing, malicious attachments, enforcing corporate polices.

Cloud Security As A Service

- **Security assessments** are third-part audits of cloud services.
- **Intrusion management** encompasses intrusion detection, prevention, and response to detect unauthorized access to a host system.

Cloud Security As A Service

- **Security information and event management (SIEM)** aggregates (via push or pull mechanisms) log and event data from virtual and real networks, applications, and systems.

Cloud Security As A Service

- **Encryption** is a pervasive service that can be provided for data at rest in the cloud, e-mail traffic, client-specific network management information, and identity information.

Cloud Security As A Service

- **Business continuity and disaster recovery** comprise measures and mechanisms to ensure operational resiliency in the event of any service interruptions.

Cloud Security As A Service

End

- **Network security** consists of security services that allocate access, distribute, monitor, and protect the underlying resource services.
- Services include perimeter and server firewalls and denial-of-service protection.

Web Security Considerations

Network Security

Web Security Considerations

Objectives of the Topic

- After completing this topic, a student will be able to
  - describe web security considerations.

Web Security Considerations

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Web Security Considerations

- The World Wide Web is fundamentally a client/server application running over the Internet and TCP/IP intranets.
- The following characteristics of Web usage suggest the need for tailored security tools:

Web Security Considerations

- 1. Web browsers are very easy to use.
- Web servers are relatively easy to configure and manage.
- Web content is increasingly easy to develop.

Web Security Considerations

- The underlying software is extraordinarily complex.
- May hide many potential security flaws.

Web Security Considerations

- 2. A Web server can be exploited as a launching pad into the corporation's or agency's entire computer complex.
- An attacker may be able to gain access to systems not part of Web itself but connected to server.

Web Security Considerations

- 3. Casual and untrained (in security matters) users are common clients for Web based services.
- Such users are not aware of security risks that exist and do not have tools/knowledge to take effective countermeasures.

Web Security Considerations

Web Security Threats:

- A summary of the types of security threats faced when using the Web is given next.

Web Security Considerations

	Tlueats	Con equence	Countermea ure
Int ,:rity	• Modificat1on of user data • Trojan horse browser • Modification of memory • Modificat1on of message traffic in transit	• Lo s of infonnation • Compromi e of machine • Vulnerability to all other threats	Cryptographic checksums
Confid ntiality	• Eavesdropping on the net • Theft of info from server • Theft of data from client •]nfo about network configuration •]nfo about which client talks to server	• Loss of 1nfonnation • Lo s of privacy	Encryption Web proxies
Denial of ervice	• Killing of user threads • Flooding machine with bogus requests • Fining up disk or memory •]solating machine by DNS attacks	• Disruptive • Annoying • Prevent user from getting work done	Difficult to prevent
Auth ntication	•]mpersonation of legitimate users • Data forgery	• **Mi** representation of user • Belief that false information is vabd	Cryptographic techniques

Web Security Considerations

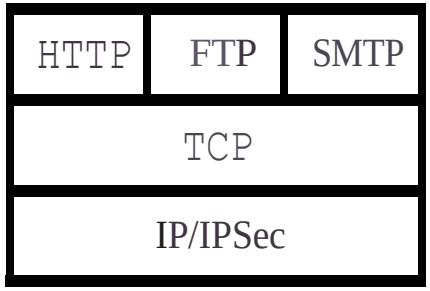
Web Traffic Security Approaches:

- A number of approaches to providing Web security are possible.

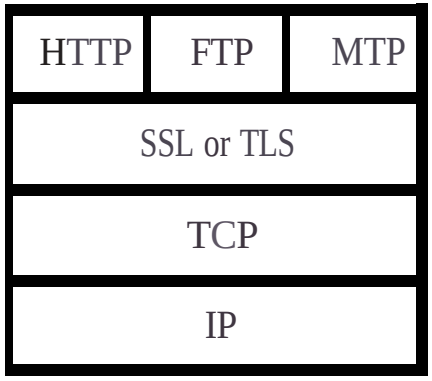
Web Security Considerations

- The various approaches differ with respect to their scope of applicability and their relative location within the TCP/IP protocol stack.

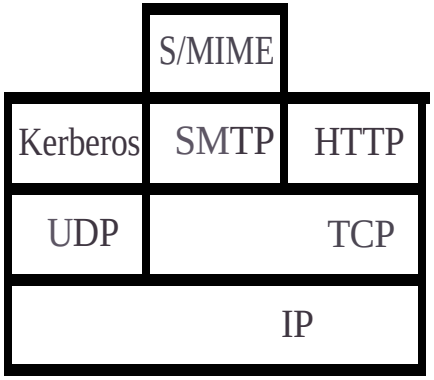
Web Security Considerations



(a) etwork level



(b) Transport level



(c) Application level

Web Security Considerations

- The advantage of using IPsec is that it is transparent to end users and applications and provides a general-purpose solution.

Web Security Considerations

End

- Implementing security just above TCP provides transparency to applications.
- The advantage of application-specific security services is that the service can be tailored to the specific needs of a given application.

Secure Sockets Layer Architecture

Network Security

Secure Sockets Layer Architecture

Objectives of the Topic

- After completing this topic, a student will be able to
  - explain the SSL architecture.

Secure Sockets Layer Architecture

Figures and material in this topic have been adapted from

- *"Network Security Essentials: Applications and Standards"*, 2014 by William Stallings.

Secure Sockets Layer Architecture

- Secure Sockets Layer (SSL) is one of the most widely used security services.
- It is a general-purpose service implemented as a set of protocols that rely on TCP.

Secure Sockets Layer Architecture

- There are two implementation choices:
- Could be provided as part of the underlying protocol suite and therefore be transparent to applications.
- Can be embedded in specific packages.

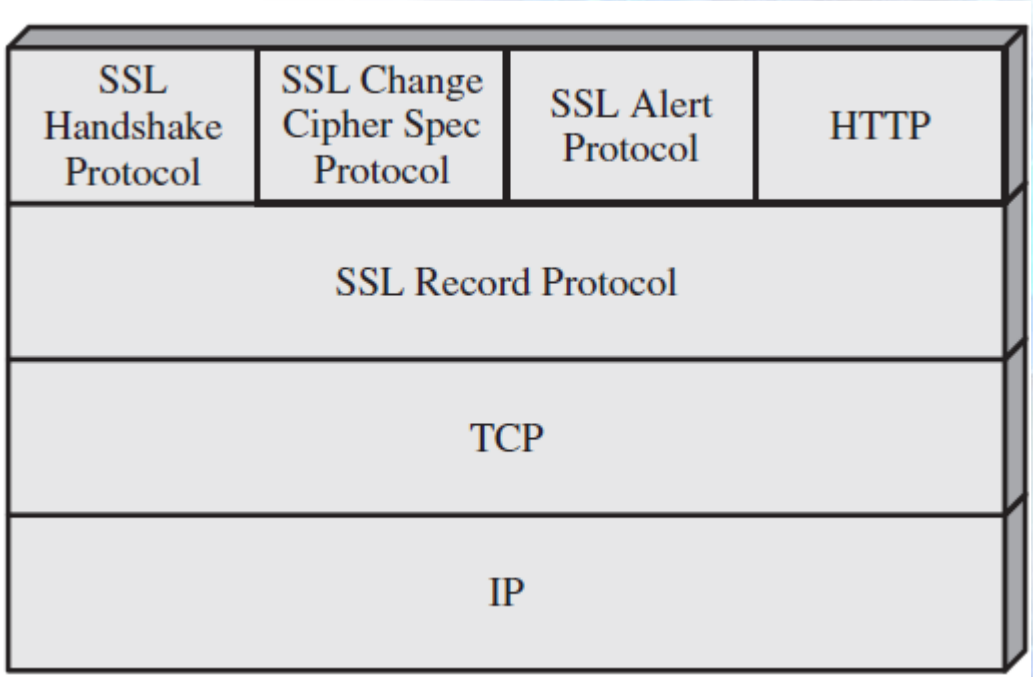
Secure Sockets Layer Architecture

SSL Architecture:

- SSL is designed to make use of TCP to provide a reliable end-to-end secure service.
- SSL is not a single protocol but rather two layers of protocols.

Secure Sockets Layer Architecture

SSL Protocol Stack



Secure Sockets Layer Architecture

- The SSL Record Protocol provides basic security services to various higher layer protocols.
- Hypertext Transfer (HTTP) which provides transfer service for Web client/server interaction, can operate on top of SSL.

Secure Sockets Layer Architecture

- Three higher-layer protocols are defined as part of SSL.
- Handshake Protocol, Change Cipher Spec Protocol, and Alert Protocol.
- These SSL-specific protocols are used in the management of SSL exchanges.

Secure Sockets Layer Architecture

- Two important SSL concepts are:
- the SSL session and,
- the SSL connection.

Secure Sockets Layer Architecture

- **Connection:** is a transport that provides a suitable type of service.
- For SSL, such connections are peer-to-peer relationships.
- Every connection is associated with one session.

Secure Sockets Layer Architecture

- **Session:** is an association between a client and a server.
- Sessions are created by the Handshake Protocol.
- Sessions define a set of cryptographic parameters which can be shared among multiple connections.

Secure Sockets Layer Architecture

- Sessions are used to avoid the expensive negotiation of new security parameters for each connection.

Secure Sockets Layer Architecture

- Between any pair of parties, there may be multiple secure connections but multiple simultaneous sessions are not used in practice.
- There are a number of states associated with each session:

Secure Sockets Layer Architecture

- **Session identifier:** An arbitrary byte sequence chosen by the server to identify an active or resumable session state.
- **Peer certificate:** An X509.v3 certificate of the peer.

Secure Sockets Layer Architecture

- **Compression method:** The algorithm used to compress data prior to encryption.
- **Is resumable:** A flag indicating whether the session can be used to initiate new connections.

Secure Sockets Layer Architecture

- **Cipher spec:** Specifies the bulk data encryption algorithm and a hash algorithm used for MAC calculation.
- **Master secret:** 48-byte secret shared between the client and the server.

Secure Sockets Layer Architecture

- A connection state is defined by the following parameters.
- **Server and client random:** Byte sequences that are chosen by the server and client for each connection.

Secure Sockets Layer Architecture

- **Server write MAC secret:** the secret key used in MAC operations on data sent by the server.
- **Client write MAC secret:** the secret key used in MAC operations on data sent by the client.

Secure Sockets Layer Architecture

- **Server write key:** The secret encryption key for data encrypted by server and decrypted by the client.
- **Client write key:** The symmetric encryption key for data encrypted by the client and decrypted by the server.

Secure Sockets Layer Architecture

- **Initialization vectors:** When a block cipher in CBC mode is used, an initialization vector (IV) is maintained for each key.

Secure Sockets Layer Architecture

End

- **Sequence numbers:** Each party maintains separate sequence numbers for transmitted and received messages for each connection.